

Sustainable University IT

A Technical Reference
for Architecture and Migration

Reference architecture on open foundations,
sovereignty grid, and a brownfield migration playbook

Companion to the report
"Infrastructure and Organisation of Information Systems
for Universities — Analysis, State of the Art and Propositions"

Document Version 2.1
Visibility: INTERNAL
Status: Approved by the approving academic units of the institution on *(approval date to be set)*
Based on the SUIT Working Group [1↗]
Print date: June 9, 2026

SUIT

International Working Group
on Sustainable University IT in the AI Era

(in formation)

Nicolas Guelfi — Chairman of the SUIT Working Group;
creator of the first version of the suite.

This document is intended for chief technology officers, information-security officers, network and systems engineers, and the governance bodies that mandate them. It complements the main report with an architecture reference and a migration playbook designed to be applicable across institutions and jurisdictions.

Note on the process:
This document is an always living document. It is provided for constructive feedback and revision in order to improve its quality. The engineering of this document was partially supported by digital tools, some of which incorporate Artificial Intelligence features.

This document contains a portion of imprecisions, missing content, errors or possibly hallucinations. We believe that a supportive and cooperative approach by the readers will make its content quality increase over time.

Foreword

This Technical Reference is the engineering counterpart of the companion report *Infrastructure and Organisation of Information Systems for Universities — Analysis, State of the Art and Propositions*. The companion report makes the institutional argument: it diagnoses the present state of university IT, surveys the state of the art, and proposes a direction. The present document does the architectural and operational work that direction implies, at the level of detail a practitioner needs in order to act.

Place of this document in the suite. The dossier of which this Reference is part includes a synthesis-oriented companion document for governance, an argumentation document addressing anticipated objections, an inspection report on deliverable quality, and the main report. The Technical Reference is the artefact that travels independently to the international university network anticipated in phase 2: it contains the contracts, instantiations, alternatives, waves and conformance material on which a peer institution can build its own implementation without re-deriving the structural choices.

Posture. The Reference adopts a deliberately stronger voice than the rest of the dossier. It is normative about *interface contracts* (what every layer must expose for the architecture to compose), illustrative about *reference instantiations* (the open-foundation defaults shown to be sufficient), analytical about *alternatives* (commercial or hybrid), and conditional about institutional projections (where the state of the art does not yet support a definite claim). It is vendor-neutral by construction: open-source projects appear as the demonstrable default because their source visibility and standard interfaces make the contracts auditable, and proprietary components are admitted as documented exceptions evaluated through the sovereignty grid of Chapter 3 of the Technical Reference.

Authorship and contact. The Reference is published under the auspices of **SUIT** — the *International Working Group on Sustainable University IT in the AI Era* — with the adopting institution's designated lead author as initial contact point. The group is intended to grow as peer institutions adopt and adapt the architecture; contributions, corrections and counter-examples from member institutions are expected to feed successive revisions.

Always-living document. This Reference is explicitly an always-living document. It records the working state of an ongoing engineering and governance investigation rather than a finished doctrine. Successive versions will integrate the operational experience of adopting institutions, the corrections that peer review surfaces, and the evolution of the standards and projects on which the architecture rests. Readers are encouraged to engage critically with the material and to communicate their findings: a supportive and cooperative posture by the readership is the mechanism by which the document's quality is expected to improve over time.

On AI assistance. The engineering of this document was partially supported by digital tools, including some that incorporate artificial-intelligence features, used as drafting aids and as cross-checking instruments. As stated on the title page, the document may consequently contain imprecisions, omissions, errors, or hallucinated material. A post-redaction verification checklist is maintained in the working repository and is applied at the close of each chapter; the institutional precedents and external references catalogue (Chapter 31 of the Technical Reference and Chapter 32 of the Technical Reference) carry an explicit invitation for member institutions to confirm and refine the claims made about them.

© SUITOAAD

Abstract

This document is a practitioner-oriented technical reference and migration playbook for universities and research-performing institutions seeking sovereignty over their digital infrastructure. It develops a five-dimension sovereignty grid — Data, Technical, Financial, Operational, Institutional — with twenty measurable indicators on a four-point scale, and introduces the *Trusted Activity Context* (TAC) as the unit of reasoning that binds subject, action, resource and context across layers. It then establishes a vendor-neutral reference architecture organised in nine layers across three planes, demonstrated on open foundations and admitting proprietary components on the condition that they honour the published interface contracts. A ten-wave migration playbook supports gradual evolution from any existing brownfield estate, with three trajectories per wave (greenfield, brownfield single-suite-centric, brownfield hybrid) and explicit reversibility criteria; a structured conformance suite provides the evidence base for closure. The document closes with a regulatory mapping that aligns the architecture and the playbook to the institution's applicable data-protection, network-and-information-security, trust-services and AI-governance regime, together with its cross-border data-transfer regime — with GDPR, NIS2, the EU AI Act, eIDAS 2 and the Schrems II line of case law as a worked instantiation — alongside the jurisdiction-neutral standards spine (NIST CSF 2.0, ISO/IEC 27001/27002/27005, COBIT 2019). The architecture, the playbook and the mapping are designed to generalise across institutions and jurisdictions and are intended as the shared technical baseline for the international university network anticipated in phase 2 of the SUIT initiative.

Reading guide

The document is structured in four parts (Foundations, Reference Architecture on Open Foundations, Migration Playbook for Mixed Estates, References and Operational Material) and is designed to be read in order. Each chapter is, however, written so that it remains intelligible on its own; cross-references are explicit so the reader can jump in wherever the table of audience entry points below directs.

Document structure at a glance.

- **Part I — Foundations** (Ch. 2–4): conceptual frame, the sovereignty grid and its twenty indicators, and the self-assessment instrument.
- **Part II — Reference architecture** (Ch. 5–16): architectural principles, the nine layer chapters (identity, policy, network, compute, storage, endpoint, observability, cryptographic services, orchestration), the sizing chapter and the conformance suite.
- **Part III — Migration playbook** (Ch. 17–30): reading the playbook, the ten waves (Wave 0–Wave 9), cross-cutting topics, the reversibility playbook, and the coexistence-pattern library.
- **Part IV — References and operational material** (Ch. 31–33): institutional precedents, external references and standards, and the regulatory mapping.

Audiences and entry points. The table below proposes a reading path for each principal audience. The synthesis chapter (Chapter 1) is the recommended common starting point.

Audience	Recommended reading path
Governing board / executive leadership	Ch. 1 (synthesis), Ch. 3 (sovereignty grid), Ch. 4 (self-assessment), Ch. 33 (regulatory mapping).
CIO / CTO	Ch. 1, Ch. 2 (TAC), Ch. 3, Ch. 5 (architectural principles), Ch. 17 (playbook reading), Ch. 31 (institutional precedents), Ch. 33.
Chief Information Security Officer	Ch. 1, Ch. 6 (Identity), Ch. 7 (Policy), Ch. 12 (Observability), Ch. 13 (Cryptographic services), Ch. 25 (Wave 7 audit and IR), Ch. 33.
Network architect	Ch. 1, Ch. 5, Ch. 8 (Network), Ch. 21 (Wave 3 network), Ch. 30 (Coexistence patterns).
Platform / SRE engineer	Ch. 1, Ch. 9–11 (Compute, Storage, Endpoint), Ch. 14 (Orchestration), Ch. 15 (Sizing), Ch. 16 (Conformance).
Data-protection officer	Ch. 1, Ch. 3, Ch. 10 (Storage), Ch. 12, Ch. 33 (regulatory mapping: data-protection, cross-border-transfer, and national-transposition sections).
Programme / migration lead	Ch. 1, Ch. 17, Part III in full, Ch. 28–30 (Cross-cutting, Reversibility, Coexistence).
Phase-2 peer institution	Ch. 1, Ch. 31 (precedents), Ch. 32 (external references), Ch. 33 (regulatory mapping), then the chapters most relevant to the institution's prevailing brownfield.

Reading the document linearly. The four parts are designed to be read in order. Part I establishes the conceptual vocabulary on which Parts II and III rest; Part II defines the architecture against which Part III's waves measure progress; and Part IV consolidates the references and the regulatory anchoring that the rest of the document points at. A reader new to the material is best served by following this order.

Reading the document in the book context. When this material is encountered as Part IV of the book *Complete Dossier*, the reader sees only the synthesis chapter (Chapter 1) together with an annotated table of contents pointing back to the present standalone document. The standalone Technical Reference is the canonical full version: the synthesis chapter is identical in

both contexts, and all cross-references named "*Chapter X of the Technical Reference*" resolve into this document.

Tonality and box conventions. Coloured boxes have stable semantics throughout the document:

- **Blue (Interface contract)** — normative. The minimum set of properties a layer must expose for the architecture to compose.
- **Green (Reference instantiation)** — illustrative. The open-foundation default shown sufficient to satisfy the contract.
- **Slate (Alternative)** — illustrative. A commercial or hybrid option evaluated against the contract.
- **Red (Common pitfall)** — cautionary. Patterns that have produced poor outcomes and the mitigations that address them.
- **Plum (Real-world reference)** — precedent. A documented institution or pattern; statements are framed conditionally pending verification by member institutions.
- **Slate caveatbox** — epistemic posture. A note on what the document claims and what it does not.

Voice conventions. The Reference is assertive when discussing contracts, standards and measurable properties; it is analytical, not advocatory, when comparing instantiations; and it is conditional ("would", "may", "is expected to") when projecting onto institutional outcomes that cannot be demonstrated from the state of the art at the time of writing. This convention is consistent across the document and is part of the always-living posture stated in the foreword.

© SUITOAAD

Contents

Foreword . . . i
Abstract . . . ii
Reading guide . . . iii

1 Synthesis **1**
1.1 Purpose and audience . . . 1
1.2 The TAC concept at a glance . . . 1
1.3 The sovereignty grid in one table . . . 2
1.4 Reference architecture in one table . . . 3
1.5 Migration playbook in one figure and one table . . . 4
1.6 Self-assessment in one minute . . . 6
1.7 Real-world precedents at a glance . . . 6
1.8 How to use the rest of the Technical Reference . . . 7

I Foundations **9**

2 Conceptual frame **11**
2.1 The Trusted Activity Context concept . . . 11
2.2 End-to-end activation sequence . . . 13
2.3 Endpoint operating-system integration matrix . . . 14
2.4 Lifecycle of a TAC . . . 15
2.5 Out of scope . . . 17

3 The sovereignty grid **19**
3.1 Five dimensions of sovereignty . . . 19
3.1.1 Data sovereignty . . . 19
3.1.2 Technical sovereignty . . . 20
3.1.3 Financial sovereignty . . . 20
3.1.4 Operational sovereignty . . . 20
3.1.5 Institutional sovereignty . . . 20
3.2 Indicators per dimension . . . 21
3.3 Scoring guidance . . . 23
3.4 Worked examples . . . 23
3.4.1 Case 1 — Pure-OSS (Keycloak + SCIM + eduGAIN) . . . 23
3.4.2 Case 2 — Pure commercial (a dominant commercial identity suite, e.g. Microsoft Entra ID, with conditional-access policies) . . . 24
3.4.3 Case 3 — Hybrid (Shibboleth federation + Keycloak local activation) . . . 25
3.5 Common misuses of the grid . . . 25
3.6 The grid as a governance instrument . . . 25

4 Institutional self-assessment **27**
4.1 Purpose and method . . . 27
4.2 Section A — Identity and federation maturity . . . 28
4.3 Section B — Network and segmentation maturity . . . 28
4.4 Section C — Observability and audit maturity . . . 28
4.5 Section D — Endpoint management maturity . . . 29
4.6 Section E — Sovereignty positioning . . . 29
4.7 Reading the results: trajectory selection matrix . . . 30
4.8 Re-assessment cadence . . . 31

II Reference Architecture on Open Foundations **33**

5 Architectural principles **35**
5.1 Interfaces over products . . . 35
5.2 Functional necessity is independent of scale . . . 35
5.3 Replaceability as a first-class property . . . 36
5.4 Standards landscape . . . 37
5.5 Layer decomposition . . . 39
5.6 What this reference architecture is and is not . . . 40

6 Identity and subject trust **41**
6.1 Functional role and interface contract . . . 41
6.2 Reference instantiation: open-source IdP + SCIM + research-and-education federation . . . 42
6.3 Alternative 1 — Incumbent commercial identity suite with conditional-access policy 43
6.4 Alternative 2 — Hybrid (open-source federation engine + open-source local activation) . . . 43
6.5 Sovereignty grid applied . . . 44
6.6 Regulatory anchoring . . . 44
6.7 Common pitfalls . . . 45

7 Policy decision and enforcement **47**
7.1 Functional role and interface contract . . . 47
7.2 Reference instantiation: OPA + bundle server + decision log to SIEM . . . 48
7.3 Alternative 1 — Cedar with the Verified Permissions pattern . . . 49
7.4 Alternative 2 — Native identity-provider authorisation rules . . . 49
7.5 Sovereignty grid applied . . . 50
7.6 Regulatory anchoring . . . 50
7.7 Common pitfalls . . . 51

8 Network and segmentation **53**
8.1 Functional role and interface contract . . . 53
8.2 Reference instantiation: VLAN/VRF + FreeRADIUS + Open vSwitch + Science DMZ . . . 54
8.3 Alternative 1 — Proprietary macro-segmentation speaking standards . . . 56
8.4 Alternative 2 — Micro-segmentation overlay . . . 56
8.5 Discussion — SASE and ZTNA: why they are not the reference . . . 57
8.6 Sovereignty grid applied . . . 57
8.7 Regulatory anchoring . . . 58
8.8 Common pitfalls . . . 58

9 Compute and workload context **61**
9.1 Functional role and interface contract . . . 61
9.2 Reference instantiation: OpenStack + Kubernetes + Harbor + SLSA . . . 62
9.3 Alternative 1 — VMware with certified Kubernetes . . . 63
9.4 Alternative 2 — Hybrid with standards-based cloud burst . . . 63
9.5 Sovereignty grid applied . . . 64
9.6 Regulatory anchoring . . . 64
9.7 Common pitfalls . . . 64

10 Storage and data classification **67**
10.1 Functional role and interface contract . . . 67
10.2 Reference instantiation: Ceph + Vault Transit + label-based access . . . 68
10.3 Alternative 1 — Enterprise storage platform with KMIP-compliant HSM . . . 69
10.4 Alternative 2 — Hybrid (on-premises + S3-compatible cloud with strict BYOK) 69
10.5 Sovereignty grid applied . . . 70
10.6 Regulatory anchoring . . . 70
10.7 Common pitfalls . . . 70

11 Endpoint management **73**
11.1 Functional role and interface contract . . . 73
11.2 Reference instantiation: Munki + osquery + Ansible + MicroMDM . . . 74
11.3 Alternative 1 — Jamf (macOS/iOS) + Intune (Windows) with OpenTelemetry export . . . 75
11.4 Alternative 2 — Workspace ONE multi-OS . . . 75
11.5 Sovereignty grid applied . . . 76
11.6 Regulatory anchoring . . . 76
11.7 Common pitfalls . . . 76

12 Observability and audit **79**
12.1 Functional role and interface contract . . . 79
12.2 Audit-store integrity . . . 80
12.3 Canonical TAC event schema . . . 80
12.4 Reference instantiation: Vector + Kafka + OpenSearch + Grafana . . . 81
12.5 Alternative 1 — Splunk Enterprise with OpenTelemetry collectors upstream . . . 82
12.6 Alternative 2 — Microsoft Sentinel with Log Analytics . . . 83
12.7 Sovereignty grid applied . . . 83
12.8 Regulatory anchoring . . . 83
12.9 Common pitfalls . . . 84

13 Cryptographic services **85**
13.1 Functional role and interface contract . . . 85
13.2 Reference instantiation: open-source ACME CA + secrets-management platform + software or hardware HSM . . . 86
13.3 Alternative 1 — Active Directory Certificate Services + commercial HSM . . . 86
13.4 Alternative 2 — External CA via ACME standard . . . 87
13.5 Sovereignty grid applied . . . 87
13.6 Regulatory anchoring . . . 88
13.7 Common pitfalls . . . 88

14 Orchestration plane **89**
14.1 Functional role and interface contract . . . 89
14.2 Reference instantiation: declarative GitOps reconciliation with composable workflows 90
14.3 Alternative 1 — ITSM-driven orchestration with Ansible . . . 91
14.4 Alternative 2 — Custom orchestrator on a durable workflow engine . . . 91

14.5 Sovereignty grid applied . . . 92
14.6 Regulatory anchoring . . . 92
14.7 Common pitfalls . . . 92

15 Sizing reference points **95**
15.1 Method and assumptions . . . 95
15.2 Identity layer sizing . . . 95
15.3 Policy layer sizing . . . 96
15.4 Network layer sizing . . . 96
15.5 Audit and observability layer sizing . . . 96
15.6 FTE indicators per layer . . . 96
15.7 Scaling levers and breakpoints . . . 97
15.8 Down-scaled profile for smaller and teaching-led institutions . . . 98

16 Conformance and replaceability tests **99**
16.1 Why a conformance suite . . . 99
16.2 Test categories . . . 99
16.3 Reference test suite per layer . . . 100
16.4 How to run a conformance day . . . 102
16.5 Reporting template . . . 102
16.6 Linkage with wave closure . . . 102

III Migration Playbook for Mixed Estates **105**

17 How to read this playbook **107**
17.1 Objectives of the playbook . . . 107
17.2 Vocabulary . . . 108
17.3 Wave dependency map . . . 108
17.4 Trajectory selection matrix . . . 109
17.5 Minimum viable subset for resource-constrained institutions . . . 110
17.6 Pace options . . . 110
17.7 Risk-and-reversibility philosophy . . . 111

18 Wave 0 — Foundations **113**
18.1 Goal and dependencies . . . 113
18.2 Pre-requisites . . . 113
18.3 Coexistence pattern . . . 114
18.4 Trajectory: greenfield . . . 114
18.5 Trajectory: brownfield single-suite-centric . . . 114
18.6 Trajectory: brownfield hybrid . . . 114
18.7 Reversibility criteria . . . 115
18.8 Exit criteria . . . 115
18.9 Regulatory anchoring . . . 115

19 Wave 1 — Identity and federation **117**
19.1 Goal and dependencies . . . 117
19.2 Pre-requisites . . . 117
19.3 Coexistence pattern . . . 118
19.4 Trajectory: greenfield . . . 118
19.5 Trajectory: brownfield on an incumbent proprietary identity suite . . . 118
19.6 Trajectory: brownfield hybrid . . . 119
19.7 Reversibility criteria . . . 119
19.8 Exit criteria . . . 120

19.9 Regulatory anchoring . . . 120

20 Wave 2 — Observability baseline 121
20.1 Goal and dependencies . . . 121
20.2 Pre-requisites . . . 121
20.3 Coexistence pattern . . . 122
20.4 Trajectory: greenfield . . . 122
20.5 Trajectory: brownfield single-suite-centric . . . 122
20.6 Trajectory: brownfield hybrid . . . 123
20.7 Reversibility criteria . . . 123
20.8 Exit criteria . . . 123
20.9 Regulatory anchoring . . . 124

21 Wave 3 — Network segmentation 125
21.1 Goal and dependencies . . . 125
21.2 Pre-requisites . . . 125
21.3 Coexistence pattern . . . 126
21.4 Trajectory: greenfield . . . 126
21.5 Trajectory: brownfield single-suite-centric . . . 126
21.6 Trajectory: brownfield hybrid (multi-vendor estate) . . . 127
21.7 Reversibility criteria . . . 127
21.8 Exit criteria . . . 128
21.9 Regulatory anchoring . . . 128

22 Wave 4 — Policy plane 129
22.1 Goal and dependencies . . . 129
22.2 Pre-requisites . . . 129
22.3 Coexistence pattern . . . 130
22.4 Trajectory: greenfield . . . 130
22.5 Trajectory: brownfield single-suite-centric . . . 130
22.6 Trajectory: brownfield hybrid . . . 131
22.7 Reversibility criteria . . . 131
22.8 Exit criteria . . . 131
22.9 Regulatory anchoring . . . 132

23 Wave 5 — TAC pilot 133
23.1 Goal and dependencies . . . 133
23.2 Pre-requisites . . . 133
23.3 Coexistence pattern . . . 134
23.4 Three illustrative pilot scenarios . . . 134
23.4.1 Scenario A: Researcher-LLM-API . . . 134
23.4.2 Scenario B: Teaching cyber-range . . . 134
23.4.3 Scenario C: Administrative compliance workspace . . . 135
23.5 Trajectories (consolidated) . . . 135
23.6 Reversibility criteria . . . 135
23.7 Exit criteria . . . 135
23.8 Regulatory anchoring . . . 136

24 Wave 6 — Endpoint and posture 137
24.1 Goal and dependencies . . . 137
24.2 Pre-requisites . . . 137
24.3 Coexistence pattern . . . 138
24.4 Trajectory: greenfield . . . 138
24.5 Trajectory: brownfield single-suite-centric . . . 138

24.6 Trajectory: brownfield hybrid . . . 139
24.7 Reversibility criteria . . . 139
24.8 Exit criteria . . . 139
24.9 Regulatory anchoring . . . 140

25 Wave 7 — TAC-aware audit and IR **141**
25.1 Goal and dependencies . . . 141
25.2 Pre-requisites . . . 141
25.3 Coexistence pattern . . . 142
25.4 Trajectory: greenfield . . . 142
25.5 Trajectory: brownfield single-suite-centric . . . 142
25.6 Trajectory: brownfield hybrid . . . 143
25.7 Reversibility criteria . . . 143
25.8 Exit criteria . . . 143
25.9 Regulatory anchoring . . . 144

26 Wave 8 — Workload classification and scale-out **145**
26.1 Goal and dependencies . . . 145
26.2 Pre-requisites . . . 145
26.3 Coexistence pattern . . . 146
26.4 Trajectory: greenfield . . . 146
26.5 Trajectory: brownfield single-suite-centric . . . 146
26.6 Trajectory: brownfield hybrid . . . 147
26.7 Reversibility criteria . . . 147
26.8 Exit criteria . . . 147
26.9 Regulatory anchoring . . . 148

27 Wave 9 — Lifecycle automation and maturity **149**
27.1 Goal and dependencies . . . 149
27.2 Pre-requisites . . . 149
27.3 Coexistence pattern . . . 150
27.4 Trajectory: greenfield . . . 150
27.5 Trajectory: brownfield single-suite-centric . . . 150
27.6 Trajectory: brownfield hybrid . . . 151
27.7 Reversibility criteria . . . 151
27.8 Exit criteria . . . 151
27.9 Regulatory anchoring . . . 152

28 Cross-cutting concerns **153**
28.1 Change management . . . 153
28.2 Communication . . . 153
28.3 Training and skills development . . . 154
28.4 Risk register . . . 154
28.5 Financial planning . . . 155
28.6 Procurement adjustments . . . 155

29 Reversibility playbook **157**
29.1 Why reversibility is non-negotiable . . . 157
29.2 Per-wave rollback procedures . . . 157
29.3 Data preservation during rollback . . . 158
29.4 Communication during rollback . . . 158
29.5 Post-mortem and re-planning . . . 159

30 Coexistence patterns library **161**
30.1 Pattern: incumbent enterprise directory ↔ institutional IdP . . . 161
30.2 Pattern: incumbent endpoint-management suite ↔ declarative configuration . . . 161
30.3 Pattern: per-volume-priced commercial SIEM ↔ open-source store . . . 162
30.4 Pattern: incumbent commercial hypervisor ↔ open virtualisation substrate . . . 162
30.5 Pattern: enterprise storage array ↔ open-source distributed storage . . . 163
30.6 Pattern: eduroam ↔ TAC-aware Wi-Fi . . . 163
30.7 Common anti-patterns . . . 164

IV References and Operational Material **165**

31 Institutional precedents **167**
31.1 Method . . . 167
31.2 European institutions . . . 168
31.3 North American institutions . . . 168
31.4 Asia-Pacific institutions . . . 169
31.5 Latin American institutions . . . 169
31.6 NRENs and consortium initiatives . . . 169
31.7 The precedents illustrate the architecture; they do not gate it . . . 170
31.8 Documented gaps . . . 171

32 External references and standards **173**
32.1 NIST publications . . . 173
32.2 ISO/IEC publications . . . 174
32.3 European regulatory framework . . . 174
32.4 Sector publications . . . 175
32.5 Open-source specifications and projects . . . 175

33 Regulatory mapping **177**
33.1 Regulatory applicability: the invariant obligation spine . . . 177
33.1.1 The functional-obligation spine (F1–F6) . . . 178
33.1.2 The obligation → mechanism matrix . . . 179
33.2 Regime typology . . . 180
33.2.1 European Union / EEA — deep regime (baseline anchor) . . . 180
33.2.2 United States — deep regime (sectoral and fragmented) . . . 182
33.2.3 United Kingdom — light regime (post-Brexit, diverging) . . . 183
33.2.4 Brazil — light regime (distributed federal stack) . . . 184
33.2.5 South Africa — light regime (single national jurisdiction) . . . 184
33.3 Mapping method: deriving a row for an unlisted regime . . . 185
33.4 Method, scope and limitations . . . 186
33.5 General Data Protection Regulation (GDPR) . . . 187
33.6 NIS2 Directive . . . 188
33.7 EU AI Act . . . 190
33.8 Schrems II and the cross-border data posture . . . 190
33.9 NIST Cybersecurity Framework 2.0 . . . 191
33.10eIDAS 2 and the trust-services dimension . . . 192
33.11ISO/IEC 27001 / 27002 / 27005 . . . 192
33.12COBIT 2019 governance and management objectives . . . 193
33.13Applicability beyond the EU jurisdiction . . . 194
33.14National-transposition cautionary note . . . 195
33.15Reading the mapping in conjunction with the chapters . . . 196
Glossary of Acronyms and Key Terms . . . 197

List of Figures

1.1 TAC activation sequence (synthesis view): the activation chain crosses six functional roles, with the `correlation_id` threading every step for cross-layer audit reconstruction. Full eleven-step development in Chapter 2 of the Technical Reference (§2.2). 2

1.2 Layer-dependency map of the reference architecture: nine functional layers in three planes. Subject and Trust feeds the Control plane; the Control plane writes to the Execution plane; Observability collects events from every layer; Orchestration spans the Execution plane on activation events. Full development in Chapter 5 of the Technical Reference through Chapter 14 of the Technical Reference. 3

1.3 Wave-dependency map of the migration playbook. Wave 0 is the entry point; Waves 1, 2 and 3 can proceed in parallel; later waves close on cumulative prerequisites. Full development in Chapter 17 of the Technical Reference. 5

2.1 End-to-end TAC activation sequence: eleven steps across the subject and the principal functional-role lifelines (cryptographic services participate within the certificate- and key-acquisition steps rather than as a separate lifeline). The TAC `correlation_id` (Crimson) propagates through every step; deactivation reverses every consequential change. 14

2.2 TAC lifecycle state machine. Seven states with their principal transitions. Each transition is a recorded governance decision; the audit trail is preserved across *Decommissioned* and *Archived*. 16

5.1 Layer decomposition of the reference architecture: nine functional layers organised in three planes. The principal dependency flows (Crimson) are: Subject and Trust feeds the Control plane; the Control plane writes to the Execution plane. Observability (dashed) collects events from every layer. 40

List of Tables

1.1 The five dimensions of the sovereignty grid (synthesis; full version with twenty indicators in Chapter 3 of the Technical Reference). 2
1.2 Reference architecture summary: nine functional layers with their principal interface contract and reference open instantiation (synthesis; per-layer detail in Chapters 6–14 of the Technical Reference). 4
1.3 Migration playbook summary: ten waves with goal and principal exit criterion (synthesis; per-wave detail in Chapters 18–27 of the Technical Reference). 5

2.1 Sketch of endpoint integration capabilities by operating system. Each cell is indicative; specific institutional deployments vary. 15
2.2 TAC lifecycle: states and transition triggers. 16

3.1 The twenty indicators of the sovereignty grid (canonical form). Indicators are ordered by dimension, then by criticality. 22
3.2 Sovereignty profile of the pure-OSS identity instantiation. 24
3.3 Sovereignty profile of the pure-commercial identity instantiation (default configuration, without optional HYOK arrangements). 24
3.4 Sovereignty profile of the hybrid identity instantiation. 25

4.1 Trajectory and pace heuristics from the self-assessment profile. "A–D maturity" is the dominant trend across the diagnostic sections; "E gap" is the gap between current and intent in Section E; "Section E intent" is the intent score itself. . . . 31

5.1 Standards landscape of the reference architecture. Status indicates the maturity of the standard relative to the architecture's expectations: *Stable* (long-established, broadly implemented), *Mature* (established but evolving), *Emerging* (recent, adopted by the architecture as forward-looking). 38

6.1 Per-dimension sovereignty profile of the three identity instantiations. Scores are consistent with Chapter 3 of the Technical Reference §3.4. 44

7.1 Per-dimension sovereignty profile of the three policy instantiations. 50

8.1 Reference zone catalogue (illustrative). Each row in an institutional catalogue is owned by a named accountable team. 55
8.2 Per-dimension sovereignty profile of the network instantiations. 57

9.1 Per-dimension sovereignty profile of the compute instantiations. 64

10.1 Per-dimension sovereignty profile of the storage instantiations. 70

11.1 Per-dimension sovereignty profile of the endpoint instantiations. The reference is scored across two columns to make the iOS/Android gap visible. 76

12.1 Canonical TAC event schema. **R** required for every event; **c** required when the field is meaningful for the producing layer; **o** optional but recommended. 81
12.2 Per-dimension sovereignty profile of the observability instantiations. 83

13.1 Per-dimension sovereignty profile of the cryptographic-services instantiations. . . 87

14.1 Per-dimension sovereignty profile of the orchestration instantiations. 92

15.1 Indicative operational envelopes per layer (engineer-equivalents, shared with adjacent duties). Ranges are not additive. 97

16.1 Reference test suite (illustrative). Categories: F = Interface fidelity, P = Data portability, X = Exit rehearsal, A = Decision auditability. 101

17.1 Wave dependency structure. "Required" pre-requisites must be closed; "Recommended" pre-requisites strengthen the wave but do not block it. 109
17.2 Trajectories through the waves, with their dominant characteristics. The Selective and Deferred profiles are tactically divergent and are treated as variations of the three principal trajectories. 109

29.1 Per-wave rollback procedures (indicative). The unit of rollback is the smallest operational increment that the wave's coexistence pattern admits. 158

33.1 Obligation → mechanism matrix — the invariant core. Each functional obligation maps to the SUIT control capabilities that contribute to discharging it; only the regulatory instrument is substituted per jurisdiction. 179
33.2 EU/EEA — F1–F6 instantiation of the invariant spine. 181
33.3 United States — F1–F6 instantiation of the invariant spine. 182
33.4 United Kingdom — F1–F6 instantiation (light regime). 183
33.5 Brazil — F1–F6 instantiation (light regime). 184
33.6 South Africa — F1–F6 instantiation (light regime). 185
33.7 GDPR mapping — principal provisions and architectural contributions. 188
33.8 NIS2 mapping — governance, risk-management measures and incident reporting. 189
33.9 EU AI Act mapping — principal provisions for a typical research-intensive institution. 190
33.10 Cross-border data — elements of the post-*Schrems II* posture and their architectural counterparts. 191
33.11 NIST CSF 2.0 mapping — the architecture's contribution by function. 191
33.12 eIDAS 2 mapping — elements relevant to a typical research-intensive institution and their architectural counterparts. 192
33.13 ISO/IEC 27001:2022 Annex A — controls most directly addressed by the architecture (illustrative subset). 193
33.14 COBIT 2019 mapping — governance and management objectives most directly addressed (illustrative subset). 194

Chapter 1

Synthesis

This chapter is a self-contained executive overview of the entire Technical Reference. It develops, at the level of essential content rather than implementation detail, the three structural contributions of the document: the sovereignty grid, the reference architecture on open foundations, and the wave-based migration playbook. It also provides a one-minute self-assessment, an annotated set of institutional precedents, and a reading map for the remaining thirty-two chapters. A reader who completes this chapter alone should be able to decide which subsequent chapters are most relevant to their role.

1.1 Purpose and audience

The Technical Reference addresses chief technology officers, information-security officers, network and platform engineers, and the institutional governance bodies that mandate them. It complements the policy-and-analysis main report with the material a practitioner would need to operationalise the architecture: explicit interface contracts, a vendor-neutral reference instantiation on open foundations, alternatives that admit proprietary components within the same contracts, and a migration playbook applicable across institutions and jurisdictions.

Reading time and dependence. The present chapter is designed to be read in approximately thirty minutes by a reader familiar with university IT. It depends on no prior knowledge of the Reference's other chapters; cross-references throughout point the reader to the development that they may wish to consult next.

Where this chapter sits in the suite. The Technical Reference is one of three documents in the dossier on university IT infrastructure: a policy-and-analysis main report, an argumentation document anticipating objections, and the present practitioner-oriented Technical Reference. In the all-in-one book edition of the dossier, this chapter is reproduced as the technical-annex part; in the standalone Technical Reference, it is the opening chapter.

1.2 The TAC concept at a glance

A **Trusted Activity Context** (Trusted Activity Context (TAC)) is a coherent, validated environment that assembles the data, tools, services, and access rights required for a specific activity — a research project, a digital examination, an administrative process, a teaching session — under documented institutional governance. Within a TAC, the identity of subjects, the classification of resources, the network attachment, the policy decisions, the cryptographic posture, and the audit trail are aligned with the activity's objectives and risk level, and are operationally bounded by the TAC's declared scope.

Why it matters. Existing access-control and isolation frameworks are typically organised around either subjects (who a user is) or resources (what a service contains). A TAC is organised around *what is being done*: the same subject, holding the same attributes, accessing the same resource, may operate in a different TAC depending on the activity engaged. This re-frames several recurring difficulties in academic IT — the researcher who is also a teacher, the visiting collaborator who is also a host, the administrative process that touches research data — as switches between TACs rather than as exceptions to a single role-based model.

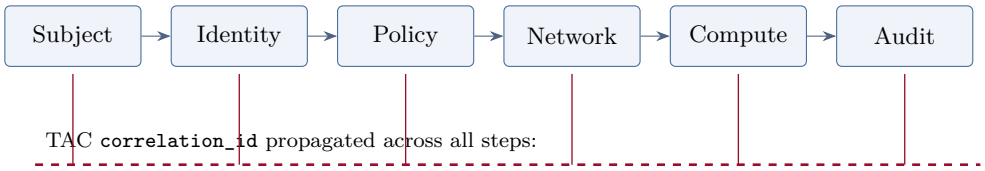


Figure 1.1: TAC activation sequence (synthesis view): the activation chain crosses six functional roles, with the `correlation_id` threading every step for cross-layer audit reconstruction. Full eleven-step development in Chapter 2 of the Technical Reference (§2.2).

Pointer. The full conceptual development of TAC — formal definition, principles, comparison with related frameworks, lifecycle state machine — is in Chapter 2 of the Technical Reference.

1.3 The sovereignty grid in one table

Sovereignty in university IT is rarely contested in principle and rarely operationalised in practice. The grid that the Technical Reference proposes is the instrument that bridges the two: a structured way of asking, for any candidate component of the digital infrastructure, whether the institution retains the capacities — legal, technical, financial, operational, and institutional — that allow it to remain the author of its own decisions.

Five dimensions, each scored independently. The grid is structurally non-aggregating: each dimension is reported on its own four-point scale (Absent / Partial / Established / Robust); no single sovereignty score is produced. A single critical gap on a dimension defines the institution's exposure on that dimension regardless of the other dimensions' strength.

Table 1.1: The five dimensions of the sovereignty grid (synthesis; full version with twenty indicators in Chapter 3 of the Technical Reference).

Dimension	Question (verifiable capacity)
Data	Where is the data stored, under which jurisdiction, accessible to which actors — including state actors?
Technical	Can the institution inspect, modify, repair, and substitute the components of its infrastructure?
Financial	Is the multi-year operating cost predictable, and is the institution exposed to captive escalation?
Operational	Are the skills required to operate the infrastructure available locally or through trusted partners (the national research and education network, peer institutions)?
Institutional	Can the institution decline a supplier roadmap change without contractual penalty, and retain authority over the decisions that matter?

Use as a governance instrument. The grid feeds four governance practices that are frequently conducted in mutual ignorance: procurement (RFP language, contractual exit assistance, gating

thresholds per workload class); internal audit (annual review of the institution's sovereignty profile per component); peer-institution benchmarking (comparison anchored by a shared grid); and public accountability (publication of the institution's sovereignty position by component).

Pointer. The grid is fully developed in Chapter 3 of the Technical Reference (twenty indicators, scoring guidance, three worked examples on identity instantiations, common misuses, governance use). The institutional self-assessment that operationalises the grid is in Chapter 4 of the Technical Reference.

1.4 Reference architecture in one table

The Technical Reference proposes a vendor-neutral architecture organised in nine functional layers grouped in three planes — Subject and Trust (Identity, Endpoint, Crypto), Execution (Network, Compute, Storage), and Control and Governance (Policy, Observability, Orchestration). The architecture's normative content is the set of interface contracts (open standards) that connect the layers; products are illustrative, not prescriptive.

The reference instantiation on open foundations. A reference instantiation is given on open-source components to demonstrate that the contracts are realisable without proprietary extensions in critical paths. Commercial alternatives that respect the contracts remain admissible; the choice between instantiations is informed by the sovereignty grid rather than imposed.

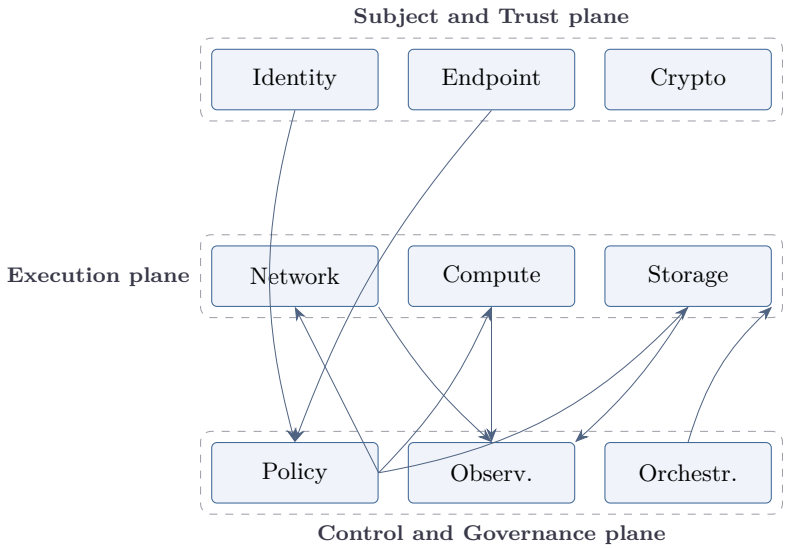


Figure 1.2: Layer-dependency map of the reference architecture: nine functional layers in three planes. Subject and Trust feeds the Control plane; the Control plane writes to the Execution plane; Observability collects events from every layer; Orchestration spans the Execution plane on activation events. Full development in Chapter 5 of the Technical Reference through Chapter 14 of the Technical Reference.

Table 1.2: Reference architecture summary: nine functional layers with their principal interface contract and reference open instantiation (synthesis; per-layer detail in Chapters 6–14 of the Technical Reference).

Layer	Interface contract (standards)	Open reference
Identity	OIDC, SAML2, SCIM 2.0, federation metadata	Keycloak + SCIM + eduGAIN
Policy	OPA REST or Cedar evaluation API	OPA + bundle server + decision log
Network	RADIUS, NETCONF/YANG, BGP/EVPN, IPFIX	VLAN/VRF + FreeRADIUS + Open vSwitch + research-data path (Science DMZ / national research and education network circuit)
Compute	Kubernetes API, OpenStack API, OCI, SLSA	OpenStack + Kubernetes + Harbor + SLSA
Storage	S3 API, KMIP, NFS v4.1	Ceph + Vault + label-based access
Endpoint	DDM/DEP, MS-MDM, declarative Linux config	Munki + osquery + Ansible + MicroMDM (gap on iOS/Android at scale acknowledged)
Observability	OpenTelemetry, CloudEvents, syslog	Vector + Kafka + OpenSearch + Loki + Grafana
Crypto	PKCS#11, ACME, KMIP	step-ca + Vault + SoftHSM or Nitrokey HSM
Orchestration	Event-driven, idempotent, observable, reversible (no single standard)	Argo Workflows + Crossplane + GitOps

Conformance and replaceability. The architecture's contracts are operationalised by a conformance suite organised in four categories (interface fidelity, data portability, exit rehearsal, decision auditability). Every wave of the migration playbook closes by passing the conformance subset relevant to its scope. The suite is the mechanism that prevents the common failure mode of migration programmes: change of product disguised as architectural progress. Full description in Chapter 16 of the Technical Reference.

1.5 Migration playbook in one figure and one table

The Technical Reference proposes a wave-based migration playbook that takes any institution from its current brownfield position toward the target architecture. Ten waves (Wave 0 to Wave 9) unfold under a documented dependency graph. Each wave declares its goal, prerequisites, coexistence pattern, three principal trajectories (greenfield, brownfield with a dominant proprietary productivity suite, brownfield hybrid), reversibility criteria, and exit criteria gated by the conformance suite.

Three pace options. The playbook admits three reference pace options — 5-year compressed, 7-year balanced (recommended default), 10-year gradual. Pace and trajectory interact; revising the pace is a normal part of operating the playbook.

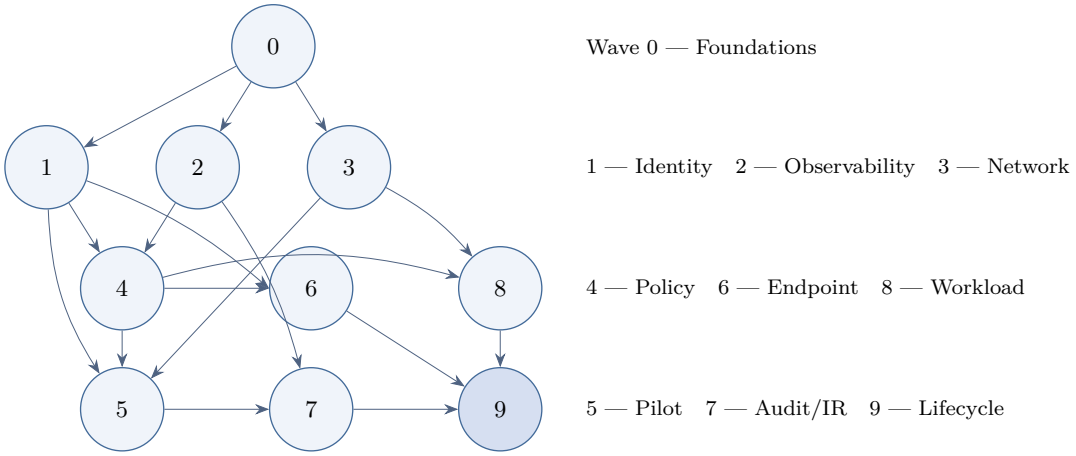


Figure 1.3: Wave-dependency map of the migration playbook. Wave 0 is the entry point; Waves 1, 2 and 3 can proceed in parallel; later waves close on cumulative pre-requisites. Full development in Chapter 17 of the Technical Reference.

Table 1.3: Migration playbook summary: ten waves with goal and principal exit criterion (synthesis; per-wave detail in Chapters 18–27 of the Technical Reference).

Wave	Goal	Principal exit criterion
0 — Foundations	Governance, baseline inventory, sovereignty grid adoption.	Four artefacts in writing; programme funded.
1 — Identity	SSO, federation, SCIM aligned with the contract.	Identity conformance subset passes; agreed application coverage.
2 — Observability	Pre-instrumentation in shadow mode.	Source coverage; canonical schema enforced.
3 — Network	Zone catalogue, RADIUS attachment, high-throughput research-data path (Science DMZ or national research and education network circuit).	Network conformance subset passes.
4 — Policy plane	PDP/PEP introduced in shadow before enforcing.	Policy conformance subset passes; migrated set enforcing.
5 — Pilot	Full stack exercised end-to-end on a contained scope.	Union of relevant conformance subsets; pilot host report.
6 — Endpoint	Posture signals routed to policy; per-population transition.	Endpoint conformance subset passes; agreed populations enforcing.
7 — Audit and IR	TAC-correlated investigation; refreshed runbooks.	Audit conformance subset; SOC proficiency demonstrated.
8 — Workload classification	Classification enforced at provisioning; cluster separation.	Compute and Storage conformance subsets; classification coverage.
9 — Lifecycle automation	Self-service, GitOps, mature operational stage.	Orchestration conformance subset; self-service ratio achieved.

Reversibility as non-negotiable. The playbook commits to the reversibility of every wave at acceptable cost during a published window. The reversibility playbook of Chapter 29 of the Technical Reference consolidates the per-wave rollback procedures, the data-preservation considerations, the communication patterns, and the post-mortem framework. The commitment

makes the migration a governance decision rather than a leap of faith.

1.6 Self-assessment in one minute

The full institutional self-assessment of Chapter 4 of the Technical Reference comprises approximately fifty questions organised in five sections. The five questions below are a one-minute version: one question per sovereignty dimension, each answered **Y** (capacity established or robust) or **N** (absent or partial).

1. **Data.** Are storage location, key custody, and disclosure regime documented per data class?
2. **Technical.** Can the institution inspect or independently rebuild every critical component of its infrastructure?
3. **Financial.** Is the multi-year operating cost of the digital infrastructure predictable and contractually capped?
4. **Operational.** Are the skills for each critical layer present in the institution or accessible through its national research and education network and peer network?
5. **Institutional.** Can the institution decline a supplier roadmap change without contractual penalty for the current procurement period?

Reading the result. Five Y answers indicate that the institution is already operating close to the architecture's sovereignty target; the playbook is then used as a checklist rather than as a roadmap. Mixed answers indicate the dominant trajectory: predominantly N answers on Data, Technical, and Institutional with a Y on Operational suggest a brownfield profile dominated by a single proprietary productivity suite; mixed answers across all dimensions suggest a brownfield hybrid profile; predominantly N answers across the board suggest that Wave 0 (governance and inventory) is the appropriate first step before trajectory selection.

1.7 Real-world precedents at a glance

The architecture and the playbook do not invent their structural patterns from first principles; they consolidate patterns visible at named institutions whose practices have been the subject of public discussion. The list below records the institutions that have appeared most consistently as references; the full annotated catalogue, with the methodological caveats, is in Chapter 31 of the Technical Reference.

- CERN — federated identity at scale; experimental network isolation patterns.
- MIT — Information Technology Governance Committee (ITGC); federated IT pattern across institutional and college units.
- Stanford — SUNet multi-zone segmentation; UIT and SRCC.
- ETH Zürich — a binding administrator-rights agreement (a contractual, proportionate transfer of root-access responsibility, on the ETH Zürich model); federated IT-services organisation.
- Cambridge — University Information Services (UIS); collegiate model with the University Data Network (UDN) connecting central services and the institutions of the Collegiate University.
- Indiana University — Jetstream2 research-cloud architecture (NSF ACCESS).
- NUS Singapore — Asia-Pacific federation patterns.
- USP Brazil — Latin American research-network integration through RNP.
- University of Michigan — ITS, Merit Network, CAEN faculty IT.
- KU Leuven — European research-intensive central IT model.

Documented gaps. Several aspects of the architecture remain thinly documented in public institutional sources: policy plane deployments at academic scale; TAC-aware audit pipelines;

sovereignty grid practice as a structured five-dimension instrument applied across an institutional portfolio. The cross-institutional infrastructure-sovereignty programme of participating institutions anticipated by this Reference is the locus where these gaps are intended to be closed.

1.8 How to use the rest of the Technical Reference

The remaining thirty-two chapters of the Technical Reference develop the elements summarised above. Three reading paths cover the principal use cases.

Reading path: governance and rectorate. Chapter 2 (the TAC concept), Chapter 3 of the Technical Reference (the sovereignty grid in full), Chapter 4 of the Technical Reference (the institutional self-assessment). Indicative reading time: approximately ninety minutes. Output: the institution's positioning against the grid and an indication of the dominant migration trajectory.

Reading path: chief technology officer or information-security officer. Add to the previous path: the architectural principles of Chapter 5 of the Technical Reference; the layer chapter most relevant to the institution's current priority among Chapters 6–14; the conformance suite of Chapter 16 of the Technical Reference; and the playbook reading guide of Chapter 17 of the Technical Reference. Indicative reading time: approximately a working day. Output: a position from which the institution can engage its trajectory selection and procurement adjustments.

Reading path: programme or migration lead. Add to the CTO path: Part III in full (Chapter 17 of the Technical Reference through Chapter 30 of the Technical Reference). Indicative reading time: two to three working days. Output: a wave plan with declared trajectories, paces, and reversibility windows.

Layer-specific reading paths. An engineer engaged on a specific layer can read the corresponding chapter (Identity: Chapter 6 of the Technical Reference; Policy: Chapter 7 of the Technical Reference; Network: Chapter 8 of the Technical Reference; Compute: Chapter 9 of the Technical Reference; Storage: Chapter 10 of the Technical Reference; Endpoint: Chapter 11 of the Technical Reference; Observability: Chapter 12 of the Technical Reference; Crypto: Chapter 13 of the Technical Reference; Orchestration: Chapter 14 of the Technical Reference), followed by the corresponding wave chapter. Each layer chapter is self-contained.

End of synthesis. The remainder of the Technical Reference (Parts I to IV) develops each of the elements summarised above in the depth required for technical implementation, operational planning, and institutional governance.

Part I

Foundations

Chapter 2

Conceptual frame

This chapter establishes the conceptual material that the rest of the Technical Reference applies. It develops the formal definition of the Trusted Activity Context (TAC), the end-to-end activation sequence that turns a TAC declaration into running infrastructure, the endpoint operating-system integration matrix, and the lifecycle state machine that governs a TAC from draft to archival. A reader who has consulted the companion main report will find parts of this material familiar; the chapter is nevertheless written to be self-contained for the standalone reader.

2.1 The Trusted Activity Context concept

Definition. A **Trusted Activity Context** (TAC) is a coherent, validated environment that assembles the data, tools, services, and access rights required for a specific activity — a research project, a digital examination, an administrative process, a teaching session — under documented institutional governance. Within a TAC, the identity of subjects, the classification of resources, the network attachment, the policy decisions, the cryptographic posture, and the audit trail are aligned with the activity's objectives and risk level, and are operationally bounded by the TAC's declared scope.

Why "trusted". The qualifier follows the dependability tradition of Avizienis et al. [2↗]: an entity is *trusted* when it delivers service that can justifiably be relied upon. The trust in a TAC is consequently not assumed; it is the result of the contractual obligations placed on each layer by the architecture of Part II and verified by the conformance suite of Chapter 16 of the Technical Reference. A TAC is trusted because its properties are checkable.

Why "activity". The qualifier is the central innovation. Existing access-control and isolation frameworks are typically organised around either subjects (who a user is) or resources (what a service contains). A TAC is organised around *what is being done*: the same subject, holding the same attributes, accessing the same resource, may operate in a different TAC depending on the activity engaged. This re-frames several recurring difficulties in academic IT — the researcher who is also a teacher, the visiting collaborator who is also a host, the administrative process that touches research data — as switches between TACs rather than as exceptions to a single role-based model.

Why "context". A TAC is not a single object; it is the assembled configuration that an activity requires. It includes:

- a *subject set*, typically with specific role activations rather than blanket role memberships;
- a *resource set* — data, tools, services — consistent with the activity's classification;
- a *network attachment* appropriate to the activity's zone (research, teaching, administration, sensitive);
- a *policy envelope* that admits the operations the activity requires and denies those it does not;

- a *cryptographic posture* (key custody, certificate chain) consistent with the resource classification;
- a *logging and audit trail* that allows every consequential decision under the TAC to be reconstructed.

The TAC is the unit of *governance* that brings these elements together, so that they can be specified, reviewed, provisioned, audited, and decommissioned as a coherent whole rather than as a coincidence of separately managed configurations.

Disambiguation. The term *Trusted Activity Context* should not be confused with IBM DB2's identically named database connection feature, nor with the Trusted Computing concepts of the Trusted Computing Group. Here the term has the specific meaning developed above.

Position relative to existing frameworks. The TAC concept draws on and extends several established frameworks without being identical to any of them. Role-based access control (RBAC) [3↗] provides session-bounded role activation but does not assemble resources, network, and audit into a single governance unit. Task-Based Authorization Controls (TBAC) [4↗] tie permissions to task lifecycles and supply part of the lifecycle intuition but do not extend to the cross-layer contractual obligations. Attribute-Based Access Control (ABAC, NIST SP 800-162) [5↗] provides the per-decision evaluation model that the TAC policy envelope uses, but does not extend to the governance-level abstraction. The contextual-awareness technique of NIST SP 800-160 Vol. 2 names contextual factors as inputs to security decisions but does not propose a unit of operational governance over those inputs. Workspace and tenancy products (cloud workspaces, Kubernetes namespaces with RBAC) operationalise aspects of the pattern but at the level of a single platform, not at the level of an institutional contract spanning identity, network, compute, storage, observability and governance.

Four founding principles. A TAC, in this Reference's sense, satisfies four properties:

Trustworthiness
: Each context is technically bounded and monitored so that the institution can grant a high degree of autonomy within it without surrendering control of the institutional perimeter.

Dependability
: Failures, misconfigurations, or security incidents within one context remain contained and do not compromise the institutional core or other contexts.

User-centricity
: The digital environment adapts to the user's current activity rather than imposing a uniform security model on every situation. Restriction is the consequence of activity-specific risk, not of institutional default.

Observability
: Every action within a TAC is logged and reconstructable, so that autonomy is accompanied by accountability.

Isolation as enabling, not restrictive. The TAC model reverses the conventional framing of isolation. In the conventional framing, isolation *restricts* users; in the TAC model, isolation *enables* autonomy by guaranteeing that mistakes, experiments, and attacks within a context cannot escape it. The forestry analogy applies: a forest is not made safer by planting trees in a single continuous mass; the *construction of firebreaks* is what prevents a blaze from spreading to the entire woodland. TACs are the institutional firebreaks of the digital infrastructure.

Relation to segmentation. A mature institution combines a relatively stable network segmentation (zones, as described in Chapter 8 of the Technical Reference) with multiple dynamic TACs that operate within those zones. Segmentation is spatial and relatively stable; TACs are activity-bound and relatively dynamic. The two mechanisms are complementary: segmentation

limits where flows can circulate; TACs determine in what validated environment an activity proceeds.

2.2 End-to-end activation sequence

A TAC is realised by the cross-layer cooperation of the architecture of Part II. The activation sequence below describes what happens, end to end, when a subject activates a TAC for a specific activity. The sequence is presented at the level of named functional roles; the actual products that play these roles depend on the institution's chosen instantiation (Chapter 6 of the Technical Reference through Chapter 14 of the Technical Reference).

Functional roles in the sequence. The sequence involves: IDENTITY (the institution's identity provider, Chapter 6 of the Technical Reference); POLICY (the policy decision point, Chapter 7 of the Technical Reference); NETWORK (the network attachment and segmentation infrastructure, Chapter 8 of the Technical Reference); COMPUTE, STORAGE, and ENDPOINT (the execution-plane layers, Chapter 9 of the Technical Reference–Chapter 11 of the Technical Reference); CRYPTO (cryptographic services, Chapter 13 of the Technical Reference); AUDIT (the observability layer, Chapter 12 of the Technical Reference); ORCHESTRATION (the cross-layer glue, Chapter 14 of the Technical Reference).

The activation sequence. The numbered steps below correspond to a typical TAC activation. Steps may overlap in time in a real implementation; the numbering reflects logical order, not strict serial execution.

1. SUBJECT AUTHENTICATION. The subject authenticates against IDENTITY; a short-lived assertion is issued carrying the institutional attribute schema.
2. ACTIVITY DECLARATION. The subject (directly, or through an institutional service such as a research-workspace portal) requests activation of a named TAC for a stated activity.
3. POLICY EVALUATION. POLICY receives the activation request, combines the subject attributes with the TAC declaration (resource set, classification, environment), and produces a decision. The decision is one of `allow`, `deny`, or `indeterminate`, accompanied by structured obligations (session timeout, audit class, additional factor required).
4. ORCHESTRATION TRIGGERS. On `allow`, ORCHESTRATION receives the decision and dispatches cross-layer commands to realise the TAC.
5. NETWORK ATTACHMENT. NETWORK attaches the subject's session to the appropriate zone, with per-session attributes (zone, egress allowance, rate limits) derived from the policy decision.
6. COMPUTE PROVISIONING. COMPUTE provisions or attaches the workload context (a virtual machine, a container namespace, a research workspace) with the institutional schema's attributes propagated.
7. STORAGE BINDING. STORAGE binds the appropriate volumes, applying classification-derived access controls and ensuring keys are obtained from CRYPTO consistent with the resource classification.
8. ENDPOINT POSTURE VERIFICATION. ENDPOINT confirms that the subject's device meets the posture requirements declared by the policy decision; mismatch is fed back to POLICY for re-evaluation or quarantine.
9. AUDIT CORRELATION. AUDIT receives events from every layer with the same TAC correlation identifier, allowing the activation chain to be reconstructed end-to-end.
10. ACTIVITY PROCEEDS. The subject conducts the activity within the bounded context. Each subsequent consequential operation under the TAC produces events correlated to the same identifier.
11. DEACTIVATION. On the activity's natural end (timeout, explicit deactivation, lifecycle transition; §2.4), ORCHESTRATION reverses the consequential changes. AUDIT records the

deactivation; STORAGE preserves classification metadata on persistent artefacts; NETWORK releases the attachment; COMPUTE releases the workload context.

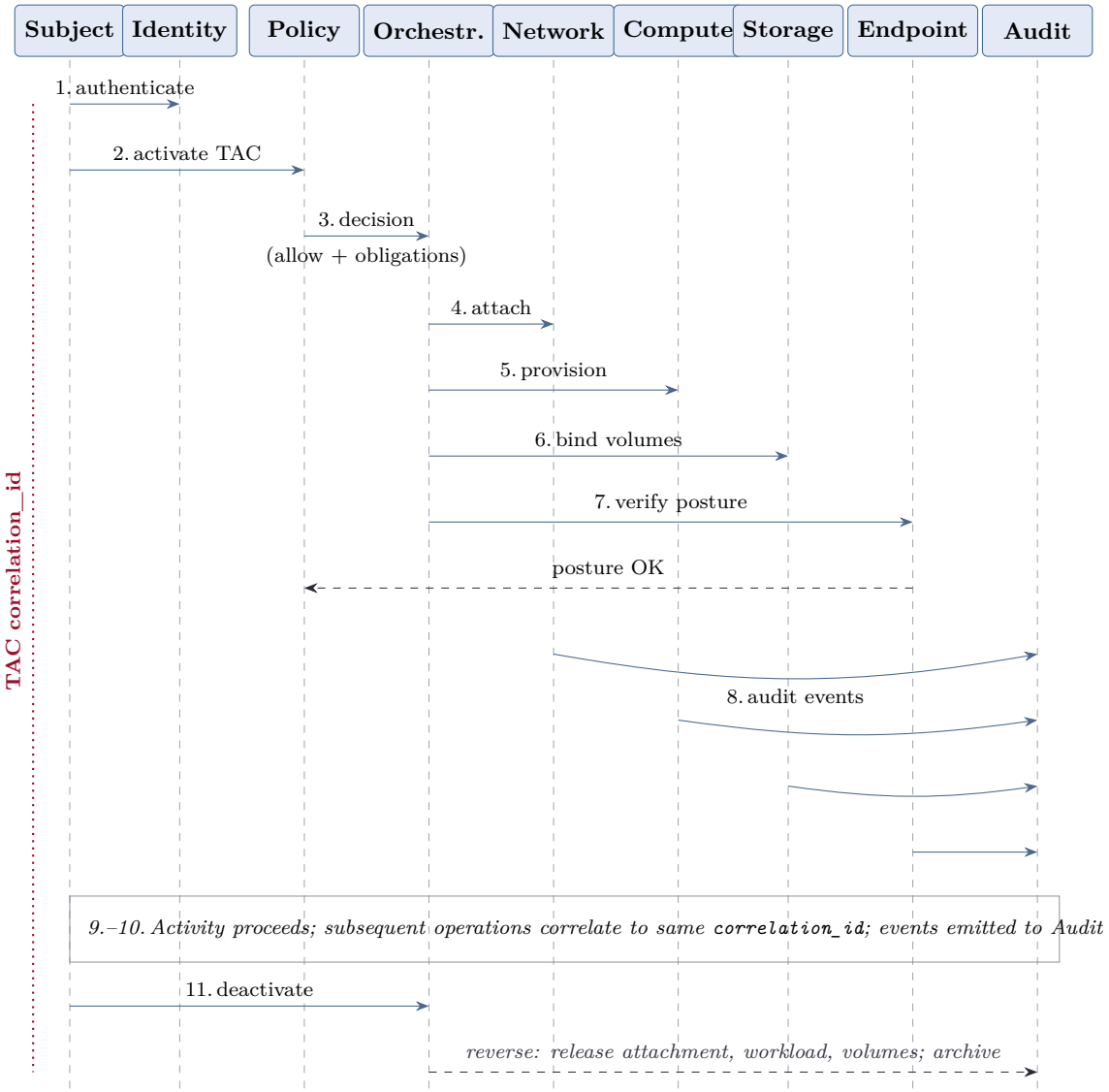


Figure 2.1: End-to-end TAC activation sequence: eleven steps across the subject and the principal functional-role lifelines (cryptographic services participate within the certificate- and key-acquisition steps rather than as a separate lifeline). The TAC `correlation_id` (Crimson) propagates through every step; deactivation reverses every consequential change.

What the sequence guarantees. If every layer respects the contracts of Part II, the sequence produces three guarantees: every TAC activation is the consequence of a recorded policy decision; every consequential change is reversible by the deactivation path; every layer's actions can be correlated through the TAC identifier for forensic and audit reconstruction. These guarantees are the operational expression of the four founding principles of §2.1.

2.3 Endpoint operating-system integration matrix

The TAC model relies on the endpoint to enforce a subset of the policy decisions and to report posture to the policy plane. The endpoint operating systems encountered at a typical research-intensive institution have differing capabilities and differing maturity for TAC integration. The matrix in Table 2.1 sketches the principal capabilities; Chapter 11 of the Technical Reference develops the operational detail and the OSS-vs-commercial trade-offs.

Table 2.1: Sketch of endpoint integration capabilities by operating system. Each cell is indicative; specific institutional deployments vary.

Capability	Linux (managed)	macOS (managed/BYOD)	Windows (corporate)
Federated identity	SSSD or realmd against AD/LDAP; OIDC clients for web apps	Apple Platform SSO with the IdP extension; Jamf Connect as alternative	Entra ID join with Conditional Access; Hello for Business
Posture verification	Custom checks via `osquery`; package-manager state	MDM compliance profile (Jamf, Mosyle, Kandji); built-in managed-client signals	Intune compliance policies; Defender for Endpoint signals
TAC-scoped tunnel	WireGuard or OpenVPN profile pushed by configuration management	Per-app VPN configuration profile delivered via MDM	Always-On VPN profile via Intune; SSE alternatives
Configuration policy	Ansible, Puppet, Salt; declarative GitOps repositories	Munki, configuration profiles, Jamf, Apple Business Manager	GPO for AD environments; Intune for cloud-managed estates
Audit ingestion	`auditd`, journald, syslog forwarder	Unified log forwarder (e.g. `log show` stream, EDR agent)	Windows Event Forwarding; EDR agent telemetry

Mobile platforms. iOS and Android share much with the macOS/Windows columns through the same MDM platforms (Jamf, Intune, Workspace ONE), with the additional constraint that posture and configuration depend on what each operating system exposes to enterprise management. As Chapter 11 of the Technical Reference discusses explicitly, the open-source ecosystem for iOS and Android at institutional scale is, at the time of writing, less mature than for the desktop platforms; the matrix above accordingly emphasises desktop coverage.

Other platforms. BSD and illumos environments, where present in the research-computing footprint, can be brought into the matrix through the same patterns as Linux for posture (`osquery` has reasonable cross-platform coverage) and through declarative configuration management. They are not listed in the matrix because their institutional footprint is typically small.

2.4 Lifecycle of a TAC

A TAC is not provisioned eternally; it has a lifecycle that the institution governs. The state machine in Figure 2.2 (and Table 2.2) describes the principal states and the transitions between them.

Table 2.2: TAC lifecycle: states and transition triggers.

State	Meaning	Principal transitions out
Drafted	The TAC declaration exists in the institutional registry but has not yet been validated. No infrastructure is provisioned.	to *Validated* on review approval; to *Discarded* on rejection.
Validated	The TAC has passed institutional review (data classification confirmed, policy envelope reviewed, governance approval recorded). It can be activated on request.	to *Provisioned* on first activation; to *Decommissioned* if validity expires.
Provisioned	The infrastructure to realise the TAC is in place but the activity is not currently running.	to *Active* on activity start; to *Suspended* on institutional pause.
Active	The activity is in progress; subjects operate under the TAC; events are being correlated.	to *Provisioned* (or *Suspended*) on activity end.
Suspended	The TAC is operationally paused: pending compliance review, stakeholder absence, or institutional pause. No activity proceeds.	to *Active* on resumption; to *Decommissioned* on permanent pause decision.
Decommissioned	The infrastructure has been released; classification metadata on persistent artefacts is preserved per the institutional retention schedule.	to *Archived* after the retention period expires.
Archived	The TAC is closed. The audit trail and metadata remain available to institutional inquiry per retention policy; no further activity is possible.	terminal state.

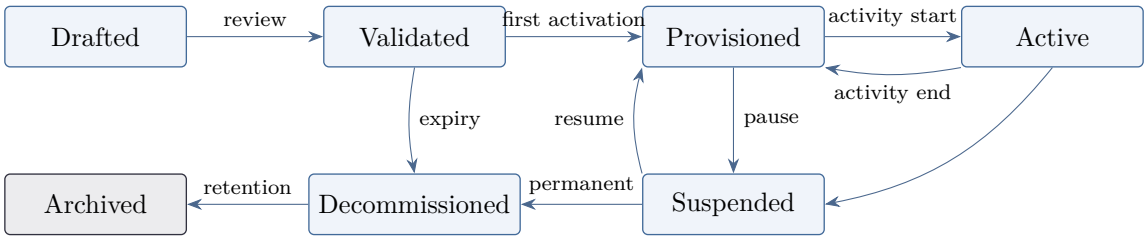


Figure 2.2: TAC lifecycle state machine. Seven states with their principal transitions. Each transition is a recorded governance decision; the audit trail is preserved across *Decommissioned* and *Archived*.

Governance over transitions. Each transition is the consequence of a recorded decision, not of an automated default. The institutional registry that holds TAC declarations records who validated, who activated, who suspended, who decommissioned; the record is itself an audit artefact governed under the canonical TAC schema of Chapter 12 of the Technical Reference. A TAC's lifecycle is consequently fully reconstructable from the audit trail.

Implications for procurement. The lifecycle requires that every component of the architecture support the full set of transitions: provisioning on activation, release on deactivation, preservation of classification metadata on decommission, and read-only access to archived audit trails. These properties are part of the procurement clauses developed in Chapter 28 of the Technical Reference (§28.6).

2.5 Out of scope

This Technical Reference does not address several adjacent domains that an institution implementing the architecture will need to engage separately.

- **Human-resources policy.** Decisions about which subjects hold which roles, how role changes are processed in the institutional system of record, and how role lifecycle interacts with employment lifecycle are addressed by the institution's HR governance, not by this Reference.
- **Pedagogical training.** The training of academic staff and students in the practical use of TAC-aware services is an institutional learning-and-development function. The Reference's training discussion (Chapter 28 of the Technical Reference §28.3) addresses operational-team skills, not end-user pedagogy.
- **Procurement law.** The Reference proposes procurement language (Chapter 28 of the Technical Reference §28.6) consistent with the architecture but does not engage the specifics of any jurisdiction's procurement law. Institutions verify the language with their own legal counsel.
- **Physical security.** The Reference assumes that the physical infrastructure on which the architecture operates is secured to a level appropriate for its classification. Physical-security framework selection and operation is out of scope.
- **Disaster recovery beyond reversibility.** The reversibility playbook of Chapter 29 of the Technical Reference addresses migration-wave reversal. Broader disaster-recovery planning (data-centre loss, regional outage) is engaged by the institution's existing DR framework and is not superseded by this Reference.

The boundaries above are deliberate. The Reference is intended to be useful in any institution's existing governance ecosystem, not to displace that ecosystem.

Chapter 3

The sovereignty grid

Sovereignty in university Information Technology (IT) is rarely contested in principle and rarely operationalised in practice. The grid presented in this chapter is the instrument that bridges the two: a structured way of asking, for any candidate component of the digital infrastructure, whether the institution retains the capacities — legal, technical, financial, operational, and institutional — that allow it to remain the author of its own decisions. The grid is the normative pivot of this Technical Reference: every subsequent chapter applies it; every recommendation derives from it.

Posture of this chapter

The grid is a deliberation and procurement instrument, not an audit scoring system. A component admissible on the grid is not, by that fact alone, the right choice; the institutional context, which the grid does not capture in full, completes the decision. Conversely, a component inadmissible on a critical dimension cannot be rescued by strengths elsewhere: each dimension is reported independently and critical thresholds may apply per workload class.

3.1 Five dimensions of sovereignty

Sovereignty is too often treated as a single concept. In practice, an institution can be sovereign in some respects and dependent in others: a stack with European data residency may still be operationally captive if only the supplier's certified engineers can operate it, and a stack that is technically open may still be financially captive if the only realistic supplier holds a monopolistic position. The five dimensions below are intentionally orthogonal: they ask different questions, can have different answers for the same component, and require different remediations.

3.1.1 Data sovereignty

The capacity to determine where institutional data is stored, under which jurisdiction it is processed, and which actors — including state actors — can compel its disclosure. Data sovereignty depends on storage location, encryption regime, key custody, and the legal basis under which a provider may transfer data across borders. The Court of Justice of the European Union, in *Schrems II* [6↗], clarified that contractual safeguards alone do not satisfy this dimension when data falls under a third-country regime that authorises disproportionate state access. The European Data Protection Board has since elaborated the conditions under which transfers remain permissible [7↗], conditions that operationalise the data dimension for any university subject to the General Data Protection Regulation (GDPR) [8↗].

The analytical structure of the data dimension transposes across jurisdictions: the questions of *where* data sits, *under which law*, and *accessible to which actors* are universal, even when the binding instruments differ.

3.1.2 Technical sovereignty

The capacity to inspect, modify, repair and extend the components of the infrastructure. Technical sovereignty requires source-code access where applicable, open data formats, documented application programming interfaces, and the absence of binary-only critical paths. A component whose internals the institution cannot examine is, by construction, opaque to its own governance: incidents cannot be analysed beyond the supplier's willingness, regressions cannot be confirmed independently, and the institution's defensive posture is bounded by the supplier's pace.

Technical sovereignty does not require that every component be open source. It requires that the institution can either inspect a component itself or substitute it with another that it can. Replaceability is the operational form of technical sovereignty when inspection is unavailable.

3.1.3 Financial sovereignty

The capacity to predict and contain the cost of operating the infrastructure over time, and to be free of captive escalation. Financial sovereignty is reduced when pricing depends on a single supplier with no realistic substitute, when licence audits create unbounded liability, or when exit costs dominate exit decisions to the point where no exit is ever attempted. It is restored by genuine multi-supplier capability, by predictable cost models with contractual caps, and by exit costs proportionate to the genuine migration work rather than to the supplier's commercial preference.

Financial sovereignty is the dimension most often treated as a secondary concern at procurement and as the primary concern at the next renewal. Treating it as a first-order dimension reverses the order: it is examined before, not after, the technical evaluation.

3.1.4 Operational sovereignty

The capacity to operate the infrastructure with skills available locally or through trusted partners — the institution's own staff, its national research and education network, sector consortia, peer institutions. A component that requires a specific supplier's certified engineers, available only through that supplier, places the institution in operational dependence even when other dimensions are satisfied. Conversely, components built on widely-known standards admit a deep labour market, peer support, and the possibility of mutualised operation across institutions.

Operational sovereignty interacts strongly with financial sovereignty: a high cost of operation may be acceptable when paid to the local labour market, and unacceptable when paid as a captive engagement to the same supplier that holds the licence.

3.1.5 Institutional sovereignty

The capacity to retain authority over the decisions that matter — what to do, when, with whom — without delegating them to a contractual arrangement that displaces them. Institutional sovereignty erodes silently: it is rarely transferred in a single decision but accumulated over many small ones. It manifests as the inability to refuse a roadmap change, to choose a non-default integration, to deviate from a supplier's reference architecture without penalty, or to set internal priorities that the supplier has not anticipated.

Cybersecurity authorities have emphasised the governance dimension of digital risk management as a distinct concern from the technical one — as the European Union Agency for Cybersecurity has done [9↗] — and the applicable cybersecurity regulatory regime commonly codifies this distinction by requiring management bodies to retain accountability for security measures, as the European NIS2 Directive does [10↗]. In a university, institutional sovereignty is the precondition of academic self-government over digital matters.

3.2 Indicators per dimension

Each dimension is grounded in four measurable indicators. The indicators are deliberately conservative: they ask whether a specific capacity *exists*, not whether the institution *exercises it optimally*. The full canonical table is given in Table 3.1.

Table 3.1: The twenty indicators of the sovereignty grid (canonical form). Indicators are ordered by dimension, then by criticality.

Dimension	Indicator	Question (verifiable capacity)
Data	Storage location	Is the storage location of all classes of data documented and contractually fixed?
	Key custody	Are encryption keys for data-at-rest held in custody that the institution controls (BYOK or HYOK)?
	Disclosure regime	Has the disclosure regime applicable to the data been characterised, including cross-border state access?
	Exit-data export	Can data be exported in a documented open format within an agreed time window without supplier cooperation?
Technical	Source visibility	Is the source code (or equivalent specification) available for inspection by the institution or its designated experts?
	Standard interfaces	Does the component speak the relevant interface standards without captive extensions in critical paths?
	Independent build	Can the operational artifact be built by a party other than the supplier from publicly available material?
	Regression auditability	Can a behavioural regression be confirmed independently of supplier diagnostics?
Financial	Cost predictability	Is the multi-year operating cost predictable within a documented envelope?
	Supplier substitutability	Are at least two realistic suppliers available for the same functional role?
	Audit liability	Is the supplier's audit-and-true-up clause bounded in scope and consequence?
	Exit-cost proportionality	Is the contractual exit cost proportionate to the genuine migration work?
Operational	Local skills availability	Are the skills required to operate the component available through the institution, the NREN or peer institutions?
	Labour-market depth	Does the underlying technology admit a labour market broader than the supplier's certified pool?
	Documentation completeness	Is the component documented to a level sufficient for an independent operator to take over?
	Mutualisation feasibility	Can the operational burden be shared with peer institutions through an existing or feasible consortium?
Institutional	Roadmap influence	Can the institution decline a supplier roadmap change without contractual penalty?
	Integration freedom	Can the institution adopt non-default integrations without operational degradation?
	Decision retention	Are the decisions of consequence (data classification, access, retention, incident handling) made by the institution rather than imposed by the supplier?
	Public accountability	Can the institution publicly account for the configuration in place without violating supplier confidentiality clauses?

The indicators are not independent: financial and operational sovereignty in particular tend to interact, since a position of supplier dependence on one dimension typically constrains the institution's ability to recover the other. This is offered as an analytical observation rather than an empirical measurement, and should be tested against the institution's own history. Reporting the dimensions separately preserves analytical clarity, but deliberation should attend to these interactions rather than treat each dimension as fully isolated.

3.3 Scoring guidance

Each indicator is scored on a fixed four-point scale:

0 — Absent
The capacity does not exist. The indicator is unsatisfied; remediation requires a structural change.

1 — Partial
The capacity exists but with significant restrictions (scope, jurisdiction, time window, supplier cooperation required).

2 — Established
The capacity is present in normal operating conditions, documented, and known to the relevant team.

3 — Robust
The capacity has been verified by exercise (a drill, an audit, or a real event) within the last twenty-four months (this Reference adopts twenty-four months by convention, to be aligned with the institution's own audit cadence), beyond which operational drift renders an unverified capacity unreliable.

Half-points are not allowed. When uncertainty exists, the lower score is recorded, with the basis for uncertainty noted.

Aggregation. The grid does *not* produce a single sovereignty score. Each dimension is reported independently. Two practical conventions apply:

- **Per-dimension reporting** — the dimension score is the minimum of its indicator scores. A dimension with a single Absent indicator is reported as Absent regardless of the others. This reflects the fact that a single critical gap defines the institution's exposure on that dimension.
- **Procurement gates** — per workload class, the institution may set lexicographic gates (e.g. *data dimension must be at least Established for sensitive workloads*). Gates are declared in advance, not adjusted to fit the candidate.

Cadence. The grid is exercised at three moments: at procurement (gate decision), at annual operational review (drift detection), and at every renewal (re-qualification). Between these moments, an event-driven re-exercise is triggered by any of: a significant pricing change, a supplier acquisition, a court decision or regulatory change affecting the disclosure regime, a major outage, or a publicly disclosed supplier security incident.

3.4 Worked examples

The three examples below score the same functional layer — identity provision — with three different instantiations. The intent is illustrative, not prescriptive: the same instantiation in a different institution may receive different scores because the verifiable capacities are institution-specific.

3.4.1 Case 1 — Pure-OSS (Keycloak + SCIM + eduGAIN)

A self-hosted Keycloak deployment, integrated with the institution's Single Sign-On (SSO) federation through eduGAIN, with System for Cross-domain Identity Management (SCIM)

provisioning to downstream applications.

Table 3.2: Sovereignty profile of the pure-OSS identity instantiation.

Dimension	Score	Comment
Data	3 Robust	Storage under the institution's own data-custody and sovereignty profile, institutional key custody, no third-country disclosure regime.
Technical	3 Robust	Source open, standards respected, regressions auditable.
Financial	2 Established	Operating cost predictable, no licence; substitutability via Shibboleth or Authentik.
Operational	2 Established	Skills available; NREN community support; no supplier-only certification.
Institutional	3 Robust	Roadmap controlled internally; integration freedom complete.

Profile. Strong on data, technical and institutional; operational and financial dimensions are good but limited by the internal staffing burden. The principal risk is operational fragility if the maintaining team shrinks below critical mass.

3.4.2 Case 2 — Pure commercial (a dominant commercial identity suite, e.g. Microsoft Entra ID, with conditional-access policies)

A managed identity tenancy from a dominant commercial suite vendor, operated by the supplier in a designated in-jurisdiction region and integrated through the institution's existing tenant arrangements.
Configuration assumed. The scoring below reflects the default supported configuration with in-jurisdiction data residency and standard supplier-managed key custody. Optional arrangements such as restricted-access lockbox features, double-key encryption, or Hold Your Own Key (HYOK) integrations would modify the data dimension upward, but at the cost of additional licence and operational commitments; their adoption is itself a sovereignty-affecting choice that an institution should evaluate explicitly.

Table 3.3: Sovereignty profile of the pure-commercial identity instantiation (default configuration, without optional HYOK arrangements).

Dimension	Score	Comment
Data	1 Partial	In-jurisdiction regions designated; key custody bounded; disclosure regime under the applicable cross-border transfer analysis remains contested in the absence of HYOK.
Technical	1 Partial	Standards spoken with captive extensions in conditional-access policy expressions; regressions traceable only via supplier diagnostics.
Financial	1 Partial	Per-seat pricing with documented historical escalation; substitutability constrained by ecosystem coupling.
Operational	3 Robust	Skills market deep; documentation extensive; enterprise support widely available.
Institutional	1 Partial	Roadmap supplier-driven; integration freedom limited to certified partner products.

Profile. Strong only on operational. The pattern is characteristic of mature commercial offerings: the dimensions where the institution's bargaining position is structurally weaker (technical,

financial, institutional) score lower in the default configuration, while the dimension underwritten by a deep labour market (operational) is excellent. Neither asymmetry is intrinsic to commercial supply; both are amenable to contractual remediation when the institution makes them an explicit gate at procurement.

3.4.3 Case 3 — Hybrid (Shibboleth federation + Keycloak local activation)

The existing Shibboleth federation is preserved for inter-institutional authentication; a self-hosted Keycloak instance handles role activation, attribute enrichment and TAC session management locally.

Table 3.4: Sovereignty profile of the hybrid identity instantiation.

Dimension	Score	Comment
Data	3 Robust	Federation metadata public; activation data held locally.
Technical	3 Robust	Both components open; standards respected end-to-end.
Financial	2 Established	Two operating teams (federation, local); cost predictable but doubled.
Operational	2 Established	Two skill sets required; mutualisation feasible through the NREN.
Institutional	3 Robust	Roadmap fully retained; integration freedom complete.

Profile. The hybrid profile illustrates a recurring pattern: better than pure-commercial on every dimension, comparable to pure-OSS on most, with a financial and operational cost premium that reflects the dual stack. The premium is the price of preserving an existing federation investment without surrendering institutional or technical sovereignty.

3.5 Common misuses of the grid

Three anti-patterns recur in practice and each defeats the purpose of the instrument.

Retro-fitting the grid to a pre-decided choice. A procurement decision is taken on other grounds (vendor relationship, ease, urgency) and the grid is then completed to legitimise the choice. The mitigation is procedural: gates are declared before the candidate is scored, not after.

Treating the dimensions as fully independent. The dimensions are orthogonal in the sense that they ask different questions, but their answers correlate. A monopoly position (financial deficit) is almost always accompanied by an inability to refuse roadmap changes (institutional deficit). Treating them as fully independent permits the false comfort of compensating one with the other.

Applying the grid only at procurement. The sovereignty profile drifts across the operational life of a component: tariffs change, suppliers consolidate, regulatory frameworks evolve. A grid applied only at procurement captures the worst predictive moment — the moment of maximum supplier accommodation — and never re-examines the trajectory.

3.6 The grid as a governance instrument

The grid is not solely a technical artifact. It is the connective tissue between four governance practices that are frequently conducted in mutual ignorance.

Procurement.
The grid translates into Request for Proposal (RFP) clauses, contractual exit assistance, and gating thresholds per workload class. It supplies the procurement team with a vocabulary independent of supplier marketing categories.

Internal audit.
The grid provides the structure for an annual review of the institution's sovereignty profile, comparable across components and across years.

Peer-institution benchmarking.
When a network of universities adopts the same grid, the comparison of profiles ceases to be anecdotal. The phase-2 international university network anticipated by this Reference is designed around this premise.

Public accountability.
An institution that publishes its sovereignty profile by component renders its digital strategy legible to its academic community, its students, and the public that funds it. The grid makes this publication concise and comparable.

The grid alone does not produce sovereign infrastructure. It produces the precondition for sovereign infrastructure: a vocabulary shared across procurement, operations, audit and governance, in which sovereignty can be discussed without reduction to ideology and without indefinite deferral.

Chapter 4

Institutional self-assessment

Dependencies

This chapter applies the five-dimension grid and the four-point scoring scale established in Chapter 3 of the Technical Reference (*The sovereignty grid*). Section E (§4.6) presupposes that the reader has completed Chapter 3 of the Technical Reference. The trajectory selection matrix (§4.7) refers forward to Chapter 17 of the Technical Reference (*How to read this playbook*) for the definitions of the three migration trajectories.

The instrument presented in this chapter is a self-administered diagnostic. Its purpose is not to grade an institution against an external benchmark but to make explicit the starting position from which any migration toward the architecture and playbook of this Reference would proceed. An honest self-assessment, conducted by the institution itself with the aid of its own documentation, is more useful than an externally produced report whose assumptions the institution has not internalised.

4.1 Purpose and method

The self-assessment is composed of five sections. Sections A–D are diagnostic: they characterise the institution's current technical maturity along the four planes that the migration playbook will exercise (identity, network, observability, endpoint). Section E is positioning: it applies the sovereignty grid of Chapter 3 of the Technical Reference to the institution as a whole, asking both *where it stands today* and *where it aims to stand*.

Time and team. An indicative envelope for completing the assessment is a single facilitated session of two to three hours within a small cross-functional group — typically one identity engineer, one network engineer, one security or governance representative, and one person familiar with procurement. Institutions will adjust the envelope to their own deliberation cadence; the resulting profile is a working artefact for the institution, not a deliverable for an external party.

Scoring. Each question admits one of four answers, using the same four-point scale as the sovereignty grid: **0 Absent**, **1 Partial**, **2 Established**, **3 Robust**. Half- points are not allowed; when uncertainty exists, the lower score is recorded with a note on the basis for uncertainty. The most useful output is not the aggregate but the distribution: a section in which most answers are 1 or 2 with one outlier 0 reveals more than an average score would.

Honesty discipline. The instrument is only useful if the institution scores itself as it actually is, not as it would prefer to appear. Two practices help: scoring is performed before the trajectory matrix (§4.7) is consulted, so respondents do not calibrate to a preferred outcome; and the basis for each non-zero score is briefly documented (one line) so that the team can revisit its judgement later.

4.2 Section A — Identity and federation maturity

This section diagnoses the maturity of the institution's identity plane — the layer that the first migration wave (Chapter 19 of the Technical Reference (*Wave 1 — Identity and federation*)) will exercise.

A1. Is there a single canonical identity provider for the institution, or multiple competing ones?
A2. Does the institution participate in eduGAIN interfederation service (eduGAIN) (or a regional equivalent) for inter-institutional federation?
A3. Is account lifecycle (creation, role change, departure) automated end-to-end via SCIM or equivalent?
A4. Is Multi-Factor Authentication (MFA) enforced for all staff and student accounts, with documented exceptions?
A5. Are role and group memberships expressed in a single source of truth, or duplicated across systems?
A6. Is the identity provider's source code or licence under institutional control (open source, or contractual right to operate independently)?
A7. Are session lifetimes and elevation policies documented and consistent across applications?
A8. Is there a documented break-glass procedure for emergency access that does not bypass audit?
A9. Is the identity provider's evolution roadmap controlled by the institution, by an external supplier, or by community consensus?
A10. Has the identity provider been independently audited within the last twenty-four months?

4.3 Section B — Network and segmentation maturity

This section diagnoses the maturity of the network plane that Chapter 21 of the Technical Reference (*Wave 3 — Network segmentation*) will exercise.

B1. Are network zones (administrative, research, teaching, Bring Your Own Device (BYOD), Internet of Things (IoT) where applicable, sensitive) declared and documented?
B2. Does each zone have a published security profile (filtering rules, egress policy, audit obligations)?
B3. Is there a Science Demilitarised Zone (Science DMZ) for high-throughput research traffic, or an explicit architectural decision against one?
B4. Is east-west traffic between zones restricted by default, or permitted by default?
B5. Are Network Access Control (NAC) policies enforced at the wired and wireless edge?
B6. Is encryption-in-transit enforced for institutional traffic (Transport Layer Security (TLS)-everywhere posture)?
B7. Are flow records (NetFlow, IPFIX, sFlow) collected and retained for a documented period?
B8. Is there a documented BYOD segregation strategy (separate Virtual Local Area Network (VLAN), captive portal, posture verification)?
B9. Are network device configurations under version control with reviewable history?
B10. Has the segmentation been independently penetration-tested within the last twenty-four months?

4.4 Section C — Observability and audit maturity

This section diagnoses the maturity of the observability plane that Chapter 20 of the Technical Reference (*Wave 2 — Observability baseline*) will exercise and that Chapter 25 of the Technical Reference (*Wave 7 — TAC-aware audit and IR*) will refine.

C1. Is there a central log collection point (Security Information and Event Management (SIEM) or equivalent) covering at least identity, network, and endpoint?
C2. Are log sources catalogued and their criticality documented?
C3. Is log retention specified per data classification and contractually enforceable?

C4. Are detection rules (correlations, alerts) documented and version-controlled?
C5. Is there a continuous monitoring capacity, internal or contracted, with defined response times?
C6. Are incident response runbooks documented and exercised?
C7. Is the SIEM cost predictable (fixed envelope, not per-GB ingestion exposed to volume spikes)?
C8. Are log schemas standardised (OpenTelemetry, CloudEvents, or an institutional canonical schema)?
C9. Has an incident response drill been conducted within the last twenty-four months?
C10. Is there a documented procedure to preserve forensic evidence during an incident?

4.5 Section D — Endpoint management maturity

This section diagnoses the maturity of the endpoint plane that Chapter 24 of the Technical Reference (*Wave 6 — Endpoint and posture*) will exercise.

D1. Is the endpoint estate inventoried and classified (managed, BYOD, IoT)?
D2. Is mobile-device management coverage in place for each managed-endpoint operating system in use?
D3. Are posture verification policies documented and reviewed?
D4. Is patch service-level documented and measured against reality?
D5. Is BYOD acceptable use enforced technically, or relied upon contractually only?
D6. Are administrative privileges on workstations centrally controlled with a documented exception process?
D7. Has the endpoint-management tooling been evaluated against the sovereignty grid (sources, exit assistance, data residency)?
D8. Is there a documented decommissioning procedure (data wipe, account deactivation, return of asset)?

4.6 Section E — Sovereignty positioning

This section applies the sovereignty grid of Chapter 3 of the Technical Reference to the institution as a whole. For each of the five dimensions, two questions are asked: one diagnostic of the current state, one diagnostic of the institution's stated intent. A gap between the two is itself useful information about the maturity of the governance.

E1 — Data sovereignty.
E1.1. Are storage location, key custody, and disclosure regime documented per data class?
E1.2. Is *"data dimension Established or better"* set as a procurement gate for sensitive workloads, in writing?

E2 — Technical sovereignty.
E2.1. Can the institution inspect or independently rebuild every critical component of the infrastructure?
E2.2. Is replaceability written into RFP language as a structural requirement, not as a desirable preference?

E3 — Financial sovereignty.
E3.1. Is multi-year operating cost for the digital infrastructure predictable and capped contractually?
E3.2. Is supplier substitutability evaluated annually as a sovereignty exercise, independent of incident response?

E4 — Operational sovereignty.

E4.1. Are the skills for each critical layer present in the institution or accessible through its national research and education network and peer network?

E4.2. Has mutualisation with peer institutions been considered at planning level for at least one shared operational burden?

E5 — Institutional sovereignty.

E5.1. Can the institution decline a supplier roadmap change without contractual penalty for the current procurement period?

E5.2. Is the institution publishing, or willing to publish, its sovereignty profile by component to its academic community?

4.7 Reading the results: trajectory selection matrix

The matrix in Table 4.1 translates a profile of answers into a recommended dominant migration *trajectory* — greenfield, brownfield single-suite-centric, or brownfield hybrid — and into an indicative *pace* (5-, 7-, or 10-year horizon).

The matrix offers heuristics, not algorithmic decisions: in particular, the trajectory and the pace are typically constrained by factors that the questionnaire does not capture (executive mandate, budget cycle, ongoing transformation programmes). The matrix is the entry into Chapter 17 of the Technical Reference, which develops the trajectory and pace choices in the context of the playbook itself.

Table 4.1: Trajectory and pace heuristics from the self-assessment profile. "A–D maturity" is the dominant trend across the diagnostic sections; "E gap" is the gap between current and intent in Section E; "Section E intent" is the intent score itself.

A–D maturity profile	E intent profile	Recommended trajectory and pace
Mostly 0–1 (low across sections), no dominant supplier yet	Intent ≥ Established on at least three dimensions	**Greenfield**, 5–7 year horizon. Rare; applies to new institutions or to a deliberate from-scratch refoundation.
Mostly 1–2, with a single dominant commercial productivity-and-identity suite across identity, endpoint, and observability (e.g. Microsoft)	Intent ≥ Established on Data and Institutional dimensions	**Brownfield single-suite-centric**, 7–10 year horizon. A common starting point for institutions whose estate is anchored on a single dominant productivity-suite incumbent; the playbook adds an open policy plane and an open observability collector layer in front of the existing incumbent-suite estate.
Mostly 1–2, with mixed Linux / macOS / Windows estates and at least one open-source identity component already in production	Intent ≥ Established on Technical and Institutional dimensions	**Brownfield hybrid**, 5–7 year horizon. Frequent where heterogeneous estates and at least one open-source identity component already coexist; the playbook progressively substitutes proprietary components at renewal moments while preserving the open-source perimeter.
Mostly 2–3 (high maturity across sections)	Intent stable at current level, no significant gap	Selective adoption: the institution may already realise much of the target architecture. The playbook is used as a checklist, not as a roadmap. Pace is set by the renewal cycles of remaining captive components.
Heterogeneous (some 0, some 3, no dominant trend)	Any	**Defer trajectory selection.** The heterogeneity itself is the finding. Wave 0 (Chapter 18 of the Technical Reference) is the appropriate first step: governance and inventory before architectural commitment.

Pace adjustments. The horizons indicated above are adjusted by Section E intent: a high intent score across all dimensions may justify the shorter horizon; a low intent score indicates that the longer horizon is realistic and that the institution should not commit to faster pace at planning time.

Trajectory revision. The trajectory selected at the self-assessment is revised at the close of each wave (Chapter 29 of the Technical Reference (*Reversibility playbook*)). It is normal for an institution to start brownfield single-suite-centric and migrate to brownfield hybrid as the open policy and observability planes mature; it is uncommon, but possible, for a stalled brownfield trajectory to be re-baselined as a greenfield refoundation in a contained perimeter.

4.8 Re-assessment cadence

The self-assessment is not a one-time exercise. Three cadences govern its repetition.

Annual review.

The full questionnaire is re-administered once per year, ideally in the same period as the

institution's operational risk review. Year-on-year drift on a single question is more diagnostic than the absolute score in any one year.

Wave closure.

At the close of each migration wave (Chapter 29 of the Technical Reference), the relevant subset of questions is re-administered. Wave 1 (Identity) re-examines Section A; Wave 3 (Network) re-examines Section B; and so on. The grid questions of Section E are re-administered after every wave.

Event-driven re-exercise.

An unscheduled re-exercise is triggered by any of: a significant pricing change from a component supplier, a supplier acquisition or restructuring, a court decision or regulatory change affecting the disclosure regime, a major outage, or a publicly disclosed supplier security incident.

The cumulative record of self-assessments forms part of the institution's sovereignty governance archive, and is the principal input to the international peer comparison anticipated in phase 2 of the network of universities to which this Reference is addressed.

© SUITOAAD

Part II

Reference Architecture on Open Foundations

Chapter 5

Architectural principles

Dependencies

This chapter rests on the sovereignty grid of Chapter 3 of the Technical Reference — in particular on the technical dimension. It establishes the principles that the layer chapters (Chapters 6–14 of the Technical Reference) will instantiate, and freezes the standards landscape that those chapters reference.

The reference architecture developed in Part II is governed by a small number of principles. They are stated here so that the per-layer chapters need only apply them, and so that any deviation in those chapters is visible against an established baseline.

5.1 Interfaces over products

The normative content of this architecture is the set of interface contracts that connect the layers. The reference instantiations proposed in the per-layer chapters — open-source implementations of identity providers, policy engines, network access servers, cloud infrastructure managers, and telemetry pipelines, among others — are illustrative: they demonstrate that the contracts are realisable on open foundations, not that the institution must adopt these specific products.

Three consequences follow from this primacy:

- **Procurement language** references standards, not products. An RFP that asks for "identity provider compatible with OIDC Core 1.0, SCIM 2.0, and federation metadata in accordance with the applicable research-and-education identity federation technical profile" admits multiple compliant suppliers; an RFP that asks for a named proprietary identity suite with its vendor-specific conditional access feature admits one.
- **Component evaluation** consists in verifying that the standard is spoken correctly, not that the supplier promises a feature. The conformance test suite of Chapter 16 of the Technical Reference (*Conformance and replaceability tests*) operationalises this verification.
- **Architectural decisions** are recorded against the contract, not against the product. A decision to use OIDC for SSO survives the replacement of the identity provider; a decision to use a specific vendor's proprietary conditional access expression `X` does not.

This principle is the operational expression of the technical sovereignty dimension: an institution that controls the contracts controls the architecture, regardless of the suppliers that currently realise those contracts.

5.2 Functional necessity is independent of scale

The interface contracts of §5.1 are not only the normative content of the architecture; they enumerate the *minimal set of functions that any institution offering a digital infrastructure must discharge*, irrespective of its size, budget, or research intensity. The moment an institution

authenticates users, holds personal or sensitive data, attaches devices to a network, and operates services, it has already incurred these functions. The only question is whether it discharges them coherently and sovereignly, or implicitly and dependently.

Several of these functions are legally compelled, without a size threshold. The GDPR [8↗] applies to any institution processing personal data, with no exemption by size; the data-protection, segmentation and audit functions are therefore obligations rather than aspirations at every scale. Where the institution is classified as an essential or important entity, the NIS2 Directive (NIS2) [10↗] obligations apply in addition. The minimal set is thus anchored in binding instruments that do not vary with the size of the institution.

What is size-invariant, and what scales. What does *not* vary with scale is the set of functional contracts and the legally compelled protections above. What *does* scale is the *instantiation* (the specific products that realise a contract), the *sizing* (Chapter 15 of the Technical Reference, given as orders of magnitude for a typical research-intensive institution, with a down-scaled profile in §15.8), and the *optional components* justified only by particular needs — a dedicated Science DMZ, multi-site federation — which a smaller or teaching-led institution may legitimately defer or mutualise. The architecture is the invariant; the realisation is the variable.

Consequence for the "we are not a flagship" objection. The objection that an institution "cannot afford what the leading universities do" misidentifies the commitment. The architecture asks no institution to match a flagship's budget or estate; it observes that the functions are already owed the moment digital services are offered, and provides the minimal coherent and sovereign way to discharge them. The alternative to adopting the architecture is not *not discharging these functions* — it is discharging the same functions incoherently and dependently.

5.3 Replaceability as a first-class property

A component is *replaceable* when it can be substituted by another one speaking the same interface contract, within an agreed time window, with the institution's data and configuration preserved. Replaceability is the property that makes the architecture survive supplier change, regulatory change, and the obsolescence of any particular product.

Four conditions, jointly, define replaceability.

Standard interfaces.
The component speaks the relevant interface standard without captive extensions in the critical path. Optional extensions are admissible if they can be turned off without loss of essential function.

Open state and configuration formats.
The component's operational state and configuration are expressed in formats that can be read and produced by parties other than the supplier.

Documented exit-data export.
A procedure exists to extract the institution's data in a documented open format within an agreed time window, without requiring the supplier's discretionary cooperation.

No hidden dependencies.
The component does not depend on supplier-specific operators, controllers or sidecars whose absence would silently degrade behaviour.

Replaceability is not the same as *having already been replaced*. The conformance suite of Chapter 16 of the Technical Reference includes an *exit rehearsal* category: the institution periodically exercises the replacement procedure on a representative subset, to confirm that the four conditions still hold.

5.4 Standards landscape

Table 5.1 lists the standards on which the reference architecture rests. The list is ordered by layer, then by the criticality of the standard within that layer. It is the canonical reference for Chapters 6–14: any layer chapter that introduces a standard not listed here either introduces a documented exception or extends this table.

Table 5.1: Standards landscape of the reference architecture. Status indicates the maturity of the standard relative to the architecture's expectations: *Stable* (long-established, broadly implemented), *Mature* (established but evolving), *Emerging* (recent, adopted by the architecture as forward-looking).

Layer	Standard	Role in the architecture	Status
Identity	OIDC Core 1.0 [11↗]	Federated authentication, identity assertion	Stable
	SAML 2.0 [12↗]	Federated authentication (legacy compatibility)	Stable
	SCIM 2.0 [13↗, 14↗]	Identity provisioning across systems	Stable
	OAuth 2.1 [15↗]	Authorisation framework underpinning OIDC	Maturing
	OpenID Federation	Trust establishment between federations	Emerging
Policy	OPA REST API [16↗]	Policy decision point query interface	Mature
	Cedar evaluation API [17↗]	Alternative policy decision interface	Emerging
Network	RADIUS [18↗]	Network access authentication and accounting	Stable
	NETCONF [19↗] / YANG [20↗]	Network device configuration and modelling	Stable
	BGP / EVPN	Routing and overlay signalling	Stable
	eBPF / CNI [21↗]	Kubernetes network plugin model	Mature
	IPFIX [22↗]	Flow record export	Stable
Compute	Kubernetes API [23↗]	Container orchestration	Stable
	OpenStack API [24↗]	Infrastructure as a Service	Stable
	OCI image format [25↗]	Container image packaging	Stable
	SLSA [26↗]	Software supply-chain provenance	Mature
Storage	S3 API	Object storage interface (de facto standard)	Stable
	KMIP [27↗]	Key management interoperability	Stable
	NFS v4.1 [28↗]	Network file system	Stable
Endpoint	DDM / DEP	Apple declarative device management	Stable
	MS-MDM	Microsoft device management open specification	Stable
	Declarative Linux config [29↗, 30↗]	Linux endpoint posture and configuration	Mature
Observability	OpenTelemetry [31↗]	Telemetry collection (traces, metrics, logs)	Stable
	CloudEvents [32↗]	Event format for cross-system signalling	Mature
	syslog [33↗]	Legacy log transport	Stable
Crypto	PKCS#11 [34↗]	Hardware security module interface	Stable
	ACME [35↗]	Automated certificate issuance	Stable
	KMIP [27↗]	Key management interoperability (cross-listed)	Stable
	OpenID Federation	Trust hierarchy for federated entities	Emerging
Orchestration	(no single standard — see §5.4 note below)	Cross-layer command issuance after a TAC activation	—

© SUITOPAS

The orchestration gap. The orchestration plane — the "glue" that turns a TAC activation decision into the cross-layer commands that realise it — has no single standard at the time of writing. Several patterns are converging (event-driven workflow engines, declarative reconcilers, GitOps repositories), but no specification consolidates them into a portable interface. This is the architecture's most honest gap; Chapter 14 of the Technical Reference (*The orchestration plane*) discusses how to bound the consequences and how the institution can avoid creating a new captive dependency in this layer.

Standards versus reference profiles. Several standards listed above (OIDC, SAML2, OPA, OpenTelemetry) admit broad configuration latitude. Where the architecture relies on a specific profile of a standard — for instance, the applicable research-and-education identity federation technical profile for SAML2 federation, or the OPA bundle distribution pattern — the profile is named in the relevant layer chapter and treated as a co-normative element.

5.5 Layer decomposition

The nine functional layers of the architecture are organised in three planes that describe what each layer governs.

Subject and trust plane.
Identity (Chapter 6 of the Technical Reference), Endpoint (Chapter 11 of the Technical Reference), Cryptographic services (Chapter 13 of the Technical Reference). These layers together define *who* is acting, *from where*, and *with what cryptographic assurances*.

Execution plane.
Network (Chapter 8 of the Technical Reference), Compute (Chapter 9 of the Technical Reference), Storage (Chapter 10 of the Technical Reference). These layers together define *where* the activity runs and on *which data*.

Control and governance plane.
Policy (Chapter 7 of the Technical Reference), Observability (Chapter 12 of the Technical Reference), Orchestration (Chapter 14 of the Technical Reference). These layers together define *how* decisions are made, recorded, and executed across the other planes.

The dependency structure has two regular features. First, the subject and trust plane is read by the control plane (Identity attributes parameterise Policy decisions; Endpoint posture conditions Policy and Network attachment; Crypto underpins all assertions). Second, the control plane writes to the execution plane (Policy decisions are enforced at Network, Compute, and Storage; Orchestration realises them across the three; Observability collects evidence of all crossings). The reference architecture is the realisation of these two flows.

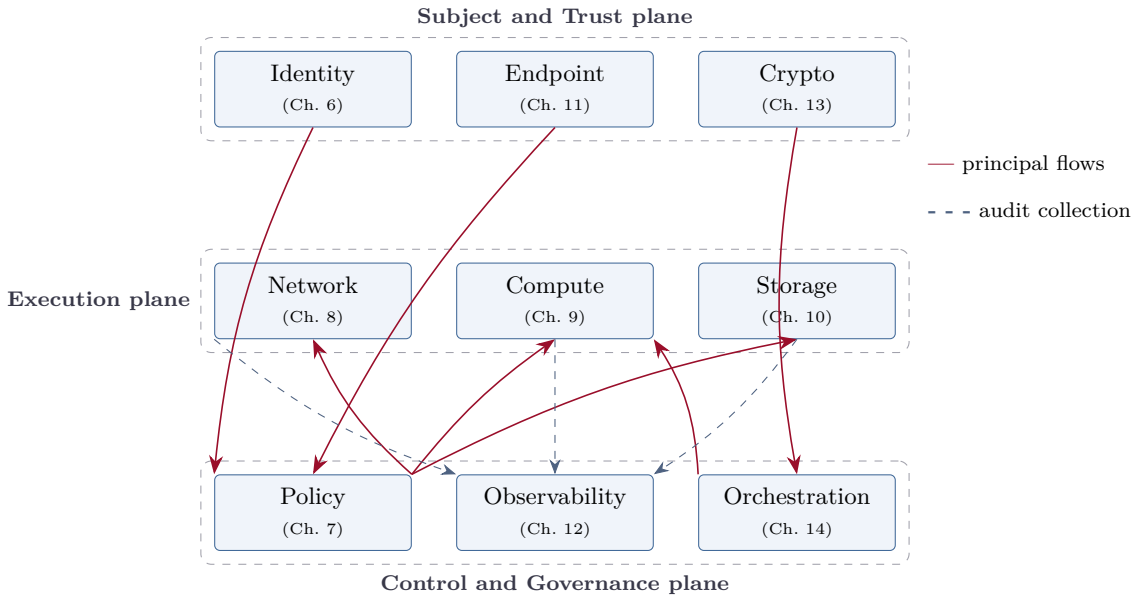


Figure 5.1: Layer decomposition of the reference architecture: nine functional layers organised in three planes. The principal dependency flows (Crimson) are: Subject and Trust feeds the Control plane; the Control plane writes to the Execution plane. Observability (dashed) collects events from every layer.

5.6 What this reference architecture is and is not

The clarity of subsequent chapters depends on a shared understanding of what this architecture commits to and what it does not.

It is. A contract-driven architecture, organised in nine layers and three planes, whose realisability is demonstrated on open foundations and which integrates proprietary components that respect the contracts. Its normative content is the standards landscape of §5.4 and the four conditions of replaceability of §5.3.

It is not. A product recommendation: the per-layer chapters present reference instantiations and alternatives, but the choice belongs to the institution and is informed by the sovereignty grid (Chapter 3 of the Technical Reference), not by this Reference. Nor is it a deployment specification: sizing (Chapter 15 of the Technical Reference) is given as orders of magnitude for a typical research-intensive institution. Nor is it a security certification: the conformance suite (Chapter 16 of the Technical Reference) verifies interface fidelity and replaceability, not absence of vulnerability.

Why the boundary matters for international generalisation. The architecture is designed to transpose across institutions and jurisdictions because its commitments are at the level of contracts and properties, not at the level of products and configurations. An institution in a different regulatory context, or with a different existing estate, instantiates the same contracts with different products without leaving the architecture. This is the condition under which the network of universities anticipated in phase 2 can share an architectural baseline despite operating in very different conditions.

Chapter 6

Identity and subject trust

Dependencies

This chapter applies the architectural principles of Chapter 5 of the Technical Reference to the identity layer. It references the standards table of §5.3 and the four conditions of replaceability of §5.2. The sovereignty profiles given in §6.5 are consistent with the worked examples of Chapter 3 of the Technical Reference (Cases 1–3). The layer belongs to the *Subject and trust plane*.

The identity layer answers the first question of any access decision: *who is acting, with what attributes, and under what session guarantees*. It is the layer on which Policy (Chapter 7 of the Technical Reference), Endpoint (Chapter 11 of the Technical Reference) and Cryptographic services (Chapter 13 of the Technical Reference) all rely; a deficiency here propagates to the entire control plane.

6.1 Functional role and interface contract

The identity layer is responsible for: authenticating subjects (human and non-human); maintaining the canonical attributes attached to each subject (affiliation, role, group, posture claim); issuing short-lived assertions that downstream layers can verify; and, where such arrangements are available and relevant to the institution, participating in federation arrangements that allow it to delegate authentication to peer institutions and accept their delegated authentications in return.

Interface contract — Identity layer

A compliant identity provider, in the sense of this architecture, must:

- issue authentication assertions over OIDC Core 1.0 [11↗] *or* SAML 2.0 [12↗] (legacy compatibility), without captive extensions in the assertion path;
- accept and emit identity provisioning over SCIM 2.0 [13↗, 14↗];
- be capable of publishing federation metadata interoperable with the academic identity interfederation, and do so where the institution participates in inter-institutional federation;
- express attributes in a documented schema, with an attribute-release policy reviewable by the institution;
- support the addition of a multi-factor authentication step that the institution can configure without supplier intervention;
- produce an authentication and assertion log in a form ingestible by the observability layer (Chapter 12 of the Technical Reference).

The contract is deliberately silent on *which* attribute schema is used, on *which* MFA factor is enforced, and on *which* research-and-education identity federation profile the institution participates in. These are matters of institutional context; the contract requires only that the

answers be documented and that the underlying mechanism be standards-based. An institution with no national research-and-education identity federation available satisfies the contract by retaining the capability to publish interoperable metadata and deferring actual participation until it joins one — the standards basis is required at all scales, the federation membership only where it exists.

6.2 Reference instantiation: open-source IdP + SCIM + research-and-education federation

The reference instantiation comprises a self-hosted open-source identity-provider deployment — Keycloak [36↗] is one mature representative — a SCIM provisioning bus, and participation in the academic identity interfederation [37↗] through its national research-and-education federation operator.

Reference instantiation — Identity layer

Topology. An open-source identity-provider realm (here illustrated with Keycloak [36↗]) hosts the institutional subject base; a SAML2 metadata feed integrates with the national research-and-education federation, which is itself a member of the wider interfederation [37↗]; SCIM 2.0 provisioning synchronises authoritative subject attributes into the identity provider from the institution's source-of-truth (typically the human resources system for staff and the student information system for students); OIDC and SAML2 are exposed to applications, with OIDC preferred for modern integrations. Authentication and assertion logs are forwarded in OpenTelemetry format to the observability layer.

Operational considerations. The reference instantiation is expected to sustain the identity needs of a research-intensive institution within a small operating team sized to the institution's own staffing profile — provided that the lifecycle automation (SCIM upstream and downstream) is robust. Actual envelopes vary with the application portfolio and the federation participation. The principal recurring effort is the maintenance of attribute-release policies as new applications join the federation; this effort scales with application count, not user count.

Federation profile. The applicable research-and-education federation's technical profile of SAML2 is co-normative with the standard itself: the institution must publish metadata signed by its national research-and-education federation operator, must commit to attribute release commitments encoded in the federation's policy framework, and must respond to deprecation cycles (typically multi-year) for cryptographic algorithms.

Real-world reference — CERN SSO

CERN operates a Keycloak-based federated SSO [38↗] serving its research community and a wide set of collaborating institutions. Aspects of the architecture have been presented in the GÉANT community and illustrate how a research-intensive institution may sustain a fully open identity plane without sacrificing operational depth. The CERN experience also illustrates a recurring pattern: the migration to Keycloak from the prior bespoke system was reported not as a single-step replacement but as a multi-year coexistence during which both stacks remained authoritative for distinct application sets. Specific scale figures and migration durations should be confirmed against current public CERN documentation before being cited in derivative work.

6.3 Alternative 1 — Incumbent commercial identity suite with conditional-access policy

Alternative — Incumbent commercial identity suite

A tenancy of a pure-commercial identity provider [39↗], operated by the supplier in a designated EU (or analogous regional) region, integrated through the institution's existing tenant arrangements, with the vendor's conditional-access policy engine expressing the role-activation rules. Authentication is exposed to applications via OIDC and SAML2; provisioning is exposed via SCIM 2.0; logs are forwarded to the observability layer through the vendor's management API or via the OpenTelemetry collectors of Chapter 12 of the Technical Reference.

Where it adds value. The operational dimension benefits from a deep and broadly available skills market, extensive documentation, and integration with an incumbent office-and-collaboration suite, where one is already dominant in the institution. The cost of activation, in operational time, is lower than for a self-hosted solution.

Where it constrains the institution. Three constraints recur. First, the vendor's conditional-access expressions, while powerful, are not portable: an authorisation logic encoded in that vendor-specific policy language does not transfer to another identity provider without rewriting. Second, several capabilities of operational interest (privileged-access management, verifiable-credential issuance, advanced risk analytics) are gated behind specific licences and may shift between licence tiers across renewals. Third, the assertion and provisioning paths admit optional extensions whose use would silently couple the institution to the supplier; an architecture-aware deployment pins the configuration to the standard interface and forgoes those extensions in critical paths.

When it is the right choice. An institution with a mature deployment of an incumbent office-and-collaboration suite, limited identity-engineering capacity, and a sovereignty position that accepts a Partial score on data, technical and institutional dimensions in exchange for a Robust score on operational. The choice is consistent with this architecture *provided* that the OIDC, SAML2, and SCIM interfaces are pinned to the standard and that an exit-data export procedure is documented and rehearsed.

6.4 Alternative 2 — Hybrid (open-source federation engine + open-source local activation)

Alternative — Hybrid identity

An institution that already operates a mature open-source federation engine — Shibboleth [40↗] is a common representative — preserves it for inter-institutional authentication (facing the research-and-education federation), and adds a self-hosted open-source activation identity provider that handles *local activation*: role enrichment, TAC session issuance, attribute mapping toward downstream applications, and short-lived OIDC token emission. The two components communicate through standard SAML2 / OIDC bridges; neither is captive to the other.

Why this pattern works. It separates two concerns that have different lifetimes and different governance bodies. Federation is long-lived, governed by inter-institutional agreements, and benefits from the stability of a mature open-source federation engine. Activation is short-lived, local, and benefits from the policy expressiveness and modern extensibility of an open-source

activation identity provider. Each component speaks the standards of §5.3; the bridge between them is the authentication context emitted by the federation engine and consumed by the activation provider.

Operational implications. The hybrid pattern carries a modest operational premium over a single-component instantiation, sized to the institution's staffing profile and divided across two skill sets (federation-engine and activation-provider operators). It is offset by the preservation of the existing federation investment and by the avoidance of a high-risk single migration.

When it is the right choice. An institution with a significant existing investment in an open-source federation engine, a research-intensive profile that already values open-source identity, and a pace constraint that does not permit a wholesale migration in the immediate term. The pattern is also a stable end-state, not only a transition.

6.5 Sovereignty grid applied

The three instantiations above were profiled in Chapter 3 of the Technical Reference (Cases 1–3) and the scores are reproduced here for the layer chapter, with brief commentary at the indicator level.

Table 6.1: Per-dimension sovereignty profile of the three identity instantiations. Scores are consistent with Chapter 3 of the Technical Reference §3.4.

Dimension	Pure OSS	Commercial suite (default)	Hybrid	Driving indicators
Data	3 Robust	1 Partial	3 Robust	Storage location, key custody, disclosure regime
Technical	3 Robust	1 Partial	3 Robust	Source visibility, standard interfaces, regression auditability
Financial	2 Established	1 Partial	2 Established	Cost predictability, supplier substitutability
Operational	2 Established	3 Robust	2 Established	Local skills availability, labour-market depth
Institutional	3 Robust	1 Partial	3 Robust	Roadmap influence, integration freedom

The principal sovereignty trade-off in the identity layer is between the operational depth of the commercial alternative and the technical / institutional / data sovereignty of the open alternatives. The hybrid pattern recovers most of the open-side profile while modestly increasing the operational footprint over a single-component instantiation, by an increment sized to the institution's own staffing profile.

6.6 Regulatory anchoring

The identity layer is the primary technical anchor of the access-control security obligations of the applicable data-protection regime (e.g. GDPR Art. 32(1)(b)) and of several measures of the applicable cybersecurity baseline regime (e.g. NIS2 Art. 21(2)): (i) human-resources security and access control, (j) multi-factor authentication and secured communications. Joiner / mover / leaver via SCIM operationalises 27001 A.5.16, A.6.5 and A.8.2; the OIDC / SAML2 federation pattern operationalises eIDAS 2 trust services and notified-eID interoperability; the MFA / FIDO2 baseline operationalises 27001 A.8.5. The layer contributes to the NIST CSF PROTECT function (PR.AA — identity management, authentication and access control). Detailed mapping in Chapter 33 of the Technical Reference §33.5, §33.6, §33.10, §33.11, §33.9.

6.7 Common pitfalls

Common pitfall — Captive attribute extensions

Encoding authorisation logic in supplier-specific attribute expressions (vendor conditional-access expressions, vendor-defined claims) turns the identity provider into a captive policy engine. The mitigation is to keep authorisation in the policy layer (Chapter 7 of the Technical Reference) and to use the identity layer only for authentication and attribute carriage, against the standard schema.

Common pitfall — Broken metadata refresh

Federation metadata expires, is rotated, and is signed by keys that themselves rotate. Institutions whose metadata refresh pipeline is undocumented or manually triggered lose federation participation silently — typically discovered during a partner authentication outage. The mitigation is to automate metadata refresh, monitor freshness through the observability layer, and include a metadata-currency check in the conformance suite of Chapter 16 of the Technical Reference.

Common pitfall — Opaque multi-factor risk decisions

Some commercial identity providers couple MFA to a proprietary risk score whose inputs and weights are not disclosed. The institution then cannot explain to its own users why a session was challenged, nor reproduce the decision for audit. The mitigation is to either use a transparent MFA factor (TOTP, FIDO2 with documented attestation handling) or, if a risk-based factor is used, to ensure that the decision is logged with sufficient detail for explanation.

Common pitfall — Attribute-release drift

The set of attributes released to each application tends to grow over time, and to lose alignment with what the application actually requires. This is both a data-minimisation issue under the applicable data-protection regime and a sovereignty issue, since unnecessary releases multiply the dependencies that an exit must address. The mitigation is an annual review of the attribute-release policy by application, recorded in the institution's data-protection register.

Chapter 7

Policy decision and enforcement

Dependencies

This chapter applies the layer template of Chapter 6 of the Technical Reference to the policy layer. It consumes identity attributes from Chapter 6 of the Technical Reference and emits decisions consumed by Network (Chapter 8 of the Technical Reference), Compute (Chapter 9 of the Technical Reference), Storage (Chapter 10 of the Technical Reference) and Endpoint (Chapter 11 of the Technical Reference). The decision log produced by this layer is consumed by Observability (Chapter 12 of the Technical Reference). The layer belongs to the *Control and governance plane*.

The policy layer answers the second question of any access decision, once the identity layer has answered the first: *given who is acting, with which attributes and from which posture, what is permitted?*. It is the layer that translates institutional rules — data classification, role-activation gating, time-of-day or location-of-access conditions, posture requirements — into machine-readable decisions consumed by the execution plane. It is also, for many adopters at the time of writing — particularly those without a dedicated platform-engineering function — the most ambitious novelty in this architecture: relatively few institutions today operate a dedicated policy decision point separate from their applications and identity provider. Adopting one is a real organisational change, addressed in Chapter 22 of the Technical Reference (*Wave 4 — Policy plane*).

7.1 Functional role and interface contract

The policy layer is responsible for: receiving a decision request that combines a subject (with attributes and posture claims), a resource (with classification and ownership), and an environment (with time, location, and contextual signals); evaluating that request against the institution's policy corpus; and returning a structured decision that downstream enforcement points consume. It is also responsible for emitting an audit-grade decision log that makes every consequential decision reconstructable.

Interface contract — Policy layer

A compliant policy decision point, in the sense of this architecture, must:

- expose a query API, either OPA REST or Cedar evaluation API, receiving a JSON-structured request and returning a JSON-structured decision;
- evaluate against a policy corpus expressed in a high-level language with formal evaluation semantics (Rego, Cedar);
- support a documented *bundle distribution* pattern by which policies are versioned, signed, and pushed to the decision point without redeployment;
- return decisions of the form `{allow, deny, indeterminate}` accompanied by struc-

tured *obligations* (e.g. session timeout, audit class, additional factor required) that the enforcement point applies;
- produce a decision log that includes the inputs, the policy version, the decision and the obligations, in a form ingestible by the observability layer;
- support a *shadow mode* in which the decision is logged but not enforced, used during introduction or after a policy change.

The contract is silent on the policy authoring workflow (who writes policies, how they are reviewed, how they are deployed) and on the mapping of institutional rules to the policy language. These are governance choices addressed in Chapter 22 of the Technical Reference; the contract requires only that the chosen workflow respect the versioning and the audit-trail properties.

7.2 Reference instantiation: OPA + bundle server + decision log to SIEM

The reference instantiation comprises an Open Policy Agent (OPA) [16↗] deployment as the decision point, a bundle server as the policy distribution mechanism, and a decision-log forwarder that delivers every decision to the observability pipeline.

Reference instantiation — Policy layer

Topology. OPA runs as a sidecar or as a centralised service depending on latency requirements; policies are authored in Rego and stored in a Git repository under standard code review; *bundles* (signed archives of compiled policies and data) are built by continuous integration and served by a bundle server, from which OPA instances pull at a configurable interval; decision logs are emitted in OpenTelemetry format and routed to the observability layer (Chapter 12 of the Technical Reference). The bundle distribution pattern is co-normative with OPA REST itself: it is the mechanism that turns a runtime decision point into a governable artefact.

Authoring workflow. Policies are authored in Rego in a Git repository under code review. Each merge produces a versioned bundle, signed by the build system, served by the bundle server. Open Policy Agent (OPA) instances pull the bundle and reload without restart. The review workflow is the institutional governance mechanism for the policy corpus; the bundle distribution is the technical mechanism that propagates the result.

Operational considerations. The reference instantiation is expected to require expertise in Rego (or in the Cedar alternative, see below), which is a domain-specific language whose learning curve is typically reported in weeks rather than days. The principal recurring effort is policy testing: each policy is unit-tested against representative request patterns, and the test suite is maintained alongside the policy corpus. The operational team would typically be small — indicatively a fraction of the institution's platform-engineering staffing profile, shared across other duties — but the institutional skill investment remains significant.

Decision log schema. The schema includes, at minimum: the request inputs (subject identifier, resource identifier, environment signals), the policy version, the decision verdict, the obligations, the evaluation duration, and a correlation identifier that ties the decision to the activity context. The canonical schema is consolidated in Chapter 12 of the Technical Reference §12.3; the policy layer is its principal producer.

Real-world reference — Policy plane in academic and research settings

The policy plane in academia is more thinly documented in policy-as-code terms than the identity plane. Authorisation patterns relevant to research collaborations are developed in GÉANT's eduTEAMS [41↗] service, which implements the AARC Blueprint Architecture [42↗] — a sector-specific design pattern for authentication and authorisation in international research collaborations. The AARC Blueprint and policy-as-code engines such as OPA address overlapping concerns at different levels: the former is a sector-specific architecture, the latter a general decision engine; their combination remains a relatively open area for academic deployments. Industrial OPA deployments publicly described by large-scale technology and financial-services organisations demonstrate the engine at scale; their transposition to academic settings is conditional on the institution's authorisation profile. The phase-2 international university network anticipated by this Reference would be one of the contexts in which a shared library of academic-context policies might emerge.

7.3 Alternative 1 — Cedar with the Verified Permissions pattern

Alternative — Cedar evaluation engine

Cedar [17↗] is an open-source policy language, developed by AWS and released as open source, designed for static verifiability. It admits a formal semantics that supports automated checks (for example, that no policy in the corpus grants a forbidden action under any input). Cedar is integrated either standalone or as part of the AWS Verified Permissions service; the architecture relies on Cedar itself, not on the AWS hosted variant, to preserve the technical sovereignty dimension.

Where it adds value. Cedar's formal semantics make the policy corpus more readable than Rego in many cases, and they admit verification techniques (consistency, no-bypass) that Rego does not. For institutions whose risk posture demands a higher assurance on the policy corpus itself, Cedar is the appropriate choice.

Where it constrains the institution. The Cedar ecosystem is younger than the OPA ecosystem; integrations with specific enforcement points (network attachment, Kubernetes admission, application middlewares) are fewer and less mature. The institutional skill investment is comparable to Rego, but the labour market is shallower at the time of writing.

When it is the right choice. An institution with a strong formal-methods culture, with a policy corpus large enough to benefit from verifiability, and with the resources to bridge gaps in the Cedar ecosystem with internal engineering. Cedar is also a reasonable choice for an institution that wants to avoid OPA's specific operational patterns (sidecar density, bundle refresh) and prefers a request-response engine.

7.4 Alternative 2 — Native identity-provider authorisation rules

Alternative — Native IdP authorisation

The institution does not introduce a separate policy decision point. Authorisation rules are expressed in the identity provider's own configuration: conditional-access expressions for the institution's incumbent proprietary identity suite, authorisation policies and scopes for Keycloak. The identity layer is also the policy layer.

Where it works. For institutions whose authorisation needs are limited to coarse-grained role gating, MFA enforcement and basic time-of-day or location conditions, the identity provider's native rules are sufficient. The reduction in moving parts is real, and the operational burden is lower.

Where it fails. TAC-aware decisions require composing multiple signals — subject attributes, posture, resource classification, time, location, environment — in expressions whose complexity quickly exceeds what a proprietary conditional-access language accommodates without becoming unmaintainable. More fundamentally, encoding the policy corpus in the identity provider couples it to that provider: an exit from the identity provider becomes an exit from the policy plane as well. Native authorisation is a viable *starting* configuration but a poor *end-state* for an institution whose sovereignty posture aims at separation of concerns.

When it is acceptable. As an early stage of the migration, before the policy plane is mature enough to take over; or as a permanent solution for institutions whose authorisation needs do not justify the cost of a separate policy layer.

7.5 Sovereignty grid applied

The three instantiations are profiled below using the grid of Chapter 3 of the Technical Reference. The scores are specific to the policy layer and are introduced in this chapter; they were not worked through in Chapter 3 of the Technical Reference.

Table 7.1: Per-dimension sovereignty profile of the three policy instantiations.

Dimension	OPA + bundle	Cedar	Native IdP authz
Data	3 Robust	3 Robust	1–2 (per IdP)
Technical	3 Robust	3 Robust	1 Partial
Financial	3 Robust	3 Robust	inherits IdP
Operational	2 Established	1–2 Partial	3 Robust
Institutional	3 Robust	3 Robust	1 Partial

OPA and Cedar score similarly on the four sovereignty dimensions other than operational, where the OPA labour market is deeper. The native IdP path inherits the IdP's profile on most dimensions and is consequently bounded by it: this is a structural property of co-locating identity and policy, not a fixable gap. A shift from native IdP authorisation to a separate policy plane (OPA or Cedar) is consequently the highest-leverage sovereignty move available in the control plane.

7.6 Regulatory anchoring

The policy layer is the per-request decision point that operationalises the applicable data-protection regime's data-protection-by-design obligation and contributes to its access-control-effectiveness obligation. Under the applicable cybersecurity-baseline regime — its risk-analysis and information-system security-policy requirement and its access-control-policy requirement — it is the locus where the institutional risk posture is enforced uniformly. Under the applicable AI regulation, its prohibited-practices and transparency provisions admit a policy-plane enforcement: rules that gate AI-related TACs on context labelling and on prohibited-use classification. The layer operationalises 27001 A.5.15 (access control), A.5.18 (access rights) and A.8.3 (information access restriction) and contributes to NIST CSF PROTECT (PR.AA). Detailed mapping in Chapter 33 of the Technical Reference §33.5, §33.6, §33.7, §33.11.

7.7 Common pitfalls

Common pitfall — Policy explosion

A policy corpus left ungoverned grows by accretion: every new application adds rules, no rules are retired, and the corpus loses the structure that makes it auditable. The mitigation is a governance process for the corpus that mirrors the governance process for application code: review, versioning, retirement, and a pre-merge consistency check that the new rule does not conflict with an existing one. Policy languages with formal semantics (Cedar in particular) support automated consistency checks; OPA admits the same through unit tests against representative inputs.

Common pitfall — Missing shadow mode

A policy change deployed directly in enforcing mode without a shadow-mode period silently denies legitimate access until the affected users open tickets. The mitigation is to make shadow mode the default for any new policy and any modification to an existing policy: the decision is logged, compared against the incumbent rule, and switched to enforcing only when the discrepancy profile is understood. The shadow / enforcing toggle is part of the contract of §7.1.

Common pitfall — Decision/log drift

The decision log is intended to allow reconstruction of any consequential decision, but a poorly-implemented log records a summary that does not allow reconstruction (e.g. the obligations are elided, the policy version is not recorded). The mitigation is to exercise the reconstruction in the conformance suite of Chapter 16 of the Technical Reference: take a decision from the log and replay it against the recorded policy version; the result must match.

Common pitfall — Hidden coupling to identity-provider attributes

Policies that reference identity-provider-specific attributes (e.g. vendor-specific extension claims from a proprietary identity suite) lose portability when the identity provider is replaced. The mitigation is to map the identity-provider attributes to a stable institutional schema before they reach the policy plane, and to author policies against the institutional schema only. The mapping is itself part of the contract between Identity and Policy.

Common pitfall — Over-centralisation of policy authoring

A central policy team that becomes the bottleneck for every application's authorisation rules slows the institution to a halt and accumulates a corpus that the team alone understands. The mitigation is to delegate authoring rights with code review: application owners propose policies for their resources; the central team reviews for consistency and conflicts. The model mirrors the federated-governance delegation pattern common in mature higher-education and research IT organisations.

Chapter 8

Network and segmentation

Dependencies

This chapter applies the layer template of Chapter 6 of the Technical Reference to the network layer. It consumes policy decisions from Chapter 7 of the Technical Reference (in particular for attachment authorisation and east-west allowance), it produces flow records consumed by Chapter 12 of the Technical Reference, and it relies on standards from §5.3. The layer belongs to the *Execution plane*.

The network layer answers a question that is operationally simple and architecturally consequential: *which traffic is permitted between which parties*. It is the first layer in which the institution's sovereignty posture meets its physical infrastructure — cables, fibres, switches, wireless access points — and the layer in which the longest-lived investments tend to reside. A sovereignty analysis that succeeds at the identity and policy planes but fails at the network plane has accomplished little of value.

8.1 Functional role and interface contract

The network layer is responsible for: declaring and operating zones with documented security profiles; authenticating and attaching subjects to the appropriate zone on the basis of identity and posture; enforcing east-west and north-south traffic rules returned by the policy layer; emitting flow telemetry of sufficient fidelity for the observability layer to support audit and incident response; and providing, where the institution's research mission requires unobstructed high-throughput data movement, a research-data path that the general stateful-filtering perimeter would otherwise penalise — realised, according to the institution's connectivity, as a Science DMZ, a dedicated circuit or overlay operated by the institution's NREN, or a tuned Data-Transfer-Node fabric [43↗].

Interface contract — Network layer

A compliant network layer, in the sense of this architecture, must:

- declare a zone catalogue with, for each zone, a published security profile (filtering rules, egress policy, audit obligations, posture requirements);
- authenticate and attach subjects via RADIUS [18↗] using attributes that carry, at minimum, the role activated and the assigned zone;
- configure devices through NETCONF [19↗] / YANG [20↗] *or* an equivalent declarative interface, without dependence on proprietary command-line interfaces in critical paths;
- exchange routing information through standard protocols (BGP, EVPN where applicable);
- emit flow records in IPFIX [22↗] format with sufficient fields for the observability layer to perform correlation;
- express east-west and north-south traffic rules in a form that can be reviewed, version-

controlled, and reconciled against the decisions emitted by Chapter 7 of the Technical Reference;
- provide (or document an architectural decision against) a high-throughput research-data path not penalised by the general stateful-filtering perimeter — a Science DMZ, a dedicated circuit or lightpath operated by the institution's NREN, a dedicated overlay (research-community L3VPN) connection, or a tuned Data-Transfer-Node fabric [43↗] — kept identity- and posture-attached, IDS-monitored, policy-governed and flow-mirrored to observability (the stateful firewall is bypassed, not the trust model).

The contract is silent on the physical topology, on the choice of overlay technology, and on the specific zones declared — which depend on the institution's mix of administration, teaching, research, and shared services. The contract requires that whatever choices are made be documented, governed by the policy layer, and visible to the observability layer.

8.2 Reference instantiation: VLAN/VRF + FreeRADIUS + Open vSwitch + Science DMZ

The reference instantiation combines three patterns of differing maturity: a classical VLAN / VRF physical segmentation; a FreeRADIUS attachment service driven by the institution's identity and policy layers; an Open vSwitch overlay for the cases where physical segmentation alone is insufficient; and a Science DMZ for the research data flows that the enterprise filtering perimeter would otherwise penalise.

Reference instantiation — Network layer

Topology. The campus fabric is partitioned at layer 2 into VLANs per zone (administration, teaching, research, BYOD, IoT, sensitive, management, Science DMZ); routing between zones is held in layer-3 *virtual routing and forwarding* (VRF) instances with explicit transit rules. Wired and wireless attachment is authenticated by FreeRADIUS [44↗], which receives attributes from the identity provider (Chapter 6 of the Technical Reference) and queries the policy layer (Chapter 7 of the Technical Reference) to determine the attachment zone and per-subject allowances. Where micro-segmentation within a zone is required (for example, between research projects sharing a single VLAN), Open vSwitch [45↗] flows are programmed by an SDN controller from policy-layer outputs. The Science DMZ is a dedicated subnet bypassing the enterprise filtering perimeter, protected by IDS and access-control lists rather than by stateful firewalling; flows are mirrored to the observability layer.

Research-network-operated realisations. The same function is realised at national and global scale through research-network- and experiment-operated dedicated paths rather than a campus-perimeter enclave: the regional and national NRENs provide dedicated circuits and lightpaths, and large research collaborations operate dedicated optical private networks and L3VPN overlays [46↗, 47↗] — a dedicated, segmented research-data fabric connecting the originating facility and its distributed data tiers. The performance-measurement component, perfSONAR [48↗], is co-maintained by the major NRENs and is common to all of these realisations. The contract of §8.1 is satisfied by any of them; the Science DMZ is the open campus-scale reference, not the only form.

Zone catalogue. The reference catalogue, adapted from established practice in research-intensive institutions, includes the zones in Table 8.1. The catalogue is illustrative; each institution declares its own. The contractual obligation is that the catalogue exist in writing and that each zone have a documented security profile.

Table 8.1: Reference zone catalogue (illustrative). Each row in an institutional catalogue is owned by a named accountable team.

Zone	Security profile (illustrative)
Administration	Stateful filtering, MFA-required for access, restricted egress, full audit.
Teaching	Stateful filtering, role-based access, broad egress, standard audit.
Research (general)	Stateful filtering, role-and-project based access, project-scoped egress, audit by project.
Research (high-throughput data path; e.g. Science DMZ)	ACL-based filtering only, IDS, dedicated IPv4/IPv6 prefixes, perfSONAR measurement, egress by IP prefix.
BYOD	Captive portal with NAC posture verification, Internet egress only, isolated from internal zones.
IoT	Network-only egress to documented destinations, no internal east-west, periodic posture re-attestation.
Sensitive	Stricter than Administration; key custody and disclosure regime documented; no direct Internet egress.
Management	Reachable only from administrative jump hosts; audited at every connection.

Operational considerations. The reference instantiation is the most demanding of the layer chapters in terms of skills: it would typically require network engineering (VLAN, VRF, BGP), Linux administration (FreeRADIUS, OvS), and a working command of the policy layer (Chapter 7 of the Technical Reference). For a research-intensive institution, a small team of engineers shared with adjacent duties is an indicative envelope; actual figures vary with the campus footprint and the research-network mission. The labour market is deep at the level of standard protocols and narrower at the level of integrating them into a TAC-aware attachment service.

Real-world reference — Science DMZ adoption at scale

The Science DMZ pattern was developed within the high-performance research-networking community and is the subject of detailed public documentation. The pattern has been implemented at a number of research-intensive universities and at large-facility experimental boundaries. Large university networks would typically operate multi-zone architectures with explicit security profiles per zone, using a combination of proprietary and open components — the brownfield hybrid pattern that this Reference's playbook anticipates. Specific zoning details and current deployment status of any named institution should be verified against current public documentation before being cited.

Real-world reference — Experiment-operated optical private networks and research backbones

At national and global scale the same need is met by research-network- and experiment-operated dedicated networks rather than by a campus enclave. A large-collaboration optical private network (originating facility to the principal data tiers) and a companion L3VPN overlay (any-to-any between the data tiers) [46↗, 47↗] carry experiment data on a dedicated, segmented fabric; the regional and national NRENs [49↗] provide the backbone and dedicated-circuit services on which member networks build, and research-network testbed work on Data Transfer Nodes [43↗] addresses the same high-throughput transfer problem at the host level. These realise the same contract function as the Science DMZ, organised as a managed dedicated network rather than a perimeter-bypass subnet.

8.3 Alternative 1 — Proprietary macro-segmentation speaking standards

Alternative — Proprietary macro-segmentation

The campus fabric is built on Cisco, Juniper, Aruba, or Arista equipment, configured through standard protocols (RADIUS for attachment, NETCONF/YANG for configuration, BGP/EVPN for routing). The institution retains the contracts of §8.1 while using established commercial gear.

Where it adds value. The skills market is the deepest of all network alternatives; the gear is mature and well supported; integration with existing operational tooling (monitoring, asset management, change management) is direct.

Where it constrains the institution. Two recurring constraints. First, the supplier's management consoles often expose features that the standard interfaces do not: an institution that adopts the management console for non-trivial operations couples itself to the supplier even though the underlying configuration is notionally NETCONF-based. Second, premium features (behavioural analytics, advanced segmentation, integrated identity) are licensed separately and shift between licence tiers across renewals; their adoption in critical paths erodes replaceability.

When it is the right choice. Most institutions, in practice, will operate the network on commercial gear for at least the medium term. The architectural commitment is not to refuse proprietary equipment but to keep it on the standard side of its interfaces, treat its management consoles as advisory, and use only features that the institution can also obtain from at least one other supplier.

8.4 Alternative 2 — Micro-segmentation overlay

Alternative — Micro-segmentation overlay

Segmentation is implemented as a software overlay independent of the underlying physical fabric: VMware NSX, Illumio, Cisco ACI, or Cilium ClusterMesh in Kubernetes-heavy environments. Policy is expressed at the workload level, often per-process or per-container, and enforced at host or hypervisor.

Where it adds value. Granularity. Micro-segmentation allows differentiation of traffic between workloads sharing a physical zone; in environments where a research group's workloads must be isolated from each other without provisioning per-group VLANs, this is the right tool. Cilium-based [21↗] micro-segmentation in Kubernetes is also the architectural fit for the compute layer (Chapter 9 of the Technical Reference) when policy needs to traverse the K8s and VM boundaries.

Where it constrains the institution. Commercial micro-segmentation overlays (NSX, Illumio, ACI) have substantial licence costs and tend to express policy in supplier-specific languages whose translation to other products is non-trivial; the exit-rehearsal condition of §5.2 is most challenged here. Cilium and other open alternatives are more recent and less broadly skilled than their commercial counterparts.

When it is the right choice. Institutions with a high density of multi-tenant workloads (research clouds, multi-faculty shared platforms) where macro-segmentation does not provide sufficient granularity. The recommendation is to adopt the open alternative (Cilium) as the reference, and the commercial alternatives only when the institution's posture cost-justifies them.

8.5 Discussion — SASE and ZTNA: why they are not the reference

Secure Access Service Edge (SASE) and Zero Trust Network Access (ZTNA) services from suppliers such as Cloudflare, Zscaler, and Netskope present an attractive operational profile: policy expressed centrally, enforcement near the user, deep integration with identity, and reduced reliance on on-premise filtering infrastructure. In a sovereignty-aware analysis, however, they present a structural difficulty.

The data plane of a SASE service is operated by the supplier, in locations and under jurisdictions chosen by the supplier, with inspection capabilities that the supplier necessarily exercises (TLS termination, content inspection, identity correlation). The supplier becomes a recipient of the institution's network traffic in a sense that the standards-only configurations of §§8.2 and 8.3 do not. The data dimension of the sovereignty grid is consequently bounded: a SASE deployment, in its standard configuration, cannot exceed Partial on the disclosure-regime indicator.

This is not an objection to SASE as a technology. SASE is an appropriate choice in two bounded scenarios: as a complement to the reference architecture for a specific population (for example, unmanaged contractor devices) where the institution accepts the sovereignty cost in exchange for a manageability gain; and as a transitional measure during a brownfield migration whose end-state is the reference architecture. The architectural posture is to treat SASE as a tactical tool, not as the structural network layer.

Zero-Trust anchoring. Declining SASE/ZTNA does not forgo Zero Trust: the reference architecture realises the seven tenets of NIST SP 800-207 [50↗] structurally — every layer treated as a protected resource with communication secured regardless of network location (Tenets 1–2); identity-mediated, per-session, strictly-enforced access through the identity and policy planes (Tenets 3 and 6); access decided by dynamic policy on identity, role, posture and environment, with default-deny zones (Tenet 4); continuous posture and integrity monitoring through the endpoint and observability layers (Tenet 5); and decision/access telemetry collected through the canonical TAC event schema to refine policy (Tenet 7). Zero Trust is thus a property of the architecture, not a procured service.

8.6 Sovereignty grid applied

Table 8.2: Per-dimension sovereignty profile of the network instantiations.

Dimension	Reference (open)	Proprietary macro-seg	Micro-seg (commercial)	SASE
Data	3 Robust	3 Robust	2 Established	1 Partial
Technical	3 Robust	2 Established	1 Partial	1 Partial
Financial	2 Established	2 Established	1 Partial	1 Partial
Operational	2 Established	3 Robust	2 Established	3 Robust
Institutional	3 Robust	2 Established	1 Partial	1 Partial

Driving indicators by dimension. Data: disclosure regime and storage location. Technical: source visibility and presence of captive extensions in the configuration path. Financial: cost predictability and exit-cost proportionality. Operational: depth of the skills market and quality of public documentation. Institutional: roadmap influence and integration freedom.

The network layer illustrates clearly the trade-off the sovereignty grid is designed to surface: each row of the table is a different way of distributing capacity along the five dimensions. The reference instantiation is dominant on Data, Technical and Institutional; the proprietary macro-segmentation gains on Operational at modest cost on Technical; the commercial micro-

segmentation and SASE deliver Operational and convenience but at structural cost on Data and Institutional.

8.7 Regulatory anchoring

The network layer is the perimeter and segmentation substrate underpinning GDPR Art. 32(1) (security of processing through technical measures). It operationalises NIS2 Art. 21(2)(a) (risk analysis applied to network design), (g) (cyber hygiene baseline including segregation), and indirectly (b) (incident handling, through the chokepoints that bound incident scope). The layer is the principal anchor of 27001 A.8.20 (network security) and A.8.22 (segregation of networks); it contributes to NIST CSF PROTECT (PR.IR — infrastructure resilience) and DETECT (DE.CM, through flow telemetry feeding the audit pipeline). Detailed mapping in Chapter 33 of the Technical Reference §33.5, §33.6, §33.11, §33.9.

8.8 Common pitfalls

Common pitfall — Standard interfaces promised, proprietary management used

An institution adopts NETCONF/YANG-capable gear, then operates it through the supplier's management console for day-to-day work. Within two to three years, the operational practices, the runbooks, and the team's reflexes are tied to the console. The standards remain technically available but operationally unused. The mitigation is to make the standard interface the operational default, treat the management console as a diagnostic aid only, and exercise the standard-only operation periodically as part of the conformance suite of Chapter 16 of the Technical Reference.

Common pitfall — Science DMZ behind the enterprise firewall

A Science DMZ that traverses the enterprise stateful filtering perimeter loses its purpose: the throughput penalty that the Science DMZ exists to avoid is reintroduced. The mitigation is explicit: the Science DMZ has its own access path to the Internet, protected by ACLs and IDS but not by a stateful firewall, and the architectural decision to bypass the enterprise perimeter is documented and reviewed.

Common pitfall — East-west allow-by-default

Many campus networks permit east-west traffic by default within a VLAN; consequently, the segmentation is at the zone boundary only. Lateral movement during an incident is then bounded only by the zone, not by the workload. The mitigation is to treat intra-zone east-west as a policy decision, expressed in Chapter 7 of the Technical Reference and enforced at the appropriate layer (host firewall, micro-segmentation overlay, or hypervisor); the default is deny, with allow-listed flows.

Common pitfall — ACL drift

Access control lists are added when needed and removed rarely. Within a few years, the ACL set on each device is a historical record of past needs rather than a current expression of policy. The mitigation is to express ACLs as the materialisation of policy decisions (Chapter 7 of the Technical Reference) under version control, with periodic reconciliation against the policy corpus and removal of rules whose justification has lapsed.

Common pitfall — BYOD VLAN as "isolation" without enforcement

A separate BYOD VLAN is declared but the enforcement that prevents BYOD endpoints from reaching internal resources is missing or broken. Users discover this when they encounter problems and their resourceful colleagues find paths around the intended isolation. The mitigation is to make the BYOD posture an enforceable policy, verified by NAC, with automated periodic re-attestation, and to monitor the actual flows from the BYOD VLAN against the policy.

Chapter 9

Compute and workload context

Dependencies

This chapter applies the layer template of Chapter 6 of the Technical Reference to the compute layer. It consumes policy decisions from Chapter 7 of the Technical Reference (admission and runtime), it respects the network zone catalogue of Chapter 8 of the Technical Reference (§8.2), and it produces workload-context events consumed by Chapter 12 of the Technical Reference. The layer belongs to the *Execution plane*.

The compute layer is the place where institutional activities — research codes, teaching environments, administrative services, web applications — actually run. It is also a layer where lock-in accumulates quietly: a custom hypervisor configuration, a proprietary container registry, a cluster-management add-on whose Application Programming Interface (API) drifts from upstream Kubernetes can each, individually, appear inexpensive, and together produce a stack from which exit becomes a multi-year project.

9.1 Functional role and interface contract

The compute layer is responsible for: provisioning workloads as virtual machines, containers, or composed workloads of both types; enforcing admission decisions returned by the policy layer at the moment of workload creation; running workloads under network-attachment and storage-binding consistent with the activity context; and producing the supply-chain provenance metadata that allows the institution to verify what it actually runs.

Interface contract — Compute layer

A compliant compute layer, in the sense of this architecture, must:

- expose a Kubernetes [23↗] API for container workloads, conformant to the upstream specification, without supplier extensions in critical paths;
- expose an OpenStack [24↗] API *or* an equivalent standards-aligned IaaS API for virtual-machine workloads;
- accept and store container images in OCI image format [25↗], in a registry whose access can be audited and exit-rehearsed;
- produce supply-chain provenance attestations conformant to the SLSA framework [26↗] for every artefact produced internally;
- enforce admission decisions returned by Chapter 7 of the Technical Reference on every workload creation, with the decision recorded in the audit trail;
- integrate with the network layer (Chapter 8 of the Technical Reference) through standard CNI plugins consistent with the institutional zone catalogue, and with the storage layer (Chapter 10 of the Technical Reference) through standard CSI plugins.

The contract treats supply-chain provenance as a structural requirement, not as a compliance afterthought. The reasoning is that without verifiable provenance, the institution cannot make auditable statements about what runs on its infrastructure — a gap that the data and institutional sovereignty dimensions surface immediately.

9.2 Reference instantiation: OpenStack + Kubernetes + Harbor + SLSA

The reference instantiation combines OpenStack [24↗] for IaaS, upstream Kubernetes [23↗] for container orchestration, Harbor [51↗] as the OCI registry with image scanning and signing (Cosign / Sigstore [52↗]), and SLSA-compliant [26↗] build attestations emitted by the institution's continuous-integration pipelines (typically built on Tekton [53↗]).

Reference instantiation — Compute layer

Topology. OpenStack provides multi-tenant virtual-machine and bare-metal provisioning at the scale of the institution; Kubernetes clusters — one per major tenancy boundary (administration, teaching, research projects of comparable scale) — run on top of OpenStack-provided infrastructure or on dedicated metal where latency or isolation requires it. Container images live in a Harbor registry deployed under the custody model the institution has chosen for this layer, scanned at push time and signed with cosign or an equivalent. Build pipelines (Tekton, Argo Workflows, or comparable) emit SLSA-compliant provenance attestations alongside the image. CNI plugins (Cilium is the reference) implement the network policies derived from Chapter 8 of the Technical Reference; CSI plugins (Ceph-CSI is the reference) expose the storage layer.

Tenancy model. Tenancy is the principal axis of governance in this layer. The reference pattern uses Kubernetes namespaces for fine-grained tenancy within a cluster, and separate clusters for tenancy boundaries that warrant operational isolation (cluster lifecycle independence, separate cryptographic identities, distinct upgrade cadences). The choice between namespace tenancy and cluster tenancy is a recurring design tension; this Reference proposes that workloads of distinct sensitivity classifications should not share a cluster.

Operational considerations. The reference instantiation is operationally non-trivial: OpenStack and Kubernetes each carry substantial operational depth, and integrating them with the identity, policy, network, and storage layers is the principal ongoing engineering investment. An indicative envelope, for a research-intensive institution running both an institutional OpenStack and several Kubernetes clusters, would be the staffing profile recorded for this layer in the institution's infrastructure plan, scaled to the size and intensity of its research compute portfolio. The labour market is broad for Kubernetes itself and narrower for the integrated stack.

Real-world reference — Research-cloud precedents

Indiana University's Jetstream2 [54↗], operated under a national research-infrastructure funding programme, provides a publicly documented research-cloud architecture built on OpenStack and serving the multi-institutional research community. Many institutions participate in a national or regional research high-performance computing facility, several of which also rest on OpenStack across multiple sites. Both should be consulted as primary sources for design and operational lessons, rather than as direct templates: each institution's compute layer reflects its specific research mission and the context of its national or regional research and education network, where one exists.

9.3 Alternative 1 — VMware with certified Kubernetes

Alternative — VMware-based compute

The IaaS layer is provided by VMware vSphere [55↗]; container orchestration runs on VMware Tanzu (or another certified Kubernetes distribution); image registry, build pipelines and CNI/CSI plugins remain on the standard interfaces, with explicit care to avoid captive extensions in their integration with the underlying hypervisor.

Where it adds value. A mature operational platform with a deep skills market, broad enterprise documentation, and existing integrations with most institutional tooling. For institutions whose compute layer was built around vSphere over many years, the operational momentum is substantial.

Where it constrains the institution. VMware's post-acquisition commercial trajectory has been the subject of considerable public discussion, with reported changes to licensing and pricing models that the institution would need to evaluate against the financial-sovereignty dimension of Chapter 3 of the Technical Reference. Beyond commercial considerations, the technical constraint is the gradual coupling of the compute layer to VMware-specific operators, controllers, and management consoles whose absence would require non-trivial adaptation. The architectural posture is to keep workloads expressed at the Kubernetes API level and to treat VMware as the underlying substrate, not as the API surface.

When it could be the right choice. An institution with a substantial existing investment in vSphere whose immediate sovereignty priorities are not in the compute layer, and whose financial planning has accounted for the supplier's pricing trajectory. The choice would remain consistent with this architecture provided that workloads are expressed in standard APIs and that exit-rehearsal is practised periodically.

9.4 Alternative 2 — Hybrid with standards-based cloud burst

Alternative — Hybrid compute

The institution operates a primary on-premises open-source compute stack and federates additional capacity from a public-cloud provider for bounded purposes (peak demand, specific research workloads, geographically distributed collaboration). The federation occurs through standard interfaces (Kubernetes API across clusters, S3-compatible object stores) without proprietary glue in the workload definition.

Where it adds value. Elasticity for workloads whose demand profile would over-provision an on-premises footprint, and geographic flexibility for collaborations spanning multiple jurisdictions. A hybrid posture also creates a continuously-exercised exit rehearsal: workloads regularly cross the boundary between on-premises and cloud, demonstrating that they are portable.

Where it constrains the institution. Public-cloud participation reintroduces the data-dimension considerations of Chapter 3 of the Technical Reference: the data accessed by the cloud portion of the workload falls under the cloud provider's regime. The institutional governance of which workloads are eligible for cloud burst, and under which conditions, becomes a permanent operational concern. The hybrid posture is also more costly to operate than a single-environment one.

When it could be the right choice. An institution with a research mission that includes large but episodic compute demand (climate modelling, genomics, astronomical surveys, and similar), where the alternative is either chronic under-provisioning or institutional-scale over-provisioning, and where the data-dimension governance is mature enough to support per-workload eligibility decisions.

9.5 Sovereignty grid applied

Table 9.1: Per-dimension sovereignty profile of the compute instantiations.

Dimension	Reference (OSS)	VMware-based	Hybrid (OSS + cloud)
Data	3 Robust	3 Robust	2 Established
Technical	3 Robust	1–2 Partial	2 Established
Financial	2 Established	1 Partial	2 Established
Operational	2 Established	3 Robust	2 Established
Institutional	3 Robust	1–2 Partial	2 Established

Driving indicators by dimension. Data: storage location, disclosure regime, especially for the cloud portion of the hybrid. Technical: source visibility, presence of captive operators or controllers in the cluster. Financial: cost predictability under the supplier's announced pricing trajectory. Operational: skills market depth and integration documentation. Institutional: roadmap control over the hypervisor and the orchestrator.
The compute layer is the layer where the financial dimension has been most visibly disturbed by recent supplier consolidation in the proprietary segment. Institutions whose compute strategy was set before that consolidation are reported to be re-examining their position; this Reference treats that re-examination as routine application of the sovereignty grid, not as an exceptional event.

9.6 Regulatory anchoring

The compute layer carries the workload-context attestations on which several security-of-processing obligations of the institution's applicable data-protection regime rest (integrity of processing, posture verification of the host that processes personal data; in the EU, GDPR Art. 32). It operationalises the business-continuity and secure-development duties of the applicable supra-national and national legal framework (in the EU, NIS2 Art. 21(2)(c), through declarative redeployability, and (e), through SLSA-level supply-chain attestations on the container images). Where the institution adopts them, the layer also maps to ISO/IEC 27001 A.8.32 (change management) and NIST CSF PROTECT (PR.PS — platform security). Detailed mapping in Chapter 33 of the Technical Reference §33.5, §33.6, §33.11, §33.9.

9.7 Common pitfalls

Common pitfall — Proprietary CNI or CSI in critical paths

A Kubernetes deployment that uses a vendor-proprietary CNI or CSI plugin for production workloads couples the cluster to that vendor: an exit requires re-validation of every networked or storage-bound workload. The mitigation is to use standards-aligned plugins (Cilium for CNI, Ceph-CSI for CSI as references) for production, and to confine vendor plugins to test or evaluation clusters.

Common pitfall — Custom orchestrator above Kubernetes

An institutional team writes a thin custom orchestrator on top of Kubernetes to simplify a particular workflow. Within a few years, the orchestrator has accumulated institutional knowledge that the standard Kubernetes API does not capture, and migrating away becomes expensive. The mitigation is to express workflow logic in standards-aligned tools (Argo Workflows, Tekton) whose behaviour can be re-implemented elsewhere if needed.

Common pitfall — Image registry lock-in

Container images stored in a registry whose data export is either undocumented or prohibitively slow create a structural exit cost. The mitigation is to keep images in an OCI-compliant registry whose export is exercised periodically as part of Chapter 16 of the Technical Reference (exit-rehearsal category).

Common pitfall — Hidden dependencies on supplier-specific operators

Kubernetes admits operators — in-cluster controllers that extend the API — contributed by suppliers, hardware vendors, or open-source projects. Some of these operators carry implicit dependencies on supplier services (telemetry endpoints, licence-validation calls, configuration retrieval) whose absence would silently degrade behaviour. The mitigation is to inventory the operators in production clusters, classify their dependencies, and either disable or substitute those whose dependencies erode the sovereignty profile.

Chapter 10

Storage and data classification

Dependencies

This chapter applies the layer template of Chapter 6 of the Technical Reference to the storage layer. It consumes classification-driven policy decisions from Chapter 7 of the Technical Reference, it binds to compute workloads through the CSI plugins referenced in Chapter 9 of the Technical Reference, and it relies on the cryptographic services of Chapter 13 of the Technical Reference. The layer belongs to the *Execution plane*.

The storage layer is where the data dimension of sovereignty is most directly tested. A network configuration can be revised in weeks; a misclassified or mislocated data corpus is rarely revised at all. The architectural commitment of this layer is consequently modest in scope but strict in observance: standard interfaces, explicit classification, institutional key custody, and an exit-data export procedure that is exercised, not assumed.

10.1 Functional role and interface contract

The storage layer is responsible for: providing object and block storage to workloads through standard interfaces; carrying a data classification label that the policy layer consults; encrypting data at rest with keys whose custody is governed; permitting the extraction of institutional data in documented open formats; and producing access events ingestible by the observability layer.

Interface contract — Storage layer

A compliant storage layer, in the sense of this architecture, must:

- expose object storage through the S3 API *or* an interface broadly compatible with it;
- expose shared-file access through NFS v4.1 [28↗] or an equivalent standard, where shared-file access is required;
- carry, for each stored object or volume, a classification label from a documented institutional scheme, accessible to Chapter 7 of the Technical Reference;
- encrypt data at rest, with key custody held in a system that speaks KMIP [27↗] *or* an equivalent open key-management interface, and that admits a Bring-Your-Own-Key arrangement;
- produce access events (object created, read, written, deleted, exported) ingestible by the observability layer in a schema consistent with Chapter 12 of the Technical Reference;
- document an exit-data export procedure that delivers stored data in a documented open format, and exercise it periodically as part of Chapter 16 of the Technical Reference.

Classification scheme. The contract requires a documented classification scheme but does not prescribe one. In practice, institutions tend to adopt either a Traffic Light Protocol variant, a domain-specific scheme (for example, those used in medical or defence-adjacent research), or

an institution-specific scheme that maps to the regulatory regimes the institution operates under. The choice belongs to the institution; the contract requires that the choice be documented and that every label used be enumerable.

10.2 Reference instantiation: Ceph + Vault Transit + label-based access

The reference instantiation combines, as representative open-source implementations, a distributed storage system such as Ceph [56↗] providing both object (RGW) and block (RBD) interfaces; an envelope-encryption secrets engine with institutionally-held keys such as HashiCorp Vault [57↗]'s Transit engine; and label-based access control implemented through a policy decision integrating the classification label into the authorisation logic.

Reference instantiation — Storage layer

Topology. Ceph clusters provide block storage to Chapter 9 of the Technical Reference workloads via Ceph-CSI (consistent with §9.2), object storage via the RGW gateway exposing the S3 API, and file storage via CephFS where shared-file semantics are required. Encryption at rest is enabled at the OSD level, with keys wrapped through Vault Transit; the institutional key-management policy resolves to either a Vault-internal master key or, for higher-classification data, an HSM-backed master key exposed through PKCS#11. Each object or volume carries a classification label as metadata; the policy decision for read or modify access combines the subject attributes from Chapter 6 of the Technical Reference with the label, and the decision is logged through the observability layer.

Operational considerations. Operating Ceph at institutional scale would typically require dedicated expertise: the cluster's health and recovery characteristics demand specific operational discipline that more conventional storage products do not require. The staffing envelope follows the institution's established operational staffing profile for distributed storage, typically a small dedicated team with substantial Ceph familiarity, often shared with the network and compute teams. The labour market is broad for Ceph itself and narrower for the integration of Ceph with classification-aware access control.

Cryptographic posture. Vault Transit provides envelope encryption that allows the encryption keys to be rotated without re-encrypting the data corpus. For data classifications whose disclosure regime warrants stronger custody, the institution would substitute a HYOK arrangement, consistent with the institution's own data-custody sovereignty profile, in which Vault never holds the cleartext key and cryptographic operations involve the institution's HSM in the live path. This shifts the data-dimension score upward at the cost of additional operational complexity, addressed in Chapter 13 of the Technical Reference.

Real-world reference — Research storage precedents

CERN's EOS distributed file system, designed for high- energy physics datasets, is one of the most extensively documented research-storage architectures and reflects the operational scale that physical-sciences research can require. European research institutions participate in the EUDAT Collaborative Data Infrastructure (EUDAT CDI), whose B2 services suite (B2SAFE for replication, B2SHARE for publication, B2STAGE for compute access, B2DROP for sync, B2FIND for discovery, B2ACCESS for federated authorisation, B2HANDLE for persistent identifiers) operates across a network of more than twenty research and computing centres in over a dozen European nations. These European research-computing references should be consulted for their design lessons rather than as direct templates — adopters in other regions have analogous national or regional research-data infrastructures — since the relative

scale of teaching, administrative and research storage at a given institution may produce a substantially different proportion than at a large-scale research-computing environment.

10.3 Alternative 1 — Enterprise storage platform with KMIP-compliant HSM

Alternative — Enterprise SAN/NAS

The institution operates an enterprise storage platform from one of the established vendors in this market that exposes the S3 API for object storage and NFS for shared file access, with encryption at rest keyed through a KMIP-compliant HSM under institutional control. Classification metadata is carried at the application level rather than natively in the storage system.

Where it adds value. A mature platform with predictable performance characteristics, vendor support, and integration with existing operational tooling. For institutions whose storage is predominantly transactional rather than research-scale, the operational simplicity may be substantial.

Where it constrains the institution. Two recurring constraints. First, classification metadata typically lives outside the storage system and must be reconciled with it through application or integration logic; the reconciliation is a non-trivial engineering effort that the reference instantiation avoids. Second, exit-data export from proprietary storage platforms is variable in cost and contractually framed; the exit-cost-proportionality indicator of Chapter 3 of the Technical Reference should be evaluated explicitly at procurement.

When it could be the right choice. An institution with limited research-storage requirements, a mature operational relationship with an enterprise storage supplier, and a sovereignty posture that accepts the trade-offs in exchange for the operational simplification.

10.4 Alternative 2 — Hybrid (on-premises + S3-compatible cloud with strict BYOK)

Alternative — Hybrid storage with BYOK

The institution operates a storage tier under an institution-controlled deployment custody model (Ceph or enterprise, self-hosted or otherwise kept under direct institutional control) for data whose classification requires institutional custody, and federates additional capacity to an S3-compatible cloud provider for less-sensitive classes of data, with all cloud-stored data encrypted under institutionally-held keys (BYOK, with HYOK for the higher-sensitivity classes that the hybrid posture would admit).

Where it adds value. Capacity flexibility for research-data corpora whose growth profile would over-provision an on-premises footprint, and geographic redundancy for data whose classification permits multi-jurisdiction storage.

Where it constrains the institution. The data dimension of Chapter 3 of the Technical Reference is permanently bounded by the weakest disclosure regime applicable to any portion of the corpus. The institutional governance of which data classes are eligible for the cloud tier becomes a structural concern, addressed through the policy layer (Chapter 7 of the Technical Reference) and the data-classification scheme.

When it could be the right choice. An institution whose research storage profile combines a sensitive on-premises core with a substantial volume of less-sensitive data (publication-stage artefacts, public datasets), and whose classification governance is mature enough to enforce the boundary reliably.

10.5 Sovereignty grid applied

Table 10.1: Per-dimension sovereignty profile of the storage instantiations.

Dimension	Reference (Ceph + Vault)	Enterprise platform + KMIP HSM	Hybrid (on-prem + cloud)
Data	3 Robust	3 Robust	1–2 Partial
Technical	3 Robust	1 Partial	2 Established
Financial	2 Established	1 Partial	2 Established
Operational	2 Established	3 Robust	2 Established
Institutional	3 Robust	2 Established	2 Established

Driving indicators by dimension. Data: storage location, key custody, disclosure regime — this is the dimension on which the storage layer is most often constrained. Technical: source visibility and the reconciliation of classification with the storage system. Financial: cost predictability and exit-cost proportionality. Operational: depth of the skills market for the chosen technology. Institutional: control over the storage roadmap.
The hybrid pattern's data-dimension score is bounded by the cloud-tier disclosure regime, even when the on-premises tier scores Robust. This is the structural reason why classification governance must be in place before the hybrid pattern is adopted.

10.6 Regulatory anchoring

The storage layer is the principal anchor of the data-dimension obligations under the applicable data-protection regime: security of processing (e.g. GDPR Art. 32), data minimisation through tiering (e.g. Art. 5(1)(c)), and the regime's constraints on international transfers (e.g. Art. 44–49), which bind when storage placement crosses jurisdictions. It is the operational counterpart of the applicable cross-border data-transfer regime: storage-placement constraints, key-custody and per-tenant key separation are the technical supplementary measures that an institution can invoke alongside whatever standard contractual transfer instruments that regime recognises. The layer operationalises NIS2 Art. 21(2)(c) (backup) and contributes to 27001 A.8.10 (information deletion), A.8.12 (data leakage prevention) and A.8.13 (information backup). It contributes to NIST CSF PROTECT (PR.DS — data security). Detailed mapping in Chapter 33 of the Technical Reference §33.5, §33.8, §33.6, §33.11.

10.7 Common pitfalls

Common pitfall — Classification drift

The classification labels attached to data corpora at creation time tend to remain unchanged as the data evolves — as new fields are added, as additional populations are sampled, as linkages with other corpora are introduced. The classification becomes increasingly disconnected from the actual sensitivity. The mitigation is to schedule a classification review at data-corpus events (substantial expansion, linkage with another corpus, publication) and to record the classification history alongside the data.

Common pitfall — Key-management lock-in

A storage system whose encryption keys can only be managed through the supplier's own key-management product creates a structural exit cost: the keys cannot be transferred to another storage system without re-encrypting the entire corpus. The mitigation is to require KMIP (or an equivalent open interface) at procurement, and to verify that the institution's keys can in fact be operated through a non-supplier key-management product.

Common pitfall — Opaque snapshots and replicas

Storage systems take snapshots and create replicas as part of normal operation; the location, retention, and access regime of those snapshots is not always documented to the institution. A data-dimension audit that ignores snapshots can score a corpus as Robust on storage location while replicas of it sit elsewhere. The mitigation is to enumerate snapshots and replicas as part of the data-dimension self-assessment, and to bring their location under the same governance as the primary storage.

Common pitfall — Cross-region replication outside jurisdiction

Cloud-tier storage often defaults to multi-region replication for durability; the regions selected by the supplier may sit outside the institution's intended jurisdiction. The mitigation is to declare region restrictions explicitly at provisioning, to verify them through the access events of Chapter 12 of the Technical Reference, and to test the assumption periodically through deliberate write-and-read patterns that would surface unexpected replication.

Chapter 11

Endpoint management

Dependencies

This chapter applies the layer template of Chapter 6 of the Technical Reference to the endpoint layer. It produces posture claims consumed by Chapter 7 of the Technical Reference, contributes attributes that Chapter 6 of the Technical Reference carries on session assertions, and is constrained at the network attachment level by Chapter 8 of the Technical Reference. The layer belongs to the *Subject and trust plane*.

The endpoint layer covers institutional and personal devices that connect to institutional services: managed Linux servers and workstations, managed macOS, managed Windows, mobile devices (iOS and Android), and BYOD endpoints that may run any of the above. The layer reports *posture* claims to the policy layer, applies *configuration* from a declarative source, and exercises *lifecycle controls* (enrolment, audit, retirement) on the devices it manages.

Honest acknowledgement

The endpoint layer is the place where the open-source reference instantiation is weakest, particularly for iOS and Android at scale. This Reference does not minimise that gap; it documents it (§11.5), proposes an open instantiation where it is realistic, and treats the commercial alternatives as the working choice for the segments where the open ecosystem has not yet matured.

11.1 Functional role and interface contract

Interface contract — Endpoint layer

A compliant endpoint layer, in the sense of this architecture, must:

- enrol managed devices through a documented procedure that binds the device to an institutional identity;
- apply configuration from a declarative source: Apple declarative device management (DDM/DEP) on Apple platforms, MS-MDM on Windows, declarative configuration management (Ansible idempotent profiles, or equivalent) on Linux;
- produce posture claims consumed by Chapter 7 of the Technical Reference, in a schema that downstream policy authoring can rely on;
- support a documented decommissioning procedure (data wipe, enrolment removal, account deactivation) executable on demand;
- integrate with Chapter 12 of the Technical Reference so that endpoint events (enrolment, posture violation, configuration failure, suspicious activity) reach the institutional audit pipeline.

The contract does not require a single product to cover all endpoint operating systems.

Multi-product instantiations are admissible provided that the institution operates a unified posture schema across them, so that Chapter 7 of the Technical Reference can author rules without per-OS branching for routine decisions.

BYOD scope. The contract applies to managed endpoints. BYOD endpoints carry a more limited posture surface (no agent, network-side observation only) and are governed through the attachment policy of Chapter 8 of the Technical Reference rather than through this layer's enrolment procedures. The architectural principle is that BYOD endpoints reach institutional services only through contexts whose posture requirements they can satisfy without agent-based verification.

11.2 Reference instantiation: Munki + osquery + Ansible + MicroMDM

Reference instantiation — Endpoint layer

Topology by operating system. Linux endpoints (servers and workstations) are configured through Ansible [30↗] idempotent playbooks under version control; posture is queried through osquery [29↗]; package state is tracked against an institutional repository. **macOS** endpoints are configured through Munki [58↗] for software distribution and through MDM commands delivered by an open-source MDM server (MicroMDM [59↗] or NanoMDM, or a comparable project) speaking Apple's DDM/DEP protocols; posture is queried through osquery. **Windows** endpoints are partially covered by declarative configuration through Ansible with the WinRM/PowerShell-DSC integration, with the explicit observation that the open-source coverage of MS-MDM is, at the time of writing, substantially less mature than the Apple and Linux equivalents. **iOS and Android** are addressed through commercial alternatives in this architecture (§11.3); the open-source ecosystem at the institutional scale would not, at the time of writing, provide a credible reference instantiation.

Posture schema. The unified posture schema is the artefact that decouples policy authoring from per-OS endpoint products. The schema covers, at minimum: device identity, enrolment status, OS version, encryption state, last-update timestamp, presence of expected security agents, deviation from declared configuration. Each product reports into this schema; the mapping from product-specific signals to the unified schema is the institution's responsibility.

Operational considerations. A multi-product reference instantiation imposes a multi-skill operating team. The indicative staffing envelope set in the resourcing profile of a typical research-intensive institution spreads a small group of engineers across the OS-specific operations, with one engineer-equivalent dedicated to the unified posture schema and its integration with the policy layer.

Real-world reference — Endpoint management precedents

Research-intensive institutions are reported to operate mixed-OS endpoint estates that combine open-source and commercial tooling along the OS boundary, typically retaining open tooling for Linux and macOS where the OSS ecosystem is mature, and commercial tooling for Windows at scale and for iOS/Android. The specific tool choices and operational details would be best confirmed against the institution's own published documentation, when available, or its presentations in the community fora of the institution's national research and education network.

11.3 Alternative 1 — Jamf (macOS/iOS) + Intune (Windows) with OpenTelemetry export

Alternative — Commercial multi-product

The institution adopts Jamf [60↗] for Apple platforms (macOS and iOS), Microsoft Intune [61↗] for Windows and Android, and continues Ansible/osquery for Linux. Posture data from each product is exported through OpenTelemetry collectors so that the unified posture schema is fed without any product becoming the authoritative store.

Where it adds value. For iOS and Android in particular, the operational depth of Jamf and Intune is, at the time of writing, substantially ahead of the open alternatives. For an institution where the mobile estate is large and lifecycle controls must be exercised reliably, this is the working choice.

Where it constrains the institution. Each product expresses configuration and posture in its own model; the reconciliation of these models with the unified schema of §11.2 is a sustained engineering effort. Beyond the schema work, the institution accepts a non-trivial financial commitment per device per year, and a roadmap that the suppliers control. The architectural posture is to keep posture data exported through OpenTelemetry collectors so that the policy layer remains the source of authorisation truth, and so that exit from either product would be a re-implementation of the data pipe rather than a re-foundation of the policy.

When it could be the right choice. An institution whose iOS and Android estates are operationally significant, whose financial position absorbs the per-device licensing, and whose sovereignty posture accepts a Partial score on the technical and institutional dimensions of the endpoint layer in exchange for the operational depth.

11.4 Alternative 2 — Workspace ONE multi-OS

Alternative — Single-vendor multi-OS

The institution adopts a single multi-OS endpoint management platform (Workspace ONE, or comparable) covering Apple, Windows, Android and a subset of Linux through one supplier relationship. Posture export to OpenTelemetry remains a contractual requirement.

Where it adds value. A single supplier relationship, a single skill set within the team, and consistent posture semantics across operating systems out of the box. The reconciliation work that the multi-product alternative imposes is largely absorbed by the supplier.

Where it constrains the institution. The single supplier becomes the sole point of failure for the entire endpoint layer. Substitutability is significantly weaker than in the multi-product alternative, and institutional negotiation leverage diminishes across renewal cycles. The exit-cost-proportionality indicator of Chapter 3 of the Technical Reference should be evaluated explicitly at procurement.

When it could be the right choice. An institution with limited engineering capacity to integrate multiple endpoint products, where the operational simplification is more valuable than the substitutability cost, and whose financial sovereignty posture is comfortable with a single-supplier exposure on the endpoint layer.

11.5 Sovereignty grid applied

Table 11.1: Per-dimension sovereignty profile of the endpoint instantiations. The reference is scored across two columns to make the iOS/Android gap visible.

Dimension	Reference *Linux/macOS*	Reference *iOS/Android*	Jamf/Intune	Workspace ONE
Data	3 Robust	— (gap)	2 Established	2 Established
Technical	3 Robust	0–1 Absent/Partial	1 Partial	1 Partial
Financial	2 Established	0–1 Absent/Partial	1 Partial	1 Partial
Operational	2 Established	0–1 Absent/Partial	3 Robust	3 Robust
Institutional	3 Robust	0–1 Absent/Partial	1 Partial	1 Partial

The transparent split of the reference column is deliberate. The open-source reference is competitive on Linux and macOS; it is not, at the time of writing, a credible institutional choice for iOS and Android. The architectural posture is to use the reference where it works and the commercial alternatives where the ecosystem requires it, while keeping the policy layer in a position to consume posture from any of them without favour.

Driving indicators by dimension. Data: enrolment data, posture data, telemetry destination. Technical: source visibility, captive extensions in the configuration model. Financial: per-device licensing and renewal trajectory. Operational: skills market depth across the institution's OS mix. Institutional: roadmap influence and integration freedom.

11.6 Regulatory anchoring

The endpoint layer is the device-side anchor of the applicable data protection regime's technical-measures obligation (technical measures applied at the device that processes personal data) and the principal locus of the applicable cybersecurity baseline regime's requirements on basic cyber hygiene practices, asset management, and indirectly authentication (where the endpoint carries the authentication factors). Posture attestations consumable by the policy layer operationalise the device dimension of zero-trust (SP 800-207). The layer contributes to 27001 A.8.1 (user endpoint devices), A.8.7 (protection against malware) and A.8.9 (configuration management) and to NIST CSF PROTECT (PR.PS — platform security). Detailed mapping in Chapter 33 of the Technical Reference §33.5, §33.6, §33.11, §33.9.

11.7 Common pitfalls

Common pitfall — BYOD posture without enforcement

The institution declares a BYOD posture (encryption, patch level, screen lock) and relies on user attestation for it. Within months, the actual fleet has drifted from the declared posture, and the network attachment of Chapter 8 of the Technical Reference no longer reflects what the institution thought it enforced. The mitigation is to make BYOD posture either verifiable (network-side observation, captive-portal challenge) or contractual without the architecture relying on it for sensitive zones.

Common pitfall — MDM cost explosion

Per-device licensing in the commercial alternatives can grow with the estate at a rate that procurement did not anticipate, particularly when contractor and visiting-researcher devices accrue. The mitigation is to budget per-device licensing as a recurring variable cost, to

maintain a current device inventory, and to include the projection in the financial-sovereignty review.

Common pitfall — Policy drift between MDM and central PDP

An MDM product expresses authorisation rules in its own language (compliance policies, conditional access expressions); the central PDP of Chapter 7 of the Technical Reference expresses them in Rego or Cedar. Over time, the two drift, and the same notional rule says different things in the two systems. The mitigation is to author posture-aware authorisation in the central PDP only, and to use the MDM product's authorisation features only for device-level decisions that the policy layer does not need to know about.

Common pitfall — Undocumented MDM extensions

Commercial MDM products extend the standard DDM/MS-MDM/declarative protocols with proprietary capabilities. Adoption of such extensions in critical paths erodes replaceability without making it visible. The mitigation is to audit the configuration profiles and policies for non-standard extensions periodically, and to confine such extensions to non-critical paths or to substitute them.

Chapter 12

Observability and audit

Dependencies

This chapter applies the layer template of Chapter 6 of the Technical Reference to the observability layer, with one additional section (§12.3) that defines the canonical TAC event schema referenced from Chapter 7 of the Technical Reference (D7.6) and from every other layer chapter that produces audit events. The chapter's outputs are consumed by Chapter 25 of the Technical Reference (*Wave 7 — TAC-aware audit and IR*). The layer belongs to the *Control and governance plane*.

The observability layer is the place where the activity of every other layer becomes visible to the institution. It is also the place where two structural risks accumulate quietly: a per-volume ingestion cost that grows faster than the institution's monitoring capacity, and a schema drift between sources that makes correlation unreliable precisely when it is most needed — during an incident. The architectural commitment of this layer is consequently to fix the schema at the institutional level and to keep the ingestion pipeline portable.

12.1 Functional role and interface contract

The observability layer is responsible for: collecting audit-grade events from every other layer in a uniform schema; transporting them through a portable ingestion pipeline; retaining them according to data-classification-driven policies; making them searchable for routine operations and forensic investigation; and producing alerting on policy-relevant patterns.

Interface contract — Observability layer

A compliant observability layer, in the sense of this architecture, must:

- collect events from every layer in the canonical TAC schema of §12.3;
- transport events through OpenTelemetry-compatible [31↗] collectors and an open intermediary (Kafka [62↗], NATS or equivalent), so that the analytical store can be substituted without re-instrumenting the sources;
- retain events under a documented retention schedule keyed on data classification, with the schedule reviewable and contractually enforceable;
- provide search and correlation capabilities sufficient for routine operations and for the incident-response runbooks of Chapter 25 of the Technical Reference;
- emit alerts on policy-relevant patterns in a form consumable by the institution's chosen incident-response workflow.

Retention is policy-driven, not product-driven. Retention durations are determined by the regulatory regime, the classification of the events, and the institution's incident response and audit obligations — not by the storage tier of the chosen product. The architectural posture

is to express retention as a documented institutional policy and to instantiate it in the chosen analytical store, never the inverse.

12.2 Audit-store integrity

The audit trail is load-bearing for accountability and for the lawful basis of monitoring, so the store that holds it must itself be tamper-evident. The architectural posture requires three controls, independent of the chosen product:

- **Append-only / WORM.** Audit events are written to an append-only or write-once-read-many cold tier; operational mutation or deletion of past records is not a supported path.
- **Tamper-evidence.** Per-record or per-batch cryptographic signing or hash-chaining lets any later alteration or gap be detected.
- **Separation of duties.** The operators who run the pipeline, the analysts who read the logs, and the authority to expire records under the retention schedule are distinct roles; retention expiry follows a four-eyes rule.

This discharges GDPR Art. 32 (integrity of processing) and Art. 5(1)(f), NIS2 Art. 21 (logging integrity), ISO/IEC 27001 controls A.8.15/A.8.16, and NIST SP 800-53 AU-9 (protection of audit information). The break-glass procedure does not bypass it: emergency access is itself an audited, signed event.

12.3 Canonical TAC event schema

The canonical TAC event schema is the institutional contract that every event-producing layer satisfies. Its purpose is to make correlation across layers possible and to make the audit trail reconstructable. Table 12.1 lists the required and recommended fields. The schema is presented as an abstract structure; its concrete representation in an institutional deployment may use OpenTelemetry, CloudEvents, or a JSON schema, provided that the abstract structure is preserved.

Table 12.1: Canonical TAC event schema. **R** required for every event; **c** required when the field is meaningful for the producing layer; **o** optional but recommended.

Field	Req.	Description
`timestamp`	R	Event time, UTC, ISO 8601, microsecond precision when available.
`correlation_id`	R	TAC session identifier or activity correlation identifier; ties events across layers.
`event_id`	R	Unique identifier of this event.
`layer`	R	Producing layer (identity, policy, network, compute, storage, endpoint, crypto, orchestration).
`event_type`	R	Layer-specific event type (e.g. `auth.success`, `policy.decision`, `storage.read`).
`subject_id`	R	Institutional identifier of the subject involved, where applicable; otherwise `system`.
`subject_attributes`	c	Role activated, group memberships, posture summary at the moment of the event.
`resource_id`	c	Identifier of the resource accessed (workload, dataset, endpoint, configuration object).
`resource_classification`	c	Data classification label of the resource, where applicable.
`environment`	c	Zone, time-of-day, location signals, posture flags.
`decision_verdict`	c	For policy-relevant events: `allow`, `deny`, `indeterminate`.
`decision_obligations`	c	Obligations applied as part of the decision (timeout, additional factor, audit class).
`policy_version`	c	Version of the policy bundle that produced the decision.
`duration_ms`	c	Evaluation or processing duration, milliseconds.
`source`	R	Producing component, instance, version.
`severity`	R	`info`, `notice`, `warn`, `error`.
`message`	o	Free-text description for human readers.

Correlation identifier. The `correlation_id` is the field that turns a stream of events into a navigable activity trace. It is set when a TAC is activated and propagated to every event emitted under that activation, across layers, until the TAC is decommissioned. The mechanism for propagating the identifier is implementation-specific (HTTP header, message attribute, log field); the architectural requirement is that propagation occur and that the identifier be preserved in the event store.

Schema evolution. The schema as published is the institutional baseline. Extensions are admissible provided they do not displace the baseline fields and provided they are documented in the institution's observability governance. Schema breakage — removing a baseline field, redefining its semantics — is a governance event, not a product-driven one.

12.4 Reference instantiation: Vector + Kafka + OpenSearch + Grafana

Reference instantiation — Observability layer

Topology. Vector [63↗] collectors are deployed at every event-producing source and convert local formats to the canonical TAC schema; Kafka [62↗] serves as the durable ingestion buffer; events are partitioned by classification and routed to two stores: OpenSearch [64↗] for indexed search and structured analytics, and Grafana Loki [65↗] for high-volume log lines whose retention is shorter. Grafana [66↗] dashboards present operational and audit views; alerting flows to the institution's chosen incident-response workflow. Cold-tier retention beyond the indexed window is held in S3-compatible object storage (consistent with §10.2).

Operational considerations. The reference instantiation is operationally substantial: the durable ingest buffer, the indexed-search cluster, and the cold-tier export pipeline each carry their own operational rhythm. An indicative envelope, for a research-intensive institution operating the full pipeline, would be the institution's observability staffing profile sized for the full pipeline and shared with the security operations function. The labour market is broad for the individual components and narrower for the integrated pipeline.

Volume management. The principal recurring effort is volume management: not every event is equally valuable, and a naive ingestion strategy floods the analytical store with noise that obscures the signal. The architectural posture is to define event-class retention and indexing tiers as part of the schema governance, and to enforce them at the collector or buffer rather than at the analytical store. This reverses the per-GB economy of the commercial alternatives.

Real-world reference — Audit pipeline precedents in academia

Public documentation of academic SIEM and observability pipelines is thinner than for identity or compute. Among what is available in the research-and-education networking community and its CSIRT fora, several research-intensive institutions are reported to operate observability pipelines that combine open-source collectors with commercial analytical stores; the specific architectures should be confirmed against their own published material when available.

12.5 Alternative 1 — Splunk Enterprise with OpenTelemetry collectors upstream

Alternative — Splunk + OTel

The institution operates Splunk Enterprise [67↗] as the analytical store and SIEM, with OpenTelemetry collectors as the upstream collection layer that feeds Splunk while also feeding, optionally, a parallel open-source store for portability. The canonical schema of §12.3 is enforced at the collector layer, not at Splunk's ingestion.

Where it adds value. Splunk's analytical depth, alerting sophistication, and the depth of its skills market are substantial. Forensic investigation and complex correlation are well supported. For institutions with mature Splunk operations, the productivity gain over a self-built pipeline can be significant.

Where it constrains the institution. Per-GB ingestion pricing is the principal financial concern, and one that has been the subject of considerable institutional revisiting in recent years. The architectural mitigation is to keep the collectors portable, so that data flow can be adjusted (sampled, tiered, re-routed) without re-instrumenting the sources, and so that exit from Splunk would be a re-routing of the collector layer rather than a re-foundation of the audit pipeline.

When it could be the right choice. An institution with mature Splunk operations, a financial framework that absorbs the per-GB exposure, and a sovereignty posture that accepts the data and institutional dimensions trade-offs in exchange for the analytical depth.

12.6 Alternative 2 — Microsoft Sentinel with Log Analytics

Alternative — Microsoft Sentinel

The institution operates Microsoft Sentinel [68↗] on Log Analytics in a designated regional tenancy. Integration with Entra ID-based identity and Microsoft 365 estate is direct; integration with non-Microsoft layers (Linux compute, OpenStack, Ceph) flows through OpenTelemetry collectors that translate to the Log Analytics ingest format.

Where it adds value. Tight integration with the Microsoft estate, where one is already in place, and the cloud-native operating model that reduces the institutional infrastructure burden.

Where it constrains the institution. The data dimension considerations of Chapter 3 of the Technical Reference apply here as in §8.5: Sentinel processes the institution's audit events in the supplier's cloud, under conditions that the institution should evaluate explicitly against its disclosure regime. The technical and institutional dimensions are bounded by Sentinel's product roadmap.

When it could be the right choice. An institution already operating its identity and endpoint layers on Microsoft products, where Sentinel's integration depth produces a meaningful operational simplification, and where the data-dimension trade-off has been evaluated explicitly.

12.7 Sovereignty grid applied

Table 12.2: Per-dimension sovereignty profile of the observability instantiations.

Dimension	Reference (Vector+Kafka+OpenSearch+Loki)	Splunk + OTel	Sentinel + Log Analytics
Data	3 Robust	2 Established	1 Partial
Technical	3 Robust	1–2 Partial	1 Partial
Financial	2 Established	1 Partial	1–2 Partial
Operational	2 Established	3 Robust	3 Robust
Institutional	3 Robust	1 Partial	1 Partial

Driving indicators by dimension. Data: storage location, disclosure regime, retention policy. Technical: source visibility, schema preservation across the pipeline. Financial: cost predictability under volume growth, exit cost. Operational: skills market depth and analytical sophistication. Institutional: roadmap control over the schema and over the alerting model.
The observability layer surfaces the financial dimension of the sovereignty grid more sharply than most others, because the per-volume pricing of the commercial alternatives interacts directly with the institution's instrumentation discipline: the more visible the institution makes itself to itself, the more it pays the supplier. The architectural mitigation is to decouple instrumentation from analytical-store choice, so that the institution can manage volume tactically without losing the activity it has chosen to make visible.

12.8 Regulatory anchoring

The observability layer produces the records on which several regulatory obligations rest. Under the applicable data protection regime it contributes to its records-of-processing obligation (derivable from the canonical TAC schema), its breach-notification obligations (through detection and timeline reconstruction) and its security-of-processing obligation (through monitoring effectiveness). Under the applicable cybersecurity baseline regime it operationalises the incident-handling

requirement and the regime's incident-reporting timelines (early warning, full notification, and final report), with the audit pipeline as the primary timeline-reconstruction substrate. The layer is the principal anchor of 27001 A.8.15 (logging) and A.8.16 (monitoring activities) and contributes to NIST CSF DETECT (DE.CM, DE.AE) and RESPOND (RS.AN — analysis). Detailed mapping in Chapter 33 of the Technical Reference §33.5, §33.6, §33.11, §33.9.

12.9 Common pitfalls

Common pitfall — Per-GB cost trap

A commercial SIEM whose pricing scales with ingestion volume creates an incentive to under-instrument: events are sampled, dropped, or routed elsewhere to keep the bill manageable, and the visibility of the institution to itself becomes a financial variable rather than a security one. The mitigation is the collector-layer decoupling described in §12.4: ingestion volume becomes a tactical question that does not require re-instrumenting the sources.

Common pitfall — Schema drift between sources

Each producing layer expresses events in its own format; without a canonical schema enforced at the collector, the analytical store accumulates events whose fields cannot be reliably correlated. Incident response that depends on `correlation_id` discovers, mid-incident, that the field is present only on some sources. The mitigation is to make the canonical schema of §12.3 a contractual obligation of the collector layer, and to verify the obligation in the conformance suite of Chapter 16 of the Technical Reference.

Common pitfall — Undocumented retention

The retention duration of the analytical store is the result of the chosen storage tier, the cleanup job's schedule, and the supplier's defaults — which together produce an actual retention different from the institution's intended policy. The mitigation is to publish the retention schedule per event class and to verify it through deliberate retrieval at the documented horizon.

Common pitfall — Sampling that breaks correlation

Volume management often takes the form of sampling: keep one event in N for a given class. Sampling that drops events from the middle of a TAC activation breaks correlation: the surviving events of the activation lose their context. The mitigation is to sample by TAC session, not by event: either an entire session is retained, or none is. Per-event sampling should be reserved for event classes that do not participate in correlation.

Chapter 13

Cryptographic services

Dependencies

This chapter applies the layer template of Chapter 6 of the Technical Reference to the cryptographic-services layer. It underpins the assertions of Chapter 6 of the Technical Reference, the encryption at rest of Chapter 10 of the Technical Reference (including the HYOK live-path of D10.6), and the device certificates of Chapter 11 of the Technical Reference. The layer belongs to the *Subject and trust plane*.

The cryptographic-services layer is the foundation on which the trustworthy assertions of every other layer rest: the certificates that authenticate institutional services, the secrets that applications consume, the keys that protect data at rest. It is also the layer where errors are the most consequential: a compromised intermediate certificate authority, an unrotatable key, or a secrets store whose backup is missing each translate into incidents whose remediation is institution-wide.

13.1 Functional role and interface contract

Interface contract — Cryptographic services

A compliant cryptographic-services layer must:

- operate an institutional certificate authority hierarchy whose trust anchor is held in hardware (HSM accessed through PKCS#11 [34↗]) under institutional custody;
- issue end-entity certificates through ACME [35↗] for machine-readable workflows, and through a documented manual or automated procedure for endpoint certificates;
- provide a secrets-management facility (key-value, dynamic secrets, transit encryption) accessible through documented APIs and integrable with the policy layer for access decisions;
- support a Bring-Your-Own-Key arrangement for any external service that consumes institutional cryptographic material;
- provide a Hold-Your-Own-Key live-path arrangement for the higher-classification data of Chapter 10 of the Technical Reference (D10.6), in which keys never leave the institutional HSM in cleartext;
- produce audit events conformant to the canonical TAC schema of Chapter 12 of the Technical Reference (§12.3).

13.2 Reference instantiation: open-source ACME CA + secrets-management platform + software or hardware HSM

Reference instantiation — Cryptographic services

Topology. An open-source ACME-capable certificate authority — for example `step-ca` [69↗] (Smallstep) — operates the institutional certificate authority, exposing ACME for machine issuance and standard interfaces for human-driven workflows. An open-source secrets-management platform — for example HashiCorp Vault [57↗] — provides secrets management with an envelope-encryption (transit) engine (consumed by Chapter 10 of the Technical Reference) and a PKI engine as a complementary issuance path. The trust anchor of the CA hierarchy is held in an HSM exposed through PKCS#11: representative choices are a software HSM (such as SoftHSM [70↗]) for non-production environments and a hardware HSM (such as Nitrokey HSM, YubiHSM, or comparable) for production. For HYOK live-path operation, the storage layer's encryption requests are forwarded to the HSM through a thin PKCS#11 broker that the institution operates.

Operational considerations. The reference instantiation would typically require a small dedicated staffing allocation — a fractional engineering capacity shared with the security and identity teams, sized to the institution's scale — plus institutional governance for the CA hierarchy (root rotation, intermediate rotation, revocation procedures). The principal recurring effort is operational discipline rather than ongoing engineering: most of the value comes from following the documented procedures, not from continuously evolving the configuration.

Real-world reference — Public infrastructure precedents

The ACME ecosystem at internet scale, exemplified by Let's Encrypt and the IETF RFC 8555 specification, demonstrates that automated certificate issuance is operationally robust. Most research and education networks operate certificate services for their members with comparable patterns; specific institutional configurations should be confirmed against current public documentation when cited.

13.3 Alternative 1 — Active Directory Certificate Services + commercial HSM

Alternative — AD CS

The institution operates a Microsoft Active Directory Certificate Services hierarchy with a commercial HSM (Thales Luna, Entrust nShield, or comparable) holding the trust anchor. ACME is exposed through a connector or front-end so that the certificate-issuance interface to applications matches the reference contract.

Where it adds value. For institutions whose Microsoft estate already includes AD CS, the operational simplification of keeping the certificate authority in the same administrative boundary is substantial. Commercial HSMs have well-documented certifications (FIPS 140 levels) that may be required by specific research mandates or regulatory contexts.

Where it constrains the institution. ADCS expresses issuance policy in templates whose semantics are Microsoft-specific; bridging to the standard contract requires the ACME connector to translate faithfully, and the connector becomes itself a critical component. Commercial HSMs introduce per-device licensing and a vendor relationship in the cryptographic-services layer that the reference instantiation avoids.

When it could be the right choice. An institution with mature AD CS operations and either a regulatory or research requirement that the chosen HSM specifically satisfies, where the operational continuity outweighs the sovereignty cost on the technical and financial dimensions.

13.4 Alternative 2 — External CA via ACME standard

Alternative — External CA via ACME

The institution does not operate its own institutional CA hierarchy beyond what is required for internal services, and relies on an external commercial CA (Sectigo, DigiCert, GlobalSign) or on Let's Encrypt for public-facing certificates, all consumed through the ACME standard. Internal services and HYOK arrangements remain on the institutional Vault and HSM.

Where it adds value. For public-facing certificates, an external CA whose trust roots are pre-installed in browsers and operating systems eliminates an institutional concern (browser trust) that the reference instantiation would have to address through manual root distribution. Let's Encrypt in particular has demonstrated that an external CA exposed through ACME is operationally compatible with the architecture's standards-only posture.

Where it constrains the institution. The institution depends on the external CA's continued operation and on its acceptance criteria. For public-facing services this dependency is modest (multiple CAs are interchangeable through ACME); for research-specific or regulatory contexts it may be more constraining. The financial dimension is excellent for Let's Encrypt and predictable for commercial CAs; the technical dimension inherits the CA's open or proprietary posture.

When it could be the right choice. As a complement, not a substitute, for the institutional CA: external CAs handle public-facing certificates while the institution retains sovereignty over its internal hierarchy.

13.5 Sovereignty grid applied

Table 13.1: Per-dimension sovereignty profile of the cryptographic-services instantiations.

Dimension	Reference (open-source CA + secrets platform + HSM)	AD CS + commercial HSM	External CA via ACME
Data	3 Robust	2 Established	2 Established
Technical	3 Robust	2 Established	2 Established
Financial	2 Established	1 Partial	3 Robust
Operational	2 Established	3 Robust	3 Robust
Institutional	3 Robust	2 Established	2 Established

The cryptographic-services layer is the layer in which the sovereignty trade-offs are typically the smallest in absolute terms (none of the alternatives is structurally below Established on any dimension when adopted with discipline) and the largest in practical consequence (a misalignment here propagates to every layer that depends on cryptographic assertions). The architectural posture is to keep the trust anchor under institutional custody regardless of the operational instantiation, and to choose the operational instantiation according to the institution's existing investments and regulatory context.

13.6 Regulatory anchoring

The cryptographic-services layer is the trust-anchor and key-custody substrate. It is the principal anchor of the applicable cybersecurity-baseline regime's cryptography requirements (in the European Union, NIS2 Art. 21(2)(h) — cryptography policies and procedures) and contributes to the applicable data protection regime's encryption and pseudonymisation obligations (in the European Union, GDPR Art. 32(1)(a)). It is also the operational counterpart of the applicable electronic-identification and trust-services regime (in the European Union, eIDAS 2: qualified electronic signatures, seals and time stamps, when the institution provides them). The layer operationalises 27001 A.8.24 (use of cryptography) and contributes to NIST CSF PROTECT (PR.DS — data security, encryption at rest and in transit). Detailed mapping in Chapter 33 of the Technical Reference §33.5, §33.6, §33.10, §33.11, §33.9.

13.7 Common pitfalls

Common pitfall — Trust anchor without an HSM

An institutional CA whose root or intermediate keys live on a workstation or a server filesystem is one disk image away from an institution-wide trust collapse. The mitigation is to hold the trust anchor in an HSM under institutional custody, and to exercise the recovery procedure periodically as part of Chapter 16 of the Technical Reference.

Common pitfall — Key escrow drift

The institution declares a key-escrow policy (which keys are escrowed, where, accessible by whom, under which procedure) and maintains it nominally; the actual escrowed keys, the actual custodians, and the actual procedure drift from the policy over years. Discovery typically occurs during a custodian transition or an incident. The mitigation is to verify the escrow state at the same cadence as the sovereignty grid (annual + event-driven).

Common pitfall — ACME outage with no fallback

An ACME-driven certificate renewal pipeline whose upstream CA is temporarily unavailable can produce service outages: certificates expire because the renewal pipeline cannot issue new ones. The mitigation is to provision certificates with a margin against renewal failures (renew well before expiry), to monitor the renewal pipeline through the observability layer, and to maintain a documented manual-issuance fallback procedure for the highest-criticality services.

Common pitfall — CA hierarchy not documented

The institutional CA hierarchy — root, intermediates, issuing CAs, their key strengths, their validity periods, their rotation schedules — is documented either incompletely or in a form that is not currently accessible. Replacement or extension becomes a recurring archaeology project. The mitigation is to maintain the hierarchy documentation under version control, with the same review cadence as the policy corpus.

Chapter 14

Orchestration plane

Dependencies and acknowledged gap

This chapter applies the layer template of Chapter 6 of the Technical Reference to the orchestration plane. As Chapter 5 of the Technical Reference (§5.3, D5.3) acknowledges, this is the layer where no single standard consolidates the required functionality. The chapter's purpose is to bound the consequences of that gap by composing components on standards-aligned sub-interfaces, by keeping the composition declarative, and by treating the orchestrator itself as replaceable infrastructure rather than as institutional knowledge in code. The layer belongs to the *Control and governance plane*.

The orchestration plane is the glue that turns a TAC activation decision into the cross-layer commands that realise it. When the policy layer returns "allow role X for resource Y in zone Z" for a given subject, the orchestration plane is what tells the network to attach the subject to zone Z, tells the compute layer to provision the workload context, tells the storage layer to bind the appropriate volumes, and tells the observability layer to start the correlation trace. The plane is consequently both critical (without it nothing happens) and exposed to lock-in (the supplier whose orchestration patterns the institution adopts becomes a structural dependency).

14.1 Functional role and interface contract

Interface contract — Orchestration plane

A compliant orchestration plane, in the sense of this architecture, must exhibit four properties rather than speak a single standard:

- **Event-driven.** The plane reacts to TAC activation and deactivation events emitted by the policy layer; it is not polled, scheduled, or driven by side channels.
- **Idempotent.** Re-issuing the same activation produces the same end state; partial failures and retries are safe by construction, not by good operational fortune.
- **Observable.** Every step the plane takes is recorded as an event conformant to the canonical TAC schema of Chapter 12 of the Technical Reference (§12.3), with the `correlation_id` preserved across the entire activation.
- **Reversible.** The deactivation of a TAC undoes every consequential change the plane made under it, in a documented procedure that the institution can audit and exercise.

Why properties rather than a standard. The four properties together form the plane's semantic contract. They can be satisfied by different technical compositions: workflow engines with explicit step-by-step execution, declarative reconcilers that converge on a target state, or hybrid arrangements that combine both. The architecture commits to the properties; the choice of composition belongs to the institution.

14.2 Reference instantiation: declarative GitOps reconciliation with composable workflows

Reference instantiation — Orchestration plane

Topology. A GitOps repository expresses the declarative target state of the institution's composed infrastructure — network attachment policies, compute namespaces, storage bindings, observability collectors, identity client registrations. A declarative reconciler — of which open-source continuous-delivery controllers such as Argo CD [71↗] or Flux are representative — ensures that the running state converges on the repository state. Workflow logic that does not naturally fit the declarative model — for example, the multi-step provisioning of a research workspace that needs explicit ordering and conditional branches — is expressed in a container-native workflow engine, of which Argo Workflows [72↗] is a representative open-source instance, with workflow definitions also held in the GitOps repository. A control-plane provider framework — the open-source Crossplane [73↗] project being one such instance — provides the infrastructure-as-code layer that lets the same declarative model reach beyond Kubernetes itself, into the virtualisation platform, into the network layer's RADIUS configuration, and into the storage layer's volume management. TAC activation events from the policy layer are received as CloudEvents and trigger either a reconciliation or a workflow, depending on the activation type. Every step emits events conformant to the canonical schema.

Operational considerations. The reference instantiation is the most demanding of the layer chapters in terms of *integration* skills, although each individual component is broadly skilled. The principal recurring effort is composition: keeping the GitOps repository, the workflow corpus, and the control-plane provider definitions consistent with each other and with the upstream layers they touch. An indicative envelope, for a typical research-intensive institution, would be on the order of two to four engineers shared with the platform-engineering function. The labour market is broad for the individual components and currently narrow for their integrated composition.

Composition discipline. The architectural posture is to treat the composition itself as institutional artefact: the GitOps repository, the workflow corpus, and the provider configurations are versioned and reviewed with the same discipline as the policy corpus of Chapter 7 of the Technical Reference. The institution that lets these artefacts drift loses the property of replaceability for the orchestration plane, even if each individual component remains replaceable.

Real-world reference — Orchestration patterns in industrial and research settings

The cloud-native orchestration ecosystem — the family of open-source GitOps reconcilers, container-native workflow engines, control-plane provider frameworks, pipeline engines, and durable workflow engines, of which Argo, Flux, Crossplane, Tekton, and Temporal are representative members — is broadly deployed in industrial settings, with publicly available reference architectures from the projects' member organisations. Specific academic deployments tend to combine these patterns with institution-specific composition, and are less extensively documented in public fora. The phase-2 international university network anticipated by this Reference would be one of the contexts in which a shared library of academic orchestration compositions might emerge.

14.3 Alternative 1 — ITSM-driven orchestration with Ansible

Alternative — ServiceNow/Jira + Ansible

The institution operates an existing IT service management platform (ServiceNow, Atlassian Jira Service Management, or comparable) that triggers Ansible playbooks (in Ansible Automation Platform or open Ansible) when service requests match TAC activation patterns. The four contractual properties are realised through workflows defined in the ITSM platform and idempotent playbooks executed by Ansible.

Where it adds value. For institutions with a mature ITSM platform and existing investment in Ansible operations, the operational continuity is substantial. The audit trail produced by the ITSM platform is well-developed, and the integration with change-management processes is direct.

Where it constrains the institution. ITSM workflow languages tend to be supplier-specific; expressing the four properties in those languages typically produces logic that is not portable across ITSM platforms. The architectural posture is to keep the workflow logic minimal in the ITSM platform and to delegate the consequential actions to standard Ansible playbooks held under version control — treating the ITSM platform as a trigger-and-audit surface rather than as the orchestration logic itself.

When it could be the right choice. An institution whose existing ITSM and Ansible operations carry the operational weight, and whose sovereignty posture accepts the trade-offs in exchange for the integration with established change-management practice.

14.4 Alternative 2 — Custom orchestrator on a durable workflow engine

Alternative — Custom on Temporal or comparable

The institution writes a bespoke orchestrator on a durable workflow engine (Temporal.io [74↗] being the principal open-source example, with comparable patterns available in other engines). Workflows are expressed in a programming language with the engine's SDK, with the engine providing durability, replayability, and at-least-once execution.

Where it adds value. For institutions whose orchestration needs include long-running workflows (multi-day provisioning, multi-stage research-environment lifecycle) where the declarative model would be awkward, a durable workflow engine provides the right semantics. Replay-based debugging and deterministic re-execution are operationally substantial benefits.

Where it constrains the institution. A custom orchestrator written in a programming language risks accumulating institutional knowledge in code that the standard interfaces do not capture: an exit from the engine then becomes a re-implementation of the workflows. The mitigation is to keep the workflows expressing the four contractual properties and nothing else, delegating consequential actions to the layer-specific standard APIs.

When it could be the right choice. An institution with strong software-engineering capacity, with workflow needs that genuinely exceed what declarative reconciliation expresses, and with the discipline to keep the workflow corpus deliberately thin.

14.5 Sovereignty grid applied

Table 14.1: Per-dimension sovereignty profile of the orchestration instantiations.

Dimension	Reference (GitOps + control-plane providers)	ITSM + config-management	Custom durable-workflow engine
Data	3 Robust	2 Established	3 Robust
Technical	3 Robust	1–2 Partial	2 Established
Financial	2 Established	1 Partial	2 Established
Operational	2 Established	3 Robust	1–2 Partial
Institutional	3 Robust	1 Partial	2 Established

The orchestration plane is the layer where the *composition discipline* is more consequential than any individual component choice. An institution that adopts the reference composition without disciplined version control and review can score worse, on the technical and institutional dimensions, than an institution that adopts the ITSM alternative with rigorous practice. The grid scores above assume disciplined operation in each instantiation.

14.6 Regulatory anchoring

The orchestration plane is the deployment-and-change substrate. It contributes to GDPR Art. 25 (data protection by design through declarative defaults) and to NIS2 Art. 21(2)(c) (business continuity through declarative redeployability), (e) (security in development and maintenance), and (f) (effectiveness assessment, through GitOps-driven reconciliation that exposes drift). The layer operationalises 27001 A.5.30 (ICT readiness for business continuity), A.8.32 (change management) and contributes to NIST CSF PROTECT (PR.PS) and RECOVER (RC.RP — recovery plan execution). It also operationalises COBIT BAI06 (managed IT changes) and BAI10 (managed configuration). Detailed mapping in Chapter 33 of the Technical Reference §33.5, §33.6, §33.11, §33.9, §33.12.

14.7 Common pitfalls

Common pitfall — Orchestrator becomes the single point of failure

An orchestration plane that holds critical state in its runtime memory, in undocumented configuration, or in product-specific formats becomes the SPOF for the entire architecture: when it fails, no TAC can activate, deactivate, or be modified. The mitigation is the GitOps discipline: every consequential decision expressed in the repository, the runtime treated as derivable from the repository, the recovery procedure exercised periodically.

Common pitfall — State not versioned

Orchestration logic exists in three layers: the declarative target state, the workflow definitions, and the runtime configuration of the engines themselves. When the third layer is not under version control, the orchestration plane has no rebuildable definition: only its current running state. The mitigation is to bring all three layers under version control, including the engines' own configuration, and to treat non-repository changes as incidents.

Common pitfall — Hidden coupling to a supplier SDK

A workflow corpus written against a supplier's SDK accumulates idioms that the SDK encourages but that the underlying contract does not require. Migration to another engine becomes a re-write rather than a re-host. The mitigation is to express workflows against the

four contractual properties of §14.1, using the SDK only for the engine interaction, and to maintain a small set of representative workflows that have been ported between engines as part of the exit-rehearsal of Chapter 16 of the Technical Reference.

Common pitfall — Side-effects untracked

A workflow that, in the course of provisioning a resource, also creates side-channel changes (firewall rules added manually, DNS records inserted by an out-of-band procedure, secrets generated and stored in a non-canonical store) accumulates technical debt that the declarative model does not capture. The deactivation procedure then leaves orphans behind. The mitigation is to require every change to flow through the declarative model or through the workflow corpus — there is no admissible third path.

Chapter 15

Sizing reference points

Status of this chapter

The figures presented in this chapter are *indicative orders of magnitude* for a reference institution profile defined in §15.1. They are not measurements, and they do not substitute for the institution's own sizing exercises. Their purpose is to give the reader a sense of the scale at which the architecture has been considered, and to flag the points at which the architecture may need reshaping. Any institutional procurement or capacity-planning decision should be informed by direct measurement of the institution's actual workload, not by the ranges below.

15.1 Method and assumptions

Reference profile. The figures in this chapter assume a research-intensive university with the following indicative characteristics:

- approximately twenty-five thousand active subjects (staff, students, contractors, visiting researchers combined);
- approximately one thousand five hundred staff members with administrative or research roles requiring elevated access;
- on the order of five hundred active research projects with distinct workspace requirements;
- a mix of institutional, organisational-unit-level, and project-level workloads, including a non-trivial research-data footprint.

Scope of the figures. For each layer, two kinds of figures are given: *steady-state* ranges describing the load the layer is expected to sustain, and *peak* ranges describing the load the layer should be provisioned to absorb. Peak figures are not multiples of steady-state; they are the result of distinct phenomena (start-of-semester authentication surges, conference deadline storage pressure, end-of-year research-data ingestion).

Sources of variation. Actual figures at any institution are influenced by factors the reference profile does not capture: the proportion of remote versus on-campus subjects, the depth of the research-computing footprint, the mix of teaching modalities, the institutional federation activity, the openness posture toward visiting researchers. The ranges below would typically span the P25–P75 of institutions in the broad reference profile, with substantial overflow on either side.

15.2 Identity layer sizing

- Authentications per second, steady state: indicatively *a few to tens*; peak (start-of-day, post-incident re-authentication storms): indicatively *hundreds*.
- Concurrent active sessions: indicatively *thousands*; peak: indicatively *a few thousand*.

- Federation transactions per day (the academic identity interfederation inbound and outbound combined): indicatively *tens to hundreds of thousands*.
- SCIM provisioning operations per day: indicatively *thousands during steady state*; peak around academic- year boundaries can be substantially higher for a bounded period.

The principal sizing variable is not the user count but the authentication frequency, which is driven by session-lifetime conventions: institutions with short sessions and frequent re-challenge have peak rates an order of magnitude higher than institutions with long sessions.

15.3 Policy layer sizing

- Decisions per second, steady state: indicatively *tens to low hundreds*; peak: indicatively *a few hundred*.
- Decision latency budget: indicatively *below ten milliseconds at the 95th percentile* for online decisions (network attachment, application authorisation); higher budgets are admissible for asynchronous decisions (workload admission, batch operations).
- Bundle refresh cadence: indicatively *minutes*, with the ability to push out-of-band for urgent policy changes.

Policy-decision rate is dominated by the integration choices, not by the user population: a single authorisation check embedded in a frequently-called API endpoint can produce more decisions per second than the rest of the institution combined.

15.4 Network layer sizing

- Campus backbone capacity: indicatively in the range of *40–400 Gb/s aggregate*, with research-intensive institutions toward the upper end.
- Science DMZ throughput, where present: indicatively *at the same order as the backbone*, with the explicit architectural choice that the Science DMZ is not penalised by enterprise filtering.
- NAC transactions per day (wired plus wireless attachment and re-attachment): indicatively *hundreds of thousands to low millions*.
- IPFIX flow records per day: indicatively *hundreds of millions*, depending on flow-export sampling rate and on research traffic volume.

15.5 Audit and observability layer sizing

- Events per day, steady state: indicatively *tens of millions to hundreds of millions*, depending on the instrumentation density.
- Storage volume per day, steady state: indicatively *tens to low hundreds of gigabytes* after standard compression; peak can substantially exceed steady-state during incidents.
- Retention scenario (illustrative): hot-tier (indexed, searchable) for ninety days; warm-tier for one year; cold-tier (object storage, retrievable) for the period required by regulatory and audit obligations, typically several years.

The audit-layer figures are the most variable in this chapter: an institution that has not yet operationalised the canonical schema of Chapter 12 of the Technical Reference will produce a small fraction of these volumes; an institution that instruments aggressively without volume-management discipline can produce multiples of them.

15.6 FTE indicators per layer

The table below consolidates the indicative operational envelopes introduced in the layer chapters. Each row is a range, not a point estimate; rows are not additive (engineers are typically shared across layers within the same operational team).

Table 15.1: Indicative operational envelopes per layer (engineer-equivalents, shared with adjacent duties). Ranges are not additive.

Layer	Indicative range	Notes
Identity (Ch. 6)	2–4	Reference instantiation; subject lifecycle automation reduces the upper bound.
Policy (Ch. 7)	1–2	Skill investment substantial relative to the headcount.
Network (Ch. 8)	3–5	Largest envelope; reflects the integrated stack.
Compute (Ch. 9)	4–7	Sustained engineering investment for OpenStack + Kubernetes.
Storage (Ch. 10)	2–4	Ceph operations require dedicated familiarity.
Endpoint (Ch. 11)	3–6	Multi-OS coverage drives the count.
Observability (Ch. 12)	3–5	Often shared with security operations.
Crypto (Ch. 13)	1–2	Operational discipline more than ongoing engineering.
Orchestration (Ch. 14)	2–4	Composition is the principal effort.

Build versus run split. The ranges above describe steady-state operations. The build phase — the migration waves of Part III — typically requires an additional one to two engineer-equivalents per active wave for the duration of the wave, on top of the steady-state figures. Institutions running multiple waves in parallel should plan for the cumulative figure rather than expect efficient resource sharing across waves.

15.7 Scaling levers and breakpoints

The reference figures imply scaling decisions at certain breakpoints. The breakpoints below are indicative thresholds at which the architecture would benefit from reshaping; the exact threshold for any institution depends on its growth profile and on its operational patterns.

- **Identity above approximately fifty thousand subjects.** The single-cluster Keycloak deployment of the reference would benefit from horizontal partitioning, either by population (staff / student / external) or by federation role. Federation participation strategies may also need reshaping.
- **Audit above approximately five hundred gigabytes per day.** The single-cluster OpenSearch deployment of the reference would benefit from data-tier separation (hot indexed cluster, warm searchable cluster, cold object storage), and the analytical-store choice may need to be revisited if the institution had committed to a per-GB priced alternative.
- **Policy above approximately five thousand decisions per second.** The single-instance OPA deployment of the reference would benefit from sidecar deployment per critical application, with bundle distribution coordinated centrally.
- **Storage above the multi-petabyte threshold.** The single-cluster Ceph deployment of the reference would benefit from federation across multiple Ceph clusters with metadata coordination, and the operational team would need substantial expansion.
- **Multi-site institutions.** Institutions with multiple physical sites or with a research-cloud presence in multiple jurisdictions face additional design decisions (cross-site identity federation, cross-site policy consistency, cross-site audit correlation) that the single-site reference does not address. These would form the subject of a future revision of this chapter.

The breakpoints above are indicative thresholds; the architecture remains valid beyond them, but the specific composition of the reference instantiation may require adaptation. The sovereignty grid of Chapter 3 of the Technical Reference continues to apply at any scale; the per-layer instantiations do not.

15.8 Down-scaled profile for smaller and teaching-led institutions

The reference instantiation is sized for a research-intensive university; it is not a floor below which the architecture ceases to apply. The same nine layers and the same sovereignty grid hold for a smaller or teaching-led institution, but their instantiation collapses to a lighter profile:

- **Collapsed tiers.** The administrative, teaching and research planes that a large institution separates physically can be realised as logical segments on shared hardware; the distinction is enforced by policy and identity rather than by dedicated fabric.
- **Managed or mutualised compute and storage.** Where an institution lacks the scale to operate its own virtualisation and object-storage layers, these can be drawn from a national research cloud, a national research and education network service, or a managed provider under an appropriate data-processing agreement — the sovereignty requirement constrains *where* and *under what terms* data sits, not whether the institution owns the metal.
- **Optional Science DMZ.** The Science DMZ is justified by sustained high-volume research data transfer; a teaching-led institution without that traffic profile can defer it entirely without weakening the rest of the architecture.
- **Non-additive minimum team.** The role inventory of §15.6 describes responsibilities, not headcount: in a small institution several roles are discharged by the same person, and the figures there are not summed into a minimum staff count.

Down-scaling counterpart to the breakpoints. Just as §15.7 identifies the thresholds at which the reference instantiation must grow, the same logic read downward identifies what a smaller institution may legitimately omit or mutualise: each layer degrades gracefully to a managed or shared realisation as scale decreases, and the architecture is judged by the sovereignty grid it satisfies, not by the size of the estate that satisfies it. The conformance expectation for this profile is read accordingly: the exit-confidence index of Chapter 16 of the Technical Reference (§16.5) is a maturity trajectory, and for a mutualised layer the institution's confidence rests on the provider's contractual exit terms rather than on a self-run test.

A concrete minimal-core envelope. For planning purposes, a teaching-led institution adopting only the minimal core — Wave 0 governance, the Identity layer and the Observability layer, with compute and storage mutualised as above — can expect an indicative steady-state envelope on the order of three to five engineer-equivalents, shared across the roles rather than summed per layer. Mutualising compute and storage converts their local engineering effort into provider-management overhead rather than headcount; the Network layer collapses to logical segmentation on shared hardware; and the optional Science DMZ is deferred. Consistent with the rest of this chapter, the figure is an order-of-magnitude planning aid, not a floor or a conformance threshold: an institution that mutualises further layers trends toward the lower bound, and the responsibilities of §15.6 remain role descriptions discharged by shared staff.

Chapter 16

Conformance and replaceability tests

The contracts of Chapters 6–14 are stated as obligations on component behaviour; the conditions of replaceability of Chapter 5 of the Technical Reference (§5.2) are stated as properties. Without a mechanism to verify that the obligations are met and the properties hold, both reduce to declarations. This chapter operationalises them through a structured test suite that the institution exercises at agreed cadences and at every wave closure of Part III.

16.1 Why a conformance suite

A contract that cannot be checked is a slogan. The conformance suite is the artefact that turns each layer's contract from a procurement clause into a verifiable property of the running infrastructure. Three uses follow:

- **Acceptance.** A component is acceptable into production when it passes the tests applicable to its layer.
- **Drift detection.** A component that previously passed and now fails reveals operational or configuration drift before the drift becomes incident.
- **Wave closure.** A migration wave (Part III) closes by passing the relevant subset of the suite, not by the subjective judgement that "the migration is done".

The suite does not replace security testing, performance testing, or functional testing of the institution's applications. It tests that the architecture's contracts and replaceability properties hold, which is a different and structurally narrower question.

16.2 Test categories

Tests are organised in four categories.

Interface fidelity.
The component speaks the standard interface correctly. The test exercises the standard's defined behaviour and verifies the response.

Data portability.
The institution's data and configuration can be exported in a documented open format and re-imported into an alternative component without loss.

Exit rehearsal.
The replacement of the component by an alternative can be performed within a documented time window, with the institution's data preserved and its operations sustained. The test is performed on a representative subset; it is rehearsed, not merely simulated.

Decision auditability.
The events and decisions emitted by the component are sufficient to reconstruct any consequential action. The test takes a recorded decision and verifies that it can be replayed against the recorded inputs and policy version to produce the same result.

The four categories together correspond to the four conditions of replaceability of §5.2. A layer that scores well on fidelity but poorly on exit rehearsal is, despite appearances, captive.

16.3 Reference test suite per layer

The reference suite below organises the conformance tests in four categories across the nine layers. The suite is illustrative and is intended to seed the institution's own; tests should be added or removed as the institutional context warrants.

Table 16.1: Reference test suite (illustrative). Categories: F = Interface fidelity, P = Data portability, X = Exit rehearsal, A = Decision auditability.

Layer	Cat.	Test
Identity (Ch. 6)	F	OIDC discovery endpoint returns metadata conformant to OpenID Connect Discovery 1.0.
	F	Authentication assertion carries the institutional attribute schema, with no captive extensions in the assertion path.
	P	SCIM 2.0 user export and re-import on an alternative IdP preserves attributes and group memberships.
	A	Authentication and session-lifecycle events allow forensic reconstruction of any session.
Policy (Ch. 7)	F	PDP query API returns decisions in the canonical `{verdict, obligations, policy_version}` shape.
	A	Recorded decision replayed against recorded inputs and policy version produces an identical verdict.
	P	Policy bundle exported, re-imported into an alternative engine, produces identical decisions on a representative input set.
	F	Shadow-mode decisions are logged with the same fidelity as enforcing-mode decisions.
Network (Ch. 8)	F	NETCONF/YANG configuration apply succeeds without recourse to the supplier's management console (D8.7).
	F	RADIUS attachment yields the expected zone assignment given a representative subject.
	F	IPFIX flow records carry the canonical `correlation_id`.
	X	Configuration exported and partially re-imported on an alternative-vendor switch restores expected connectivity on a test segment.
Compute (Ch. 9)	F	Kubernetes API passes upstream conformance tests on the production cluster.
	P	Container image migration from the production registry to an alternative OCI-compliant registry preserves the image digest.
	A	SLSA attestations verify against expected provenance for a representative artefact.
Storage (Ch. 10)	F	S3 API operations on the production object store interoperate with an independent S3-compatible implementation on a representative test set.
	P	KMIP key migration to an alternative key manager preserves the key material's usability.
	A	Snapshot inventory matches the published retention policy without orphans.
	P	Classification labels preserved across an export-import cycle.
Endpoint (Ch. 11)	F	Posture data from each managed OS arrives at the policy layer in the canonical schema.
	F	Decommissioning of a representative endpoint executes the documented procedure end-to-end.
	P	MDM configuration profiles export to a documented format that an alternative MDM can consume on a representative subset.
Observability (Ch. 12)	F	Events from every layer arrive at the analytical store conformant to the canonical TAC schema.
	F	Retention horizon verified by deliberate retrieval at the documented limit.
	A	Cross-layer correlation via `correlation_id` succeeds for a representative TAC activation.
	X	Event re-routing from the primary analytical store to an alternative produces the same query results on a sampling window.
Crypto (Ch. 13)	F	ACME issuance conforms to RFC 8555 against the institutional CA.
	A	Key-escrow recovery procedure executes successfully on a representative escrowed key.
	X	HSM key migration to an alternative HSM preserves the key's

16.4 How to run a conformance day

A *conformance day* is a scheduled, time-boxed exercise of the suite, conducted by a cross-functional team. The reference structure is:

- **Scope.** The subset of tests applicable to the current scope (full institutional review, single layer, single wave closure).
- **Participants.** One engineer per affected layer, one observability operator (to retrieve replay material), one note-taker, and the operational owner of the scope.
- **Duration.** Indicatively, half a day for a single layer; one day for a full institutional review.
- **Output.** A structured report (§16.5) and a remediation timeline for any test that did not pass.

Cadence. For the layers the institution operates itself, the full applicable suite is exercised at a regular cadence (a yearly minimum is a reasonable default for a research-intensive operator; a down-scaled adopter sets the cadence in proportion to the layers it self-operates). Layer-specific subsets are exercised at the closure of each relevant wave (Part III), and ad hoc when a component is replaced or when its supplier announces a material change.

16.5 Reporting template

The conformance report records, for each test exercised:

- the test identifier and category;
- the result: *pass*, *conditional pass* (with documented condition), *fail*;
- the evidence: log excerpt, command output, screenshot, or artefact reference;
- the remediation owner and timeline, if applicable.

Exit-confidence index per layer. A summary index, on the same four-point scale as the sovereignty grid (0 Absent, 1 Partial, 2 Established, 3 Robust), is produced per layer based on the test results. The index reflects the institution's confidence that the layer can be replaced within a documented time window: 3 if all tests in all four categories pass; 2 if interface fidelity and at least one of data portability or exit rehearsal pass; 1 if only interface fidelity passes; 0 if interface fidelity is broken. The index is graded against the institution's own conformance test set: an institution extends the illustrative reference suite (Table 16.1) to cover all four categories for each layer it operates, so a 3 (Robust) is attainable wherever that coverage is implemented — the reference suite is a starting illustration, not the grading baseline.

The index is a maturity trajectory, not a day-one gate. The exit-confidence index measures where the institution stands on its path to replaceability; it is not a pass/fail compliance verdict and no institution is expected to reach 3 (Robust) on every layer at the outset. The starting baseline is diagnosed by the self-assessment of Chapter 4 of the Technical Reference, on the same four-point scale, and the trajectory and pace toward higher confidence are set by the playbook (Chapter 17 of the Technical Reference); the index then records progress along that trajectory. A smaller or teaching-led institution following the down-scaled profile (Chapter 15 of the Technical Reference, §15.8) may legitimately target a steady-state index below 3 on layers it consumes as managed or mutualised services: for such a layer the replaceability question is answered by the provider's contractual exit terms rather than by a test the institution runs itself.

16.6 Linkage with wave closure

Every wave of Part III closes by passing the conformance subset applicable to its scope. This is the mechanism that prevents the common failure mode of migration programmes: the change of product disguised as architectural progress. A wave that delivered a new identity provider

but did not pass the identity-layer data-portability and exit-rehearsal tests has not closed; the institution has merely changed supplier.

Wave-to-test mapping. The mapping is published in each wave chapter (Chapters 18–27) under the *exit criteria* heading. The reference mapping is, briefly: Wave 1 (Identity) closes against the Identity-layer tests; Wave 2 (Observability) against the Observability-layer tests; Wave 3 (Network) against the Network-layer tests; Wave 4 (Policy) against the Policy-layer tests; Wave 5 (Pilot) against the tests on the layers exercised by the pilot, across the categories they implement; Wave 6 (Endpoint) against the Endpoint-layer tests; Wave 7 (Audit and IR) against an Observability subset reinforced with audit-replay exercises; Wave 8 (Workload) against the Compute and Storage tests; Wave 9 (Lifecycle) against the Orchestration-layer tests. The Crypto layer (Ch. 13) is a cross-cutting foundation rather than a standalone wave: certificate and key services underpin Identity, so the layer is stood up as the technical prerequisite of Wave 1 (Identity), and its three tests — ACME/RFC 8555 issuance, key-escrow recovery, and HSM migration — close with Wave 1's exit criteria. With this, all nine architecture layers are closed across the roadmap.

The conformance suite is not a one-time effort. Its value accumulates over time, as the suite reflects the institution's specific risks, as the test results form a longitudinal record of the architecture's health, and as the suite itself becomes an artefact that the institution can share with peers, where it participates in a peer or research-network community.

Part III

Migration Playbook for Mixed Estates

Chapter 17

How to read this playbook

Dependencies

The playbook of Part III applies the architecture of Part II under the framework of Part I. It expects the reader to have completed the self-assessment of Chapter 4 of the Technical Reference, and to be familiar with the sovereignty grid of Chapter 3 of the Technical Reference and with the conformance suite of Chapter 16 of the Technical Reference, which closes every wave.

The playbook is structured as ten waves (Wave 0 to Wave 9) that, in combination, take an institution from its current brownfield position to the target architecture of Part II. The waves are not calendar phases: their sequencing is governed by their pre-requisite graph, and their pace is a function of the institution's operational rhythm rather than of an externally imposed timeline.

17.1 Objectives of the playbook

The playbook serves four institutional objectives that the wave structure of Chapters 18–27 then operationalises.

1. **Move from brownfield to target.** The principal objective is to take the institution from its current brownfield position — whatever that may be — to the target architecture of Part II. The waves are the units of that movement, and the institution's chosen trajectory (§17.4) determines how that movement is paced.
2. **Operationalise the sovereignty grid.** The grid of Chapter 3 of the Technical Reference is a deliberation instrument; the playbook makes it operational by turning it into the gating mechanism at procurement, at wave closure, and at every renewal. A wave that closes against the grid produces a documented sovereignty profile per affected component; a procurement that follows the playbook is informed by the grid before it is decided.
3. **Preserve reversibility.** Every wave is reversible at acceptable cost during a published window. The playbook treats reversibility as non-negotiable (Chapter 29 of the Technical Reference). The institution that follows the playbook does not commit to a one-way change.
4. **Generate a longitudinal record.** Conformance results, post-mortems, and re-assessment outcomes accumulate into a record that the institution uses for its own governance and that the international peer-comparison phase of this initiative depends on. The playbook is consequently not only a transformation tool but also a documentation discipline.

What the playbook does not promise. The playbook does not promise that every institution will reach the target architecture in a fixed period, that every wave will succeed at its first attempt, or that the architecture will be operationally identical at every adopting institution. The first two are managed through the pace options of §17.6 and the reversibility playbook of

Chapter 29 of the Technical Reference; the third is a feature, since the sovereignty grid permits institutional differentiation within the shared contract.

Failure mode to avoid. The most common failure mode of architecture-transformation programmes is the substitution of products without architectural progress: a new identity provider replaces an old one, but the institution has not gained sovereignty, replaceability, or auditability. The playbook guards against this through the conformance suite of Chapter 16 of the Technical Reference: a wave closes only when the conformance subset passes, and conformance verifies that the contracts of Part II hold — not merely that products have changed.

17.2 Vocabulary

The chapters of Part III use the following terms in stable senses.

Wave.
One discrete stage of the migration, with a stated goal, declared pre-requisites, a coexistence pattern that governs the period of the wave, exit criteria that close it, and reversibility criteria that allow it to be undone. Waves are numbered Wave 0 to Wave 9.

Trajectory.
One of the five migration paths through the waves, distinguished by the institution's starting position: *greenfield*, *brownfield single-suite-centric*, *brownfield hybrid*, *selective adoption*, or *deferred*. Each wave chapter develops the three principal trajectories (greenfield, brownfield single-suite-centric, brownfield hybrid) in detail, with selective adoption and deferred treated as cases that diverge from the framework.

Coexistence pattern.
A documented bridging arrangement between an incumbent and an incoming component during a wave. Coexistence is the operational state of the wave; it is not a transitional inconvenience but the principal engineering effort of the wave's duration.

Pre-requisite.
An institutional or technical condition that must hold before the wave begins. Each wave declares its pre-requisites in the wave chapter; the dependency map of §17.3 consolidates them.

Exit criteria.
The conditions under which the wave is considered closed. Exit criteria include the relevant subset of the conformance suite of Chapter 16 of the Technical Reference; they are not subjective.

Reversibility criteria.
The conditions under which the wave can be reversed at acceptable cost during a published window. Reversibility is non-negotiable in this playbook (Chapter 29 of the Technical Reference).

17.3 Wave dependency map

The waves do not unfold in strict sequence; they unfold under a dependency graph that allows certain waves to proceed in parallel and others to wait. The reference dependency structure is given in Table 17.1.

Table 17.1: Wave dependency structure. "Required" pre-requisites must be closed; "Recommended" pre-requisites strengthen the wave but do not block it.

Wave	Required pre-requisites	Recommended
0 — Foundations	— (entry point)	—
1 — Identity	0	—
2 — Observability	0	—
3 — Network	0	2 (to baseline flows)
4 — Policy	1, 2	3
5 — Pilot	1, 2, 3, 4	—
6 — Endpoint	1, 4	2, 5
7 — Audit & IR	2, 4, 5	—
8 — Workload	1, 3, 4	5
9 — Lifecycle	1–8 in some form	—

Wave 0 is the entry point for every trajectory: it establishes the governance and inventory without which the other waves cannot be evaluated. Waves 1, 2 and 3 (Identity, Observability, Network) can proceed in parallel after Wave 0 if the institution's available staffing profile provides the operational capacity to staff them. Wave 4 (Policy) requires both Identity and Observability. Wave 5 (Pilot) requires the four preceding waves and is the first opportunity to exercise the architecture end-to-end on a contained scope.

Reading the dependency map. An institution that has mature observability and identity but immature network segmentation can reasonably proceed with Wave 4 (Policy) before completing Wave 3 (Network), provided the policy enforcement boundary remains within the segments already secured. The dependency map is a constraint, not a strict ordering.

17.4 Trajectory selection matrix

The trajectory through the waves is a function of the institution's starting position, captured in the self-assessment of Chapter 4 of the Technical Reference. The matrix in Table 17.2 expands the heuristics of §4.7 with their operational implications.

Table 17.2: Trajectories through the waves, with their dominant characteristics. The Selective and Deferred profiles are tactically divergent and are treated as variations of the three principal trajectories.

Trajectory	Dominant characteristics through the waves
Greenfield	Rare; applies to new institutions or to a deliberate refoundation. The waves are sequential rather than coexistent because there is little to coexist with.
Brownfield single-suite-centric	A common starting point, especially for institutions whose estate is anchored on a single dominant productivity-suite incumbent. The playbook adds an open policy plane and an open observability collector layer in front of the existing incumbent-suite estate; that estate evolves at its own renewal pace.
Brownfield hybrid	Frequent where heterogeneous estates and at least one open-source identity component already coexist. The playbook substitutes proprietary components at renewal moments while preserving the open-source perimeter; the institution is rarely starting from zero on any wave.
Selective adoption	For institutions already largely aligned with the architecture. The playbook is used as a checklist, with waves run only on the non-aligned components.
Deferred	For institutions whose self-assessment shows heterogeneity without a dominant trend. Wave 0 is the first step, and the trajectory is re-baselined after that wave.

17.5 Minimum viable subset for resource-constrained institutions

The trajectories above describe *how* an institution moves through the full wave programme, and the pace options (§17.6) describe *how fast*. A resource-constrained institution may also legitimately adopt *less*: a minimal coherent core that delivers the size-invariant, legally compelled functions of Chapter 5 of the Technical Reference (§5.2) without committing to the full programme, and that can be extended later along the same dependency graph.

The minimal core. The dependency map (Table 17.1) defines this subset precisely: Wave 0 (Chapter 18 of the Technical Reference — governance and inventory), Wave 1 (Chapter 19 of the Technical Reference — sovereign identity) and Wave 2 (Chapter 20 of the Technical Reference — observability and the audit trail), with Wave 4 (Chapter 22 of the Technical Reference — policy) a natural next step once Identity and Observability are in place. Waves 1 and 2 depend only on Wave 0, so the subset is internally consistent and needs no later wave to function.

Why these waves. This core delivers exactly the functions that no institution offering a digital infrastructure can avoid: documented governance and inventory, sovereign authentication, and the observability and audit trail required under data-protection obligations and, where the institution is in scope, NIS2. It is the operational expression, in playbook terms, of the minimal necessary set of §5.2.

What it does not deliver — stated plainly. The minimal core does not provide the deeper network segmentation that contains a breach (Wave 3, Chapter 21 of the Technical Reference), managed endpoint fleet control (Wave 6) or sovereign workload and storage (Wave 8, Chapter 26 of the Technical Reference). A constrained institution defers these or consumes them as mutualised services (Chapter 15 of the Technical Reference, §15.8). The minimal subset is therefore a legitimate *steady state*, not an abandoned migration: the conformance index (Chapter 16 of the Technical Reference) is read as a maturity trajectory, and the institution extends the subset wave by wave when capacity allows.

17.6 Pace options

The reference pace options describe three indicative horizons for completing the playbook. They are operational planning aids, not contractual commitments: the actual pace is set by the institution's operational rhythm and by the renewal cycles of the components the playbook substitutes.

5-year compressed.
The playbook is run with significant parallelisation, with waves overlapping, and with substantial additional resourcing during the active period. This pace is appropriate for institutions whose strategic context warrants accelerated transformation (sovereignty risk crystallised by an incident, regulatory deadline, decisive executive mandate). It requires either substantial budget supplements or a willingness to defer other strategic initiatives for the duration. Risk tolerance is structurally higher.

7-year balanced.
The recommended default. Waves proceed largely in sequence with limited parallelisation, additional resourcing is moderate, and most waves close within their reversibility window without difficulty. This pace tolerates institutional rhythm changes (academic-year cadence, budget cycles, leadership transitions) without losing direction.

10-year gradual.
The playbook is run with minimal additional resourcing, with each wave aligned to the natural renewal cycle of the components it substitutes. Risk tolerance is structurally lower;

coexistence periods are longer; the institution accumulates less migration debt at any moment. This pace is appropriate for institutions whose context does not warrant acceleration and whose financial planning operates on multi-year horizons.

Pace and trajectory interact. A greenfield trajectory on a 10-year horizon is unusual; a brownfield-hybrid on a 5-year horizon is demanding. The combinations that an institution can sustain are bounded by its self-assessment results in Chapter 4 of the Technical Reference (Section E intent), and revising the pace is a normal part of operating the playbook.

17.7 Risk-and-reversibility philosophy

The playbook treats reversibility as a non-negotiable property of every wave. The reasoning is structural: an institution that commits to a transformation it cannot undo at acceptable cost has ceased to govern the transformation. Three practical commitments follow from the principle.

- Every wave declares a *reversibility window*: the period during which the wave can be reversed at acceptable cost. Outside this window, reversal is still possible but is treated as a new wave with its own planning.
- The *coexistence pattern* of a wave is the principal mechanism of reversibility: as long as the incumbent component remains operationally viable, the wave can be reversed by re-routing to the incumbent.
- The *exit criteria* of a wave include passage of the relevant conformance subset (Chapter 16 of the Technical Reference); a wave that closes without the conformance subset is not closed in this playbook's sense, regardless of stakeholder declarations.

When reversibility is forfeited. The principle is non-negotiable in normal operation; it admits exceptions when the institution's competent governing authority, at whatever level holds the mandate to bind the institution, accepts the loss of reversibility explicitly, in writing, against the sovereignty grid. The architectural posture is that such forfeits should be exceptional and that they should be revisited at every renewal as part of the sovereignty grid's annual review.

The remainder of Part III develops each wave in turn. Each wave chapter follows the same template: goal and dependencies, pre-requisites, coexistence pattern, the three principal trajectories, reversibility criteria, exit criteria, and a real-world reference where one is publicly documented.

Chapter 18

Wave 0 — Foundations

Dependencies

Wave 0 is the entry point of the playbook. It has no technical pre-requisite. It draws on the sovereignty grid of Chapter 3 of the Technical Reference, which the wave formally adopts, and on the self-assessment of Chapter 4 of the Technical Reference, which the wave conducts as part of its baseline inventory work. The vocabulary follows Chapter 17 of the Technical Reference.

Wave 0 is the wave that produces no technical change. Its purpose is to install the governance, the decision authority, and the baseline inventory without which the technical waves cannot be evaluated, prioritised, or financed. Institutions that skip Wave 0 typically rediscover its content midway through Wave 1 or Wave 2, under conditions less conducive to deliberation.

18.1 Goal and dependencies

The goal of Wave 0 is to establish four institutional artefacts that the rest of the playbook will reference:

- an executive mandate authorising the programme, with named sponsorship and a declared scope;
- a governance body — either dedicated or composed of an existing institutional body extended for this purpose — with decision rights over the programme's strategic choices;
- the formal adoption of the sovereignty grid of Chapter 3 of the Technical Reference as the institution's deliberation instrument for procurement, audit and renewal;
- a baseline inventory of the institution's current digital infrastructure, sufficient to populate the self-assessment of Chapter 4 of the Technical Reference and to derive the trajectory and pace of subsequent waves.

No technical change is undertaken in Wave 0. The wave is consequently the lowest-risk in the playbook and, simultaneously, the most consequential: every subsequent wave inherits its artefacts as constraints.

18.2 Pre-requisites

Wave 0 has no technical pre-requisite, but two institutional conditions must hold for the wave to begin meaningfully:

- the institution's leadership has accepted, in principle, that the programme will engage the sovereignty dimension of its digital infrastructure — not as a technical refactoring but as a deliberate policy commitment;
- the institution's existing IT and security functions are represented in the governance body, so that the programme's decisions are made in awareness of operational reality rather than in parallel to it.

Modest budget. A foundation budget — indicatively a small staffing envelope of a few staff-months to a low single-digit number of full-time-equivalent staff over the wave's duration, scaled to the institution's size — covers the inventory work, the governance secretariat, and the external review or peer consultation that the institution may choose to commission. Larger budgets at this stage are typically unnecessary and may bias the programme toward action before deliberation.

18.3 Coexistence pattern

Wave 0 has no coexistence pattern in the technical sense: there is no incumbent component to bridge against. The pattern is *institutional*: the new governance body and the new sovereignty deliberation overlay existing IT decision processes without displacing them. Procurement, change management, incident response all continue under their current arrangements; the new artefacts inform but do not yet bind those arrangements.

Avoiding parallel structures. An anti-pattern at this stage is the creation of a parallel governance structure that duplicates rather than extends existing decision rights. The mitigation is to integrate the new artefacts into existing bodies where possible (an IT Council adds the sovereignty grid to its agenda; a procurement committee adopts grid-based gating clauses) rather than create competing forums.

18.4 Trajectory: greenfield

For institutions in a genuinely greenfield position — new institutions, deliberate refoundations, or research initiatives incubated outside an existing institution — Wave 0 is the wave where governance is built from scratch around the sovereignty grid. The grid becomes the founding instrument, and the inventory is trivial because there is little to inventory. The trajectory is correspondingly compressed (typically under six months) but still non-trivial: the absence of existing structures requires the governance design to be more deliberate, not less.

18.5 Trajectory: brownfield single-suite-centric

For the starting point most common among institutions of the adopting institution's type and jurisdiction, Wave 0 is principally the work of *integrating* the sovereignty grid into an established procurement and governance practice that has historically operated around the incumbent suite's enterprise-agreement renewal cycles (e.g. a Microsoft Enterprise Agreement). The grid is examined against the institution's standard procurement clauses; gaps are documented but not yet remedied; the governance body's first task is to schedule the sovereignty grid's annual review against the next procurement cycle. The inventory work in this trajectory is dominated by the documentation of the incumbent suite's estate components, their contractual envelopes, and their data flows.

18.6 Trajectory: brownfield hybrid

For research-intensive institutions with mixed estates, Wave 0 is the work of *consolidating* a governance practice that often exists in fragments across faculty IT, central IT, and research-computing units. The sovereignty grid is the unifying instrument that allows these fragments to align on a common deliberation vocabulary. The inventory is more involved than in the single-suite-centric trajectory because the components are more diverse; this is a feature of the wave, not a delay.

18.7 Reversibility criteria

Wave 0 is the most reversible wave of the playbook: the executive mandate can be revoked, the governance body can be dissolved or reabsorbed into existing bodies, and the artefacts produced are informational rather than binding. The reversibility window is indefinite; reversal at any later stage is operationally costless, although the institutional cost of having undertaken the wave and not pursued it is reputational.

What Wave 0 does *not* commit to. Wave 0 does not commit the institution to any specific technical trajectory or pace. The trajectory and pace are determined by the self-assessment results during the wave, and they are themselves revisable at every wave closure thereafter.

18.8 Exit criteria

Wave 0 has no technical conformance subset, since it produces no technical change. Exit is consequently *procedural*: the wave is closed when the four institutional artefacts of §18.1 exist in writing, are accessible to the relevant teams, and have been reviewed by the governance body in its constitutive meeting.

- Executive mandate: signed, scoped, with named sponsor.
- Governance body: convened, with declared decision rights and meeting cadence.
- Sovereignty grid: formally adopted, with the procurement and audit cadences declared.
- Baseline inventory: published, with the self-assessment results derived from it and recorded.

Onward planning. The closure of Wave 0 produces the inputs for the trajectory selection of Chapter 17 of the Technical Reference and for the prioritisation of Waves 1, 2 and 3, which can proceed in parallel after Wave 0 provided the institution's operational capacity allows it.

Real-world reference — Governance body precedents

Public documentation of university IT governance bodies exists but is uneven. Patterns reported in national research-and-education-network community fora and in EDUCAUSE include institutional councils dedicated to IT strategy, joint senate–administration committees, and federated bodies that include faculty IT representatives. Among publicly documented examples are MIT's Information Technology Governance Committee (ITGC), reporting to the Provost and Executive Vice President, with related committees on infrastructure, policy, and projects; and the central University Information Services (UIS) at Cambridge supporting a collegiate model that combines central and college-level IT arrangements. The institution adopting the playbook should identify the governance precedents that resonate with its own constitutional framework rather than transposing wholesale.

18.9 Regulatory anchoring

Wave 0 is the governance-foundation wave. It is the principal anchor of the management-body-accountability obligation of the applicable national NIS2 transposition (corresponding to NIS2 Art. 20 on accountability for security measures and training) and of the controller-responsibility duty of the institution's applicable data-protection regime (in the EU baseline, GDPR Art. 24) when read at institutional level. It operationalises the management-system clauses of ISO/IEC 27001:2022 (clauses 4 "context of the organisation", 5 "leadership", 6 "planning", 7 "support"), the COBIT 2019 governance objectives EDM01 (governance framework) and EDM03 (risk optimisation), and the NIST CSF GOVERN function. The procurement-clause workstream initiated in this wave is also the entry point for the supply-chain-security obligation of the applicable national NIS2 transposition (corresponding to NIS2 Art. 21(2)(d)), operationalised

more fully at Wave 9. Detailed mapping in Chapter 33 of the Technical Reference §33.6, §33.11, §33.12, §33.9.

Chapter 19

Wave 1 — Identity and federation

Dependencies

Wave 1 applies the wave chapter template established in Chapter 18 of the Technical Reference. Its pre-requisite is Wave 0 (governance and inventory in place). It instantiates the identity contract of Chapter 6 of the Technical Reference, and its closure is gated by the four Identity tests of the conformance suite of Chapter 16 of the Technical Reference (§16.3).

Wave 1 is, in most institutions, the wave that produces the most visible operational change. The identity layer is touched by nearly every institutional service; a wave that succeeds here demonstrates that the playbook is operationally feasible, and a wave that struggles here typically reveals limitations in the governance established by Wave 0. The wave is consequently both critical and instructive.

19.1 Goal and dependencies

The goal of Wave 1 is to bring the institution's identity layer into conformance with the contract of Chapter 6 of the Technical Reference: a documented identity provider speaking standard interfaces (OIDC, SAML2, SCIM 2.0), a federation participation aligned with the applicable regional research-and-education identity federation, an attribute schema reviewable by the institution, and an authentication and assertion log ingestible by the observability layer.

What the wave does not undertake. Wave 1 does not introduce policy-as-code (Wave 4), does not refactor endpoint posture verification (Wave 6), and does not extend authentication to workloads beyond what the identity layer naturally supports. These are deferred to their respective waves; Wave 1's success criterion is the contract, not the wider activation logic.

19.2 Pre-requisites

Wave 1 has Wave 0 as its only required pre-requisite, but four operational conditions strengthen the wave when present:

- the existing identity provider is inventoried, with its federation contracts, attribute schema, and downstream application set documented;
- the institution's source-of-truth for staff and student populations is identified, with the lifecycle events (creation, role change, departure) understood operationally;
- federation-policy responsibilities are clarified — the institution knows which contracts it has signed with which federations and what attribute releases those contracts obligate;

- the network attachment of Chapter 8 of the Technical Reference is in a stable state (not being actively migrated under Wave 3), since identity changes that interact with network attachment are best made against a stable substrate.

19.3 Coexistence pattern

The principal engineering effort of Wave 1 is the coexistence of the legacy and the incoming identity providers during the migration period. Indicative durations are twelve to twenty-four months for brownfield trajectories and substantially shorter for greenfield; the actual duration is determined by the application portfolio's re-federation pace.

Federation bridge. The two identity providers are brought into a federation relationship: each issues assertions that the other can verify, applications can choose which provider to trust during the migration, and a session begun on one is recognisable to the other. The bridge is built on standard interfaces (SAML2 metadata exchange, OIDC discovery), so that neither provider becomes captive to the bridge configuration.

Application migration cohorts. Applications are migrated to the new provider in cohorts, typically organised by risk profile (least-critical first), by organisational unit (one unit at a time for distributed institutions), or by technical similarity (all OIDC-native applications, then SAML2-only). Each cohort's migration is reversible within an agreed window; the next cohort begins only when the previous cohort's reversibility window has passed without incident.

19.4 Trajectory: greenfield

For institutions in a greenfield position — no significant incumbent identity provider, or a deliberate decision to refound the identity layer — Wave 1 is the most direct of the three trajectories. The reference instantiation of §6.2 (an open-source identity provider with SCIM provisioning, joined to the applicable regional research-and-education identity federation) is built without the burden of coexistence; federation participation is established once; the application portfolio is integrated as it is built. Indicative duration is on the order of six to nine months.

19.5 Trajectory: brownfield on an incumbent proprietary identity suite

For a common brownfield position — an institution whose identity layer already runs on a pure-commercial identity provider — Wave 1 is the wave in which the institution's relationship with that incumbent proprietary identity suite is restructured rather than replaced. The architectural posture of the playbook is to retain the incumbent suite as the identity provider for operational reasons (skills market, integration with the institution's existing office-productivity estate) while adding the infrastructure that prevents that suite from becoming the institution's policy plane in addition to its identity plane.

Pattern: incumbent suite retained, external policy engine added in parallel. The institution retains the incumbent proprietary identity suite for authentication, federation participation, and SCIM provisioning. A new policy plane (Wave 4) is prepared in parallel, which will eventually take over the authorisation logic that the suite's proprietary conditional-access expressions currently encode. During Wave 1, that conditional-access configuration is documented, simplified where possible, and pinned to expressions whose translation to an open declarative policy language is known to be tractable. The objective is to bring Wave 1's exit criteria within reach *without* blocking on Wave 4.

What changes in Wave 1. The federation metadata is audited and, where necessary, brought into the applicable regional research-and-education identity federation in conformance with that federation's technical profile. The attribute schema released to downstream applications is reviewed and, where appropriate, reduced. The authentication and assertion logs are routed to the observability layer through OpenTelemetry collectors deployed in this wave. SCIM provisioning is verified end-to-end against an alternative IdP test environment, to demonstrate that exit-data export works.

What does not change. The conditional-access logic itself remains in place; it will be partially reproduced in the external policy engine during Wave 4. The office-productivity estate is unaffected. The institution's existing procurement framework for the incumbent suite continues through this wave.

Indicative duration. Twelve to eighteen months, dominated by the application portfolio's federation review and the SCIM provisioning verification.

19.6 Trajectory: brownfield hybrid

For research-intensive institutions with a mature, SAML-based inter-institutional federation stack (for example a Shibboleth deployment), Wave 1 is structured around the preservation of that investment. The architectural posture is that the existing federation stack remains authoritative for inter-institutional federation, and a local OIDC identity broker (for example a Keycloak instance) is introduced for local role activation, attribute enrichment, and the TAC session model that subsequent waves will exercise.

Pattern: federation stack retained, local OIDC broker added for local activation. Federation participation continues through the existing federation deployment, with its applicable-federation metadata, attribute-release commitments, and operational team unchanged. A new local broker instance is deployed as a component that consumes the federation's assertions, enriches them with institution-specific attributes, and emits short-lived OIDC tokens that downstream applications consume.

What changes in Wave 1. The local OIDC broker is provisioned and integrated with the existing source-of-truth via SCIM; the authentication flow "federation stack → local broker → application" is established for a first cohort of applications; the observability layer receives events from both the federation stack and the local broker. The federation contracts are not renegotiated; the metadata is not reissued.

What does not change. Inter-institutional federation behaviour, registration with the applicable identity federation, and the relationships with peer institutions remain unaffected. The applications that have not yet adopted the local broker continue to authenticate directly against the existing federation stack.

Indicative duration. Nine to fifteen months. Shorter than the incumbent-proprietary-suite trajectory because the federation work is largely already done; longer than the greenfield trajectory because the dual stack must be operated with discipline.

19.7 Reversibility criteria

Wave 1 is reversible at acceptable cost throughout the application migration period and for an additional grace period after the last cohort migrates.

- The legacy identity provider is kept warm — operational but with no new applications onboarding to it — for an indicative period of six to twelve months after the final cohort migration.
- Per-cohort rollback is the unit of reversal: a cohort that encounters difficulties is rolled back to the legacy provider while the diagnostic proceeds; only when the diagnostic is closed is the next cohort moved.
- The full-wave rollback procedure is documented at wave open and exercised in a tabletop manner before any production cohort migration.

19.8 Exit criteria

Wave 1 closes when the four Identity tests *and* the three Crypto-layer tests of the conformance suite of Chapter 16 of the Technical Reference (§16.3) pass on the new identity instantiation — certificate and key services are stood up here as the cryptographic prerequisite that identity depends on — when at least the agreed percentage of applications has been migrated, and when the governance body has reviewed the wave outcome.

- OIDC discovery endpoint conformant; attribute schema institutionally controlled; SCIM export-import on alternative IdP preserves attributes; authentication and session events forensically reconstructable. (Identity conformance subset.)
- ACME/RFC 8555 certificate issuance conforms against the institutional CA; key-escrow recovery executes on a representative escrowed key; HSM key migration preserves cryptographic identity. (Crypto conformance subset — the cryptographic foundation that identity is built on.)
- An institutionally agreed proportion of applications has been migrated, with the remainder either in a documented schedule or in the documented exception register.
- The governance body has reviewed the wave outcome and formally closed it, releasing the resources for the next waves.

Real-world reference — Identity migration precedents

Several research-intensive institutions are reported to have undertaken multi-year identity migrations of comparable scope. Among the publicly discussed: CERN's migration to an open-source SSO platform, ETH Zürich's federation evolution, and various campus deployments described in the research-and-education networking community (including national research and education network and EDUCAUSE community fora). Specific durations, application coverage, and operational outcomes should be confirmed against current public documentation before being cited; the patterns reported above are consistent with the trajectories described in this chapter.

19.9 Regulatory anchoring

Wave 1 establishes the identity-and-federation substrate. It contributes to GDPR Art. 32(1)(b) (access-control effectiveness) and Art. 25 (data minimisation through controlled attribute release), and operationalises NIS2 Art. 21(2)(i) (HR security and access control) and (j) (MFA and secured communications). It also operationalises eIDAS 2 trust services and notified-eID interoperability for institutions that participate in the EUDI Wallet ecosystem. The wave is the principal anchor of 27001 A.5.16, A.8.2 and A.8.5 and contributes to NIST CSF PROTECT (PR.AA — identity management, authentication and access control). Detailed mapping in Chapter 33 of the Technical Reference §33.5, §33.6, §33.10, §33.11, §33.9.

Chapter 20

Wave 2 — Observability baseline

Dependencies

Wave 2 applies the wave chapter template established in Chapter 18 of the Technical Reference. Its pre-requisite is Wave 0 (governance and inventory in place); it can proceed in parallel with Wave 1. It instantiates the observability contract of Chapter 12 of the Technical Reference, including the canonical TAC schema of §12.3, and its closure is gated by the four Observability tests of Chapter 16 of the Technical Reference.

Wave 2 is the wave that measures the institution before any substantial change is made to it. The reasoning is procedural: an institution that begins technical transformation without a baseline of its current state has no objective way to recognise regression. It is also the lowest-risk wave of the playbook — the wave is purely additive, and the existing logging arrangements continue unchanged for as long as the institution chooses.

20.1 Goal and dependencies

The goal of Wave 2 is to deploy a collector layer that captures events from every layer of the architecture in the canonical TAC schema of Chapter 12 of the Technical Reference (§12.3), to route those events to a portable ingestion pipeline, and to establish the retention schedule that the data classification warrants. The wave commits to the collector layer and the ingestion pipeline; it does not commit to a specific analytical store, which is treated as a substitutable consumer.

Why before other waves. Subsequent waves change operational state. Without a baseline, the change cannot be distinguished from drift, regression, or pre-existing condition. Wave 2's purpose is to make those distinctions possible.

20.2 Pre-requisites

Beyond Wave 0, four operational conditions strengthen Wave 2:

- the log sources of the existing infrastructure are catalogued, with their volume, format, and current retention documented;
- the institution's data classification scheme (or the intent to develop one) is articulated, since the retention schedule is keyed on it;
- the existing SIEM (or the explicit absence thereof) is acknowledged, with its contractual envelope documented;
- the security operations function and its staffing profile — whether delivered by an internal team, by a contracted managed-security provider, or by a distributed arrangement shared across units — is identified, since the wave will produce events that the function will consume.

20.3 Coexistence pattern

Wave 2 introduces no displacement. The existing log paths continue to operate; existing dashboards, alerts, and detection rules remain in place; the existing analytical store, if any, continues to receive its incumbent feed.

Collector layer in shadow mode. The new collectors are deployed at the event-producing sources and forward to the new ingestion pipeline (an open-source log-routing agent feeding an open-source distributed event-streaming bus). Initially, the events flow only into a development or staging analytical store, where the institution exercises the canonical schema, the retention policy, and the correlation patterns. The production analytical store — whether it remains the existing one or is migrated later — consumes from the ingestion pipeline only when the institution has decided which analytical store it wishes to commit to (a decision that is neither blocked nor pre-empted by Wave 2).

Operating two layers. For the duration of the wave, the institution operates the legacy log paths and the new collector layer simultaneously. The cost is real but bounded; the benefit is that any subsequent wave's regression is observable against the baseline established here.

20.4 Trajectory: greenfield

For institutions in a greenfield position, Wave 2 establishes the collector layer, the ingestion pipeline, and the analytical store together. There is no incumbent to coexist with, and the wave is correspondingly compressed (indicative duration four to six months). The greenfield trajectory has the freedom to commit to an analytical store at wave open, since the substitution risk is absent.

20.5 Trajectory: brownfield single-suite-centric

For institutions whose existing observability is dominated by a cloud-vendor-native SIEM (for example Microsoft Sentinel with Log Analytics), Wave 2 introduces an open-source collector layer, built on a vendor-neutral telemetry-collection standard, upstream of the incumbent SIEM, without displacing its role.

Pattern. Open-source collectors, such as those built on a vendor-neutral telemetry-collection standard, are deployed at every event-producing source (identity, network, endpoint, compute). The events are converted to the canonical TAC schema and forwarded to two destinations: the incumbent SIEM (which continues its role for the operational SOC) and a parallel open-source store (an open-source search-and-analytics engine or an open-source log-aggregation store) for portability and for the retention horizons that the incumbent SIEM's pricing makes unattractive. The institution retains the incumbent SIEM for the analytical-depth use cases and acquires the data-portability property of the architecture's contract.

What changes in Wave 2. The institution gains a canonical schema across its sources, an ingestion pipeline whose re-routing is tactical rather than structural, and a retention horizon for cold-tier events that does not pay the per-GB premium of the production SIEM. The collector deployment is itself conformance-tested before the wave closes.

What does not change. The incumbent SIEM remains the production SOC tool, with its dashboards, detections, and the team's familiarity. The incumbent vendor's licensing trajectory is unaffected by this wave; the institution gains the option to revisit it in future waves without operational disruption.

Indicative duration. Six to twelve months, dominated by the source-by-source deployment of collectors and by the canonical-schema enforcement effort.

20.6 Trajectory: brownfield hybrid

For institutions whose existing observability is built on Splunk or a comparable per-volume-priced analytical store, Wave 2 introduces the same collector layer upstream of Splunk, with the same parallel open-source store, for analogous reasons.

Pattern. Open-source collectors built on a vendor-neutral telemetry-collection standard deployed at every event-producing source, with conversion to the canonical TAC schema. The events flow to Splunk (incumbent SOC store) and to a parallel open-source search-and-analytics engine or log-aggregation store. Sampling decisions become tactical at the collector layer (D12.8: sample by TAC session, not by event), reducing the per-volume exposure to Splunk without losing the activity that the institution has chosen to make visible.

What changes in Wave 2. The volume reaching Splunk is brought under deliberate control; the parallel open store preserves the events that volume management would otherwise have discarded; the canonical schema is enforced uniformly, removing the schema drift that ad hoc Splunk-side parsing accumulates over years.

What does not change. Splunk remains the production analytical surface. The detection content (alerts, correlations, dashboards) is preserved.

Indicative duration. Six to twelve months.

20.7 Reversibility criteria

Wave 2 is structurally reversible: removing the collectors returns the institution to its prior state without operational impact. Three explicit conditions support this:

- the legacy log paths are not modified, so a removal of the new collectors leaves them operational;
- the analytical-store decision is deferred to a subsequent wave or wave-internal milestone, so no commitment is made that would be costly to reverse;
- the parallel open-source store, if exercised during the wave, is sized for the wave's purpose and can be decommissioned without contractual penalty.

20.8 Exit criteria

Wave 2 closes when the four Observability tests of the conformance suite of Chapter 16 of the Technical Reference (§16.3) pass on the new collector layer, when the agreed source coverage is achieved, and when the retention schedule is documented and verified.

- Events from every layer arrive in the canonical TAC schema at the parallel store; the retention horizon is verified by deliberate retrieval at the documented limit; cross-layer correlation via `correlation_id` succeeds on a representative test activation; event re-routing to an alternative analytical store succeeds on a sampling window. (Observability conformance subset.)
- Source coverage: the institutionally agreed proportion of event-producing sources is feeding the new collector layer. The remaining sources are either in a documented schedule or in the documented exception register.
- Retention schedule: published, with the documented horizons per data class, and verified at least once during the wave.

Real-world reference — Audit pipeline precedents

Several research-intensive institutions are reported to operate observability pipelines combining open-source collectors with commercial analytical stores. Specific architectures discussed in the fora of the national research and education network and the NREN CSIRT, and in the security operations environments of large research infrastructures, would benefit from being consulted in their current published form before being cited; the patterns described in this chapter are consistent with those reported in those settings.

20.9 Regulatory anchoring

Wave 2 establishes the observability and audit baseline. It is a key contributor to GDPR Art. 30 (records of processing, derivable from the canonical TAC schema), Art. 32 (security of processing, monitored through measurable indicators) and Art. 33–34 (breach notification, supported by the timeline-reconstruction substrate produced by the wave). It also supports the incident-handling obligations of the applicable national cybersecurity baseline regime — the national transposition of the NIS2 Directive where it applies — under its incident-handling provision (NIS2 Art. 21(2)(b)) and prepares the ground for that regime's incident-reporting timelines (NIS2 Art. 23), fully exercised at Wave 7. The wave is the principal anchor of 27001 A.8.15 (logging) and A.8.16 (monitoring activities) and of NIST CSF DETECT (DE.CM, DE.AE). Detailed mapping in Chapter 33 of the Technical Reference §33.5, §33.6, §33.11, §33.9.

Chapter 21

Wave 3 — Network segmentation

Dependencies

Wave 3 applies the wave chapter template established in Chapter 18 of the Technical Reference. Its pre-requisite is Wave 0; Wave 2 is recommended (to baseline current flows before changing the segmentation). It instantiates the network contract of Chapter 8 of the Technical Reference, in particular the zone catalogue of §8.2 (D8.6) and the standard-interface discipline of D8.7. Closure is gated by the four Network tests of Chapter 16 of the Technical Reference.

A note on the trajectory labels. The trajectory labels *brownfield single-suite-centric* and *brownfield hybrid* are used consistently across the playbook, with their meaning calibrated for identity, endpoint, and observability. In the network layer, the operationally relevant distinction is between single-vendor and multi-vendor estates rather than between Microsoft and non-Microsoft. The labels are retained for consistency; their meaning in this chapter is mapped accordingly.

21.1 Goal and dependencies

The goal of Wave 3 is to bring the institution's network infrastructure into conformance with the contract of Chapter 8 of the Technical Reference: a declared zone catalogue with documented security profiles per zone, standards-aligned attachment via RADIUS, declarative configuration via NETCONF/YANG (or equivalent), flow telemetry in IPFIX, and a Science DMZ where the research mission warrants it. The wave's success is measured against the zone catalogue and the standard-interface discipline, not against a complete refresh of the physical fabric.

What the wave does not undertake. Wave 3 does not require the institution to replace its network gear. It requires that the gear be operated through standards on the operationally relevant paths, that the zones be declared and enforced, and that the conformance tests of Chapter 16 of the Technical Reference pass on a representative sample.

21.2 Pre-requisites

Beyond Wave 0, four operational conditions strengthen Wave 3:

- a current inventory of network flows — ideally established by Wave 2 — so that the segmentation can be designed against actual usage rather than against assumed usage;
- an institutional addressing plan that supports the zone catalogue, with sufficient address space for the institution's planned growth (research, BYOD, IoT, or other drivers as applicable);
- a change-window agreement with the principal user constituencies (academic organizational units, research projects, administrative services), since per-segment cut-over requires scheduled downtime tolerable to those constituencies;

- an identified accountable team for the network operation, with authority to coordinate across organizational-unit IT functions where those exist independently.

21.3 Coexistence pattern

Wave 3 is the wave with the most spatially distributed coexistence in the playbook: the legacy flat network and the new zoned network operate together for as long as the institution requires, with the boundary of coexistence drawn at the building, the organizational unit, or the network segment level rather than at the institutional level.

Cut-over by perimeter. Each building, organizational unit, or segment is cut over to the new segmentation as a self-contained operation: the new zone is provisioned, the attachment service is configured, the flow telemetry is activated, and the segment is moved over. The remainder of the institution continues to operate on the legacy flat network during this period. Per-segment cut-over allows the institution to learn at modest scale before propagating the design.

Bridge between zones during coexistence. Some flows must traverse the boundary during coexistence (services in a migrated zone consumed by users in non-migrated buildings, for example). The bridge is built on routing rules under change control, with the explicit understanding that bridges are temporary; bridges that have not been retired within an agreed horizon are flagged for the governance body's attention.

Science DMZ established early. The Science DMZ, where present, is typically established early in the wave because its construction is largely orthogonal to the rest of the segmentation. Establishing it early demonstrates the architecture's research- serving capability and decouples its delivery from the broader cut-over schedule.

21.4 Trajectory: greenfield

For institutions in a genuinely greenfield network position — a new building, a new site, a research-network refoundation — the trajectory is direct: the zone catalogue is implemented from the start, the attachment service is the new RADIUS deployment, the Science DMZ is a separate fabric, and the gear is procured against the standard-interface contract. Indicative duration is six to nine months for a new building of moderate size; longer for site-scale greenfield, in which case the trajectory is split into staged sub-projects.

21.5 Trajectory: brownfield single-suite-centric

For institutions whose network is built around a single dominant vendor (a homogeneous Cisco, Juniper, Aruba, or Arista estate), Wave 3's principal task is to operationalise the standard interfaces of the existing gear without acquiring new equipment.

Pattern. The existing gear is configured through NETCONF/YANG (or its vendor-supported standard equivalent) for the operationally relevant changes. The vendor's management console is retained for diagnostic purposes only; production changes flow through the standard interface under version control. RADIUS attachment is reconfigured to consume identity attributes from Wave 1's identity layer; flow telemetry is brought into the collector layer of Wave 2.

What changes in Wave 3. The zone catalogue is declared, the attachment service is reconfigured for zone assignment, the Science DMZ is established, the standard-interface discipline is operationalised, and the conformance tests of §16.3 pass on a representative sample. The gear

itself remains on its current refresh schedule; its eventual substitution at refresh time is informed by the sovereignty grid but not predetermined by Wave 3.

What does not change. The physical topology, the cabling, the gear inventory, and the existing vendor relationship. The institutional procurement framework continues through this wave; the wave produces information that the next procurement cycle will use, not procurement decisions itself.

Indicative duration. Twelve to twenty-four months, dominated by the per-segment cut-over schedule and by the change windows that user constituencies tolerate.

21.6 Trajectory: brownfield hybrid (multi-vendor estate)

For institutions whose network is multi-vendor — often the result of acquisitions, organizational-unit-level autonomy, or research-network specialisation — Wave 3's principal task is to reconcile the configuration model across vendors while preserving the existing fabric.

Pattern. The institution adopts a declarative configuration management layer (for example an infrastructure-automation toolchain or a source-of-truth-driven configuration generator, or a comparable approach) that emits NETCONF/YANG to each vendor and tolerates the residual vendor-specific syntax for the cases where the standard does not yet cover the configuration in question. The zone catalogue is declared once at the institutional level and applied consistently across vendors.

What changes in Wave 3. The same zone catalogue and attachment behaviour are realised across the multi-vendor estate; flow telemetry is normalised at the collector layer (D12.3) regardless of the vendor's IPFIX dialect; the Science DMZ is established with the understanding that its specific gear may differ from the rest of the estate and that this is acceptable. The configuration is brought under version control across vendors.

What does not change. The vendor mix itself is not changed by this wave. Organizational-unit-level network autonomy, where it exists, is respected; the wave provides the institutional contract under which the autonomy operates, not a new central authority.

Indicative duration. Twelve to twenty-four months, similar to the single-vendor trajectory but with a higher initial investment in the cross-vendor configuration management layer and a correspondingly lower marginal cost per subsequent zone.

21.7 Reversibility criteria

Wave 3 is reversible at the per-segment level for an indicative window of three to six months after each segment's cut-over. Beyond that window, reversal is operationally possible but is treated as a new project rather than as a wave rollback.

- Each segment's pre-cut-over configuration is preserved in version control and is re-deployable if the post-cut-over state proves unworkable for that segment.
- Inter-segment routing rules established during coexistence are documented per segment, so that a reversal of one segment does not affect others.
- Where a vendor-specific standard interface proves operationally insufficient, the wave's response is documented — substitution at next refresh, retention with documented sovereignty cost, or partial retention — rather than a full-wave reversal.

21.8 Exit criteria

Wave 3 closes when the four Network tests of the conformance suite of Chapter 16 of the Technical Reference (§16.3) pass on a representative sample of the segmentation, when the agreed segment coverage is achieved, and when the Science DMZ (where present) operates against its measurement targets.

- NETCONF/YANG configuration apply succeeds without recourse to the supplier's management console; RADIUS attachment yields expected zone assignment; IPFIX flow records carry the canonical `correlation_id`; configuration export and partial re-import on alternative-vendor switch restores expected connectivity on a test segment. (Network conformance subset.)
- Segment coverage: the institutionally agreed proportion of segments has been cut over. The remainder is in a documented schedule.
- Science DMZ: where present, operating against its documented throughput and latency targets, with measurement data routed to the observability layer.

Real-world reference — Network segmentation precedents

The Science DMZ pattern, developed at ESnet (Lawrence Berkeley National Laboratory) and adopted at a number of research-intensive universities, is one of the most extensively documented patterns in academic network architecture. Multi-zone campus segmentation is reported in various forms across large research-intensive universities, among the institutions whose architectural choices have been discussed in academic and NREN community fora. At regional and global scale the equivalent function is met by NREN- and experiment-operated dedicated networks — the regional and national research and education networks' dedicated circuits [49↗] and the CERN LHCOPN/LHCONE fabric [46↗] — rather than by a campus enclave. Specific deployment details should be verified against current public documentation when cited.

21.9 Regulatory anchoring

Wave 3 establishes zone-based segmentation and attachment-time enforcement. It contributes to GDPR Art. 32(1) (security through technical measures applied at the network layer) and operationalises NIS2 Art. 21(2)(a) (risk-analysis applied to network design) and (g) (cyber-hygiene baseline including segregation). It is the principal anchor of 27001 A.8.20 (network security) and A.8.22 (segregation of networks) and contributes to NIST CSF PROTECT (PR.IR — infrastructure resilience). The Science DMZ pattern operationalises segregation specifically for high-throughput research traffic. Detailed mapping in Chapter 33 of the Technical Reference §33.5, §33.6, §33.11, §33.9.

Chapter 22

Wave 4 — Policy plane

Dependencies

Wave 4 applies the wave chapter template established in Chapter 18 of the Technical Reference. Its required pre-requisites are Waves 1 and 2: an identity layer that emits attributes in the institutional schema, and an observability layer that captures decisions. It instantiates the policy contract of Chapter 7 of the Technical Reference, with the mapping of identity attributes to the institutional schema specified in Chapter 7 of the Technical Reference. Closure is gated by the four Policy tests of Chapter 16 of the Technical Reference.

Wave 4 is, for most universities at the time of writing, the most ambitious novelty of the playbook. Few institutions today operate a dedicated policy decision point separate from their applications and identity provider. Adopting one is a real organisational change as well as a technical one: the institution acquires a new artefact (the policy corpus), a new governance process (policy authoring and review), and a new operational capability (decision auditability). The wave's success depends as much on the institutional change as on the technical deployment.

22.1 Goal and dependencies

The goal of Wave 4 is to deploy a policy decision point conformant to the contract of Chapter 7 of the Technical Reference, to migrate selected authorisation decisions from the identity-provider-native rules and from in-application logic into the policy plane, and to establish the policy authoring and review process under which the corpus will evolve.

Selected, not all. Wave 4 does not require that every authorisation decision in the institution be expressed in the policy plane. The wave's success criterion is that the plane exists, that it is conformant, that an institutionally agreed set of decisions has been migrated, and that the process for migrating further decisions is established. The transition of the rest of the corpus is the work of subsequent waves and of routine operations.

22.2 Pre-requisites

Beyond Waves 0, 1 and 2, three operational conditions strengthen Wave 4:

- the institutional attribute schema (D7.7) is stable; the identity layer of Wave 1 emits attributes against it;
- the existing authorisation logic — whether expressed in the identity provider's rules, in application configuration, or in code — is inventoried at the level of intent if not at the level of implementation;
- the security operations function (which will consume decision logs) is engaged with the canonical schema of Chapter 12 of the Technical Reference.

22.3 Coexistence pattern

The principal engineering pattern of Wave 4 is *shadow mode*: the policy decision point evaluates every relevant request and emits its decision into the audit trail, but the existing enforcement points continue to apply the incumbent authorisation logic. The institution thereby acquires the ability to compare proposed decisions against actual behaviour before any decision is moved to enforcing.

Per-policy transition. Each authorisation rule is migrated in three steps: it is expressed in the policy language; the resulting decisions are observed in shadow mode for an institutionally agreed period; if the discrepancy profile is understood and the institution accepts the proposed behaviour, the rule is switched to enforcing and the incumbent rule is retired. The transition is per-policy, not per-application; an application may have some of its authorisation in the policy plane and some still in its incumbent location for a substantial period.

Shadow observation period. An indicative period is two to four weeks per policy for routine rules, longer for rules with infrequent triggers (year-end administrative procedures, research-data extraction patterns, incident-response invocations) that may not be exercised within a shorter window. The observation period is set per policy, not by a single institutional rule, and is documented in the policy corpus alongside the policy itself.

22.4 Trajectory: greenfield

For institutions in a greenfield position, Wave 4 establishes the policy plane as the authorisation surface from the start: there is no existing authorisation logic to migrate from. The wave is correspondingly compressed but not trivial — the policy corpus must still be authored, the schema integration with identity verified, and the auditing trail exercised. Indicative duration is six to nine months.

22.5 Trajectory: brownfield single-suite-centric

For institutions whose authorisation logic resides primarily in the incumbent identity suite's conditional-access (or equivalent) expressions and in that suite's application-level configuration, Wave 4 introduces the policy plane in front of, not in place of, the existing authorisation arrangements.

Pattern. A standalone policy decision point is deployed alongside the incumbent identity suite. For each conditional-access expression identified in Wave 1's inventory, an equivalent policy is authored in the chosen policy language and exercised in shadow mode. The incumbent suite's conditional-access expression remains authoritative until the shadow comparison demonstrates equivalence; at that point, the institution decides whether to retire the vendor expression in favour of the policy-plane rule or to keep it as a defence-in-depth element.

What the wave does not promise. Wave 4 does not promise that all conditional-access expressions will be migrated. Some are unproductive to migrate (rules that genuinely belong with identity, such as MFA enforcement); some are operationally costly to migrate (rules that depend on vendor-specific signals not exposed to the policy plane); some are simply not worth the effort. The selection is institutional and is informed by the sovereignty grid: rules that confer roadmap leverage to the supplier are the priority candidates for migration.

Indicative duration. Twelve to eighteen months, dominated by the per-policy shadow observation and by the institutional debate over which rules to migrate.

22.6 Trajectory: brownfield hybrid

For institutions whose authorisation logic is scattered across standards-based federation attribute releases, open-source identity-broker authorisation policies, in-application configuration, and ad hoc code paths, Wave 4 is principally the work of *consolidation*.

Pattern. The policy plane becomes the surface against which scattered authorisation logic is gradually consolidated. The three steps of the per-policy transition apply to each candidate rule, regardless of where it currently resides. Rules that already live in standards-aligned components (open-source identity-broker authorisation policies expressed in standard ways) are migrated more easily; rules that live in application code require more engineering investment per migration.

What the wave changes. The policy corpus becomes the canonical home for institutional authorisation decisions. The governance of the corpus — review process, authoring rights, deprecation discipline — is established and exercised. The decision log becomes a reliable forensic resource.

Indicative duration. Twelve to eighteen months, with substantial variation depending on the spread of the incumbent authorisation logic and on the institution's appetite for code refactoring.

22.7 Reversibility criteria

Wave 4 is reversible at the per-policy level for as long as the incumbent authorisation logic is preserved as defence-in-depth. Beyond the point at which the incumbent rule is retired, reversal is operationally possible but is treated as a re-authoring of the incumbent rule rather than as a policy-plane reversal.

- The shadow / enforcing toggle is per policy and is exercised through the policy bundle distribution mechanism; reversal is the deployment of a new bundle, not the redeployment of the engine.
- An emergency disable procedure — a tested mechanism for switching the policy plane to permissive mode within minutes — is part of the wave's deliverables.
- The full-wave rollback procedure (return to the pre-Wave-4 authorisation arrangements) is documented at wave open and exercised in tabletop form before any production enforcement migration.

22.8 Exit criteria

Wave 4 closes when the four Policy tests of the conformance suite of Chapter 16 of the Technical Reference (§16.3) pass, when the agreed set of policies is enforcing, and when the governance process for the corpus is operating.

- PDP query API returns canonical decisions; recorded decisions replay identically; policy bundle export and re-import on alternative engine produces identical decisions on a representative input set; shadow-mode logging is at parity with enforcing-mode logging. (Policy conformance subset.)
- Migrated policy set: the institutionally agreed set of rules has been migrated and switched to enforcing; the remaining rules are either in a documented schedule or in the documented exception register.
- Governance: the policy corpus is under version control with a documented review process, and the first quarterly governance cycle has been completed.

Real-world reference — Policy plane adoption patterns

The policy plane is more thinly documented in academia than in industry. Industrial deployments of standalone policy engines at scale (publicly described at organisations including Netflix, Capital One and Pinterest) demonstrate that the per-policy shadow-mode pattern operates reliably under substantial load; their applicability to academic settings is conditional on the institution's specific authorisation profile. A cross-institutional academic network would be one of the contexts in which a shared library of academic-context policies might emerge.

22.9 Regulatory anchoring

Wave 4 introduces the policy plane as the per-request decision point. It contributes to the applicable data-protection regime's data-protection-by-design obligation enforced at decision time (e.g. GDPR Art. 25), and to the applicable cybersecurity-baseline regime's risk-analysis-policy and access-control-policy requirements (e.g. NIS2 Art. 21(2)(a) and (i)). Under the applicable AI regulation it is the locus where the prohibited-practices and transparency provisions (e.g. EU AI Act Art. 5 and Art. 50) admit a policy-plane enforcement: rules that gate AI-related TACs on context labelling and on prohibited-use classification. The wave operationalises 27001 A.5.15 (access control), A.5.18 (access rights) and A.8.3 (information access restriction) and contributes to NIST CSF PROTECT (PR.AA). Detailed mapping in Chapter 33 of the Technical Reference §33.5, §33.6, §33.7, §33.11, §33.9.

Chapter 23

Wave 5 — TAC pilot

Dependencies and template adaptation

Wave 5 applies the wave chapter template established in Chapter 18 of the Technical Reference with one adaptation: the principal differentiating variable is the chosen pilot scenario rather than the institution's starting position, so the chapter develops three illustrative scenarios (§23.4) and consolidates the trajectory discussion (§23.5). Required pre-requisites are Waves 1, 2, 3 and 4. Closure is gated by the union of conformance subsets corresponding to the layers the pilot exercises.

Wave 5 is the wave in which the architecture is exercised end-to-end, in production conditions, on a contained scope. It is the first wave that demonstrates the integration of the preceding waves, and the first opportunity for the institution to encounter the architecture's emergent behaviour — the combination effects that no single layer's testing can surface.

23.1 Goal and dependencies

The goal of Wave 5 is to operate one or more Trusted Activity Contexts in production, on a scope contained enough that failure of the pilot does not affect institutional services, and to extract from the experience the learnings that subsequent waves (Endpoint, Audit-and-IR, Workload, Lifecycle) will apply at larger scale. The pilot is consequently both a technical demonstration and an organisational learning event.

Pilot, not deployment. The wave does not promise generalisation of the chosen scenario across the institution. A pilot that succeeds operationally has produced what the wave required; further deployment is the work of subsequent waves and of the institution's own scaling decisions.

23.2 Pre-requisites

Beyond the closure of Waves 1 to 4, three operational conditions strengthen Wave 5:

- a participating faculty, research project, or service that has accepted to host the pilot, with named accountable contacts who will engage with the engineering team throughout;
- a pilot-specific governance arrangement, typically a small steering group composed of the pilot host, the programme sponsor, and the engineering lead, meeting at a higher cadence than the broader programme governance;
- a documented success-and-failure framework agreed at wave open, so that the pilot's outcome can be evaluated against declared criteria rather than against retrospective interpretation.

23.3 Coexistence pattern

Wave 5's coexistence pattern is structurally simpler than the preceding waves: the pilot operates in an isolated zone of the network and on isolated tenancies of the compute and storage layers, without affecting production services. Coexistence is spatial rather than temporal — the pilot and the production services share the institution's infrastructure but do not share critical operational paths.

Bounded blast radius. The architectural commitment of Wave 5 is that an incident within the pilot — a misconfiguration, a security event, a performance regression — does not propagate to production. The mechanisms that bound the blast radius (zone isolation, separate identity attribution, separate audit correlation) are part of the pilot's design.

23.4 Three illustrative pilot scenarios

The three scenarios below are illustrative; institutions choose the scenario that aligns with their strategic priorities, with their willingness to engage the pilot host, and with the sovereignty grid's current emphasis. The scenarios are not exclusive — an institution may run more than one pilot in sequence or in parallel — but a single first pilot is generally preferable to ensure the team's full attention.

23.4.1 Scenario A: Researcher-LLM-API

A research group requests scoped, audited access to a generative-AI cloud endpoint from a dedicated research zone, with data classification rules and a documented egress policy. The scenario surfaces most cross-cutting concerns at once: federated identity, policy decision combining role and posture, network attachment to a research zone, third-country data egress under the applicable cross-border data-transfer regime (in the EU, GDPR Art. 32 read with the *Schrems II* doctrine), audit aggregation across layers.

Activation sequence. The researcher authenticates through the institutional SSO and requests activation of a *Researcher-LLM-API* role. The identity layer issues a short-lived assertion. The policy layer evaluates the request against the institutional rules: role granted, posture verified, classification of the data the researcher intends to access permitted under the egress policy. The network layer attaches the researcher's session to the research zone with the appropriate egress allowance. The compute layer provisions or attaches the research workspace. The storage layer binds the project volumes with the classification labels active. Every step emits events under the canonical TAC schema.

Why this scenario. The cross-jurisdiction data flow is the most institutionally consequential aspect of the scenario. A pilot that demonstrates a documented egress policy under the conditions of the applicable cross-border data-transfer regime (in the EU, the *Schrems II* doctrine) produces an artefact that the institution can show to its governance body, its data-protection function, and the regulators that may inspect its operations.

23.4.2 Scenario B: Teaching cyber-range

A teaching department requests a time-bounded laboratory environment for cybersecurity instruction: students receive isolated networks within a controlled zone, instructors hold elevated roles for the class duration, and the entire environment is decommissioned when the term ends.

Why this scenario. The teaching cyber-range exercises the lifecycle of a TAC — activation at term start, re-activation per class session, decommissioning at term end — more rigorously than other scenarios. It also exercises multi-tenant isolation at a scale (typically tens of student contexts simultaneously active) that other pilots do not.

23.4.3 Scenario C: Administrative compliance workspace

An administrative service handling regulated data (research-ethics reviews involving sensitive subject data, compliance reporting toward regulatory bodies) requests a workspace with stricter audit, restricted egress, and disclosure-regime guarantees. The scenario exercises the higher-classification end of the data-dimension spectrum.

Why this scenario. The compliance scenario exercises HYOK arrangements (Chapter 10 of the Technical Reference D10.6), the strictest audit-retention obligations, and the integration with existing institutional compliance processes. It is the scenario that most directly engages the institution's governance bodies beyond the IT function.

23.5 Trajectories (consolidated)

Across the three principal trajectories of the playbook, Wave 5 varies in its integration burden but not in its essential form.

- **Greenfield.** The pilot is the institution's first operational TAC; the integration burden is minimal because there is no incumbent to coexist with. The wave is correspondingly compressed (indicative duration four to six months).
- **Brownfield single-suite-centric.** The pilot operates against the institution's existing incumbent identity suite and office-productivity estate (e.g. Entra-based identity with a Microsoft 365 estate), with policy decisions evaluated by the Wave 4 OPA deployment. Integration testing focuses on the incumbent-IdP-to-policy-plane decision chain.
- **Brownfield hybrid.** The pilot operates against the existing Shibboleth federation and the Wave 1 Keycloak activation layer. Integration testing focuses on the cross-component activation sequence.

Indicative duration. Six to nine months for brownfield trajectories, with the variability driven by the chosen scenario and by the institutional change-management cadence.

23.6 Reversibility criteria

Wave 5 is structurally reversible: the pilot can be stopped at any time without affecting production services, and the data generated during the pilot is preserved according to the institutional classification scheme.

- Pilot stop procedure: documented, exercised in tabletop form before pilot start, and invoked without escalation when the pilot host requests it.
- Data preservation: research data, teaching artefacts, or administrative artefacts produced during the pilot are exported in documented formats before the pilot decommissions.
- Learning preservation: the technical and organisational learnings from the pilot are documented in a wave-closure report whose content is preserved regardless of whether the pilot was operationally successful.

23.7 Exit criteria

Wave 5 closes when the conformance subsets corresponding to the layers exercised by the pilot pass on the pilot configuration, when the pilot host has reported its operational experience, and

when the wave-closure report has been reviewed by the governance body.

- Conformance: the union of the relevant Identity, Policy, Network, Compute, Storage and Observability tests passes against the pilot configuration. The exact subset depends on the chosen scenario.
- User experience: the pilot host has produced a structured report describing the operational experience — what worked, what did not, what should be revised before any broader deployment.
- Wave-closure report: technical learnings, organisational learnings, and recommendations for subsequent waves are consolidated and reviewed by the programme governance.

Real-world reference — Research-cloud pilot precedents

Indiana University's Jetstream2, operated under the United States National Science Foundation's ACCESS programme, is a publicly documented research-cloud architecture from which pilot patterns can be drawn. European institutions participating in the EGI federated cloud and in EUDAT-aligned research-data projects have produced comparable patterns. The institutional specifics — pilot scope, success criteria, durations — vary substantially across institutions and should be evaluated against each institution's own context rather than transposed wholesale.

23.8 Regulatory anchoring

Wave 5 is the first wave that exercises the architecture end-to-end on a research-class TAC. Its regulatory profile depends on the pilot scenario chosen. The Researcher-LLM-API scenario is the principal locus where the adopter's applicable AI-governance regime bites; in the EU, the AI Act Art. 2(6) (research exemption, when the pilot is conducted as research and not as a production service) is typically invoked, with Art. 50 (transparency obligations) still applicable when end-users interact with AI-generated content. For all pilot scenarios, GDPR Art. 25 (data protection by design) and Art. 35 (DPIA where the pilot processes personal data on a non-trivial scale) frame the documentation duty. The wave is the first integration test for the GDPR-Art. 32 / NIS2-Art. 21(2)(a) measures introduced by Waves 1–4. Detailed mapping in Chapter 33 of the Technical Reference §33.5, §33.6, §33.7.

Chapter 24

Wave 6 — Endpoint and posture

Dependencies

Wave 6 applies the wave chapter template established in Chapter 18 of the Technical Reference. Required pre-requisites are Wave 1 (identity provider emitting the institutional schema) and Wave 4 (policy plane consuming attribute and posture signals); Waves 2 (observability) and 5 (pilot) strengthen the wave when present. It instantiates the endpoint contract of Chapter 11 of the Technical Reference, including the unified posture schema of D11.6 and the boundary with network attachment of D11.7. Closure is gated by the three Endpoint tests of Chapter 16 of the Technical Reference.

Wave 6 brings the endpoint estate into the architecture's authorisation surface: posture claims produced by managed devices become an input to the policy decisions of Chapter 7 of the Technical Reference, unmanaged or BYOD devices are governed at the network attachment layer of Chapter 8 of the Technical Reference, and the institutional decommissioning procedures are exercised against the new pipeline. The wave is also the place where the architecture's most candid acknowledgement — the open-source gap on iOS and Android at scale (D11.3) — becomes operationally consequential.

24.1 Goal and dependencies

The goal of Wave 6 is to deploy a unified posture schema across the endpoint operating systems in production, to route the resulting posture data into the policy plane established in Wave 4, and to integrate the institutional decommissioning procedures with the canonical event schema of Chapter 12 of the Technical Reference. The wave does not require a single MDM product across all OSes; it requires that the posture data produced by whatever products the institution operates be normalised at the wave's boundary.

24.2 Pre-requisites

Beyond Waves 1 and 4, four operational conditions strengthen Wave 6:

- the endpoint estate is inventoried by operating system, by management state (managed, unmanaged, BYOD), and by user population (staff, student, contractor, visiting researcher);
- the existing endpoint-management products are documented against their licence terms and renewal trajectories;
- the boundary with the network layer's BYOD attachment policy is articulated, since posture verification of BYOD endpoints relies on network-side observation rather than on agent-based collection (D11.7);
- the unified posture schema (D11.6) is drafted and reviewed against the policy authoring cadence of Wave 4.

24.3 Coexistence pattern

Wave 6 introduces posture signals into the policy plane in *advisory* mode before any enforcement decision depends on them. The pattern parallels the shadow mode of Wave 4 but operates on signal availability rather than on decision evaluation: the posture claims are produced and routed to the policy layer, the policy decisions are evaluated as if posture were enforced, but no access is denied on posture grounds during the advisory period.

Per-population transition. Endpoint populations are typically advanced through advisory-to-enforcing in cohorts: managed staff devices first (operationally controlled), then managed student devices, then BYOD with network-side enforcement. Each cohort's transition is per-policy: a posture rule may be enforcing for staff devices while still advisory for student devices for an extended period.

Multi-product reconciliation. For institutions with a mixed MDM estate (a dedicated management product for the Apple platforms, a separate suite for Windows and Android, and configuration-management-plus-osquery tooling for Linux), the principal engineering effort of Wave 6 is the reconciliation of the products' native posture formats into the unified schema. Each product's posture data is mapped, the mapping is exercised in shadow, and the policy plane ultimately consumes only the unified schema — never the product-specific signals.

24.4 Trajectory: greenfield

For institutions in a greenfield position, Wave 6 deploys the endpoint products and the unified schema together: there is no incumbent MDM logic to reconcile, and the posture-to-policy integration is built from the start. Indicative duration is six to nine months for an institution of moderate scale.

24.5 Trajectory: brownfield single-suite-centric

For institutions whose endpoint management is dominated by a single proprietary management suite, Wave 6 is the work of routing that suite's compliance signals into the unified schema and of reconciling its native authorisation with the policy plane.

Pattern. The incumbent suite's compliance policies remain in place for device-level enforcement (encryption, screen lock, OS version, patch SLAs); their compliance signals are exported through OpenTelemetry collectors deployed during Wave 2 and reach the policy plane in the unified schema. The conditional-access expressions of the institution's incumbent identity suite that depend on device compliance are exercised in shadow mode through the equivalent OPA policies authored in Wave 4. Linux endpoints — typically present in environments characteristic of the institution's research-computing profile even where a single proprietary suite dominates — are managed through configuration-management and osquery tooling, with their posture also normalised to the unified schema.

The iOS gap. For institutions with a substantial iOS estate, a proprietary suite's iOS coverage is the working choice; there is no credible open-source alternative at scale at the time of writing. This is a known limitation of the architecture (D11.3 in Chapter 11 of the Technical Reference). The sovereignty consequence — a Partial score on the technical and institutional dimensions for the iOS portion of the estate — should be acknowledged in the wave-closure report rather than elided.

Indicative duration. Twelve to eighteen months, dominated by per-population cohort transition.

24.6 Trajectory: brownfield hybrid

For institutions with a multi-OS estate combining Apple, Windows, Linux and mobile platforms across organisational-unit boundaries, Wave 6 is principally the work of *normalisation*: producing a common posture schema across products that were chosen at different times and managed by different teams.

Pattern. Each existing endpoint-management product (a dedicated suite for macOS and iOS where present, a separate suite for Windows and Android, configuration-management-plus-osquery tooling for Linux, possibly a further unified-endpoint product in some segments) continues to operate in its own domain. A collector layer translates each product's posture format into the unified schema; the policy plane consumes only the unified schema. The institutional posture schema becomes the authoritative artefact; the products become substitutable consumers of the schema.

What changes in Wave 6. The posture data flow becomes uniform across the institution; the policy plane no longer branches on operating system for routine decisions (D11.6); the decommissioning procedures become testable end-to-end against the canonical event schema. The product mix itself is not changed by this wave.

Indicative duration. Twelve to eighteen months, with the variability driven by the heterogeneity of the existing product mix.

24.7 Reversibility criteria

Wave 6 is reversible at the per-policy and per-population level throughout the advisory-to-enforcing transition. Beyond that transition, reversal is operationally possible but requires the incumbent enforcement logic to be re-instated.

- The advisory / enforcing toggle is per posture rule and per population; reversal of a posture rule is the deployment of a new policy bundle, not the redeployment of the endpoint products.
- Per-population rollback: if a population's transition to posture-enforced authorisation produces unworkable behaviour, that population is returned to advisory mode while the discrepancy is diagnosed.
- The unified posture schema can be revised; a schema change is treated as a governance event rather than an operational one (D12.2).

24.8 Exit criteria

Wave 6 closes when the three Endpoint tests of the conformance suite of Chapter 16 of the Technical Reference (§16.3) pass on the unified posture pipeline, when the agreed populations are in posture-enforced authorisation, and when the BYOD attachment boundary with Chapter 8 of the Technical Reference is verified.

- Posture data from each managed OS arrives in the canonical schema; decommissioning of a representative endpoint executes end-to-end; MDM configuration profiles export to a documented format that an alternative MDM can consume on a representative subset. (Endpoint conformance subset.)
- Population coverage: the institutionally agreed populations are operating under posture-enforced authorisation; the remainder is in a documented schedule or exception register.

- BYOD boundary: the network-side BYOD posture verification of Chapter 8 of the Technical Reference is consistent with the institution's BYOD acceptable-use policy.

Real-world reference — Endpoint management at large institutions

Public documentation of endpoint architectures at large institutions is uneven. Patterns reported in the national research and education network's community fora and at sector conferences include mixed-OS estates combining a dedicated suite for Apple platforms, a separate suite for Windows and Android, and open tooling (configuration management, osquery, and macOS package managers) for Linux and macOS. Specific institutional configurations and the current state of any cited deployment should be confirmed against the institution's own published material before being cited as precedent.

24.9 Regulatory anchoring

Wave 6 brings managed endpoints under the same attestation discipline as the rest of the architecture. It contributes to GDPR Art. 32 (technical measures on the device that processes personal data) and operationalises the applicable national cybersecurity baseline regime's risk-management measures — the national transposition of the NIS2 Directive where it applies — specifically cyber-hygiene practices (NIS2 Art. 21(2)(g)), asset management (Art. 21(2)(i)) and, indirectly, multi-factor authentication (Art. 21(2)(j)) where the endpoint carries the authentication factors. The wave operationalises 27001 A.8.1 (user endpoint devices), A.8.7 (protection against malware), A.8.9 (configuration management) and contributes to NIST CSF PROTECT (PR.PS — platform security). Detailed mapping in Chapter 33 of the Technical Reference §33.5, §33.6, §33.11, §33.9.

Chapter 25

Wave 7 — TAC-aware audit and IR

Dependencies

Wave 7 applies the wave chapter template established in Chapter 18 of the Technical Reference. Required pre-requisites are Wave 2 (observability baseline), Wave 4 (policy plane producing decision logs) and Wave 5 (pilot demonstrating end-to-end correlation). It applies the canonical TAC event schema of Chapter 12 of the Technical Reference (§12.3, D12.2) and the TAC-session sampling rule (D12.8). Closure is gated by the Observability conformance subset of Chapter 16 of the Technical Reference reinforced with audit-replay exercises.

Wave 7 transforms the observability pipeline from a passive collection layer into an active investigative resource. The TAC correlation that the canonical schema makes possible becomes the primary axis of forensic and operational investigation; the incident-response runbooks of the institution are refreshed against the architecture's actual operational behaviour, observed during the Wave 5 pilot. The wave is consequently both a technical configuration effort and an organisational training exercise.

25.1 Goal and dependencies

The goal of Wave 7 is to operationalise three capabilities that the preceding waves have made technically possible but organisationally unexercised:

- **TAC-correlated investigation.** The Security Operations team (whether internal, contracted, or distributed) is trained to investigate incidents along the TAC correlation axis: starting from a suspect activity, retrieving the full activation chain across layers, and bounding the scope of the incident by TAC session rather than by host or by user.
- **Refreshed IR runbooks.** Existing incident-response runbooks are updated to incorporate the new investigative paths and the new containment options (TAC suspension, per-TAC re-evaluation, scoped revocation) that the architecture admits.
- **Audit replay.** The capability to replay consequential decisions against their recorded inputs and policy versions becomes part of routine audit rather than only of post-incident analysis.

25.2 Pre-requisites

Beyond Waves 2, 4 and 5, four operational conditions strengthen Wave 7:

- the Wave 5 pilot has produced a structured wave-closure report identifying the cross-layer behaviours that the runbooks must accommodate;
- the Security Operations function is engaged at the workshop level rather than at the consultation level: the team that will use the new runbooks has authored or co- authored them;
- the canonical TAC event schema is operating across the layers exercised by the pilot, with a verified `correlation_id` propagation;

- the institution's existing incident-response framework (CSIRT or CSIRT-equivalent function, MoUs with the national/governmental CSIRT and the NREN-CSIRT where applicable) is documented so that the new runbooks integrate with it rather than supersede it.

25.3 Coexistence pattern

Wave 7 is structurally additive: existing incident-response runbooks remain authoritative throughout the wave, and the TAC-aware extensions are added as enrichments rather than as replacements. The pattern reduces the operational risk of the wave to acceptable levels — a wave that introduces new investigative procedures cannot afford to disrupt the institution's incident-response capacity.

Per-runbook update. Each runbook is updated as a self-contained exercise: the existing version is preserved, an enriched version is authored, the two are exercised in parallel on tabletop scenarios, and the enriched version replaces the existing one only when the SOC team has demonstrated proficiency on the new investigative path. The order of runbook update is typically determined by the Wave 5 pilot's findings: the runbooks most exercised by the pilot's scope are updated first.

Detection rules. Detection rules in the analytical store (whether SIEM-native or expressed in the open store of Chapter 12 of the Technical Reference) are refactored to consume the canonical schema. Existing rules are not deleted; they remain parallel until the refactored rules are demonstrated equivalent on a representative observation window.

25.4 Trajectory: greenfield

For institutions in a greenfield position, Wave 7 is the wave in which the IR function itself is built around the TAC correlation model from the start. There is no incumbent runbook corpus to update, but the absence is itself a challenge: the institution must author a complete runbook set without the incremental benefit of an existing baseline. Indicative duration is six to nine months, dominated by the runbook authoring and tabletop exercising rather than by technical configuration.

25.5 Trajectory: brownfield single-suite-centric

For institutions whose existing audit pipeline is built around a cloud-vendor-native SIEM (for example Microsoft Sentinel), Wave 7 enriches the incumbent SIEM's investigative surface with the canonical TAC schema while keeping it as the primary SOC tool.

Pattern. The OpenTelemetry collector layer of Wave 2 is configured to emit the canonical TAC schema both into the incumbent SIEM and into the parallel open store. SOC analysts continue to operate the incumbent SIEM as their primary investigative interface; the new investigative queries are authored as the incumbent SIEM's detection content (e.g. Sentinel KQL) consuming the canonical schema, with parallel queries authored against the open store for portability. Audit replay — the capability to retrieve a recorded decision and its policy version — is exercised against the open store, since the policy plane's decision log of Wave 4 was routed there without going through the incumbent SIEM's per-GB ingestion premium.

What changes in Wave 7. The incumbent SIEM's detection corpus (e.g. Sentinel KQL) is refactored to use the canonical schema fields rather than vendor-native field names; the runbooks reference the canonical investigation paths; the SOC training programme is refreshed.

What does not change. The incumbent SIEM remains the SOC's primary surface; the existing notification and escalation channels with the institution's CSIRT and with the national/governmental CSIRT counterparts are preserved.

Indicative duration. Six to twelve months.

25.6 Trajectory: brownfield hybrid

For institutions whose existing audit pipeline is built around Splunk or a comparable per-volume-priced analytical store, Wave 7 produces a parallel pattern with one important distinction: the volume management of Wave 2's collector layer has by now demonstrated its operational discipline, and Wave 7 formalises the corresponding cost management.

Pattern. The collector layer of Wave 2 routes canonical events to Splunk for the SOC's primary investigative surface, and to the open store for retention beyond the cost-managed Splunk window. Detection content in Splunk is refactored to consume canonical fields. Audit replay queries the open store for the longer-horizon material that Splunk no longer holds.

What changes in Wave 7. The split between Splunk's investigative window and the open store's longer retention becomes operationally formalised — runbooks for incidents older than the Splunk window are explicitly authored against the open store. The TAC-session sampling rule of D12.8 is applied to bound the Splunk ingestion volume without losing correlation within preserved sessions.

What does not change. Splunk remains the SOC's primary surface within its window; the institution's existing IR relationships are preserved.

Indicative duration. Six to twelve months.

25.7 Reversibility criteria

Wave 7 is structurally additive and is reversible at the runbook level throughout the wave. Beyond the wave, reversal is operationally possible but is treated as a runbook re-authoring exercise rather than as a wave rollback.

- Per-runbook reversal: a runbook whose enriched version proves operationally inferior is reverted to the existing version, with the divergence diagnosed before any further runbook is updated.
- Detection content reversal: refactored detection rules that produce false-positive rates inconsistent with the SOC's tolerance are reverted to the prior version while the rule is re-tuned.
- The canonical schema itself is not subject to wave-level reversal (it was frozen by D12.2 at the architecture level).

25.8 Exit criteria

Wave 7 closes when the Observability conformance subset of Chapter 16 of the Technical Reference (§16.3) passes against the enriched pipeline, when the audit-replay exercises succeed on a representative sample, when the agreed runbook set has been updated, and when the SOC has demonstrated proficiency on the new investigative paths.

- Observability conformance subset passes (canonical schema enforced, retention verified, cross-layer correlation succeeds, alternative-store re-routing succeeds);
- Audit replay: a sampled set of decisions from Chapter 7 of the Technical Reference's log is replayed against recorded inputs and policy versions, with verdicts identical;

- Runbook coverage: the institutionally agreed set of runbooks has been updated; the remaining runbooks are in a documented schedule;
- SOC proficiency: tabletop exercises on TAC-correlated investigation have been conducted with documented outcomes, and at least one exercise has been conducted with institutional CSIRT or NREN-CSIRT participation.

Real-world reference — Audit and IR practice in research-intensive institutions

Patterns reported in NREN community fora and at REN-ISAC indicate that research-intensive institutions typically operate IR functions in close coordination with their NREN-CSIRT counterparts and with sector incident-sharing networks. Specific runbook structures and exercise cadences vary substantially across institutions and should be developed locally rather than imported from external precedents. The institutional CSIRT relationships, where they exist, would benefit from being engaged early in the wave rather than at its closure.

25.9 Regulatory anchoring

Wave 7 is the wave at which the institution becomes *operationally accountable* for the audit-and-IR obligations of the regulatory framework. It is the principal anchor of the applicable supranational and national legal framework (in the EU, the national NIS2 transposition — NIS2 Art. 23: incident reporting, with a 24-hour early warning, 72-hour notification and one-month final report) and of the personal-data-breach notification duty of the institution's applicable data-protection regime (in the EU, GDPR Art. 33–34: notification to the competent data-protection authority and to data subjects), with the TAC-aware audit pipeline as the timeline-reconstruction substrate. The wave also operationalises that regime's incident-handling and effectiveness-assessment duties (in the EU, NIS2 Art. 21(2)(b) and Art. 21(2)(f), the latter through audit-replay exercises). It is the operational anchor of 27001 A.8.15 (logging) and A.8.16 (monitoring activities) at maturity, and of NIST CSF DETECT (DE) and RESPOND (RS) functions in their entirety. Detailed mapping in Chapter 33 of the Technical Reference §33.5, §33.6, §33.11, §33.9.

Chapter 26

Wave 8 — Workload classification and scale-out

Dependencies

Wave 8 applies the wave chapter template established in Chapter 18 of the Technical Reference. Required pre-requisites are Wave 1 (identity emitting institutional schema), Wave 3 (network zone catalogue declared and operational), and Wave 4 (policy plane consuming classification signals); Wave 5 (pilot) strengthens the wave when present. It applies the contracts of Chapter 9 of the Technical Reference and Chapter 10 of the Technical Reference, the cluster separation rule of D9.6, and the classification-labelling discipline of D10.4 and D10.7. Closure is gated by the Compute and Storage conformance subsets of Chapter 16 of the Technical Reference.

Wave 8 is the wave in which classification ceases to be a documentary discipline and becomes an enforced architectural property. Workloads — virtual machines, containers, research workspaces, administrative services — carry classification labels that the policy plane consults at provisioning and that the storage layer respects at binding. The wave's principal engineering effort is not in introducing the labels (their schema was fixed in earlier waves) but in extending classification to the existing workload estate and in enforcing the cluster- separation rule that the labels imply.

26.1 Goal and dependencies

The goal of Wave 8 is to make the classification of every workload an authoritative input to its provisioning, its storage binding, and its policy evaluation. Three concrete objectives follow:

- every newly provisioned workload declares its classification at the moment of provisioning, with the declaration verified by the policy layer;
- every existing workload acquires a classification through a retrospective labelling exercise, with explicit governance of the period during which workloads operate without classification;
- the cluster-separation rule of D9.6 (workloads of distinct sensitivity classifications should not share a cluster) is operationalised on the production estate, with documented exceptions where the rule is impractical.

26.2 Pre-requisites

Beyond Waves 1, 3 and 4, four operational conditions strengthen Wave 8:

- the institutional classification scheme is stable (whether TLP-derived, domain-specific, or institutional — the scheme matters less than its stability);
- the policy corpus of Wave 4 contains the classification- consuming rules that the wave will operationalise;

- the storage layer's classification metadata mechanism is in place, with a documented procedure for assigning and revising labels;
- the network zone catalogue of Wave 3 is mature enough to accommodate workload migrations between zones when the classification of a workload changes.

26.3 Coexistence pattern

Wave 8 introduces enforcement gradually, distinguishing newly- provisioned workloads from existing ones.

Newly-provisioned workloads. From the wave's start, every new workload provisioning request must declare a classification; the absence of a declaration produces an explicit provisioning failure that the requester can act on. The classification is consulted by the policy layer's admission decision; the storage layer applies the corresponding label to any volume bound to the workload.

Existing workloads. A retrospective labelling exercise classifies the existing workload estate. The exercise is typically run unit-by-unit or service-by-service, with a nominated classification owner per cohort. Workloads remain operational throughout, with an interim default (typically the most permissive classification consistent with the workload's visible behaviour) until the formal classification is recorded.

Cluster-separation enforcement. The rule that workloads of distinct sensitivity classifications should not share a cluster (D9.6) is applied as a target rather than as a hard gate at wave open: existing co-located workloads are identified, their separation is scheduled, and the schedule is managed against the institutional change calendar. The wave closes only when the agreed separation has been achieved or explicitly excepted.

26.4 Trajectory: greenfield

For institutions in a greenfield position, Wave 8 establishes the classification-aware provisioning from the start: there are no existing workloads to retro-classify, and the cluster- separation rule applies trivially because clusters are provisioned per classification class as they are needed. Indicative duration is four to six months.

26.5 Trajectory: brownfield single-suite-centric

For institutions whose compute estate is dominated by a single proprietary vendor suite (public-cloud tenancies aligned to that vendor, the vendor's productivity and collaboration workloads, virtualisation substrates with vendor-heavy clusters), Wave 8 brings classification to the visible workload boundary while accepting that some vendor-internal workloads remain partly opaque.

Pattern. The retrospective labelling targets the workloads visible to the institution's provisioning surface — virtual machines under institutional management, containers under the institution's container-orchestration platform, research workspaces. The dominant suite's productivity workloads (mailboxes, document repositories, collaboration workspaces) are addressed at the application level rather than at the workload level, with classification expressed as sensitivity labels integrated with the incumbent identity-and-productivity suite vendor's information-protection capability where the institution has adopted it.

Cluster-separation under a dominant-suite estate. Virtualisation-based or vendor-private-cloud clusters that host workloads of mixed classifications have a documented separation plan. The plan typically aligns with the next infrastructure refresh cycle or with a new cluster's provisioning, rather than with disruptive mid-cycle migration.

Indicative duration. Twelve to twenty-four months, dominated by the retrospective labelling and by the cluster- separation schedule.

26.6 Trajectory: brownfield hybrid

For institutions with a multi-vendor compute estate (an open-source private cloud plus a proprietary virtualisation platform plus public-cloud burst, with a mix of container-orchestration clusters across organisational units), Wave 8's principal effort is the *normalisation* of classification across these substrates.

Pattern. A common classification metadata interface is established across the substrates: the same label vocabulary is applied whether a workload runs on the open-source private cloud, on the proprietary virtualisation platform, or in a cloud burst. The workload-context events of Chapter 9 of the Technical Reference carry the classification consistently; the storage labels of Chapter 10 of the Technical Reference match. The multi-vendor reality of the estate is preserved; the classification governance is unified.

Unit-level classification authorship. In research-intensive institutions, classification is often authored at organisational-unit or research-project level rather than centrally. The wave operationalises this delegation: a classification owner per cohort, a central review for consistency, no central authority over individual labels.

Indicative duration. Twelve to twenty-four months.

26.7 Reversibility criteria

Wave 8 is reversible at the per-workload level for the duration of the retrospective labelling and for an additional grace period thereafter.

- Per-workload reversal: a classification that proves operationally inappropriate is revised through the labelling governance rather than through a wave-level reversal.
- Cluster-separation reversal: a separation schedule that cannot be sustained for resource reasons is documented as an exception, not as a wave failure.
- Provisioning enforcement toggle: the requirement for a classification declaration at provisioning can be disabled in defined emergency cases, with the disablement logged and reviewed.

26.8 Exit criteria

Wave 8 closes when the Compute and Storage conformance subsets of Chapter 16 of the Technical Reference (§16.3) pass, when the agreed classification coverage is achieved, and when the cluster-separation schedule has been completed or explicitly excepted.

- Compute conformance subset (Kubernetes API conformance, OCI image migration, SLSA attestation verification); Storage conformance subset (S3 conformance, KMIP migration, snapshot inventory, classification preservation across export/import).
- Classification coverage: the institutionally agreed proportion of workloads has a recorded classification. Workloads in the residual exception register are documented individually with the rationale.

- Cluster-separation schedule: closed, with documented exceptions where applicable. Exceptions are revisited at the next sovereignty grid review.
- Snapshots and replicas (D10.7): brought under the classification governance, with their location and retention reconciled with the primary storage.

Real-world reference — Workload classification at research institutions

Multi-tenant research-cloud architectures, such as those reported under large national research-computing allocation programmes or within continental-scale federated research clouds, illustrate classification-aware patterns at substantial scale. The mapping of those patterns to a single-institution context is non-trivial and would benefit from the institution's own pilot work (Wave 5) rather than from direct transposition.

26.9 Regulatory anchoring

Wave 8 brings classified workloads under the attestation discipline at scale. It contributes to the security-of-processing obligation of the institution's applicable data-protection regime (e.g. GDPR Art. 32, applied to the workload tier) and to that regime's data-minimisation principle (e.g. GDPR Art. 5(1)(c), realised through classification-aware tiering). It also operationalises the business-continuity and secure-development obligations of the applicable supranational and national legal framework (e.g. NIS2 Art. 21(2)(c), through declarative redeployability, and (e), through SLSA-level supply-chain attestations). Where the institution adopts them, the wave is also a principal anchor of ISO/IEC 27001 A.8.32 (change management) at scale and contributes to NIST CSF PROTECT (PR.PS) and RECOVER (RC.RP). Detailed mapping in Chapter 33 of the Technical Reference §33.5, §33.6, §33.11, §33.9.

Chapter 27

Wave 9 — Lifecycle automation and maturity

Dependencies

Wave 9 applies the wave chapter template established in Chapter 18 of the Technical Reference. The required pre-requisite is the closure of Waves 1–8 in some form: not every wave must have reached its full scope, but each must have closed the elements on which Wave 9 builds. It applies the orchestration contract of Chapter 14 of the Technical Reference (the four properties of D14.1, the composition discipline of D14.4, the no-third-path rule of D14.7). Closure is gated by the four Orchestration tests of Chapter 16 of the Technical Reference.

Wave 9 is the wave in which the architecture acquires the operational ergonomics of a mature platform. The provisioning that earlier waves have established as technically possible becomes a self-service capability for the institution's consumers. The GitOps discipline that earlier waves have respected becomes the operational source of truth. The wave is consequently both the last wave of the playbook and the wave in which the institution stops thinking about "the playbook" and starts thinking about routine operations.

27.1 Goal and dependencies

The goal of Wave 9 is to make the architecture's day-to-day operation sustainable without continuous engineering intervention. Three concrete objectives follow:

- self-service provisioning of TACs by their authorised consumers (researchers requesting research workspaces, teaching staff requesting lab environments, administrative staff requesting compliance workspaces), with the policy plane gating the request;
- GitOps repository elevated to the operational source of truth: changes to the architecture's running state are made by repository commit, reviewed under the same discipline as application code, and reconciled into running state by the orchestration plane;
- operational stability metrics agreed and reported, so that the institution can recognise when the architecture is operating at maturity.

27.2 Pre-requisites

The closure of Waves 1–8 is the principal pre-requisite. Three operational conditions strengthen the wave when present:

- the orchestration plane's GitOps repository is in active use by the engineering team, with established review and merge cadences;

- the policy plane has accumulated sufficient policy coverage that consumer-initiated provisioning requests do not require ad hoc human authorisation in the routine case;
- the conformance suite of Chapter 16 of the Technical Reference has been exercised at least twice, so that the institution has a baseline for the maturity metrics that Wave 9 will use.

27.3 Coexistence pattern

Wave 9's coexistence is between ticket-driven provisioning (the institution's incumbent service-management pattern) and self-service provisioning (the wave's target pattern).

Per-consumer-group rollout. Self-service is rolled out group by group rather than institution-wide. Typical sequence: a research group with mature DevOps practice first, then teaching environments where the requester is the instructor, then administrative services where the requester is typically a unit manager. Each group's rollout is evaluated against the maturity metrics before the next group begins.

Ticket-driven legacy preserved. Throughout the wave, the existing ticket-driven flows remain available. Consumers who do not yet have self-service for their use case continue through tickets; the engineering team operates both flows without requiring consumers to choose. The ticket-driven flow is gradually retired only when the corresponding self-service flow has demonstrated stability for an institutionally agreed period (indicatively three to six months).

27.4 Trajectory: greenfield

For institutions in a greenfield position, Wave 9 establishes self-service and GitOps from the start of the institution's production operation. There is no incumbent ticket-driven flow to preserve, and the wave is correspondingly compressed. Indicative duration is four to six months for the technical configuration; the maturity metrics require additional time to accumulate.

27.5 Trajectory: brownfield single-suite-centric

For institutions whose existing service-management is built around ServiceNow, Microsoft Service Management, or a comparable ITSM platform, Wave 9 introduces the self-service capability alongside the ITSM platform rather than in replacement of it.

Pattern. The ITSM platform continues to operate for the use cases that genuinely benefit from its workflow features (approval chains involving multiple stakeholders, financial authorisation, regulated processes). Self-service is introduced for the use cases where the policy plane's authorisation is sufficient and where the platform's workflow features add ceremony rather than value. The ITSM platform may itself become a consumer of the policy plane and the orchestration plane: an ITSM-initiated request becomes a GitOps commit through a thin adapter.

What changes in Wave 9. The boundary between self-service and ITSM-driven provisioning is documented and governed; the institution's consumers know which path applies to their request. The GitOps repository becomes the authoritative state, with the ITSM platform acting as a trigger rather than as the system of record.

Indicative duration. Twelve to twenty-four months, dominated by the per-consumer-group rollout and by the ITSM–GitOps boundary work.

27.6 Trajectory: brownfield hybrid

For institutions with a multi-vendor compute estate and an organisational-unit-level service-management heterogeneity, Wave 9 operationalises a unified self-service interface across the heterogeneous substrate.

Pattern. A common self-service portal (or, where preferred, a CLI plus IaC pattern) is exposed across the substrates that Waves 3, 8 and 9 have brought under common governance. The portal does not eliminate organisational-unit-level autonomy in service management; it provides the institutional baseline that organisational-unit-specific extensions build on.

What changes in Wave 9. The institution acquires a shared provisioning surface that respects organisational-unit autonomy while delivering consistent classification, audit, and sovereignty properties across the estate.

Indicative duration. Twelve to twenty-four months.

27.7 Reversibility criteria

Wave 9 is reversible at the per-consumer-group level for as long as the ticket-driven legacy flow remains operational.

- Per-group rollback: a consumer group whose self-service rollout produces unworkable behaviour is returned to the ticket-driven flow while the divergence is diagnosed.
- Self-service portal disable switch: a tested mechanism for switching the portal to read-only or fully off within minutes is part of the wave's deliverables.
- Manual fallback procedure: for the case in which both self-service and ITSM are unavailable, a documented manual procedure ensures that the architecture's critical operations can still be exercised.

27.8 Exit criteria

Wave 9 closes when the four Orchestration tests of the conformance suite of Chapter 16 of the Technical Reference (§16.3) pass, when the agreed self-service ratio is achieved, and when the institution's operational stability metrics are within agreed thresholds.

- Orchestration conformance subset (idempotency, deactivation reverses consequential changes, GitOps repo suffices to rebuild state, workflow portability across engines).
- Self-service ratio: the institutionally agreed proportion of provisioning requests is fulfilled through self-service rather than through tickets. The ratio is typically expressed per consumer group rather than as a single institutional figure.
- Operational stability metrics: agreed thresholds for incident frequency, change-failure rate, and deactivation completeness are met over an institutionally agreed window.

Beyond Wave 9. The closure of Wave 9 marks the end of the playbook and the beginning of routine operations. The sovereignty grid (Chapter 3 of the Technical Reference) continues to apply at every renewal; the conformance suite (Chapter 16 of the Technical Reference) is exercised on its established cadence; the international peer comparison anticipated in phase 2 begins to operate against the institution's longitudinal record.

Real-world reference — Self-service patterns

Self-service provisioning patterns at research- intensive institutions are reported in NREN community fora and in EDUCAUSE publications. Some institutions operate sophisticated self-service portals for research-cloud provisioning (typically those participating in NSF

ACCESS or EGI federations); others operate hybrid arrangements with ITSM-mediated approval for sensitive provisioning. The specific portal designs and approval thresholds vary substantially with the institution's research mix and governance culture; no single design is universally appropriate.

27.9 Regulatory anchoring

Wave 9 closes the supply-chain and lifecycle loop. It is the principal anchor of the supply-chain security obligation of the applicable national NIS2 transposition (Art. 21(2)(d) of the directive) operationalised through SLSA / Sigstore attestations and through provenance-aware orchestration. Under the adopter's applicable AI-governance regime (in the EU, Art. 53 of the AI Act — obligations for providers of general-purpose AI models, including model documentation and provenance), the wave's lifecycle discipline applies to AI artefacts. The wave operationalises 27001 A.8.30 (outsourced development) and contributes to NIST CSF GOVERN (GV.SC — supply-chain risk management) and IDENTIFY (ID.AM — asset management). It also operationalises COBIT APO10 (managed vendors) and BAI03 (managed solutions identification and build). Detailed mapping in Chapter 33 of the Technical Reference §33.6, §33.7, §33.11, §33.9, §33.12.

Chapter 28

Cross-cutting concerns

The waves of the playbook describe *what* the institution does, in what sequence, against which criteria. The cross-cutting concerns of this chapter describe *how* the institution does it: the organisational disciplines, the communication patterns, the financial framework, the procurement adjustments without which the technical work of the waves does not produce the institutional outcome the playbook intends. They are presented as topical guidance rather than as prescriptions, since each institution's existing arrangements differ substantially.

28.1 Change management

The architecture's transformation interacts with the institution's existing change-management process. Three patterns recur and merit explicit handling.

Per-wave change-management cadence. Each wave produces a stream of changes that the institution's change advisory board (or equivalent) must review. The stream is bounded by the wave's scope and predictable in volume; the cadence agreed at wave open ensures that the engineering team's pace and the change-management process's pace are aligned. Misalignment in either direction — a backlog of unreviewed changes, or a change-management process calibrated for a slower pace — typically produces the wave's most visible operational difficulties.

ITIL or COBIT integration. For institutions whose service-management framework is built on ITIL or COBIT, the playbook's vocabulary maps onto familiar concepts: a wave is a change programme, an exit criterion is a change closure, a reversibility window is a back-out window. The architectural posture is to use the institution's existing vocabulary where it fits, rather than imposing the playbook's vocabulary as a parallel.

Change windows during waves. Several waves (particularly Wave 3 network segmentation, Wave 6 endpoint, and Wave 9 lifecycle) require scheduled disruption of services that the institution's user constituencies tolerate at agreed windows. Coordinating these windows across faculties, with academic-calendar awareness, is a persistent organisational effort that the playbook does not eliminate.

28.2 Communication

A transformation programme of the playbook's scope requires communication at three levels, each with its own audience, cadence, and tone.

Governance communication. The programme governance body (established in Wave 0) receives structured updates at its regular cadence: progress against the wave plan, conformance results from Chapter 16 of the Technical Reference, sovereignty grid drift since the last review,

and risk register updates. The governance update is concise and decision-oriented; it is not a technical report.

Faculty and operational communication. Faculties, departments, and research projects receive communication at the events that affect them: the cut-over schedule for their building or service, the changes to their endpoint posture, the introduction of self-service for their consumers. The pattern is *advance notice plus contact point*: the affected constituency is informed before the change, with a named person to whom they can address concerns.

Institutional and public communication. The sovereignty position itself — the institution's commitment to the grid, the migration trajectory it has chosen, the precedents it draws on — is suitable for communication beyond the IT audience. The phase-2 international peer comparison anticipated by this Reference is one of the contexts in which institutional communication of sovereignty positioning becomes valuable.

28.3 Training and skills development

The architecture's operation requires skills that may not be fully present in the institution at the playbook's start. Three categories of skill investment merit explicit planning.

Per-layer skill development. Each layer of Part II implies specific skills (policy-language authoring for the policy layer, distributed-storage operation for the storage layer, container-orchestration administration for the compute layer, policy-driven infrastructure composition for the orchestration layer). The institution's training plan addresses these skills proportionately to its chosen trajectory: a brownfield trajectory anchored on an incumbent commercial platform invests less in distributed storage and more in the bridging logic between that platform and the open policy layer; a brownfield-hybrid trajectory invests more uniformly across the layers.

Research-network and peer-institution mutualisation. Several skills the playbook requires are scarce in any single institution. The institution's relationship with its national research and education network, with peer institutions through its regional research-network federation, and with any cross-institutional academic network it joins, are opportunities for shared training, shared on-call, and shared expertise that no single institution would sustain alone.

Long-horizon skill investment. The skills the playbook builds are not transitional. The institution that operates the architecture five years after Wave 9 needs the same skill mix it had at Wave 9. The training investment is consequently a continuing operational expense rather than a project expense.

28.4 Risk register

A wave-aware risk register is part of the programme's deliverables from Wave 0 forward. The register's structure follows the institution's existing risk methodology where one is in place (a national risk-analysis method, ISO/IEC 27005, FAIR, or comparable); the recommendation of this chapter is that the register be *wave-tagged* so that each risk is associated with the wave or waves in which it is most acute.

Per-wave risk profile. Each wave chapter implicitly identifies risks: identity-migration risk (Wave 1), policy miscalibration risk (Wave 4), classification-drift risk (Wave 8). The register makes these risks explicit and tracks them through the wave's life. A risk that materialises is documented; a risk that does not materialise is documented as such at wave closure.

© SUITOAAD

Cross-wave risks. Some risks span multiple waves: the risk that the engineering team's capacity is exceeded by parallel waves; the risk that an institutional change (leadership transition, funding shift) disrupts the programme's continuity; the risk that supplier consolidation alters the financial projections of the chosen trajectory. These risks have no single-wave home; they are reviewed by the programme governance at every cycle.

Risk acceptance. Some risks are accepted explicitly rather than mitigated. The acceptance is documented, with the sovereignty-grid dimension on which the risk falls, the reasoning, and the review schedule.

28.5 Financial planning

The playbook implies a financial trajectory that the institution plans against. Three observations recur across institutional contexts.

CAPEX-to-OPEX shift. The reference architecture typically shifts a portion of the institution's IT spending from capital expenditure (large infrastructure refreshes) to operating expenditure (continuous engineering, supplier subscriptions, training). The shift is not absolute — substantial CAPEX remains for compute, storage and network refreshes — but the proportion changes in a manner the institution's financial planning should anticipate.

Sovereignty reinvestment. A portion of the operating expenditure that earlier flowed to a single dominant supplier (licence renewals, premium support, captive services) is reinvested in institutional capability: engineer salaries, peer participation, training, contribution to open-source projects on which the architecture rests. The reinvestment is the financial form of sovereignty: the same money produces institutional capability rather than supplier revenue.

Multi-year horizon. The 5/7/10-year pace options of Chapter 17 of the Technical Reference imply matching financial horizons. An institution whose financial planning operates on a single-year cycle will struggle to commit to the playbook durably. The wave's incremental structure mitigates this — each wave can be financially scoped — but the cumulative trajectory benefits from a multi-year envelope.

28.6 Procurement adjustments

The sovereignty grid translates into procurement clauses. The institution's existing RFP templates can absorb the playbook's requirements through targeted additions rather than through wholesale rewriting.

Standard-interface clauses. For every procurement that touches a layer of Part II, the RFP requires the candidate to demonstrate conformance with the relevant standard interface (OIDC for identity, OPA REST for policy, NETCONF/YANG for network, S3 API for object storage, OpenTelemetry for observability, and so on). The conformance is verified during the procurement evaluation against the test categories of Chapter 16 of the Technical Reference.

Exit-assistance clauses. The contract includes a documented exit-assistance procedure: data export in agreed formats, configuration export in re-deployable form, support during a transition period whose duration is set in advance. The exit cost is bounded contractually and is proportionate to the genuine migration work rather than to the supplier's commercial preference.

Sovereignty-gating language. The institution may adopt explicit sovereignty gates for specified workload classes: *the data-dimension score must be Established or better for sensitive workloads*, *the financial dimension must be Robust or better for institution-critical components*, and so on. The gates are declared before the candidate is scored, not after, and they apply uniformly to commercial and open candidates alike.

Multi-supplier capability. For each layer, the institution preserves the realistic possibility of substituting the supplier within an agreed window. The procurement framework ensures that the practical exercise of this possibility is not prevented by contractual terms (no exclusivity that would prevent parallel evaluation, no licence terms that would penalise reduced consumption during transition, no data formats that would prevent independent re-import).

Chapter 29

Reversibility playbook

The wave chapters of Part III each declare their own reversibility criteria. This chapter consolidates the cross-cutting reversibility discipline: the reasoning behind it, the rollback procedures applicable to each wave, the data and communication considerations that any rollback engages, and the post-mortem framework that captures what the institution has learned from a reversal.

29.1 Why reversibility is non-negotiable

The architectural commitment of this Reference is that no wave is allowed to produce a one-way change at acceptable cost. The commitment is not theoretical: every wave declares a reversibility window, every component is procured with exit-assistance clauses (D28.4), every change to the running state flows through the declarative GitOps model (D14.4) so that prior states can be reconstructed. The reasoning is structural rather than tactical.

Sovereignty as a temporal property. Sovereignty is not only the property of the architecture today; it is the property of the architecture across time. An institution that has committed to a transformation it cannot undo at acceptable cost has surrendered its sovereignty over the matter, regardless of the transformation's merits. The reversibility playbook is the operational expression of this insight.

Reversibility differs from rollback. A *rollback* is the execution of a documented procedure to return to a prior state. *Reversibility* is the standing capacity to do so within an agreed cost envelope. The wave chapters declare reversibility windows; this chapter develops the rollback procedures that those windows guarantee.

When reversibility is forfeited. The principle admits exceptions when the institution's leadership accepts the loss of reversibility explicitly, in writing, against the sovereignty grid (Chapter 3 of the Technical Reference). The forfeit is documented with the dimension on which it falls, the rationale, and a review schedule. Forfeits are exceptional and are revisited at every sovereignty grid annual review.

29.2 Per-wave rollback procedures

Table 29.1 summarises the rollback procedure applicable to each wave. The procedures are not exhaustive; the institution adapts them to its operational specifics. The intent is to ensure that a rollback decision is not blocked by the absence of a documented procedure.

Table 29.1: Per-wave rollback procedures (indicative). The unit of rollback is the smallest operational increment that the wave's coexistence pattern admits.

Wave	Rollback unit	Procedure summary
0 — Foundations	Mandate	Governance body dissolved or reabsorbed; sovereignty grid de-adopted (informational state preserved).
1 — Identity	Application cohort	Cohort returned to the incumbent identity provider; federation metadata refreshed; user re-onboarded if needed. Incumbent identity provider kept warm 6–12 months.
2 — Observability	Collector source	New collectors removed at the source; legacy log paths unaffected throughout; parallel store decommissioned.
3 — Network	Segment / building	Segment configuration reverted to pre-cut-over version under change control; inter-segment routing rules updated.
4 — Policy	Policy rule	New bundle deployed reverting the rule to shadow or removing it; incumbent enforcement (conditional-access expression, in-app rule) re-instated.
5 — Pilot	Pilot	Pilot decommissioned per Wave 5 stop procedure; data exported; tenancy released.
6 — Endpoint	Population	Population returned to advisory mode; posture rule reverted in policy bundle.
7 — Audit and IR	Runbook	Refactored runbook reverted to prior version; refactored detections reverted in detection corpus.
8 — Workload classification	Workload	Workload classification revised through labelling governance; cluster-separation schedule extended.
9 — Lifecycle automation	Consumer group	Group returned to ticket-driven flow; self-service portal disabled for the group.

29.3 Data preservation during rollback

A rollback that succeeds technically but loses institutional data has not actually succeeded. Three classes of data require explicit preservation.

Operational data produced under the wave. Audit events, decision logs, configuration histories produced while the wave was active are preserved according to the institution's classification scheme. The rollback does not delete this data; it only changes the operational state of the components that produced it. The data remains available to subsequent investigation and to the post-mortem of §29.5.

User data affected by the wave. Where a wave touches user-facing storage or workspaces (Wave 5 pilot, Wave 8 workload), the rollback preserves the user data through documented export procedures. The export occurs before the rollback executes; the exported data is provided to the user and retained according to the institutional retention policy.

Migration artefacts. Configuration that was authored during the wave (policy-as-code rules, GitOps manifests, runbook revisions) is not discarded by the rollback. It remains in version control as a historical record and as a starting point for any future re-attempt.

29.4 Communication during rollback

Rollback communication addresses three audiences with three distinct needs.

Affected user constituency. The constituency directly affected by the rollback (a faculty whose segment is reverted, a research group whose pilot is decommissioned, a population whose posture rule is reverted) receives advance notice through the established communication channel for the wave. The notice includes the rollback timeline, the operational impact, and the named contact for questions.

Programme governance. The governance body established in Wave 0 is informed of the rollback at its next regular cycle, or earlier if the rollback affects the programme's overall plan. The information is decision-oriented: what triggered the rollback, what was preserved, what the next steps are.

External stakeholders. Where the rollback affects external relationships (federation partners, supplier contracts, regulatory bodies whose obligations are touched by the wave), explicit communication ensures that the external parties are not surprised. The message is calibrated to the stakeholder: federation partners need technical detail, suppliers need contractual clarity, regulators need documentation that the institution remains within its obligations.

29.5 Post-mortem and re-planning

A rollback is followed by a structured post-mortem. The intent is not to assign blame but to extract learning that the next attempt can apply.

Post-mortem template. The post-mortem records, at minimum: the trigger that produced the rollback decision, the rollback execution itself (what worked, what did not), the data and communication outcomes, the root cause as best understood, and the recommendations for any future attempt. The template is consistent across waves so that post-mortems accumulate into a comparable record.

Conditions for re-attempt. The post-mortem produces explicit conditions under which the wave (or its rolled-back portion) may be re-attempted. The conditions typically include specific technical changes, process changes, or pre-requisites that were absent the first time. A re-attempt is treated as a new wave phase, not as a continuation of the original.

Lessons-learned propagation. The post-mortem is shared with the broader programme, with peer institutions through the NREN community, and where appropriate with the international network anticipated in phase 2. The institutional cost of the rollback becomes shared learning; the next institution that attempts the same wave benefits from the experience.

The reversibility playbook is the discipline that allows the playbook of Part III to be ambitious without being reckless. An institution that has internalised the playbook can commit to a wave with the confidence that, if the wave proves unworkable, the institution will return to a known state at acceptable cost. That confidence is what makes the architecture transformation a governance decision rather than a leap of faith.

Chapter 30

Coexistence patterns library

The wave chapters of Part III each declare a coexistence pattern as the operational state of the wave. Several of those patterns recur across waves and across institutions; this chapter consolidates the six most frequently encountered, presents their bridging mechanisms, and notes the anti-patterns that recur with them. The patterns are described at the level of operational principle rather than at the level of specific tooling, since their realisation varies with the products the institution operates.

30.1 Pattern: incumbent enterprise directory ↔ institutional IdP

The pattern in which the incumbent enterprise directory remains the authoritative source for staff identities while a new institutional identity provider (an open-source IdP or comparable) handles federation, role activation, and downstream OIDC integrations.

Bridging mechanism. The incumbent enterprise directory, supplied by the institution's incumbent identity-suite vendor, continues to authenticate users at the institutional perimeter. The new IdP federates against the directory through standard SAML2 or OIDC bridges. Attributes from the directory — group membership, role, organisational unit — are mapped to the institutional schema (D7.7) at the boundary of the new IdP rather than propagated into downstream applications in their native form.

Synchronisation direction. The pattern is unidirectional from the incumbent directory toward the new IdP for the duration of Wave 1. Reverse synchronisation (changes made in the new IdP flowing back to the directory) is generally avoided to keep the directory's authoritative status unambiguous.

Drift detection and exit window. Discrepancies between the directory and the new IdP are surfaced through the observability layer. The pattern's exit window is the period during which the institution can return to directory-only operation if the new IdP fails; the window is typically aligned with the legacy IdP retirement schedule.

30.2 Pattern: incumbent endpoint-management suite ↔ declarative configuration

The pattern in which the institution's existing endpoint configuration management (the incumbent vendor's unified endpoint management suite) coexists with declarative configuration (a declarative configuration-management toolchain) for the populations the new approach covers.

Bridging mechanism. Each population is governed by a single source. Staff desktop endpoints typically remain on the incumbent-suite side; servers and research workstations typically move to the declarative-configuration side; other endpoint classes can sit on either side depending on the institution's mature tooling. The boundary between the populations is documented and stable for the duration of the coexistence.

Configuration overlap. Where a single endpoint must be visible to both systems (rare, but it occurs in shared-use scenarios), the institution declares which system is authoritative for which configuration domain — typically the incumbent suite for compliance policy and the declarative toolchain for application configuration.

Posture export. The unified posture schema of D11.6 ingests posture from both sides. Policies in Chapter 7 of the Technical Reference are authored against the unified schema and do not depend on which configuration management produced the signal.

30.3 Pattern: per-volume-priced commercial SIEM ↔ open-source store

The pattern in which a per-volume-priced commercial SIEM operates alongside an open-source store, with the institution managing the boundary deliberately for operational and financial reasons.

Bridging mechanism. The collector layer of Wave 2 emits the canonical TAC schema to both stores. The commercial SIEM ingests the events that the SOC actively investigates within the investigation window the institution chooses to fund; the open-source store ingests the longer-tail retention that the commercial SIEM's per-GB pricing makes unattractive. Detection content is authored in both stores where the institution's risk profile warrants duplication.

Per-source routing. Sources whose events are most operationally consumed by the SOC (identity, network attachment, endpoint posture) are routed to the commercial SIEM in full; sources whose events serve audit-replay rather than routine investigation (verbose flow records, low-severity informational events) are routed primarily to the open-source store with a sampled stream to the commercial SIEM for context.

Migration of dashboards. Commercial-SIEM dashboards are migrated incrementally to the open-source store and its visualisation layer when the institution chooses to retire a commercial-SIEM content element. The choice to retire is informed by financial review rather than by technical inability.

30.4 Pattern: incumbent commercial hypervisor ↔ open virtualisation substrate

The pattern in which the incumbent commercial hypervisor platform continues to host the institution's existing workloads while new workloads are provisioned on an open virtualisation substrate (a Kubernetes-native VM platform or an open-source IaaS), with explicit governance of which platform hosts which workload.

Bridging mechanism. The governance layer (Wave 8 classification) decides per workload class which platform is appropriate: existing legacy workloads stay on the commercial hypervisor through their natural lifecycle; new workloads provision on the open substrate by default; specific

workload classes that benefit from the commercial platform's operational features (live migration, mature DR) remain on it by explicit decision.

Live-migration boundary. Live migration between substrates is technically possible (the open substrate can import the commercial platform's VMs, and supports VM-level migration) but is treated as a project rather than a routine operation. Cold migration on workload retirement / refresh is the more common pattern.

Skills coexistence. Operational teams need both skill sets during the coexistence, and the institution's staffing profile must carry both for the duration. The skill investment is typically an explicit programme item rather than a passive expectation.

30.5 Pattern: enterprise storage array ↔ open-source distributed storage

The pattern in which an enterprise storage array from a commercial vendor continues to host the institution's existing data corpora while an open-source distributed storage cluster provides storage for new workloads and for the research-scale capacity the enterprise platform is not cost-effective for.

Bridging mechanism. The classification scheme of D10.4 determines which platform hosts which data class. Enterprise storage typically retains administrative and compliance data; the open-source cluster typically holds research data, container persistent volumes, and the cold-tier object storage that the observability layer (D12.3) needs.

Migration of pools. Migration from one platform to the other occurs at workload boundaries: a workload migrating between platforms (Wave 8) typically migrates its storage at the same time. Storage-only migration without workload migration is operationally costly and is reserved for specific drivers (end-of-support, cost reset, disclosure-regime change).

Data-integrity validation. A migration between platforms validates data integrity through documented checksums or content-addressable verification. The validation is part of the conformance suite of Chapter 16 of the Technical Reference (data-portability category).

30.6 Pattern: eduroam ↔ TAC-aware Wi-Fi

Where the institution participates in a federated academic-roaming service (in the research-and-education community, eduroam), this is the pattern in which that participation continues for inter-institutional roaming while a TAC-aware RADIUS attachment governs intra-institutional connections.

Bridging mechanism. The institution's RADIUS service recognises both authentication paths. eduroam-routed authentications (visiting researchers from peer institutions, staff roaming abroad) follow the eduroam attribute schema unchanged. Local authentications (staff and students at the institution's sites) carry the institutional schema with TAC- relevant attributes that the policy plane consumes.

Attribute schema preservation. The federated-roaming technical profile (eduroam, where used) is treated as inviolate: extending it with institution-specific attributes for inter-institutional sessions would break federation. The institutional attributes are added only on the non-roaming authentication path.

Roaming policy. Visiting researchers receive the default eduroam treatment (Internet access from a guest zone) unless an explicit institutional arrangement (a hosted research project, a long-stay visitor) provisions a TAC for them.

30.7 Common anti-patterns

The patterns above describe how coexistence is managed. The anti-patterns below describe how it goes wrong.

Long-running dual stack without exit date. A coexistence period whose end is not declared at the wave's start tends to become permanent. The institution operates two of everything indefinitely, and the cost grows. The mitigation is to declare the exit date at wave open, to track it through the programme governance, and to escalate when the date drifts.

Unspecified bridging ownership. The bridge between two systems requires operational ownership. When ownership is implicit, the bridge fails silently — a synchronisation job stops, a metadata refresh expires, a policy mapping drifts — and the discovery is during an incident. The mitigation is to name the bridge owner explicitly at wave open, with documented escalation path.

Bidirectional sync without conflict resolution. A bridge that synchronises in both directions without a documented conflict-resolution rule produces silent data loss when the two sides diverge. The mitigation is unidirectional sync wherever possible; where bidirectional is unavoidable, an explicit conflict-resolution rule documented and tested before production deployment.

Coexistence as a permanent feature. Some institutions stabilise on a coexistence pattern and treat it as the architecture rather than as a transition. The pattern is not always wrong (a hybrid open-source federation-and-IdP identity arrangement is a legitimate end-state, for example), but it should be a deliberate decision rather than an accident. The mitigation is the periodic review under the sovereignty grid: a coexistence that has not been revisited in twenty-four months is reviewed against its current costs and benefits.

The patterns and anti-patterns above are the principal operational shapes of coexistence in the playbook. Their explicit documentation in the institution's wave plans turns coexistence from an unplanned consequence of migration into a deliberate engineering artefact.

Part IV

References and Operational Material

Chapter 31

Institutional precedents

Status of this chapter

The institutional precedents in this chapter are identified as starting points for the institution's own research, not as direct templates. The architectural choices, operational practices, and contractual arrangements at any cited institution should be confirmed against that institution's own current public documentation before being cited as precedent in derivative work. This chapter records the institutions that have appeared in public discussion of the patterns this Reference draws on; it does not claim independent verification of every aspect of every deployment.

The architecture and playbook of this Reference do not invent their structural patterns from first principles — they consolidate patterns visible at research institutions whose practices have been the subject of public discussion. This chapter records the institutional patterns that have appeared most consistently as references, organised by region and by the practice they illustrate. The catalogue is intended for the international university network anticipated in phase 2 of this initiative as a starting point that the network will refine and extend with direct contributions from each member.

31.1 Method

The institutions below are identified through three methodological filters: appearance in research-and-education-network community fora and at regional higher-education associations (such as EDUCAUSE in North America) in recent publications; reference in NIST or ISO/IEC publications that draw on academic deployments; mention in publicly available research-network case material (regional and national research-network case studies). The filters bias the catalogue toward institutions that publish their architectures — in practice, larger and flagship institutions that maintain public architecture documentation; institutions whose practice is mature but undocumented, and smaller or teaching-led institutions that consume the same primitives as shared services rather than documenting their own builds, are necessarily under-represented. This is a documentation bias, not a statement about which institutions the architecture can serve (see §31.7).

What is and is not claimed. The catalogue claims that each pattern has been the subject of public discussion at the kind of institution to which it is attributed. The catalogue does *not* claim that the institution's current architecture matches the description; that the institution endorses the pattern's use in this Reference; or that the cited practice is the institution's authoritative position. Each entry should be treated as a starting point for the reader's own research.

Refresh cadence. The catalogue would benefit from annual review: institutional architectures evolve, public documentation is revised or withdrawn, NREN community discussions move forward. The phase-2 international network is the natural locus for this refresh.

31.2 European institutions

A large research organisation. A large European research organisation operating a multi-institutional collaboration across many countries illustrates the pattern of an identity federation, an audit pipeline, and a high-performance experimental network architecture maintained under a strong public-documentation practice. The migration of such an organisation's identity and access management from a proprietary federation service to a Keycloak-based open-source single sign-on is documented in conference proceedings [38↗]. Scale and an open documentation practice make this class of organisation one of the most frequently cited research-organisation references for research-intensive university IT.

A federal institute of technology. A federal institute of technology illustrates the model of granting local administrator rights through a documented procedure (request, IT risk assessment, approval by an authorised person in the applicant's organisational unit) and an IT-services group federated across departments. The pattern of distributed IT authority within a coherent institutional framework is a recurring point of reference in this Reference's federated-governance discussions.

A collegiate university. At a collegiate university, a central information-services function operates the institution's technology while an institutional data-network backbone connects the central services and the constituent colleges. The collegiate model illustrates a federated-network pattern under a coherent institutional architecture.

A second collegiate university. Distributed IT under a central information-security policy framework is similarly documented at other collegiate institutions. The pattern is similar in spirit to the preceding case but differs in operational details that each institution's own documentation should be consulted for.

A national flagship research university. A national flagship research-intensive university operating a central IT function is a typical European reference institution for research-data infrastructure. Public documentation at such an institution is often more limited than at the larger network-anchored institutions.

31.3 North American institutions

A research-intensive institute of technology. At a research-intensive institute of technology, a central information-systems function, an information-technology governance committee reporting to the chief academic and executive officers, and a flagship laboratory's technical-infrastructure group appear recurrently as references for the federated-IT-governance pattern. Such a governance committee typically operates with a set of related committees (infrastructure steering, policy, project) that consult on different aspects of IT strategy. Public documentation at this class of institution is extensive and accessible.

A large research-intensive university. A campus-network function, a central university-IT organisation, and a dedicated research-computing centre appear as references for large-scale research-intensive university IT. The public documentation of the multi-zone segmentation pattern at such institutions is a frequently cited starting point.

A network-anchored public research university. A central IT-services organisation, an information-technology council, and a regional research-network relationship illustrate the network-anchored pattern at a large research-intensive university. A college of engineering's own computing network is a typical instance of faculty-level IT autonomy under institutional governance.

A national research-cloud deployment. A research-cloud architecture [54↗], operated under a national science-funding agency's access programme, is one of the most extensively documented research-cloud deployments. It is cited recurrently in this Reference's discussion of compute and research-storage patterns.

A federated research university. A research-intensive university is frequently cited for its identity-federation participation and for the integration of faculty IT with central services. Public documentation is accessible through such an institution's IT-services pages.

31.4 Asia-Pacific institutions

A regional federation hub. A leading national research university in the region has been cited for federation patterns at the regional scale and for the integration of multi-jurisdiction research collaborations. Public documentation is often partial, with the accessibility of English-language material varying across regional references.

A federation-participating national university. A national university's participation in its country's access federation and in network-anchored research networking is a publicly documented reference for Asia-Pacific research-network patterns.

A research-intensive university with limited public documentation. Some of the most-cited references in the region maintain only limited English-language public documentation relative to the European and North American institutions discussed above. Direct engagement with such an institution would be necessary for any precedent claim.

31.5 Latin American institutions

A national flagship research university. A national flagship research university is one of the principal references for Latin American research-network patterns. Its participation in the national research and education network and in the national identity federation provides documented federation precedent.

A large public research university. A national flagship public research university is a reference for large-scale public-university IT. Public documentation in the national language is often extensive, with English-language material more limited.

31.6 NRENs and consortium initiatives

National Research and Education Networks and their consortia are the principal multipliers of the patterns this Reference develops. They produce shared documentation, operate shared services, and host community fora in which architectural discussions take place.

© SUITOAAA

The regional research-network backbone. The research-network backbone serving the institution's region connects the national research and education networks of that region and operates the federated-identity and federated-access services on which the Reference's identity and attachment patterns rest — typically a federated single-sign-on interconnect, a collaborative-identity service, and a roaming network-access service. Its community fora are a principal venue for the discussions feeding this Reference.

The institution's national research and education network. The national research and education network connects the country's research and education community to the regional backbone and operates institutional services, commonly including a national computer security incident response capability. The national network's role as a shared operator is relevant to several of the architecture's mutualisation patterns.

Regional research-network consortia. Beyond the national network, regional research-network consortia operate services analogous to the backbone's and serve as the principal venues for community discussion of architectural patterns at research-intensive universities in their respective regions.

Sector service organisations. National and regional research-and-education service organisations operate the country or region's academic backbone network and support a large body of community guidance on which the Reference's patterns draw; several also operate the national or regional identity federation.

31.7 The precedents illustrate the architecture; they do not gate it

The catalogue above is dominated by large, research-intensive institutions for the methodological reason stated in §31.1: such institutions maintain extensive public architecture documentation, so their practice is citable. This must not be read as an admissibility bar. As established in Chapter 5 of the Technical Reference (§5.2), the functions the architecture discharges are a minimal necessary set for any institution offering a digital infrastructure, several of them legally compelled regardless of size; the precedents illustrate *how* those functions are realised at scale, they do not define *which* institutions the architecture serves.

The shared-service channel. A national research and education network exists to serve its country's entire research and education community, not its flagship institutions alone; national networks are mandated accordingly, a mandate documented for European national operators, e.g. [75, 76↗, 77↗], with comparable mandates in other regions. Through such operators, federated identity through the national or regional identity-federation profile [37↗], collaborative identity [41↗], and federated network access are available to a small or teaching-led institution as managed services, without that institution operating the underlying infrastructure; the regional research backbone (membership and backbone capacity per region) carries the same primitives across borders (in the EU, GÉANT [49↗]). A precedent need not be a flagship to be relevant: an institution that consumes federated identity through its national research and education network is exercising exactly the identity-layer pattern of Chapter 19 of the Technical Reference, at a realisation it can sustain.

Implication for the catalogue. The phase-2 international network (§31.1) is the natural locus for recording such adoptions explicitly and broadening the catalogue beyond the publication-rich flagships that necessarily dominate it today; sector-guidance bodies such as Jisc in the UK [78↗], and their regional analogues elsewhere, already document these patterns for institutions across the size range.

© SUITOAAA

31.8 Documented gaps

Several areas of the architecture remain thinly documented in public institutional sources:

- **Policy plane deployments at academic scale.** The industrial OPA and Cedar deployments provide most public documentation; academic deployments are reported informally in NREN fora but are rarely the subject of detailed public architecture documents.
- **TAC-aware audit pipelines.** The canonical TAC schema and the cross-layer correlation pattern are not, at the time of writing, the subject of any single publicly documented academic deployment. Various aspects are visible at various institutions; the consolidated pattern is novel to this Reference.
- **Sovereignty grid practice.** The grid is novel to this Reference. Adjacent practice exists (procurement sovereignty clauses, exit-data-export contractual language) but a structured five-dimension grid applied across an institutional IT portfolio has not, to the author's knowledge, been the subject of public institutional documentation.

The phase-2 international university network is the locus where these gaps would be addressed: institutions that adopt the architecture would publish their experience, and the catalogue of precedents would acquire entries that this version cannot yet record.

Chapter 32

External references and standards

This chapter is a curated index of the normative references on which the architecture and the playbook rest. It is not a literature review; the standards listed below are those that appear in the contracts of Part II or in the wave declarations of Part III. Each entry indicates briefly the role the reference plays in this document; full citations are in the bibliography.

32.1 NIST publications

The NIST series provides several of the architectural anchors this Reference draws on. The following are most directly used.

NIST CSF 2.0 — Cybersecurity Framework [79↗]. The five-function structure (Govern, Identify, Protect, Detect, Respond, Recover) is referenced implicitly throughout the architecture: Govern aligns with the sovereignty grid and the playbook's wave-0 governance discipline; Detect and Respond align with the observability and audit chapters; Recover aligns with the reversibility playbook.

NIST SP 800-207 — Zero Trust Architecture [50↗]. The zero-trust principles — never trust by location, verify continuously, assume breach — align with the TAC model's per-activity context and with the policy layer's per-request decision. The SP 800-207 abstract decomposition into PE (policy engine), PA (policy administrator), and PEP (policy enforcement point) maps onto the architecture's policy layer (Chapter 7 of the Technical Reference) and its enforcement points across the execution plane.

NIST SP 800-53 Rev. 5 [80↗]. The control families (AC, SC, AU, IA, CM, IR among others) are referenced as the source for several of the architecture's contractual obligations: SC-7 (boundary protection) for Chapter 8 of the Technical Reference; AU-2 and AU-12 (audit events) for Chapter 12 of the Technical Reference; IA-2 and IA-8 (identification and authentication) for Chapter 6 of the Technical Reference.

NIST SP 800-162 — Attribute-Based Access Control [5↗]. The ABAC framework underpins the policy layer's evaluation model: attributes from the subject (identity), the resource (classification), and the environment (zone, time, posture) compose the policy decision.

NIST SP 800-171 Rev. 3 [81↗]. The CUI (Controlled Unclassified Information) protection requirements inform the data-classification discussion of Chapter 10 of the Technical Reference, particularly for institutions with United-States government research contracts.

NIST SP 800-160 Vol. 2 [82↗]. Cyber-resiliency techniques — segmentation, contextual awareness, dynamic positioning, deception — are referenced as the resilience underpinning of the architecture's fault-tolerance posture.

NIST SP 800-215 [83↗]. Trusted infrastructure considerations relevant to the reference architecture's hardware and platform choices.

NIST SP 1800 series. The practice-guide series (notably SP 1800-3 *Attribute Based Access Control* and SP 1800-19 *Trusted Cloud*) provides worked-example deployments for several of the patterns this Reference develops. These guides are practitioner-oriented and complement the SP 800 family.

32.2 ISO/IEC publications

ISO/IEC 27001:2022. The information-security management system standard frames the institutional context in which the architecture operates. The control catalogue (Annex A) is a recurring reference for procurement clauses; the management system clauses inform the wave-0 governance discipline.

ISO/IEC 27002. The implementation guidance accompanying ISO/IEC 27001 expands several controls into operational practice; A.8.22 (network segregation) is referenced in Chapter 8 of the Technical Reference as the framework anchor for the zone-based segmentation pattern.

ISO/IEC 27005. Risk management for information security; provides the methodology underpinning the wave-aware risk register of Chapter 28 of the Technical Reference.

ISO/IEC 19790 and FIPS 140 series. Cryptographic-module security requirements frame the HSM choices of Chapter 13 of the Technical Reference, particularly for institutions with regulatory obligations that name a specific FIPS level.

32.3 European regulatory framework

General Data Protection Regulation (GDPR) [8↗]. The risk-based security obligation (Art. 32), the data-protection-by-design obligation (Art. 25), and the data-protection-impact-assessment obligation (Art. 35) are the EU instance of the data-protection regime against which the data dimension of the sovereignty grid is scored (generically, the institution's applicable data-protection regime).

NIS2 Directive [10↗]. The cybersecurity obligations on essential and important entities, particularly the management-body accountability for security measures (Art. 20), are the EU instance of the cybersecurity-baseline regime (generically, the applicable supranational and national legal framework) that informs the institutional sovereignty dimension and the wave-0 governance discipline. The incident-reporting obligations align with the audit and IR pipeline of Chapter 25 of the Technical Reference.

***Schrems II* judgement (C-311/18) [6↗].** The CJEU's clarification that contractual safeguards alone do not satisfy data sovereignty when data falls under a third-country surveillance regime is, for adopters under the EU regime, the anchor of the data-dimension scoring in the sovereignty grid; generically that scoring follows the applicable cross-border data-transfer regime.

EU AI Act (Regulation 2024/1689). The risk-based classification of AI systems intersects with the policy-plane authorisation decisions for AI-related TACs (the Researcher-LLM-API pilot scenario of Chapter 23 of the Technical Reference in particular).

eIDAS 2. The renewed framework for electronic identification and trust services informs the cryptographic services chapter for institutions that provide EU-recognised electronic credentials.

EDPB transfer guidelines [7↗]**.** The European Data Protection Board's recommendations on data transfers operationalise the post-Schrems-II posture for the data- dimension assessment.

32.4 Sector publications

EDUCAUSE [84↗]**.** In North-American higher education, the principal venue for IT discussion. Its Top 10 IT issues, governance case material, and identity-and-access- management practice papers inform several of the institutional-precedent claims in Chapter 31 of the Technical Reference; equivalent sector bodies (e.g. UCISA in the UK, regional consortia elsewhere) play the analogous role in other jurisdictions.

REN-ISAC [85↗]**.** In the North-American context, the Research and Education Networks Information Sharing and Analysis Center provides incident-response intelligence and coordination patterns referenced in Chapter 25 of the Technical Reference; the analogous role elsewhere is the regional NREN CSIRT or national R&E ISAC.

ENISA [9↗]**.** The European Union Agency for Cybersecurity provides risk-management and incident-response guidance; its publications underpin several institutional sovereignty-dimension considerations.

Research-and-education-network community publications. The institution's national research and education network, and the regional research-network community to which it belongs, publish architecture reviews, operational case material, and federation guidance (the applicable inter-institutional identity-federation profile, e.g. eduGAIN [37↗], the associated collaboration-management service eduTEAMS [41↗], and the community authentication-and-authorisation AARC Blueprint [42↗]) that inform the multiple references in this document to identity federation, audit pipelines, and research-network patterns.

Verizon DBIR [86↗]**.** The annual Data Breach Investigations Report provides the empirical anchor for several of the threat-pattern discussions in the policy and audit chapters.

32.5 Open-source specifications and projects

The reference instantiation of Part II can be realised with open-source specifications and projects such as those listed below. The list is illustrative rather than prescriptive or exhaustive; it records representative projects of the kind referenced in the Reference's contracts and instantiations, and equivalent alternatives may be substituted on a like-for-like basis. Project documentation should be consulted for current capability statements; the ecosystem evolves at a faster cadence than this Reference.

Identity layer. Keycloak [36↗] (federated identity provider with OIDC and SAML2 support); Shibboleth [40↗] (SAML2 federation, widely deployed in academia); the applicable inter-institutional identity-federation technical profile [37↗] (inter-institutional federation policy framework).

Policy layer. Open Policy Agent (OPA) [16↗] (CNCF graduated, Rego-based policy decision engine); Cedar [17↗] (open formal-semantics policy language).

Network layer. FreeRADIUS [44↗] (open-source RADIUS server); Open vSwitch [45↗] (OVS, programmable switch); Cilium [21↗] (eBPF-based CNI for Kubernetes, micro-segmentation); NETCONF/YANG [19↗, 20↗] (IETF standards for declarative network configuration).

Compute and storage. Kubernetes [23↗] (CNCF, container orchestration); OpenStack [24↗] (OpenInfra Foundation, IaaS); Ceph [56↗] (distributed storage); Harbor [51↗] (CNCF, container registry); SLSA [26↗] (Supply-chain Levels for Software Artifacts, OpenSSF); Sigstore [52↗] (artifact signing and verification); OCI image format [25↗].

Endpoint. Munki [58↗] (macOS software distribution); osquery [29↗] (cross-platform endpoint posture queries); Ansible [30↗] (declarative configuration management); MicroMDM [59↗] / NanoMDM (open Apple MDM servers).

Observability. Vector [63↗] (event collection and routing); Apache Kafka [62↗] (durable event ingestion); OpenSearch [64↗] (analytical store); Grafana Loki [65↗] (log-line search); Grafana [66↗] (dashboards); OpenTelemetry [31↗] (CNCF, telemetry collection standard); CloudEvents [32↗] (CNCF, event format).

Cryptography. HashiCorp Vault [57↗] (secrets and PKI); step-ca [69↗] (Smallstep, ACME-compliant institutional CA); SoftHSM [70↗] (software HSM for non-production); Nitrokey HSM (hardware HSM with PKCS#11 support).

Orchestration. Argo Workflows [72↗] (CNCF, workflow engine); Argo CD [71↗] / Flux (CNCF, GitOps reconcilers); Crossplane [73↗] (CNCF, infrastructure-as-code beyond Kubernetes); Temporal.io [74↗] (durable workflow engine); Tekton [53↗] (CNCF, CI/CD pipelines).

The standards and projects above illustrate one viable backbone for the Reference's instantiation. The list is a working artefact: projects gain or lose maturity over time, new projects emerge, specifications are revised, and equivalent components may be substituted. The phase-2 international university network would be the natural locus for maintaining a current and collectively curated version of this catalogue.

Chapter 33

Regulatory mapping

Status of this chapter

This chapter records the working interpretive mapping between the architecture's contracts (Part II) and the playbook's waves (Part III) on the one hand, and the regulatory provisions and normative controls most likely to apply to a typical research-intensive institution on the other. The mapping is interpretive and would need to be reviewed by qualified counsel and by the institution's data-protection and information-security officers before being relied on for a compliance argument. National transpositions of European directives, sectoral regulations, and contractual obligations from research funders may add provisions that this chapter does not record.

The architecture and the playbook of this Reference are not designed against a regulatory checklist; they are designed against the engineering question of how a university can be sovereign at the architectural level, and they are then read against the regulations that the institution will face. This chapter performs that second reading at two levels. It opens with the shared, jurisdiction-neutral *Regulatory Applicability* module, which abstracts the size- and jurisdiction-invariant functional-obligation spine (F1–F6) and its obligation → mechanism matrix (Table 33.1); that matrix is the shared anchor that the Policy and this Solution both reference for the Policy ↔ Solution traceability. It then continues with the detailed, per-article EU instantiation that follows the module — organised by regulation and, within each regulation, by article or control. Each per-article mapping row identifies: the provision, the architecture element (layer, wave, or contract) that the institution may invoke, and the chapters and sections of this Reference where the operationalisation is described. The per-article mapping is the consolidated view of the per-chapter *Regulatory anchoring* paragraphs introduced in the layer and wave chapters; it is one worked instantiation — the EU/EEA regime row of the module's typology (§33.2.1) — developed to article granularity.

33.1 Regulatory applicability: the invariant obligation spine

Status and scope of this module

This module records an interpretive engineering mapping between a small set of functional obligations that every modern data-and-cyber regulatory regime imposes on a university, and the SUIT control set that an institution can invoke to discharge them. It is *not* legal advice. The named instruments, authorities and deadlines are the worked instantiation of each regime as of mid-2026; an adopting institution must have its mapping reviewed by qualified counsel and by its own data-protection and information-security officers before relying on it for a compliance argument. National transpositions, sectoral overlays and funder-imposed clauses may add provisions this module does not record.

The architecture and the playbook of the SUIT suite are not designed against a regulatory checklist; they are designed against the engineering question of how a university can be sovereign at the architectural level, and they are then *read* against the regulations the institution faces. This module performs that reading at the level of the regime, not the article. Its claim is deliberately narrow and therefore transferable: across every regime we examined — and, we argue, across every regime an adopter will meet — the same short list of **functional obligations** recurs. The instruments that carry them, the competent authorities that enforce them and the exact deadlines differ by jurisdiction; the *functions* do not. That invariant list is the proof an adopter can carry from one jurisdiction to the next.

33.1.1 The functional-obligation spine (F1–F6)

We name the spine in role terms so that it survives translation across regimes. Each obligation is a *function the regulator requires the institution to perform*, independent of the statute that happens to require it in a given country.

F1 — Personal-data protection / security of processing.
Classify personal data and apply appropriate technical and organisational measures to protect its confidentiality, integrity and availability. This is the omnibus data-protection duty (GDPR Art. 32 in the baseline; an equivalent exists in every regime examined).

F2 — Cybersecurity risk governance.
Run a documented, risk-based information-security programme — risk analysis, accountable owner, cyber-hygiene, network and information-system security measures — attaching to the *function performed* rather than to headcount.

F3 — Incident and breach notification.
Detect security and personal-data incidents and notify the competent authority (and, where the risk is high, affected individuals) within a regime-specific deadline.

F4 — Cross-border / international data transfers.
Establish a lawful route to move personal data outside the home jurisdiction for cloud, identity, research-collaboration and AI services.

F5 — Electronic identification, trust services and AI / technology governance.
Provide trustworthy electronic identification, signatures and seals, and govern the controlled technologies the institution deploys (AI systems; export-controlled or otherwise restricted technology) under the applicable risk-based regime.

F6 — Accountability, auditable logging and conformity.
Retain auditable logs and records and be able to *demonstrate* that F1–F5 are in place — the cross-cutting evidentiary duty that makes the other five reviewable.

Why the spine is size-invariant. The spine is a **minimal necessary set**: it is the smallest collection of functions below which an institution is not compliant in *any* of the regimes examined, and it does not grow with the size of the institution. The anchor for the claim is the data-protection regime's *absence of a de-minimis threshold* for the security, accountability and breach duties: under the baseline GDPR, the only size-conditioned relief is the Art. 30(5) records-of-processing derogation below 250 persons, which is itself conditional and does not touch security, accountability or breach duties [8↗]. The cybersecurity regime attaches the same way: NIS2 scope is a function of the *service performed*, not of headcount [10↗]. A small institution therefore performs the same six functions as a large one; only the *instantiation* — the number of systems, the size of the team, the volume of logs — scales. This is the transferable core: an adopter that can show it discharges F1–F6 has shown the regulator-facing minimum, whatever its size and wherever it sits.

33.1.2 The obligation → mechanism matrix

The spine becomes operational when each function is mapped to the SUIT control set that contributes to discharging it. The matrix below is the size- and jurisdiction-invariant core: it is read identically in every regime, and only the *instrument* column (the local statute, authority and deadline) is substituted per jurisdiction in Section 33.2. The control-set references are role-based — they name architectural *capabilities*, not products — so the matrix transfers without editing.

Table 33.1: Obligation → mechanism matrix — the invariant core. Each functional obligation maps to the SUIT control capabilities that contribute to discharging it; only the regulatory instrument is substituted per jurisdiction.

Functional obligation	SUIT control mechanism (invariant)	What the regulator can be shown
F1 Personal-data protection / security of processing	Identity, policy, network and cryptographic-services capabilities as the technical chain enforcing access control and confidentiality; storage-placement constraints; the sovereignty-grid data dimension	A documented technical-measures chain proportionate to risk, keyed to the data classification
F2 Cybersecurity risk governance	The ISO/IEC 27005-aligned risk-analysis method; the policy and governance capabilities; network segmentation and cyber-hygiene baselines; the conformance suite as evidence of effectiveness	A risk-based, owner-accountable security programme with current risk analysis and tested controls
F3 Incident and breach notification	Observability capability (logging, monitoring, detection); the audit pipeline for timeline reconstruction; the documented incident-response procedure with a notification path	Detection-to-notification within the regime deadline, with an evidenced timeline
F4 Cross-border / international data transfers	Storage-placement and key-custody controls; the sovereignty-grid data dimension recording the disclosure-regime exposure; transfer safeguards (encryption, pseudonymisation) as supplementary measures	A lawful-transfer route with a documented transfer-risk assessment and supplementary technical measures
F5 Electronic identification, trust services and AI / technology governance	Identity and cryptographic-services capabilities (qualified signatures/seals); the technology-control and segregation patterns for restricted technology; AI-system inventory and human-oversight hooks	Trustworthy e-identification and a governed inventory of controlled technologies with oversight evidence
F6 Accountability, auditable logging and conformity	The auditable-logging and records capability; the conformance suite producing assessment artefacts; the sovereignty grid as the design-decision record	A standing evidence base demonstrating that F1–F5 are in place and reviewable on request

How to use the matrix. The left column is fixed: it is the spine of Section 33.1.1. The middle column is fixed: it is the SUIT capability set, named in role terms. Only the binding *instrument* changes per regime — which statute imposes F1, which authority enforces F3, what the F3 deadline is. The regime typology that follows fills exactly that variable part, regime by regime; the mapping method of Section 33.3 lets an adopter in an unlisted regime fill it for itself.

33.2 Regime typology

Regimes differ in **depth**, not in the spine they impose. A **deep** regime (here the EU and the US) carries the spine through a dense, multi-instrument stack with hard deadlines and conformity machinery; it earns a full F1–F6 table plus a worked applicability demonstration. A **light** regime (here the United Kingdom, Brazil and South Africa) carries the same spine through a more compact instrument set; it earns a concise but real F1–F6 table. The five profiles below span Europe, North America, South America and Africa. Each is one worked instantiation an adopter substitutes with its own.

33.2.1 European Union / EEA — deep regime (baseline anchor)

The EU/EEA is the SUIT baseline anchor: a deep, directly-applicable stack in which the spine is carried by named Regulations and a Directive, each with its own competent authority and operative deadline. The data-protection authority is each Member State's national DPA, made consistent by the European Data Protection Board; the cybersecurity authority is the national NIS2 competent authority and CSIRT, coordinated by ENISA; trust services run through the national eIDAS supervisory body; AI through national market-surveillance authorities and the European AI Office; and transfer adequacy is decided by the European Commission.

Table 33.2: EU/EEA — F1–F6 instantiation of the invariant spine.

Obligation	Instrument and authority	Deadline / mechanism
F1 Data protection / security of processing	GDPR Art. 32 [8↗]; national DPA, EDPB for consistency	Directly applicable since 25 May 2018; standing duty, no size threshold
F2 Cybersecurity risk governance	NIS2 Directive (EU) 2022/2555 with Implementing Regulation (EU) 2024/2690 [9↗, 10↗, 87↗]; national NIS2 competent authority / CSIRT, ENISA	Transposed by 17 Oct 2024; ten Art. 21(2) measure families (MFA, cryptography, access control, supply-chain); function-based scope
F3 Incident and breach notification	GDPR Arts. 33–34 [7↗, 8↗]; NIS2 Art. 23 reporting [10↗]; national DPA and NIS2 authority	GDPR: notify DPA without undue delay, ≤72 h; NIS2 tiered: early warning ≤24 h, full notice ≤72 h, final report ≤1 month
F4 Cross-border transfers	GDPR Chapter V: adequacy (Art. 45), SCCs (Art. 46, Decision 2021/914), EU–US DPF adequacy [8↗, 88↗, 89↗]; European Commission (adequacy), DPAs/EDPB (safeguards)	Transfer mechanism: adequacy where it exists, else SCCs + a post-*Schrems II* transfer-impact assessment and supplementary measures
F5 eID, trust and AI governance	eIDAS 2 — Reg. (EU) 910/2014 as amended by 2024/1183 [90↗]; AI Act Reg. (EU) 2024/1689 [91↗]; AI Act via national market-surveillance authorities and the European AI Office	eIDAS 2 in force 20 May 2024, EUDI Wallet by end-2026; AI Act phased: prohibited practices Feb 2025, GPAI Aug 2025, high-risk Aug 2026 (research/R&D exemptions)
F6 Accountability, logging, conformity	GDPR Arts. 5(2), 24, 30 [8↗]; NIS2 Art. 21 logging / Art. 23 reporting [10↗, 87↗]; national single-window platforms [92]	Standing: records of processing on DPA request; NIS2 logging / maturity reporting through the national reporting platform

Worked applicability demonstration (EU). Take a mid-sized research-intensive university operating only in one Member State, with no defence research and a single national campus. Does the spine apply, and at what depth? *F1* applies in full and unconditionally: the GDPR security duty has no de-minimis threshold, so the institution must run the technical-measures chain keyed to its data classification regardless of size [8↗]. *F2* applies because NIS2 scope is function-based: a university that operates its own network, identity and research-computing services performs the services that bring an entity into scope as an essential or important entity, irrespective of headcount [10↗]. *F3* therefore bites at two deadlines simultaneously — the GDPR 72-hour breach clock to the DPA and the NIS2 tiered clock (24 h / 72 h / 1 month) to the cyber authority — so the observability and incident-response capability must satisfy the *shorter* of the applicable clocks. *F4* engages the moment the institution uses a non-EEA cloud or collaborates with a third-country partner: it needs an adequacy route or SCCs plus a transfer-impact assessment [88↗, 89↗]. *F5* engages partially: eIDAS 2 governs any qualified signing/sealing of diplomas and contracts [90↗], and the AI Act engages *only* for deployed (not pure-research) AI systems, with the high-risk obligations arriving Aug 2026 [91↗]. *F6* is standing throughout: the auditable log and records capability is what lets the institution *show* the DPA and the cyber authority that F1–F5 are in place. The demonstration shows the method: walk the six functions, mark each as full / partial / conditional, and record *which* clock or mechanism

governs — the architecture's contribution is identical in each case; only the trigger and deadline are read from the instrument column.

33.2.2 United States — deep regime (sectoral and fragmented)

The US carries the same spine through a *sectoral and fragmented* stack: no omnibus statute, but federal sector statutes (FERPA for student records, HIPAA for health data, GLBA / FTC Safeguards for financial-aid data), federal-contracting baselines (NIST SP 800-171, CMMC, FISMA), export-control regimes (EAR, ITAR) and a growing state-privacy layer (CCPA/CPRA). Enforcement is distributed across the Department of Education, HHS Office for Civil Rights, the FTC, the DoD, Commerce/BIS, State/DDTC and state Attorneys General.

Table 33.3: United States — F1–F6 instantiation of the invariant spine.

Obligation	Instrument and authority	Deadline / mechanism
F1 Data protection / privacy	FERPA (20 U.S.C. §1232g; 34 C.F.R. Part 99) [93↗]; HIPAA Privacy Rule for covered health components; CCPA/CPRA as the state-law layer [94↗]; ED/SPPO, HHS OCR, state AGs	FERPA: no fixed breach deadline, administrative enforcement via funding withdrawal; CCPA/CPRA largely exempts universities except via vendors / for-profit affiliates
F2 Risk governance / written security programme	FTC Safeguards Rule (16 C.F.R. Part 314) [95↗]; HIPAA Security Rule risk analysis [96↗]; NIST CSF 2.0 (voluntary baseline) [79↗]; FTC, HHS OCR	Safeguards full-compliance 9 Jun 2023 (written programme, qualified individual, risk assessment); HIPAA risk analysis a continuing duty; Title-IV pulls in essentially all universities
F3 Incident / breach notification	HIPAA Breach Notification Rule (45 C.F.R. §§164.400–414) [97↗]; FTC Safeguards notification [95↗]; state breach statutes [94↗]; HHS OCR, FTC, state AGs	HIPAA: notify individuals and HHS ≤60 days (500+ contemporaneous); FTC: notify ≤30 days for events affecting 500+ consumers (since 13 May 2024); state timelines layer on top
F4 Cross-border transfers	Handled functionally through export control rather than a transfer-adequacy regime — see F5; CCPA/CPRA vendor flow-down for consumer data [94↗]	No EU-style adequacy list; the operative cross-border control for research data is the deemed-export regime (F5)
F5 Trust / AI / technology governance (export control)	EAR (15 C.F.R. 730–774, fundamental-research exclusion §734.8) [98↗]; ITAR (22 C.F.R. 120–130) [99↗]; Commerce/BIS, State/DDTC	Licensing + deemed-export: releasing controlled technology/technical data to foreign nationals (even on US soil) is an export; operationalised via technology-control plans and segregated environments
F6 Conformity assessment / certification	CMMC Program (32 C.F.R. Part 170) with DFARS implementation [100↗]; NIST SP 800-171 Rev. 3 as the assessed control set [80↗, 81↗, 101↗]; DoD (CMMC PMO, DIBCAC), C3PAOs	CMMC final rule effective 16 Dec 2024; DFARS clause effective 10 Nov 2025, phased over 3 years; Level 2 (CUI) requires a C3PAO assessment; artefacts retained six years

Worked applicability demonstration (US). Take the same mid-sized research university, now with a Title-IV financial-aid office, a small health clinic and one DoD-funded research project. The spine applies, but it is *assembled* from sector statutes rather than read off one instrument. *F1* is anchored by FERPA over student records [93↗]; CCPA/CPRA mostly does

not reach the institution directly but reaches its vendors [94↗]. *F2* is triggered the moment the institution participates in Title-IV: the FTC Safeguards Rule classifies it as a financial institution and requires the written security programme with a qualified individual [95↗]; the clinic adds the HIPAA Security Rule risk analysis [96↗]. *F3* gives the institution *two* breach clocks — HIPAA's 60-day outer limit and the FTC's 30-day / 500-consumer trigger — plus any state clock; as in the EU case, the architecture must meet the *shortest* applicable deadline [97↗]. *F4* is unusual: there is no adequacy regime, so the cross-border control that bites is the *deemed-export* concept — releasing the DoD-project's controlled technical data to a foreign-national researcher, even on campus, is an export needing a license or a technology-control plan [98↗, 99↗]. *F5* therefore *is* the cross-border control here, which is why F4 and F5 fold together in the US column. *F6* is where the US regime is most distinctive: CMMC converts the NIST SP 800-171 controls into a *contractually enforceable, third-party-assessed* certification that the DoD-funded project cannot be awarded without [81↗, 100↗]. The demonstration shows the same six functions resolving to a different instrument geometry — the spine is invariant, the assembly is sectoral.

33.2.3 United Kingdom — light regime (post-Brexit, diverging)

The UK carries the spine through retained-and-amended EU-derived instruments now diverging via domestic reform. The data-protection authority is the ICO (becoming the Information Commission under the Data (Use and Access) Act 2025); cyber resilience runs through the NIS Regulations 2018 with sector competent authorities and the NCSC; accessibility runs on domestic statute.

Table 33.4: United Kingdom — F1–F6 instantiation (light regime).

Obligation	Instrument and authority	Deadline / mechanism
F1 Data protection / security of processing	UK GDPR with the Data Protection Act 2018, amended by the Data (Use and Access) Act 2025 [102↗, 103↗, 104↗]; ICO / Information Commission	Standing security-of-processing duty (Art. 32); DUAA 2025 key provisions in force 5 Feb 2026
F2 Cyber-security risk governance	NIS Regulations 2018 (SI 2018/506); forthcoming Cyber Security and Resilience Bill [105↗, 106↗, 107↗]; sector competent authorities, ICO (RDSPs), NCSC	Risk-management duty; NCSC Cyber Assessment Framework; CSR Bill expands scope (e.g. managed service providers), not yet in force
F3 Incident / breach notification	UK GDPR Art. 33 [102↗]; NIS Regs reg. 11 [105↗]; ICO; sector competent authority / NCSC	GDPR breach to ICO $\leq$72 h; significant NIS incident to the competent authority $\leq$72 h
F4 Cross-border transfers	UK GDPR Chapter V; ICO IDTA and the UK Addendum to the EU SCCs [102↗, 104↗, 108↗]; ICO, Secretary of State (adequacy)	Adequacy where it exists, else IDTA / Addendum + a transfer-risk assessment; DUAA 2025 "not-materially-lower" data-protection test
F5 eID / trust services	UK eIDAS (retained Reg. 910/2014 as amended; SI 2016/696) [109↗]; ICO as supervisory body	Conformity / qualified-status mechanism: ICO grants/revokes qualified status with breach reporting and audits
F6 Accountability / accessibility conformity	Public Sector Bodies Accessibility Regulations 2018 (SI 2018/952), WCAG 2.1 AA / EN 301 549 [110↗, 111↗]; GDS (monitoring), EHRC (enforcement)	Standing conformance + published accessibility statement; GDS samples, EHRC may issue unlawful-act notices

33.2.4 Brazil — light regime (distributed federal stack)

Brazil carries the spine through a distributed federal stack with no single omnibus cybersecurity statute: the LGPD (data protection and breach notification), the national cyber strategy and federal incident-management decrees, the Inclusion Law (accessibility), the Access to Information Law (transparency) and the Federal Administrative Procedure Law (due process). Federal public universities are in scope as *autarquias / fundações públicas* of the federal public administration.

Table 33.5: Brazil — F1–F6 instantiation (light regime).

Obligation	Instrument and authority	Deadline / mechanism
F1 Data protection / security of processing	LGPD (Lei nº 13.709/2018), esp. Art. 46 [112↗]; ANPD	Continuous duty: technical and administrative security measures; ANPD may set minimum standards; applies to public-power controllers
F2 Cybersecurity governance / risk management	E-Ciber national cyber strategy (Decreto nº 10.222/2020) [113↗]; Marco Civil da Internet baseline [114↗]; GSI/PR	Federal bodies (incl. universities) implement strategic actions under GSI coordination; strategy-cycle instrument plus GSI normative instructions
F3 Incident / breach notification	LGPD Art. 48 operationalised by Resolução CD/ANPD nº 15/2024 [115↗]; federal cyber track via Decreto nº 10.748/2021 (CTIR.Gov) [116↗]; ANPD, GSI/PR–CTIR.Gov	Personal-data breaches: notify ANPD and subjects ≤3 business days (supplementable ≤20 business days); 5-year retention; federal cyber incidents via CTIR.Gov
F4 Cross-border transfers	LGPD international-transfer regime (Chapter V of Lei 13.709/2018) [112↗]; ANPD	Transfer on an adequacy / safeguards / consent / contractual basis; ANPD supervises (no EU-style adequacy list)
F5 Accessibility / inclusion (trust-equivalent duty)	Lei Brasileira de Inclusão (Lei nº 13.146/2015), Arts. 63 ff., operationalised by e-MAG [117↗]; MEC, Governo Digital	Standing accessibility duty assessed against e-MAG; conditions MEC course authorisation/recognition
F6 Accountability / transparency / due process	Access to Information Law (Lei nº 12.527/2011) [118↗]; Federal Administrative Procedure Law (Lei nº 9.784/1999) [119↗]; CGU, each federal body	Active + passive disclosure with statutory response deadlines; baseline procedural guarantees governing decisions arising from F1–F5

33.2.5 South Africa — light regime (single national jurisdiction)

South Africa carries the spine through a single national jurisdiction with no member-state transposition layer and no standalone unified Cybersecurity Act. POPIA supplies data protection, breach notification and cross-border transfer; the Cybercrimes Act supplies incident / offence reporting; the ECT Act supplies trust services; and accessibility is principle-based under the Equality Act. The African Union's Malabo Convention is regional *context* only — South Africa has signed but not ratified it, so no transfer obligation flows from it to ZA institutions [120↗].

Table 33.6: South Africa — F1–F6 instantiation (light regime).

Obligation	Instrument and authority	Deadline / mechanism
F1 Data protection / security of processing	POPIA (Act 4 of 2013), Condition 7, s.19 [121↗, 122↗]; Information Regulator	Continuous risk-based duty: appropriate, reasonable technical and organisational measures; no threshold / size carve-out
F2 Cyber-security risk governance	POPIA Condition 7 security safeguards read with the Cybercrimes Act baseline [121↗, 123↗]; Information Regulator, SAPS	Risk-based security duty; no standalone unified Cybersecurity Act, so the security limb is carried by POPIA
F3 Incident / breach notification	POPIA s.22 [121↗]; Cybercrimes Act s.54 (offence reporting) [123↗]; Information Regulator, SAPS	POPIA: notify Regulator and subjects as soon as reasonably possible after discovery (no hour-count); Cybercrimes Act: report qualifying offence $\leq$72 h where the university is an ECS provider
F4 Cross-border transfers	POPIA s.72 [121↗, 122↗]; Information Regulator (oversight), responsible party self-assesses adequacy	Transfer on adequate-protection / BCR / binding-agreement / consent / contractual-necessity basis; adequacy self-assessed and documented per transfer (no adequacy list)
F5 eID / trust services	ECT Act (Act 25 of 2002), ss.13 and 37–40 [124↗]; South African Accreditation Authority	Legal recognition of data messages and signatures; advanced electronic signature requires an accredited provider's certificate (rebuttable presumption of validity)
F6 Accountability / accessibility (non-discrimination)	PEPUDA / Equality Act (Act 4 of 2000), s.9 [125↗]; Equality Courts, SAHRC	Standing reasonable-accommodation duty; no dedicated web-accessibility statute, WCAG as de-facto benchmark

33.3 Mapping method: deriving a row for an unlisted regime

The five profiles above are worked instantiations, not an exhaustive list. An adopter in any other jurisdiction derives its own row by the same procedure: the spine of Section 33.1.1 is fixed, the control set of Table 33.1 is fixed, and only the *instrument* column has to be filled. The playbook below fills it.

Step 1 — Identify your data-protection authority and its security duty (F1). Find the competent authority for personal data (a national DPA, a sectoral regulator, or — as in the US — several). Locate its *security-of-processing* duty and confirm whether a size/de-minimis threshold exists. In every regime examined, the security duty has *no* size exemption; treat its absence as the default and verify it explicitly. Map the duty to the F1 row of Table 33.1.

Step 2 — Identify your lawful-basis and risk-governance regime (F2). Determine the lawful basis on which the institution processes personal data (public task, legitimate interest, consent) and the statute or framework that requires a documented, risk-based security programme. Where no dedicated cyber statute exists (as in Brazil

or South Africa), the risk-governance duty is usually carried by the security limb of the data-protection law; record which instrument carries it.

Step 3 — Identify your breach / incident deadline (F3).
Find every applicable notification clock — the data-protection breach clock and any cyber-incident clock — and record the *shortest* one, because the observability and incident-response capability must satisfy the tightest deadline that can bite. Note both the recipient (DPA, CSIRT, police) and the trigger (risk-of-harm, affected-count, offence type).

Step 4 — Identify your essential-entity / cyber-duty status (F2/F3 scope).
Determine whether the institution falls into an essential- or important-entity (or equivalent) category, and on what basis — function-performed (as under NIS2) or sector listing. This sets the depth at which F2 and F3 apply and whether tiered (24 h / 72 h / final) reporting is in scope.

Step 5 — Identify your transfer regime (F4).
Establish how personal data may lawfully leave the jurisdiction: an adequacy-list mechanism (EU/UK style), self-assessed adequacy plus safeguards (Brazil / South Africa style), or a functional substitute such as export control (US style). Record the documented artefact the regime expects (transfer-impact assessment, binding agreement, technology-control plan).

Step 6 — Identify your sector overlays (F5/F6).
Add the sector-specific layers the institution triggers: a trust-services / eID regime for signed diplomas and contracts; an AI-governance regime for deployed AI; export / controlled-technology rules for restricted research; health, financial-aid or accessibility statutes for the relevant units. Each overlay maps to F5 (governed technology) or F6 (conformity / accountability).

Step 7 — Bind each finding to the control set.
For each of Steps 1–6, write the local instrument, authority and deadline into the instrument column against the corresponding F row, leaving the SUIT control-mechanism column of Table 33.1 unchanged. The result is the adopter's own regime profile in the same shape as the five worked profiles above — and the same architectural evidence base discharges it.

Closing note on transferability. The procedure terminates because the spine is finite and size-invariant: there are six functions, each maps to a fixed control capability, and the only per-jurisdiction work is reading the local instrument that carries each function. An adopter that completes Steps 1–7 has reproduced, for its own regime, the proof the five worked profiles already carry — that discharging F1–F6 is the regulator-facing minimum, and that the SUIT control set is the same in every jurisdiction. The mapping is interpretive engineering guidance and must be confirmed against the adopter's own legal framework and counsel before being relied upon.

The remainder of this chapter develops the EU/EEA regime row of the module above (§33.2.1) to per-article granularity, binding each provision to the specific architecture element and to the chapter where it is operationalised.

33.4 Method, scope and limitations

Perimeter. The regulations and frameworks covered below are the per-article development of the EU/EEA regime row of the shared module's typology (§33.2.1); they are those most frequently encountered by a typical research-intensive institution operating internationally, presented here as one worked instantiation of the applicable regulatory regime that each adopting institution substitutes with its own — the spine and the obligation → mechanism matrix (§33.1.2) being identical across regimes, only the instrument column changing. The worked instantiation comprises the applicable data-protection regime (here the EU GDPR); the applicable

cybersecurity baseline regime (here the NIS2 Directive); the applicable AI-governance regulation (here the EU AI Act); the cross-border data-transfer regime (here the *Schrems II* judgement and the EDPB transfer guidelines that operationalise it); the NIST Cybersecurity Framework 2.0; the applicable electronic-identification and trust-services regime (here eIDAS 2, the renewed framework for electronic identification and trust services); the ISO/IEC 27001 / 27002 / 27005 management-system and risk-management family; and COBIT 2019 as a governance framework. The selection privileges international applicability over national specificity.

What the mapping is and is not. The mapping shows where the architecture's contracts and the playbook's waves *contribute* to the satisfaction of a regulatory provision. It does not claim that adopting the architecture is sufficient to demonstrate compliance: most provisions also require organisational elements (policies, training, designated officers, audit reports) that are outside this Reference's scope. It also does not claim that any specific deployment described in the architecture is *necessary* for compliance: alternative architectures may satisfy the same provisions through different means. The mapping is best read as a tool for identifying which architectural elements the institution can invoke when responding to a regulator's question.

Reading conventions. For each regulation, the provisions are listed in the order the source instrument adopts. The architecture-element column references chapters of this Reference using the `\trchap` cross-reference convention. The operationalisation column points to specific sections; multiple references appear when several layers contribute jointly.

Scope of binding force. Among the references covered, the data-protection regime, the cybersecurity baseline regime and the AI-governance regulation are binding statutory instruments within their regime (in the worked instantiation, the GDPR, NIS2 and the AI Act); the cross-border data-transfer regime is binding authority (here *Schrems II* case law from the CJEU); the electronic-identification and trust-services regime is a binding regulation (here eIDAS 2). NIST CSF 2.0, ISO/IEC 27001 and COBIT 2019 are non-binding frameworks unless made binding by contract (a research funder requirement, a procurement clause) or by sectoral national transposition. The institution must read its own contracts and national legal framework alongside this chapter.

33.5 General Data Protection Regulation (GDPR)

The applicable data-protection regime establishes risk-based security and accountability obligations applicable to any institution processing personal data; in the worked instantiation below this regime is the GDPR [8↗]. The provisions below are the most frequently invoked in IT architecture discussions; the mapping is not exhaustive, and an adopting institution reads its own data-protection regime in place of the worked instantiation.

Table 33.7: GDPR mapping — principal provisions and architectural contributions.

Provision	Architectural contribution	Operationalised in
Art. 5(1)(f) integrity and confidentiality	Identity, policy, network, crypto layers as the technical chain enforcing access control and confidentiality	Chapter 6 of the Technical Reference, Chapter 7 of the Technical Reference, Chapter 8 of the Technical Reference, Chapter 13 of the Technical Reference
Art. 6(1)(e)/(f) lawful basis	Public-task and legitimate-interest bases for the monitoring, audit and identity processing the architecture entails; the per-processing determination is finalised in the DPIA/RoPA, with the sovereignty-grid institutional dimension recording it	Chapter 3 of the Technical Reference, Chapter 7 of the Technical Reference, Chapter 12 of the Technical Reference
Art. 25 data protection by design and by default	TAC contract enforces minimum necessary attribute release; sovereignty grid surfaces design-time choices	Chapter 2 of the Technical Reference, Chapter 3 of the Technical Reference, Chapter 6 of the Technical Reference §6.1
Art. 30 records of processing	Canonical TAC schema and its persistence in the audit pipeline produce the per-activity record from which RoPA entries can be derived	Chapter 12 of the Technical Reference, Chapter 20 of the Technical Reference, Chapter 25 of the Technical Reference
Art. 32 security of processing	Identity, policy, network, crypto, observability layers; conformance suite as evidence of effectiveness	Chapter 6 of the Technical Reference–Chapter 12 of the Technical Reference, Chapter 16 of the Technical Reference
Art. 33–34 notification of breaches	TAC-aware audit pipeline and the wave-7 IR procedure provide detection and timeline reconstruction	Chapter 25 of the Technical Reference
Art. 35 data-protection impact assessment	Sovereignty grid and TAC scenario inventory provide structured input to a DPIA	Chapter 3 of the Technical Reference, Chapter 4 of the Technical Reference
Art. 44–49 international transfers	Storage layer placement constraints, cryptographic-key custody, sovereignty-grid data dimension	Chapter 10 of the Technical Reference, Chapter 13 of the Technical Reference, Chapter 3 of the Technical Reference

Scope of the contribution. The architecture provides the technical substrate for the obligations above. The organisational substrate (data-protection officer, RoPA maintenance, supplier contracts, data-subject-rights procedures) is outside this Reference's scope and would need to be in place independently.

33.6 NIS2 Directive

The applicable cybersecurity baseline regime applies to the classes of entity its scoping rules designate as in scope; in the worked instantiation below this regime is the NIS2 Directive [10↗], whose classification basis distinguishes essential and important entities. Whether a research-intensive university falls in scope depends on the applicable national transposition of that regime (research is not in itself a covered sector but several university activities — digital infrastructure, education-as-a-public-service in some jurisdictions, hospital affiliations — may

bring the institution within scope). The provisions below are most frequently relevant when the institution is in scope.

Table 33.8: NIS2 mapping — governance, risk-management measures and incident reporting.

Provision	Architectural contribution	Operationalised in
Art. 20 governance — management-body accountability and training	Wave-0 governance discipline; sovereignty-grid review by the management body	Chapter 18 of the Technical Reference, Chapter 28 of the Technical Reference
Art. 21(2)(a) risk-analysis and information-system security policy	Sovereignty grid and self-assessment; cross-cutting risk register	Chapter 3 of the Technical Reference, Chapter 4 of the Technical Reference, Chapter 28 of the Technical Reference
Art. 21(2)(b) incident handling	TAC-aware audit pipeline and the wave-7 IR procedure	Chapter 25 of the Technical Reference
Art. 21(2)(c) business continuity, backup, crisis management	Reversibility playbook; storage and orchestration backup contracts	Chapter 29 of the Technical Reference, Chapter 10 of the Technical Reference, Chapter 14 of the Technical Reference
Art. 21(2)(d) supply-chain security	Lifecycle wave; SLSA / Sigstore supply-chain instantiation; procurement-clause workstream	Chapter 27 of the Technical Reference, Chapter 18 of the Technical Reference
Art. 21(2)(e) acquisition, development, maintenance security	Conformance suite; coexistence-pattern library; orchestration GitOps controls	Chapter 16 of the Technical Reference, Chapter 30 of the Technical Reference, Chapter 14 of the Technical Reference
Art. 21(2)(f) policies to assess effectiveness	Conformance-suite execution and reporting; observability and audit dashboards	Chapter 16 of the Technical Reference, Chapter 12 of the Technical Reference
Art. 21(2)(g) cyber hygiene and training	Endpoint posture controls; identity-layer MFA / FIDO2 baseline	Chapter 11 of the Technical Reference, Chapter 6 of the Technical Reference
Art. 21(2)(h) cryptography policies and procedures	Cryptographic services contract; HSM custody; key-rotation procedure	Chapter 13 of the Technical Reference
Art. 21(2)(i) HR security, access control, asset management	Identity layer (joiner/mover/leaver via SCIM); endpoint inventory; asset-tagging in observability	Chapter 6 of the Technical Reference, Chapter 11 of the Technical Reference, Chapter 12 of the Technical Reference
Art. 21(2)(j) MFA, secured communications	Identity-layer MFA contract; cryptographic-services certificate distribution	Chapter 6 of the Technical Reference, Chapter 13 of the Technical Reference
Art. 23 incident reporting (24h / 72h / 1m)	TAC-aware audit pipeline and wave-7 IR procedure provide the timeline-reconstruction substrate	Chapter 25 of the Technical Reference

Cumulative argument. The cybersecurity baseline regime's risk-management provisions are designed to be read as an integrated set, not satisfied control by control. The architecture's contribution should be presented in the institution's compliance argument as the technical foundation on which the organisational measures (policies, drills, third-party assessments) build.

33.7 EU AI Act

The applicable AI-governance regulation classifies AI systems by risk level and imposes graduated obligations; in the worked instantiation below this regulation is the EU AI Act (Regulation 2024/1689). For a university, three contexts most frequently apply: research, testing and development of AI prior to placing it on the market or putting it into service (Art. 2(8)), alongside AI developed for the sole purpose of scientific research and development (Art. 2(6)); deployment of AI tools that interact with users or generate content (Art. 50 transparency obligations); and use or hosting of general-purpose AI models, which carry baseline provider obligations (Art. 53) and, where classified as posing systemic risk (Art. 51), additional obligations (Art. 55).

Table 33.9: EU AI Act mapping — principal provisions for a typical research-intensive institution.

Provision	Architectural contribution	Operationalised in
Art. 2(6) research exemption	Pilot-wave scoping (Researcher-LLM-API scenario); audit pipeline records the research-only nature of the activity	Chapter 23 of the Technical Reference, Chapter 25 of the Technical Reference
Art. 2(8) pre-market R&D activity exemption	Development and testing activity scoped and recorded as pre-market R&D, distinct from production deployment (real-world testing excluded)	Chapter 23 of the Technical Reference, Chapter 25 of the Technical Reference
Art. 5 prohibited practices	Policy-layer authorisation rules; sovereignty-grid institutional dimension flags incompatible procurement	Chapter 7 of the Technical Reference, Chapter 3 of the Technical Reference
Art. 6 high-risk classification	TAC scenario inventory; sovereignty-grid risk register	Chapter 2 of the Technical Reference, Chapter 28 of the Technical Reference
Art. 27 fundamental-rights impact assessment	Sovereignty-grid institutional dimension; TAC scenario record	Chapter 3 of the Technical Reference, Chapter 4 of the Technical Reference
Art. 50 transparency obligations	Policy layer enforces context labelling; observability records AI-interaction events	Chapter 7 of the Technical Reference, Chapter 12 of the Technical Reference
Art. 53 obligations for general-purpose AI providers	Lifecycle wave (model documentation and provenance); supply-chain attestations	Chapter 27 of the Technical Reference

Research-context caveat. The Art. 2(6) and Art. 2(8) research exemptions are narrow and would not in themselves shield AI services that the institution operates as production tools for staff or students. The pilot wave (Wave 5) is therefore designed to distinguish research activity from operational deployment, with distinct audit records and access patterns; the institution's AI governance body would be expected to maintain this distinction.

33.8 Schrems II and the cross-border data posture

The applicable cross-border data-transfer regime governs when contractual safeguards alone do not satisfy data sovereignty because the data falls under a third-country surveillance regime; in the worked instantiation this regime is the CJEU's *Schrems II* judgement [6↗] together with the EDPB transfer guidelines [7↗] that operationalise its consequences. The architecture's

contribution to the resulting cross-border posture is concentrated in the data dimension of the sovereignty grid and in the storage and cryptographic layers.

Table 33.10: Cross-border data — elements of the post-*Schrems II* posture and their architectural counterparts.

Element	Architectural contribution	Operationalised in
Transfer impact assessment (TIA)	Sovereignty-grid data dimension provides the indicator-level structure for the TIA	Chapter 3 of the Technical Reference, Chapter 4 of the Technical Reference
Supplementary technical measures	Cryptographic services contract; storage-layer key-custody constraints; per-tenant key separation	Chapter 13 of the Technical Reference, Chapter 10 of the Technical Reference
Standard contractual clauses (SCC) supplementation	Procurement-clause workstream of Wave 0; sovereignty-grid review of supplier disclosure obligations	Chapter 18 of the Technical Reference, Chapter 3 of the Technical Reference
Onward-transfer surveillance	Audit pipeline records cross-border traffic and identity-federation interactions	Chapter 12 of the Technical Reference, Chapter 25 of the Technical Reference

33.9 NIST Cybersecurity Framework 2.0

The NIST CSF 2.0 [79↗] is non-binding but widely used as the structuring framework for a cybersecurity programme. The six functions (Govern, Identify, Protect, Detect, Respond, Recover) provide a useful checklist against which the architecture and the playbook can be presented.

Table 33.11: NIST CSF 2.0 mapping — the architecture's contribution by function.

Function	Architectural contribution	Operationalised in
GOVERN (GV)	Sovereignty grid; wave-0 governance discipline; cross-cutting risk register	Chapter 3 of the Technical Reference, Chapter 18 of the Technical Reference, Chapter 28 of the Technical Reference
IDENTIFY (ID)	Self-assessment; institutional-precedents catalogue; coexistence-pattern inventory	Chapter 4 of the Technical Reference, Chapter 31 of the Technical Reference, Chapter 30 of the Technical Reference
PROTECT (PR)	Identity, policy, network, endpoint, crypto layers	Chapter 6 of the Technical Reference–Chapter 8 of the Technical Reference, Chapter 11 of the Technical Reference, Chapter 13 of the Technical Reference
DETECT (DE)	Observability layer; TAC-aware audit pipeline	Chapter 12 of the Technical Reference, Chapter 20 of the Technical Reference
RESPOND (RS)	Wave-7 audit and IR; coexistence-pattern fallback procedures	Chapter 25 of the Technical Reference, Chapter 30 of the Technical Reference
RECOVER (RC)	Reversibility playbook; storage backup contract; orchestration declarative redeployment	Chapter 29 of the Technical Reference, Chapter 10 of the Technical Reference, Chapter 14 of the Technical Reference

33.10 eIDAS 2 and the trust-services dimension

The applicable electronic-identification and trust-services regime is relevant to a typical research-intensive institution in three ways; in the worked instantiation this regime is the renewed EU framework for electronic identification and trust services (Regulation 2024/1183 amending Regulation 910/2014). The three ways are: participation in the EU Digital Identity Wallet ecosystem when issuing or relying on academic credentials; provision of qualified electronic signatures for institutional acts; and the trust-services baseline for cross-border identity federation. The operationalisation is concentrated in the identity and cryptographic layers.

Table 33.12: eIDAS 2 mapping — elements relevant to a typical research-intensive institution and their architectural counterparts.

Element	Architectural contribution	Operationalised in
Trust services (qualified signature, seal, time stamp)	Cryptographic services layer; HSM custody; institutional CA pattern	Chapter 13 of the Technical Reference
Notified eID schemes	Identity-federation pattern (eduGAIN, eduTEAMS); SAML2 / OIDC carriage	Chapter 6 of the Technical Reference
EU Digital Identity Wallet (EUDI Wallet) interoperability	Identity layer carrying wallet-issued attestations; policy layer authorising on attribute claims	Chapter 6 of the Technical Reference, Chapter 7 of the Technical Reference
Cross-border recognition obligations	Audit pipeline records federation interactions; sovereignty-grid institutional dimension addresses cross-border governance	Chapter 12 of the Technical Reference, Chapter 3 of the Technical Reference

33.11 ISO/IEC 27001 / 27002 / 27005

The ISO/IEC 27000 family provides the management-system framing that many institutions use to structure their information-security programme. ISO/IEC 27001:2022 provides the management-system clauses (clauses 4–10) and the Annex A control catalogue (93 controls organised in four themes); ISO/IEC 27002:2022 provides implementation guidance for those controls; ISO/IEC 27005:2022 provides the risk-management methodology. The mapping below focuses on Annex A controls that are most directly addressed by the architecture.

Table 33.13: ISO/IEC 27001:2022 Annex A — controls most directly addressed by the architecture (illustrative subset).

Annex A control	Architectural contribution	Operationalised in
A.5.7 Threat intelligence	Observability ingest; integration with the relevant R&E ISAC / sectoral threat-intel feeds (e.g. REN-ISAC)	Chapter 12 of the Technical Reference, Chapter 25 of the Technical Reference
A.5.23 Information security for cloud services	Sovereignty-grid data and institutional dimensions; procurement-clause workstream	Chapter 3 of the Technical Reference, Chapter 18 of the Technical Reference
A.5.30 ICT readiness for business continuity	Reversibility playbook; orchestration declarative redeployment	Chapter 29 of the Technical Reference, Chapter 14 of the Technical Reference
A.8.2 Privileged access rights	Identity layer joiner/mover/leaver; policy layer step-up authorisation	Chapter 6 of the Technical Reference, Chapter 7 of the Technical Reference
A.8.5 Secure authentication	Identity-layer MFA / FIDO2 baseline; OIDC / SAML2 federation	Chapter 6 of the Technical Reference
A.8.15 Logging	Observability layer; canonical TAC schema	Chapter 12 of the Technical Reference
A.8.16 Monitoring activities	Observability dashboards; conformance-suite execution	Chapter 12 of the Technical Reference, Chapter 16 of the Technical Reference
A.8.22 Network segregation	Network-layer zone-based segmentation; Cilium / Open vSwitch instantiation	Chapter 8 of the Technical Reference
A.8.24 Use of cryptography	Cryptographic services contract; key-rotation procedure	Chapter 13 of the Technical Reference
A.8.30 Outsourced development	Lifecycle wave; SLSA / Sigstore supply-chain pattern	Chapter 27 of the Technical Reference
A.8.32 Change management	Orchestration GitOps reconciler; conformance-suite gating	Chapter 14 of the Technical Reference, Chapter 16 of the Technical Reference

Risk methodology. ISO/IEC 27005:2022 provides the risk-identification, analysis and evaluation methodology against which the wave-aware risk register of Chapter 28 of the Technical Reference should be cross-checked. The sovereignty grid provides the indicator-level structure that operationalises several of the 27005 inputs (asset valuation, vulnerability assessment of supplier dependencies, threat-context evaluation).

33.12 COBIT 2019 governance and management objectives

COBIT 2019 organises governance and management of enterprise IT into 40 governance and management objectives across five domains (EDM — Evaluate, Direct and Monitor; APO — Align, Plan and Organise; BAI — Build, Acquire and Implement; DSS — Deliver, Service and Support; MEA — Monitor, Evaluate and Assess). The mapping below highlights objectives most directly addressed by the architecture and the playbook; the institution's IT-governance function would be expected to consolidate a complete mapping in its IT governance documentation.

Table 33.14: COBIT 2019 mapping — governance and management objectives most directly addressed (illustrative subset).

Objective	Architectural contribution	Operationalised in
EDM01 Ensure governance framework	Wave-0 governance discipline; cross-cutting management body cadence	Chapter 18 of the Technical Reference, Chapter 28 of the Technical Reference
EDM03 Ensure risk optimisation	Sovereignty grid; wave-aware risk register	Chapter 3 of the Technical Reference, Chapter 28 of the Technical Reference
APO12 Managed risk	ISO/IEC 27005 alignment; sovereignty grid as indicator-level structure	Chapter 28 of the Technical Reference, Chapter 3 of the Technical Reference
APO13 Managed security	Layered architecture; conformance suite as effectiveness evidence	Chapter 6 of the Technical Reference–Chapter 13 of the Technical Reference, Chapter 16 of the Technical Reference
BAI03 Managed solutions identification and build	Reference instantiations and replaceability conditions	Chapter 5 of the Technical Reference, layer chapters
BAI06 Managed IT changes	Orchestration GitOps reconciler; coexistence-pattern controlled migrations	Chapter 14 of the Technical Reference, Chapter 30 of the Technical Reference
BAI10 Managed configuration	Endpoint declarative configuration; orchestration as configuration source of truth	Chapter 11 of the Technical Reference, Chapter 14 of the Technical Reference
DSS02 Managed service requests and incidents	Wave-7 audit and IR procedure	Chapter 25 of the Technical Reference
DSS04 Managed continuity	Reversibility playbook; storage backup contract	Chapter 29 of the Technical Reference, Chapter 10 of the Technical Reference
DSS05 Managed security services	Identity / policy / network / crypto layers as the security-service backbone	Chapter 6 of the Technical Reference, Chapter 7 of the Technical Reference, Chapter 8 of the Technical Reference, Chapter 13 of the Technical Reference
MEA02 Managed system of internal control	Conformance suite; observability dashboards; audit pipeline	Chapter 16 of the Technical Reference, Chapter 12 of the Technical Reference, Chapter 25 of the Technical Reference
MEA03 Managed compliance with external requirements	This chapter (consolidated regulatory mapping); per-chapter pointers	§33.4–§33.14

33.13 Applicability beyond the EU jurisdiction

The per-article mapping above is built against EU instruments because they are the institution's own binding context. It should not be read as confining the architecture to EU jurisdictions. As established in Chapter 5 of the Technical Reference (§5.2), the functions the architecture discharges are necessary to any institution offering a digital infrastructure; that necessity is jurisdiction-invariant just as it is size-invariant. What changes across jurisdictions is the instrument that names the obligation, not the architectural element that contributes to satisfying it. The shared module that opens this chapter makes this explicit: the regime typology (§33.2) gives worked F1–F6 instantiations for the EU, the US, the UK, Brazil and South Africa, and the mapping method (§33.3) gives an adopter in an unlisted jurisdiction a seven-step procedure to

derive its own regime row against the same invariant matrix. The paragraphs below summarise how a non-EU adopter reads the per-article EU mapping through that lens.

Lead with the jurisdiction-neutral spine. A non-EU institution can ground its compliance argument on the international frameworks already mapped in this chapter — ISO/IEC 27001 (§33.11), the NIST Cybersecurity Framework 2.0 (§33.9) and COBIT 2019 (§33.12) — which are adopted worldwide and are independent of any single legal regime. The EU-instrument mappings then read as one worked example of how a regional regulatory regime maps onto that spine.

Functional substitution. Where this chapter cites the GDPR, NIS2 or the AI Act, a non-EU institution substitutes its host jurisdiction's functional analogue — a data-protection regime, a cybersecurity or critical-infrastructure regime, and an emerging AI-governance regime respectively. Illustrative, non-exhaustive analogues for data protection include the UK GDPR and Data Protection Act 2018, Brazil's LGPD, California's CCPA/CPRA and Canada's PIPEDA; these are *functional analogues, not legal equivalences*, and the architectural element invoked against the obligation is unchanged regardless of which instrument names it.

Verification remains local. As with national transpositions (§33.14), the institution's data-protection officer, chief information security officer and legal counsel are the authoritative interpreters of the regime that actually applies. This section identifies the portable structure of the argument; it does not assert equivalence between any two legal instruments.

33.14 National-transposition cautionary note

The mapping above is constructed against EU regulations and internationally recognised frameworks. National transpositions and sectoral regulations frequently add provisions that this chapter does not record:

- **Cybersecurity baseline transposition.** Jurisdictions vary in the sectoral scope of the applicable national transposition of the cybersecurity baseline regime (whether higher-education institutions fall under the classification basis that designates in-scope entities, whether research is in scope), in the national competent authority designated to supervise it, and in the incident-reporting thresholds and channels.
- **Data-protection national supplements.** Many jurisdictions have adopted national data-protection laws that operate alongside the general data-protection regime, with provisions on research exemptions, employee monitoring, and identifiers that the architecture must respect.
- **Sectoral regulations.** University hospitals, institutions handling government research contracts, and institutions operating critical national infrastructure may be subject to sectoral regulations not addressed here.
- **Funder requirements.** Research funders (institutional, national, EU framework programmes) frequently impose security and data-management obligations through grant agreements; these are contractual rather than regulatory but operate as binding constraints on the institution.
- **Non-EU jurisdictions.** Institutions operating branches or research stations outside the EU are subject to the host jurisdiction's regulations; the international scope of this Reference does not imply a single legal framework. A wholly non-EU institution adopting the architecture reads the mapping through §33.13.

The institution's data-protection officer, chief information security officer, and legal counsel would be the authoritative interpreters of the provisions that apply at the institution's specific situation. Where adopters cooperate — for example through an international university network — that forum is a natural locus for sharing transposition notes and harmonising the practical interpretation of the framework above.

33.15 Reading the mapping in conjunction with the chapters

The per-chapter *Regulatory anchoring* paragraphs in the layer chapters (Chapter 6 of the Technical Reference–Chapter 14 of the Technical Reference) and the wave chapters (Chapter 18 of the Technical Reference–Chapter 27 of the Technical Reference) each record the principal regulatory references the chapter contributes to, and point back to the section of this chapter where the contribution is mapped. The two views are complementary: the per-chapter pointer answers "which regulations does this layer or wave touch ?", and the consolidated mapping of this chapter answers "which layers and waves contribute to this regulatory provision ?". A compliance argument typically draws on both.

Glossary of Acronyms and Key Terms

Technical Infrastructure

ACL Access Control List — a set of rules on a network device that permits or denies traffic based on source/destination addresses and ports.

API Application Programming Interface — a standardised interface allowing software systems to communicate with each other.

BYOD Bring Your Own Device — the practice of employees or students using personal devices to access institutional resources.

DHCP Dynamic Host Configuration Protocol — automatically assigns IP addresses to devices on a network.

DMZ Demilitarised Zone — a network segment between an internal network and the Internet, hosting externally accessible services.

DNS Domain Name System — translates human-readable domain names into IP addresses.

DPI Deep Packet Inspection — a method of examining the content of network packets as they pass through a checkpoint.

DTN Data Transfer Node — a server optimised for high-throughput scientific data transfers in a Science DMZ.

EDR Endpoint Detection and Response — security software monitoring endpoints for threats.

HPC High-Performance Computing — computing systems designed for large-scale scientific simulations and data processing.

IAM Identity and Access Management — systems and processes for managing digital identities and controlling access to resources.

IDS Intrusion Detection System — monitors network traffic for suspicious activity (detection only, no inline blocking).

IPS Intrusion Prevention System — monitors and actively blocks detected threats inline.

LMS Learning Management System — platform for delivering and managing educational content (e.g. Moodle).

MFA Multi-Factor Authentication — requiring two or more verification factors to access a resource.

NAC Network Access Control — system enforcing authentication, device posture assessment, and dynamic VLAN assignment at the network edge (e.g. PacketFence, Cisco ISE).

PKI Public Key Infrastructure — framework for managing digital certificates and encryption keys.

RBAC Role-Based Access Control — access permissions assigned to roles rather than to individual users.

Science DMZ Science Demilitarised Zone — a network architecture pattern developed by ESnet for high-performance scientific data transfers, bypassing enterprise firewalls in favour of ACLs and dedicated IDS.

SDN Software-Defined Networking — centralised, programmable control of network behaviour.

SIEM Security Information and Event Management — centralised platform for collecting and analysing security logs and alerts.

SOC Security Operations Centre — team and facility responsible for monitoring and responding to security incidents.

SSO Single Sign-On — authentication allowing access to multiple systems with one set of credentials.

© SUITOAAA

TAC Trusted Activity Context — a coherent, validated environment assembling data, tools, services, and access rights for a specific university activity (concept introduced in this report).

VDI Virtual Desktop Infrastructure — technology delivering desktop environments from a centralised server to any device.

VLAN Virtual Local Area Network — a logical subdivision of a physical network, isolating traffic between groups of devices.

VPN Virtual Private Network — encrypted tunnel for secure remote connectivity.

Governance Frameworks and Standards

ABAC Attribute-Based Access Control — access decisions based on attributes of the user, resource, and environment (NIST SP 800-162).

COBIT Control Objectives for Information and Related Technologies — Control Objectives for Information and Related Technologies, IT governance framework by ISACA distinguishing governance from management.

FAIR Factor Analysis of Information Risk — Factor Analysis of Information Risk, a quantitative methodology for assessing and managing information risk.

ISMS Information Security Management System — the set of policies and procedures for systematically managing security (ISO 27001).

Zero Trust Zero Trust architecture — security model based on never trust, always verify; access decisions based on identity and device posture rather than network location (NIST SP 800-207).

European Regulations and Legal Instruments

AI Act European AI Act — Regulation (EU) 2024/1689 on artificial intelligence, risk-based classification of AI systems.

CJEU Court of Justice of the European Union — the EU highest court, interpreting EU law.

DPO Data Protection Officer — person responsible for overseeing GDPR compliance within an organisation.

ECtHR European Court of Human Rights — court enforcing the ECHR, based in Strasbourg.

EDPB European Data Protection Board — EU body ensuring consistent application of the GDPR.

EDPS European Data Protection Supervisor — independent EU authority overseeing the application of GDPR by EU institutions and bodies (distinct from the EDPB which coordinates national DPAs).

ENISA European Union Agency for Cybersecurity — European Union Agency for Cybersecurity.

GDPR General Data Protection Regulation — General Data Protection Regulation (EU) 2016/679 – EU regulation on the protection of personal data.

ICRADP Independent Commission for Reasonable Adjustments of Digital Policies — Independent Commission for Reasonable Adjustments of Digital Policies (proposed in this report; French: CARPN).

NIS2 NIS2 Directive — NIS2 Directive (EU) 2022/2555 – directive on measures for a high common level of cybersecurity.

Cross-border Data Transfers

SCC Standard Contractual Clauses — pre-approved European Commission contractual clauses for transfers of personal data outside the EEA; valid under Schrems II only when supplemented by a Transfer Impact Assessment and supplementary measures.

TIA Transfer Impact Assessment — documented assessment of whether a third country offers a level of personal-data protection essentially equivalent to EU law, required by CJEU Schrems II for transfers outside the EEA when relying on Standard Contractual Clauses.

Sovereignty Grid and Technical Reference Vocabulary

BYOK Bring Your Own Key — a key-management arrangement in which the customer generates and provides the encryption keys used by a third-party service, retaining custody and rotation control.

HYOK Hold Your Own Key — an arrangement stronger than BYOK in which the customer retains the keys in their own infrastructure (typically an HSM) and the service never has cleartext access; cryptographic operations require live customer participation.

IoT Internet of Things — networked devices typically embedded in physical objects (sensors, controllers, lab instruments) with limited or no user interface and constrained security update mechanisms.

IT Information Technology — the systems, software, networks and processes used to store, manipulate and transmit institutional information.

OPA Open Policy Agent — CNCF graduated open-source policy decision engine using the Rego language; widely adopted as a general-purpose authorisation and admission-control PDP.

PDP Policy Decision Point — the component that evaluates a request against the policy corpus and returns a decision; distinct from the Policy Enforcement Point (PEP) that applies the decision.

PEP Policy Enforcement Point — the component that intercepts an access request, queries the PDP, and applies the returned decision (allow/deny plus obligations).

RFP Request for Proposal — a procurement document issued by an institution to solicit proposals from suppliers, specifying functional, technical, and contractual requirements.

SCIM System for Cross-domain Identity Management — IETF standard (RFC 7643/7644) for automating the exchange of user identity information between identity domains.

TLS Transport Layer Security — IETF cryptographic protocol (RFC 8446 for TLS 1.3) providing confidentiality and integrity for network communications; the foundation of HTTPS.

Research Networks and Organisations

CSIRT Computer Security Incident Response Team — team responsible for detecting, analysing, and responding to cybersecurity incidents.

eduGAIN eduGAIN interfederation service — global interfederation service connecting identity federations, enabling cross-institutional single sign-on.

eduroam Education Roaming — Education Roaming, federated Wi-Fi service allowing users to connect at any participating institution worldwide using their home credentials.

FIRST Forum of Incident Response and Security Teams — Forum of Incident Response and Security Teams, global network of CSIRTs facilitating coordination across national and sectoral incident-response teams.

GEANT GEANT pan-European research network — pan-European backbone network connecting 40+ NRENs, serving 50 million users in 10,000+ institutions.

NREN National Research and Education Network — a specialised ISP dedicated to supporting research and education (each country operates one).

Bibliography

[1] Nicolas Guelfi et al. *SUIT — Sustainable University IT Infrastructure & Technology*. SUIT Working Group reference document suite. Reference document suite of the SUIT Working Group, chaired by Nicolas Guelfi. Always-living document. 2026. URL: https://github.com/suit-working-group/suit-suite.

[2] Algirdas Avizienis, Jean-Claude Laprie, Brian Randell, and Carl Landwehr. "Basic Concepts and Taxonomy of Dependable and Secure Computing". In: *IEEE Transactions on Dependable and Secure Computing* 1.1 (2004). Seminal taxonomy paper that formalises dependability as an integrating concept encompassing availability, reliability, safety, integrity, maintainability, and security. Introduces the orthogonal classification of threats (faults, errors, failures), attributes, and means (prevention, tolerance, removal, forecasting)., pp. 11–33. DOI: 10.1109/TDSC.2004.2. URL: https://ieeexplore.ieee.org/document/1335465.

[3] R. S. Sandhu, E. J. Coyne, H. L. Feinstein, and C. E. Youman. "Role-Based Access Control Models". In: *IEEE Computer*. Vol. 29. 2. IEEE, 1996, pp. 38–47. URL: https://www.profsandhu.com/journals/computer/i94rbac(org).pdf.

[4] R. K. Thomas and R. S. Sandhu. "Task-based Authorization Controls (TBAC): A Family of Models for Active and Enterprise-Oriented Authorization Management". In: *Database Security XI: Status and Prospects* (1997), pp. 166–181. URL: https://www.profsandhu.com/confrnc/ifip/i97tbac.pdf.

[5] Vincent C. Hu, David Ferraiolo, Rick Kuhn, Adam Schnitzer, Kenneth Sandlin, Robert Miller, and Karen Scarfone. *Guide to Attribute Based Access Control (ABAC) Definition and Considerations*. Tech. rep. NIST SP 800-162. Defines ABAC as the access control methodology where decisions are based on subject, object, action, and environment attributes evaluated against policies. National Institute of Standards and Technology, 2014. DOI: 10.6028/NIST.SP.800-162. URL: https://csrc.nist.gov/publications/detail/sp/800-162/final.

[6] CJUE (Grande Chambre). *Data Protection Commissioner c. Facebook Ireland et Schrems*. Aff. C-311/18, 16 juillet 2020 — This decision profoundly impacts university IT infrastructure, requiring institutions to reassess all data transfers to third countries, particularly when using US-based cloud computing platforms, learning management systems, and research collaboration tools. 2020. URL: https://curia.europa.eu/juris/liste.jsf?num=C-311/18.

[7] EDPB. *Guidelines on Security of Processing under GDPR*. European Data Protection Board. The EDPB page is a filterable directory for guidelines, recommendations, and enforcement decisions related to GDPR Article 32 on the security of personal data processing. It serves as a hub for guidance documents that help organizations understand and implement appropriate technical and organizational measures to protect personal data. For universities handling research data, student records, and employee information, these guidelines are essential for establishing compliant data security policies and cybersecurity obligations under EU law. URL: https://www.edpb.europa.eu/gdpr-articles/article-32-security-processing_en.

[8] *Règlement (UE) 2016/679 du Parlement européen et du Conseil relatif à la protection des personnes physiques à l'égard du traitement des données à caractère personnel (RGPD)*. Article 32 : Sécurité du traitement — The GDPR imposes compliance requirements on student and employee data handling, research data management, cybersecurity incident response protocols, and IT infrastructure standards. Article 32 specifically mandates appropriate technical and organizational security measures. 2016. URL: https://eur-lex.europa.eu/legal-content/FR/TXT/?uri=CELEX:32016R0679.

[9] ENISA. *Risk-Based Approach to Data Processing Security*. European Union Agency for Cybersecurity. Although originally targeting SMEs, the guidelines are broadly applicable to any organization subject to GDPR requirements. For universities managing sensitive research and student data, it provides actionable guidance for developing appropriate security measures that balance risk mitigation with operational constraints. URL: https://www.enisa.europa.eu/publications/guidelines-for-smes-on-the-security-of-personal-data-processing.

[10] *Directive (UE) 2022/2555 du Parlement européen et du Conseil concernant des mesures destinées à assurer un niveau élevé commun de cybersécurité dans l'ensemble de l'Union (NIS2)*. Universities operating data centers, cloud services, or critical research networks may fall within the directive's scope, requiring them to structure cybersecurity governance and risk management in compliance with its provisions. 2022. URL: https://eur-lex.europa.eu/legal-content/FR/TXT/?uri=CELEX:32022L2555.

[11] N. Sakimura, J. Bradley, M. Jones, B. de Medeiros, and C. Mortimore. *OpenID Connect Core 1.0 incorporating errata set 2*. OpenID Foundation specification. 2023. URL: https://openid.net/specs/openid-connect-core-1_0.html.

[12] OASIS Security Services Technical Committee. *Assertions and Protocols for the OASIS Security Assertion Markup Language (SAML) V2.0*. OASIS Standard. 2005. URL: http://docs.oasis-open.org/security/saml/v2.0/saml-core-2.0-os.pdf.

[13] P. Hunt, K. Grizzle, E. Wahlstroem, and C. Mortimore. *System for Cross-domain Identity Management: Core Schema*. RFC 7643, Internet Engineering Task Force. 2015. URL: https://datatracker.ietf.org/doc/html/rfc7643.

[14] P. Hunt, K. Grizzle, M. Ansari, E. Wahlstroem, and C. Mortimore. *System for Cross-domain Identity Management: Protocol*. RFC 7644, Internet Engineering Task Force. 2015. URL: https://datatracker.ietf.org/doc/html/rfc7644.

[15] IETF OAuth Working Group. *The OAuth 2.1 Authorization Framework*. IETF Internet-Draft draft-ietf-oauth-v2-1 (Standards Track, work in progress). Work in progress; latest revision draft-ietf-oauth-v2-1-15 (March 2026). Stable overview at oauth.net/2.1/. 2026. URL: https://datatracker.ietf.org/doc/draft-ietf-oauth-v2-1/.

[16] Open Policy Agent Project. *Open Policy Agent (OPA)*. CNCF graduated project documentation. 2024. URL: https://www.openpolicyagent.org/.

[17] Cedar Policy Project. *Cedar Policy Language*. Open-source project documentation. 2024. URL: https://www.cedarpolicy.com/.

[18] C. Rigney, S. Willens, A. Rubens, and W. Simpson. *Remote Authentication Dial In User Service (RADIUS)*. RFC 2865, Internet Engineering Task Force. 2000. URL: https://datatracker.ietf.org/doc/html/rfc2865.

[19] R. Enns, M. Bjorklund, J. Schoenwaelder, and A. Bierman. *Network Configuration Protocol (NETCONF)*. RFC 6241, Internet Engineering Task Force. 2011. URL: https://datatracker.ietf.org/doc/html/rfc6241.

[20] M. Bjorklund. *The YANG 1.1 Data Modeling Language*. RFC 7950, Internet Engineering Task Force. 2016. URL: https://datatracker.ietf.org/doc/html/rfc7950.

[21] Cilium Project. *Cilium: eBPF-based Networking, Observability, and Security*. CNCF graduated project documentation. 2024. URL: https://cilium.io/.

[22] B. Claise, B. Trammell, and P. Aitken. *Specification of the IP Flow Information Export (IPFIX) Protocol for the Exchange of Flow Information*. RFC 7011, Internet Engineering Task Force. 2013. URL: https://datatracker.ietf.org/doc/html/rfc7011.

[23] Kubernetes Project. *Kubernetes: Production-Grade Container Orchestration*. CNCF graduated project documentation. 2024. URL: https://kubernetes.io/.

[24] OpenInfra Foundation. *OpenStack: Open Source Cloud Computing Infrastructure*. OpenInfra Foundation project documentation. 2024. URL: https://www.openstack.org/.

[25] Open Container Initiative (OCI). *OCI Image Format Specification*. Open Container Initiative specification. 2024. URL: https://github.com/opencontainers/image-spec.

[26] Open Source Security Foundation (OpenSSF). *Supply-chain Levels for Software Artifacts (SLSA)*. OpenSSF specification. 2024. URL: https://slsa.dev/.

[27] OASIS Key Management Interoperability Protocol Technical Committee. *Key Management Interoperability Protocol Specification Version 2.1*. OASIS Standard. 2020. URL: https://docs.oasis-open.org/kmip/kmip-spec/v2.1/kmip-spec-v2.1.html.

[28] S. Shepler, M. Eisler, and D. Noveck. *Network File System (NFS) Version 4 Minor Version 1 Protocol*. RFC 5661, Internet Engineering Task Force. 2010. URL: https://datatracker.ietf.org/doc/html/rfc5661.

[29] osquery Project. *osquery: Performant endpoint visibility*. Linux Foundation project documentation. 2024. URL: https://osquery.io/.

[30] Ansible Project. *Ansible: Simple IT Automation*. Open-source project documentation. 2024. URL: https://www.ansible.com/.

[31] Cloud Native Computing Foundation (CNCF). *OpenTelemetry Specification*. CNCF specification. 2024. URL: https://opentelemetry.io/docs/specs/.

[32] Cloud Native Computing Foundation (CNCF). *CloudEvents Specification*. CNCF specification. 2024. URL: https://cloudevents.io/.

[33] R. Gerhards. *The Syslog Protocol*. RFC 5424, Internet Engineering Task Force. 2009. URL: https://datatracker.ietf.org/doc/html/rfc5424.

[34] OASIS PKCS 11 Technical Committee. *PKCS #11 Cryptographic Token Interface Base Specification Version 3.0*. OASIS Standard. 2020. URL: https://docs.oasis-open.org/pkcs11/pkcs11-spec/v3.0/pkcs11-spec-v3.0.html.

[35] R. Barnes, J. Hoffman-Andrews, D. McCarney, and J. Kasten. *Automatic Certificate Management Environment (ACME)*. RFC 8555, Internet Engineering Task Force. 2019. URL: https://datatracker.ietf.org/doc/html/rfc8555.

[36] Keycloak Project. *Keycloak: Open Source Identity and Access Management*. Open-source project documentation. 2024. URL: https://www.keycloak.org/.

[37] GÉANT. *eduGAIN — Global Interfederation Service*. Original description extracted from edugain.org. — AI-generated contextual summary: for university IT departments, eduGAIN is directly relevant to identity management and access governance, providing a scalable solution for supporting global resource access while maintaining institutional security and user privacy controls. URL: https://edugain.org/.

[38] A. Mascetti, P. Tedesco, S. Lopienski, E. Tejedor Saavedra, M. Lamanna, and H. Short. "CERN's Identity and Access Management: A Journey to Open Source". In: *EPJ Web of Conferences* 245 (2020), p. 03012. URL: https://www.epj-conferences.org/articles/epjconf/pdf/2020/21/epjconf_chep2020_03012.pdf.

[39] Microsoft. *Microsoft Entra ID*. Commercial identity service documentation. 2024. URL: https://learn.microsoft.com/entra/identity/.

[40] Shibboleth Consortium. *Shibboleth: Federated Identity Management*. Open-source project documentation. 2024. URL: https://www.shibboleth.net/.

[41] GÉANT Association. *eduTEAMS: Authentication and Authorisation for Research and Collaboration*. GÉANT Trust and Identity service documentation. 2024. URL: https://eduteams.org/.

[42] AARC Project. *AARC Blueprint Architecture*. AARC2 deliverable. 2019. URL: https://aarc-community.org/architecture/.

[43] GÉANT. *Data Transfer Node (DTN) Tests on the GÉANT Testbeds*. GÉANT GN4-3 White Paper. 2022. URL: https://resources.geant.org/wp-content/uploads/2022/02/GN4-3_White-Paper_DTN.pdf.

[44] FreeRADIUS Project. *FreeRADIUS Server*. Open-source project documentation. 2024. URL: https://www.freeradius.org/.

[45] Open vSwitch Project. *Open vSwitch (OvS)*. Linux Foundation project documentation. 2024. URL: https://www.openvswitch.org/.

[46] Edoardo Martelli and Simone Stancu. "LHCOPN and LHCONE: Status and Future Evolution". In: *Journal of Physics: Conference Series* 664.5 (2015). Last consulted 15 February 2026. Describes two major networking infrastructures supporting CERN's LHC data transfer operations. Directly relevant to universities participating in large-scale scientific computing collaborations and managing high-bandwidth research network connectivity through NRENs., p. 052025. DOI: 10.1088/1742-6596/664/5/052025. URL: https://iopscience.iop.org/article/10.1088/1742-6596/664/5/052025.

[47] WLCG. *Worldwide LHC Computing Grid*. CERN. Original description extracted from wlcg.web.cern.ch. — AI-generated contextual summary: this resource exemplifies a federated model of large-scale research computing that depends on coordinated cybersecurity policies, resource sharing agreements, and multi-institutional governance frameworks organized into tiered computing centers. URL: https://wlcg.web.cern.ch/.

[48] *perfSONAR — Network Measurement Toolkit*. Original description extracted from perfsonar.net. — AI-generated contextual summary: the global infrastructure assists engineering teams in troubleshooting and helps increase productivity when utilizing network resources, making it particularly valuable for universities managing complex research and educational networks. URL: https://www.perfsonar.net/.

[49] GÉANT. *GÉANT — Pan-European Research and Education Network*. Original description extracted from about.geant.org/about/ (main site blocks bots with 403). — AI-generated contextual summary: GÉANT provides critical infrastructure for university IT connectivity, cybersecurity collaboration, and international academic research networking, enabling European researchers to lead international collaboration. URL: https://geant.org.

[50] Scott Rose, Oliver Borchert, Stu Mitchell, and Sean Connelly. *Zero Trust Architecture*. Tech. rep. NIST SP 800-207. This framework is particularly relevant for university IT infrastructure as institutions increasingly support remote work, personal devices, and cloud-based services that fall outside traditional network boundaries, necessitating resource-level protection rather than perimeter-based defenses. National Institute of Standards and Technology, Aug. 2020. DOI: 10.6028/NIST.SP.800-207. URL: https://csrc.nist.gov/publications/detail/sp/800-207/final.

[51] Harbor Project. *Harbor: Cloud Native Registry*. CNCF graduated project documentation. 2024. URL: https://goharbor.io/.

[52] Sigstore Project. *Sigstore: Software supply-chain integrity for everyone*. OpenSSF project documentation. 2024. URL: https://www.sigstore.dev/.

[53] Tekton Project. *Tekton: Cloud Native CI/CD*. CNCF graduated project documentation. 2024. URL: https://tekton.dev/.

[54] D. Y. Hancock, J. Fischer, J. M. Lowe, W. Snapp-Childs, M. Pierce, S. Marru, J. E. Coulter, M. Vaughn, B. Beck, N. Merchant, E. Skidmore, and G. Jacobs. "Jetstream2: Accelerating cloud computing via Jetstream". In: *Practice and Experience in Advanced Research Computing (PEARC '21)*. ACM, 2021. URL: https://par.nsf.gov/servlets/purl/10296117.

[55] Broadcom (VMware). *VMware vSphere*. Commercial virtualisation platform documentation. 2024. URL: https://www.vmware.com/products/vsphere.html.

[56] Ceph Project. *Ceph: A Unified, Distributed Storage System*. Open-source project documentation. 2024. URL: https://ceph.io/.

[57] HashiCorp. *HashiCorp Vault: Identity-based secrets and encryption management*. Open-source project documentation. 2024. URL: https://www.vaultproject.io/.

[58] Munki Project. *Munki: Managed software installation for macOS*. Open-source project documentation. 2024. URL: https://www.munki.org/munki/.

[59] MicroMDM Project. *MicroMDM: Mobile Device Management for Apple platforms*. Open-source project documentation. 2024. URL: https://micromdm.io/.

[60] Jamf Software. *Jamf: Apple device management*. Commercial MDM product documentation. 2024. URL: https://www.jamf.com/.

[61] Microsoft. *Microsoft Intune*. Commercial unified endpoint management documentation. 2024. URL: https://learn.microsoft.com/intune/.

[62] Apache Software Foundation. *Apache Kafka: Distributed event streaming platform*. Apache Software Foundation project documentation. 2024. URL: https://kafka.apache.org/.

[63] Vector Project. *Vector: A high-performance observability data pipeline*. Open-source project documentation. 2024. URL: https://vector.dev/.

[64] OpenSearch Project. *OpenSearch: Open-source search and analytics suite*. Open-source project documentation, Linux Foundation. 2024. URL: https://opensearch.org/.

[65] Grafana Labs. *Grafana Loki: Like Prometheus, but for logs*. Open-source project documentation. 2024. URL: https://grafana.com/oss/loki/.

[66] Grafana Labs. *Grafana: The open and composable observability platform*. Open-source project documentation. 2024. URL: https://grafana.com/oss/grafana/.

[67] Splunk. *Splunk Enterprise: Security and observability platform*. Commercial SIEM and analytics product documentation. 2024. URL: https://www.splunk.com/en_us/products/splunk-enterprise.html.

[68] Microsoft. *Microsoft Sentinel: Cloud-native SIEM and SOAR*. Commercial SIEM service documentation. 2024. URL: https://learn.microsoft.com/azure/sentinel/.

[69] Smallstep. *step-ca: Open Source Certificate Authority*. Open-source project documentation. 2024. URL: https://smallstep.com/docs/step-ca/.

[70] OpenDNSSEC Project. *SoftHSM: Software implementation of a generic cryptographic device with a PKCS#11 Cryptographic Token Interface*. Open-source project documentation. 2024. URL: https://www.opendnssec.org/softhsm/.

[71] Argo Project. *Argo CD: Declarative GitOps continuous delivery for Kubernetes*. CNCF graduated project documentation. 2024. URL: https://argoproj.github.io/cd/.

[72] Argo Project. *Argo Workflows: Kubernetes-native workflow engine*. CNCF graduated project documentation. 2024. URL: https://argoproj.github.io/workflows/.

[73] Crossplane Project. *Crossplane: Cloud Native Control Planes*. CNCF incubating project documentation. 2024. URL: https://www.crossplane.io/.

[74] Temporal Technologies. *Temporal.io: Durable execution for distributed applications*. Open-source project documentation. 2024. URL: https://temporal.io/.

[75] National research and education network. *National research and education network (NREN) — telecommunications, internet resources and cybersecurity services*. Generic NREN role description; an adopting institution substitutes the NREN of its own country. 2026.

[76] DFN. *DFN — Deutsches Forschungsnetz*. 2024. URL: https://www.dfn.de/en/.

[77] SWITCH. *SWITCH — Swiss National Research and Education Network*. 2024. URL: https://www.switch.ch/en/.

[78] Jisc. *Cyber Security Guidance for Boards and Senior Leaders in Higher Education*. Written by David Batho, Jisc's Director of Security. Directly addresses how university leadership should approach cybersecurity oversight and institutional defense strategies as a board-level priority, drawing from the Association of Colleges Governance Professionals Conference. 2024. URL: https://www.jisc.ac.uk/blog/cyber-resilience-a-strategic-board-level-priority.

[79] NIST. *The NIST Cybersecurity Framework (CSF) 2.0*. Tech. rep. NIST CSWP 29. The CSF 2.0 is a foundational tool for academic institutions seeking to establish or enhance their cybersecurity governance posture and align risk management efforts with standardized best practices across all sectors. National Institute of Standards and Technology, Feb. 2024. DOI: 10.6028/NIST.CSWP.29. URL: https://www.nist.gov/cyberframework.

[80] NIST. *Security and Privacy Controls for Information Systems and Organizations*. Tech. rep. NIST SP 800-53 Rev. 5. For academic institutions, adopting these controls strengthens cybersecurity posture while meeting requirements under the Federal Information Security Modernization Act (FISMA) and other regulatory mandates that apply to federally-funded research operations. National Institute of Standards and Technology, 2020. DOI: 10.6028/NIST.SP.800-53r5. URL: https://csrc.nist.gov/publications/detail/sp/800-53/rev-5/final.

[81] NIST. *Protecting Controlled Unclassified Information in Nonfederal Systems and Organizations*. Tech. rep. NIST SP 800-171 Rev. 3. Final, 14 May 2024; 97 requirements consolidated from 110 in Rev. 2. National Institute of Standards and Technology, 2024. DOI: 10.6028/NIST.SP.800-171r3. URL: https://csrc.nist.gov/pubs/sp/800/171/r3/final.

[82] Ron Ross, Victoria Pillitteri, Richard Graubart, Deborah Bodeau, and Rosalie McQuaid. *Developing Cyber-Resilient Systems: A Systems Security Engineering Approach*. Tech. rep. NIST SP 800-160 Vol. 2 Rev. 1. Fourteen cyber-resiliency techniques including segmentation. Foundational reference for university IT architecture resilience. National Institute of Standards and Technology, 2021. DOI: 10.6028/NIST.SP.800-160v2r1. URL: https://csrc.nist.gov/publications/detail/sp/800-160/vol-2-rev-1/final.

[83] NIST. *Guide to a Secure Enterprise Network Landscape*. Tech. rep. SP 800-215. For university IT infrastructure, this resource is directly relevant as academic institutions increasingly adopt distributed cloud resources and remote access models, making zero-trust security frameworks critical for protecting sensitive research data and institutional systems. National Institute of Standards and Technology, 2021. URL: https://csrc.nist.gov/pubs/sp/800/215/final.

[84] EDUCAUSE. *Top 10 IT Issues*. EDUCAUSE annual publication. 2024. URL: https://www.educause.edu/research/top-10-it-issues-and-trends.

[85] REN-ISAC. *REN-ISAC — Research and Education Networking ISAC*. Original description extracted from ren-isac.net/what-we-do/Overview.html. — AI-generated contextual summary: members gain access to a community of cybersecurity experts and professional development opportunities including webinars and workshops, strengthening institutional security postures. URL: https://ren-isac.net/what-we-do/Overview.html.

[86] Verizon. *Data Breach Investigations Report (DBIR)*. Annual security report. 2024. URL: https://www.verizon.com/business/resources/reports/dbir/.

[87] European Commission. *Commission Implementing Regulation (EU) 2024/2690 of 17 October 2024 laying down rules for the application of Directive (EU) 2022/2555 (NIS2) regarding technical and methodological requirements for cybersecurity risk-management measures*. 2024. URL: https://eur-lex.europa.eu/eli/reg_impl/2024/2690/oj.

[88] European Commission. *Commission Implementing Decision (EU) 2021/914 of 4 June 2021 on standard contractual clauses for the transfer of personal data to third countries pursuant to Regulation (EU) 2016/679 of the European Parliament and of the Council*. OJ L 199, 7 June 2021, p. 31. CELEX: 32021D0914. Entry into force 27 June 2021; legacy SCCs (Decisions 2001/497/EC and 2010/87/EU) repealed 27 September 2021; transition period for pre-existing contracts ended 27 December 2022 — Direct operational anchor for university adoption of non-EU AI cloud services, paired with a Transfer Impact Assessment and technical safeguards (encryption, pseudonymisation, data classification). 2021. URL: https://eur-lex.europa.eu/eli/dec_impl/2021/914/oj.

[89] European Commission. *Commission Implementing Decision (EU) 2023/1795 of 10 July 2023 pursuant to Regulation (EU) 2016/679 of the European Parliament and of the Council on the adequate level of protection of personal data under the EU–US Data Privacy Framework*. OJ L 231, 20 September 2023, p. 118. CELEX: 32023D1795. Competent authority for the adequacy determination is the European Commission; supervision of individual transfers and complaints remains with national data protection authorities coordinated by the EDPB. Where a recipient is not DPF-certified, transfers fall back to Article 46 SCCs (Decision (EU) 2021/914) plus a Transfer Impact Assessment. 2023. URL: https://eur-lex.europa.eu/eli/dec_impl/2023/1795/oj.

[90] European Parliament and Council of the European Union. *Regulation (EU) 2024/1183 of the European Parliament and of the Council of 11 April 2024 amending Regulation (EU) No 910/2014 as regards establishing the European Digital Identity Framework (eIDAS 2)*. OJ L, 2024/1183, 30 April 2024. CELEX: 32024R1183. Entered into force 20 May 2024 (20 days after publication). Directly applicable, no national transposition; the base instrument it amends is Regulation (EU) No 910/2014 (CELEX 32014R0910). Supervision is by each Member State's designated eIDAS/trust-services supervisory body, with the European Commission setting the wallet's technical architecture and reference framework through implementing acts. 2024. URL: https://eur-lex.europa.eu/eli/reg/2024/1183/oj.

[91] *Regulation (EU) 2024/1689 of the European Parliament and of the Council laying down harmonised rules on artificial intelligence (Artificial Intelligence Act)*. OJ L, 12 July 2024. Articles 2(6), 2(8): exemptions for scientific research and R&D — This regulation requires institutions deploying AI in education, admissions, or research to conduct conformity assessments, maintain documentation, and ensure human oversight while benefiting from research exemptions. 2024. URL: https://eur-lex.europa.eu/legal-content/EN/TXT/?uri=CELEX:32024R1689.

[92] National competent authority. *National single-window cybersecurity risk-management and reporting platform*. 2026.

[93] United States Congress. *Family Educational Rights and Privacy Act (FERPA)*. 20 U.S.C. § 1232g; 34 C.F.R. Part 99. Primary student-privacy obligation (F1) for US universities. No fixed breach-notification deadline in FERPA itself; enforced by withdrawal of federal education funding. 1974. URL: https://studentprivacy.ed.gov/ferpa.

[94] California State Legislature. *California Consumer Privacy Act of 2018, as amended by the California Privacy Rights Act (CCPA/CPRA)*. Cal. Civ. Code §§ 1798.100 et seq.; exemptions at § 1798.145. State consumer-privacy layer (F1). Non-profit / GLBA / HIPAA / FERPA exemptions place most universities outside direct scope; residual exposure via vendors and for-profit affiliates. Enforced by CPPA and California AG. 2023. URL: https://oag.ca.gov/privacy/ccpa.

[95] US Federal Trade Commission. *Standards for Safeguarding Customer Information (FTC Safeguards Rule)*. Tech. rep. 16 C.F.R. Part 314. Security-program (F3) + breach-notification (F4) obligation for Title-IV universities. FTC notification: no later than 30 days after discovery for events affecting 500+ consumers (16 CFR 314.4(j)). Enforced by the FTC. US Federal Trade Commission, 2023. URL: https://www.ftc.gov/business-guidance/resources/ftc-safeguards-rule-what-your-business-needs-know.

[96] US Department of Health and Human Services. *HIPAA Security Rule: Security Standards for the Protection of Electronic Protected Health Information*. Tech. rep. 45 C.F.R. Part 160 and Part 164, Subparts A and C. Health-data security obligation (F2/F3) for university covered components; hybrid-entity scoping is the key design move. Enforced by HHS OCR. US Department of Health and Human Services, Office for Civil Rights, 2003. URL: https://www.hhs.gov/hipaa/for-professionals/security/laws-regulations/index.html.

[97] US Department of Health and Human Services. *HIPAA Breach Notification Rule*. Tech. rep. 45 C.F.R. Part 164, Subpart D (§§ 164.400–164.414). Health-data incident-notification deadline (F4): 60 calendar days to individuals/HHS; HHS notified contemporaneously for breaches of 500+. Enforced by HHS OCR. US Department of Health and Human Services, Office for Civil Rights, 2009. URL: https://www.hhs.gov/hipaa/for-professionals/breach-notification/index.html.

[98] US Department of Commerce, Bureau of Industry and Security. *Export Administration Regulations (EAR)*. 15 C.F.R. Parts 730–774; fundamental research exclusion at § 734.8. Export-control obligation (F5) for research IT, dual-use technology. Administered by BIS; fundamental research exclusion at 15 CFR 734.8 is the operative carve-out; controlled inputs/deemed exports remain in scope. 2024. URL: https://www.bis.doc.gov/index.php/regulations/export-administration-regulations-ear.

[99] US Department of State, Directorate of Defense Trade Controls. *International Traffic in Arms Regulations (ITAR)*. 22 C.F.R. Parts 120–130; fundamental research carve-out at § 120.34(a)(8). Strictest export-control obligation (F5) for defence-related research. Administered by DDTC; no general fundamental-research safe harbour for controlled technical data; releases to foreign nationals are deemed exports needing DDTC authorisation. 2024. URL: https://www.pmddtc.state.gov/ddtc_public?id=ddtc_kb_article_page&sys_id=24d528fddbfc930044f9ff621f961987.

[100] US Department of Defense. *Cybersecurity Maturity Model Certification (CMMC) Program*. Tech. rep. 32 C.F.R. Part 170. Defense-research security certification (F3) and its transfer mechanism (F6). 32 CFR Part 170 effective 16 December 2024; DFARS clause effective 10 November 2025, phased over 3 years. Administered by US DoD; Level 2 via C3PAO assessment. US Department of Defense, 2024. URL: https://www.federalregister.gov/documents/2024/10/15/2024-22905/cybersecurity-maturity-model-certification-cmmc-program.

[101] NIST. *Protecting Controlled Unclassified Information in Nonfederal Systems and Organizations*. Tech. rep. NIST SP 800-171 Rev. 2. For universities, compliance with SP 800-171 is often mandatory when handling federal research data, participating in government contracts, or maintaining systems processing sensitive government information in defense-related projects. National Institute of Standards and Technology, 2020. DOI: 10.6028/NIST.SP.800-171r2. URL: https://csrc.nist.gov/publications/detail/sp/800-171/rev-2/final.

[102] United Kingdom. *The UK GDPR: Regulation (EU) 2016/679 as retained, amended and incorporated into UK law by section 3 of the European Union (Withdrawal) Act 2018 and the Data Protection, Privacy and Electronic Communications (Amendments etc) (EU Exit) Regulations 2019*. Information Commissioner's Office (ICO), https://ico.org.uk/for-organisations/uk-gdpr-guidance-and-resources/. F1 (data protection) and F2 (security of processing) anchor for the UK regime. Competent authority: ICO (transitioning to the Information Commission under the DUAA 2025). Breach notification: 72 hours to the ICO. 2021. URL: https://ico.org.uk/for-organisations/uk-gdpr-guidance-and-resources/.

[103] United Kingdom. *Data Protection Act 2018 (c. 12)*. The National Archives, https://www.legislation.gov.uk/ukpga/2018/12/contents. F1 (data protection) primary statute for the UK; pairs with uk-gdpr. Competent authority: Information Commissioner (ICO). Amended by the Data (Use and Access) Act 2025. 2018. URL: https://www.legislation.gov.uk/ukpga/2018/12/contents.

[104] United Kingdom. *Data (Use and Access) Act 2025 (c. 18)*. The National Archives, https://www.legislation.gov.uk/ukpga/2025/18/contents. Amends F1 (data protection) and F4 (international transfers) for the UK. Restructures the ICO into the Information Commission; key provisions in force 5 February 2026. 2025. URL: https://www.legislation.gov.uk/ukpga/2025/18/contents.

[105] United Kingdom. *The Network and Information Systems Regulations 2018 (SI 2018/506)*. The National Archives, https://www.legislation.gov.uk/uksi/2018/506/contents. F3 (network and information security) anchor for the UK. Competent authority: sector CAs for OES, ICO for RDSPs; NCSC is SPOC/CSIRT. Notification: 72 hours. 2018. URL: https://www.legislation.gov.uk/uksi/2018/506/contents.

[106] National Cyber Security Centre. *NCSC: the UK technical authority for cyber security and NIS single point of contact and CSIRT*. National Cyber Security Centre, https://www.ncsc.gov.uk/. F3 supporting authority for the UK: NCSC as NIS single point of contact and national CSIRT / technical authority. 2026. URL: https://www.ncsc.gov.uk/.

[107] United Kingdom. *Cyber Security and Resilience (Network and Information Systems) Bill*. UK Parliament, https://bills.parliament.uk/. F3 (network and information security) — forthcoming UK successor to SI 2018/506; in legislative progress, not yet enacted. 2025. URL: https://bills.parliament.uk/.

[108] Information Commissioner's Office. *International Data Transfer Agreement (IDTA) and the UK Addendum to the EU SCCs*. Information Commissioner's Office (ICO), https://ico.org.uk/for-organisations/uk-gdpr-guidance-and-resources/international-transfers/. F4 (international / cross-border data transfers) transfer mechanism for the UK. Authority: ICO. Mechanism: adequacy decision, else IDTA or EU SCCs + UK Addendum + transfer risk assessment. 2022. URL: https://ico.org.uk/for-organisations/uk-gdpr-guidance-and-resources/international-transfers/.

[109] United Kingdom. *The Electronic Identification and Trust Services for Electronic Transactions Regulations 2016 (SI 2016/696), and Regulation (EU) No 910/2014 as retained (UK eIDAS)*. The National Archives, https://www.legislation.gov.uk/uksi/2016/696. F5 (electronic identification / trust services) anchor for the UK. Supervisory body: the Information Commissioner (ICO). UK eIDAS = retained Regulation (EU) 910/2014 + SI 2016/696 + 2019 EU Exit amendments. 2016. URL: https://www.legislation.gov.uk/uksi/2016/696.

[110] United Kingdom. *The Public Sector Bodies (Websites and Mobile Applications) (No. 2) Accessibility Regulations 2018 (SI 2018/952)*. The National Archives, https://www.legislation.gov.uk/uksi/2018/952/contents/made. F6 (digital accessibility) anchor for the UK. Standard: WCAG 2.1 AA via EN 301 549 (WCAG 2.2 from Oct 2024). Monitoring: GDS; enforcement: EHRC. 2018. URL: https://www.legislation.gov.uk/uksi/2018/952/contents/made.

[111] Jisc. *Accessibility regulations: what you need to know (higher and further education guidance)*. Jisc, https://www.jisc.ac.uk/guides/accessibility-regulations-what-you-need-to-know. Authoritative HE-sector secondary source for F6 (digital accessibility) in the UK. 2024. URL: https://www.jisc.ac.uk/guides/accessibility-regulations-what-you-need-to-know.

[112] Brazil, Presidência da República. *Lei nº 13.709, de 14 de agosto de 2018 — Lei Geral de Proteção de Dados Pessoais (LGPD)*. Federal statute, Diário Oficial da União. Art. 46 (security of processing) and Art. 48 (incident communication to ANPD and data subjects) are the operative pegs for the data-protection and incident-notification functional obligations. Public bodies, including federal universities, are within scope (Chapter IV, public-power processing). 2018. URL: https://www.planalto.gov.br/ccivil_03/_ato2015-2018/2018/lei/l13709.htm.

[113] Brazil, Presidência da República. *Decreto nº 10.222, de 5 de fevereiro de 2020 — Estratégia Nacional de Segurança Cibernética (E-Ciber)*. Federal decree, Diário Oficial da União. Cyber-governance baseline for the federal public administration; GSI/PR is the coordinating authority. Operational incident-handling structures are established by Decreto 10.748/2021 (Rede Federal de Gestão de Incidentes Cibernéticos, CTIR.Gov). 2020. URL: https://www.planalto.gov.br/ccivil_03/_ato2019-2022/2020/decreto/d10222.htm.

[114] Brazil, Presidência da República. *Lei nº 12.965, de 23 de abril de 2014 — Marco Civil da Internet*. Federal statute, Diário Oficial da União. Foundational connectivity and online-privacy framework; the granular personal-data security and breach-notification duties are carried by the LGPD (Law 13.709/2018), with Marco Civil providing the constitutional-style Internet-rights baseline. 2014. URL: https://www.planalto.gov.br/ccivil_03/_ato2011-2014/2014/lei/l12965.htm.

[115] Brazil, Autoridade Nacional de Proteção de Dados (ANPD). *Resolução CD/ANPD nº 15, de 24 de abril de 2024 — Regulamento de Comunicação de Incidente de Segurança*. ANPD board resolution, Diário Oficial da União. Sets the operative 3-business-day notification deadline (with 20-business-day supplementation) under LGPD Art. 48. The ANPD is the competent authority. Companion to the official CIS reporting channel at gov.br/anpd. 2024. URL: https://www.gov.br/anpd/pt-br/canais_atendimento/agente-de-tratamento/comunicado-de-incidente-de-seguranca-cis.

[116] Brazil, Presidência da República. *Decreto nº 10.748, de 16 de julho de 2021 — Rede Federal de Gestão de Incidentes Cibernéticos*. Federal decree, Diário Oficial da União. Establishes mandatory federal cyber-incident coordination via CTIR.Gov (GSI/PR). Together with LGPD Art. 48 + ANPD Res. 15/2024 (personal-data breaches) it forms the dual incident-notification track for a federal university. 2021. URL: https://www.planalto.gov.br/ccivil_03/_ato2019-2022/2021/decreto/d10748.htm.

[117] Brazil, Presidência da República. *Lei nº 13.146, de 6 de julho de 2015 — Lei Brasileira de Inclusão da Pessoa com Deficiência (Estatuto da Pessoa com Deficiência)*. Federal statute, Diário Oficial da União. Accessibility functional obligation. Web/digital conformance is operationalised through the e-MAG standard (gov.br / governo digital); higher-education accessibility also touches MEC course-recognition requirements (Portaria MEC 3.284/2003). 2015. URL: https://www.planalto.gov.br/ccivil_03/_ato2015-2018/2015/lei/l13146.htm.

[118] Brazil, Presidência da República. *Lei nº 12.527, de 18 de novembro de 2011 — Lei de Acesso à Informação (LAI)*. Federal statute, Diário Oficial da União. Transparency functional obligation; CGU is the federal oversight authority. Procedural gaps are filled subsidiarily by the federal administrative-procedure law (Lei 9.784/1999). 2011. URL: https://www.planalto.gov.br/ccivil_03/_ato2011-2014/2011/lei/l12527.htm.

[119] Brazil, Presidência da República. *Lei nº 9.784, de 29 de janeiro de 1999 — Processo Administrativo no âmbito da Administração Pública Federal*. Federal statute, Diário Oficial da União. Administrative due-process / governance functional obligation; applies to federal universities as autarquias/fundações and subsidiarily to LAI and other procedural regimes. 1999. URL: https://www.planalto.gov.br/ccivil_03/leis/l9784.htm.

[120] African Union. *African Union Convention on Cyber Security and Personal Data Protection (Malabo Convention)*. Regional context instrument (analogous to AU-level framing). Adopted 27 June 2014; in force 8 June 2023 (Art. 36, 15th ratification). South Africa: signed, NOT ratified — no transfer/transposition obligation flows to South African institutions; provides continental policy baseline only. Depositary/authority: African Union Commission. 2014. URL: https://au.int/en/treaties/african-union-convention-cyber-security-and-personal-data-protection.

[121] Republic of South Africa, Parliament. *Protection of Personal Information Act 4 of 2013 (POPIA), Republic of South Africa*. F1 security of processing: s.19 (Condition 7). F2 breach notification: s.22 (notify Information Regulator and data subjects as soon as reasonably possible). F4 transborder flow: s.72 (adequate-protection / binding-agreement / consent / contractual-necessity transfer mechanism, self-assessed, no EU-style adequacy list). Competent authority: Information Regulator (South Africa). 2013. URL: https://popia.co.za/.

[122] Information Regulator (South Africa). *Information Regulator (South Africa) — supervisory authority under POPIA and PAIA*. Competent authority for F1 (security of processing) and F2 (breach notification, s.22 recipient) under POPIA. Independent body under POPIA s.39; also enforces PAIA. Receives security-compromise notifications and may direct publicity of a compromise. 2021. URL: https://inforegulator.org.za/.

[123] Republic of South Africa, Parliament. *Cybercrimes Act 19 of 2020, Republic of South Africa*. F3 incident/offence reporting: s.54 — report to SAPS without undue delay, where feasible within 72 hours; applies to electronic communications service providers and financial institutions. Authority: South African Police Service (SAPS) with national 24/7 point of contact. Note: South Africa has no standalone unified Cybersecurity Act; the Cybercrimes Act is the operative criminal/incident instrument. 2020. URL: https://www.michalsons.com/focus-areas/cybercrime-law-around-the-world/cybercrimes-act-south-africa.

[124] Republic of South Africa, Parliament. *Electronic Communications and Transactions Act 25 of 2002 (ECT Act), Republic of South Africa*. F5 electronic transactions / trust services and electronic signatures: ECT Act ss.13, 37–40 (advanced electronic signature, accreditation). Authority: South African Accreditation Authority (SAAA) under the Department of Communications and Digital Technologies. eIDAS-equivalent function; no EU-style mutual-recognition regime. 2002. URL: https://www.gov.za/documents/electronic-communications-and-transactions-act.

[125] Republic of South Africa, Parliament. *Promotion of Equality and Prevention of Unfair Discrimination Act 4 of 2000 (PEPUDA / Equality Act), Republic of South Africa*. F6 digital accessibility / non-discrimination: PEPUDA s.9 and disability provisions (reasonable accommodation; removal of obstacles). Authority/forum: Equality Courts; South African Human Rights Commission (SAHRC). No standalone web-accessibility statute — obligation is principle-based, WCAG used as de facto benchmark. 2000. URL: https://www.saflii.org/za/legis/consol_reg/rrttpoeapoud2003887/.